Mémoire présenté devant l'ENSAE Paris
pour l'obtention du diplôme de la filière Actuariat
et l'admission à l'Institut des actuaires
en mars 2027

Par : **Kélian KADDOURI**

Titre : **Quantification du SCR lié à la non-conformité au règlement DORA**

Confidentialité : ☒ NON ☐ OUI (Durée : ☐ 1 an ☐ 2 ans)

Les signataires s'engagent à respecter la confidentialité indiquée ci-dessus

Membres présents du jury de la filière

Nom : Caroline HILLAIRET

Membres présents du jury de l'Institut des Actuaires

Entreprise :
Nexialog Consulting
Signature :

Directeur du mémoire en entreprise :

Nom : Hugo RAPIOR
Signature :

Autorisation de publication et de mise en ligne sur un site de diffusion de documents actuariels *(après expiration de l'éventuel délai de confidentialité)*

Signature du responsable entreprise

Secrétariat :

Signé par :
Hugo Rapior
3CB0F8BFA4D042C...

Signature du candidat

Bibliothèque :

Ecole Nationale de la Statistique et de l'Administration Economique (ENSAE)
5, avenue Henry Le Chatelier - 91120 PALAISEAU, FRANCE

The credibility of inference decreases with the strength of the assumptions maintained.

Charles F. Manski, *Partial Identification of Probability Distributions*, 2003.

Remerciements

Je remercie Ali BEHBAHANI, fondateur de Nexialog Consulting, de m'avoir accueilli dans son cabinet et de la confiance qu'il m'a accordée.

Je remercie mon maître de stage, Hugo RAPIOR, responsable R&D en actuariat, pour son accueil dans son équipe, sa disponibilité et son encadrement. Nos points d'avancement hebdomadaires et ses conseils ont beaucoup apporté à ce travail.

Je remercie également les équipes du pôle Actuariat de Nexialog Consulting pour leur accueil et nos échanges. Je remercie en particulier les trois praticiens qui ont confronté les affirmations du modèle à leur expérience.

Mes remerciements vont aussi au corps enseignant de l'ENSAE Paris et à la filière Actuariat, pour la qualité de leurs enseignements. Je remercie ma tutrice académique, Caroline HILLAIRET, pour son suivi et ses remarques sur le traitement de l'incertitude, qui ont fait évoluer ce travail.

Je remercie enfin ma famille pour son soutien.

Résumé

Le règlement européen DORA impose aux entités financières de maîtriser leurs risques informatiques. Nous comparons le besoin de capital entre états de conformité supposés, puis examinons sa sensibilité aux informations manquantes sur la contagion et les coûts.

Le modèle combine le nombre annuel d'incidents, leurs pertes et leur propagation entre les cinq domaines de contrôle. Le besoin de capital est le quantile à 99,5 % de la perte annuelle, avec addition des coûts par pilier touché. Les pénalités et les polices cyber vendues sont exclues.

Sur le périmètre financier étudié, le besoin passe de 6 049 à 20 188 M€ entre les états conforme et non conforme, soit un facteur 3,34. Ces montants dépendent des paramètres de scénario et de la règle de coût. Pour une entité de 20 000 M$ d'actifs, la plage de 131,5 à 183,3 M€ reste une extrapolation d'ordre de grandeur.

Les sources ne permettent pas de calibrer la propagation. Nous conservons la force des liens posée à dire d'expert et faisons varier leur sens. Le capital va de 6 858 à 8 697 M€ aux 1 024 sommets admissibles, la largeur variant de 189 M€ (écart-type) d'une graine à l'autre ; ces extrema ne sont pas des bornes globales démontrées. Documenter le sens de six dépendances réduirait cette plage de 32,7 % en moyenne (22 à 44 % selon la graine). Ce scénario précise l'intérêt d'un registre d'incidents, sans garantir le gain d'une collecte réelle.

Mots-clés. Risque cyber ; DORA ; SCR ; Solvabilité II ; théorie des valeurs extrêmes ; cascade dirigée ; identification partielle ; bornes de capital ; inférence bayésienne ; valeur de l'information.

Usage de l'intelligence artificielle générative. Des outils d'IA générative ont servi à la rédaction et à la reformulation du manuscrit, à l'écriture des scripts d'analyse et à la relecture du texte, sous le contrôle de l'auteur. Les analyses, les choix méthodologiques et l'interprétation des résultats relèvent de l'auteur. Aucun résultat chiffré n'est produit par l'assistant : tout nombre publié provient de l'exécution d'un script du dépôt. L'annexe G détaille cet usage et les contrôles qui l'encadrent.

Abstract

The European DORA regulation requires financial entities to control their IT risks. We compare capital needs across assumed compliance states, then examine their sensitivity to missing information on contagion and costs.

The model combines annual incident counts, losses and propagation across five control areas. Capital need is the 99.5 % quantile of annual loss, with costs added across affected pillars. Regulatory penalties and the cyber policies an insurer sells are excluded.

For the financial sample, capital need rises from 6 049 to 20 188 M€ between the compliant and non-compliant states, a factor of 3.34. These amounts depend on scenario parameters and on the cost rule. For an entity with 20 000 M$ of assets, the range from 131.5 to 183.3 M€ remains an extrapolated order of magnitude.

The sources cannot calibrate propagation. We hold expert-set link strength fixed and vary direction. Capital ranges from 6 858 to 8 697 M€ at the 1 024 admissible vertices, the width varying by 189 M€ (standard deviation) across seeds; these extrema are not proven global bounds. Documenting six link directions would narrow this range by 32.7 % on average, from 22 to 44 % depending on the simulation seed. This scenario indicates the potential value of an incident register without guaranteeing the benefit of collecting actual observations.

Table des matières

Remerciements **2**
Résumé **3**
Abstract **4**
Glossaire **8**
Note de synthèse **10**
Executive summary **13**
Introduction **16**
1 Risque cyber, DORA et cadre prudentiel **18**
1.1 Pertes, propagation et dépendance . . . 18
1.2 Limites de l'assurabilité et de la capitalisation du risque cyber . . . 20
1.3 Marché français de la cyberassurance . . . 21
1.4 Le règlement DORA . . . 22
1.5 Perception du risque et traitement prudentiel . . . 24
1.6 Cadre prudentiel et articulation avec DORA . . . 25
2 Revue de littérature et positionnement **30**
2.1 Comparaison aux approches existantes . . . 30
2.2 Dépendance dirigée et dépendance à l'ordre . . . 31
2.3 Travaux par thème . . . 31
2.4 Positionnement . . . 32
3 Données **34**
3.1 Sources et rôles . . . 34
3.2 Biais statistiques des sources . . . 34
3.3 Hétérogénéité temporelle et actualisation des sinistres . . . 35
3.4 Fréquences et seuils de collecte . . . 36
3.5 Effet chiffré de deux biais . . . 37
3.6 Hackmageddon et la structure du risque . . . 37
3.7 OpRisk Global et la sévérité en euros . . . 38
3.8 Analyse exploratoire et profilage des variables . . . 39
3.9 Limites des données . . . 46
4 Modèle fréquence-sévérité **47**
4.1 Théorèmes de l'extrapolation de queue . . . 48
4.2 Estimation de l'indice de queue . . . 49
4.3 Loi de fréquence . . . 50
4.4 Loi de sévérité . . . 51
4.5 Comparer les estimateurs à population fixée . . . 51
4.6 Adéquation des lois . . . 52
4.7 Backtest hors échantillon . . . 53
5 Cascade dirigée entre piliers **55**
5.1 Modèle de Vasicek à un facteur . . . 56
5.2 Facteur systémique par pilier . . . 57
5.3 Propagation dirigée . . . 57
5.4 Normalisation de Leontief et stabilité . . . 59
5.5 Processus de branchement . . . 60
5.6 Seuil K_j, substitut de $\Phi^{-1}(\mathrm{PD})$ . . . 61
5.7 Faisabilité de l'estimation sur données simulées . . . 61
5.8 Définitions et propriétés formelles . . . 62
5.9 Vérification numérique des propriétés . . . 64

6 Modélisation multi-états de la conformité 65
6.1 Deux échelles de temps . . . 65
6.2 Vasicek multi-états à seuils ordonnés . . . 66
6.3 Quatre canaux de la conformité . . . 67
6.4 Valeurs posées de g et invariance de l'ordre . . . 68
6.5 État de conformité par pilier . . . 69
6.6 Chaîne de Markov et séjours de type phase . . . 70
6.7 Couplage systémique et analogie de crédit . . . 70
7 Identifiabilité de la direction de contagion 71
7.1 Conditions d'identification de W . . . 71
7.2 Trois sources agrégées . . . 71
7.3 Direction de contagion et réversibilité . . . 72
7.4 Expérience naturelle du choc MOVEit . . . 73
7.5 Corpus de rapports post-incident . . . 74
7.6 Corpus étendu et matrice ordonnée . . . 74
7.7 Biais de narration . . . 75
7.8 Formalisation bayésienne . . . 76
7.9 Frontière d'identification . . . 76
8 Identification partielle et bornes de capital 77
8.1 Modèle en couches . . . 77
8.2 Capital sur l'ensemble admissible . . . 78
8.3 Comparaison d'une matrice posée et de l'identification partielle . . . 79
8.4 Niveaux et rapports de capital . . . 79
8.5 Échelle de repli sur la direction . . . 80
9 Résultats 82
9.1 Besoin de capital par état de conformité . . . 82
9.2 Décomposition et allocation par pilier . . . 84
9.3 Trajectoire du capital et ordre de remédiation . . . 86
9.4 Comparaison aux copules et à la Formule Standard . . . 87
9.5 Méthode de descente à l'échelle d'une entité . . . 88
9.6 Comparaison des entités et sensibilité à l'enregistrement . . . 91
9.7 Agrégation au capital total . . . 92
9.8 Détention du capital et transfert du risque . . . 93
9.9 Cas d'usage, de l'état de conformité à la décision . . . 94
10 Robustesse, limites et recommandations 95
10.1 Synthèse de robustesse . . . 95
10.2 Ordre de remédiation et sensibilité à la propagation . . . 96
10.3 Données manquantes et choix du modèle . . . 97
10.4 Incertitude du besoin de capital . . . 97
10.5 Écarts de calibration et de transposition . . . 99
10.6 Défaillances simultanées et additivité des coûts . . . 101
10.7 Unité de perte et incertitude jointe . . . 101
10.8 Recommandations à l'entité et au superviseur . . . 105
10.9 Spécification d'un registre d'incidents utile à la modélisation . . . 106
10.10 Gouvernance du modèle . . . 108
Conclusion 109
Bibliographie 111

Annexes 114
Organisation des annexes et matériel complémentaire 114
A Démonstrations du modèle de cascade 115

B Démonstrations et compléments sur la théorie des valeurs extrêmes 119
B.1 Théorème de Fisher-Tippett-Gnedenko . . . 119
B.2 Théorème de Pickands-Balkema-de Haan . . . 119
B.3 Information de Fisher et normalité asymptotique de l'EMV de la GPD . . . 120
B.4 Loi asymptotique de l'estimateur de Hill . . . 120
B.5 Formes fermées du quantile de sévérité et de sa moyenne de queue . . . 121
B.6 Hill contre maximum de vraisemblance . . . 121
B.7 Le seuil de la calibration, deux règles écrites . . . 123
B.8 Backtest hors échantillon, détail des tests . . . 124
C Adaptations par pilier et cas d'usage 128
C.1 Queue de sévérité par pilier . . . 128
C.2 Pilier des tiers et accumulation . . . 129
C.3 Détection de P2 et P3 comme courbe de survie . . . 133
C.4 Cas d'usage, des adaptations aux indicateurs pilotables . . . 134
C.5 Piliers laissés en perspective . . . 139
D Protocole d'élicitation et relectures de praticiens 140
D.1 Méthode de Cooke . . . 140
D.2 Protocole construit pour la matrice de contagion . . . 140
D.3 Documents produits et diffusés . . . 141
D.4 Portée de l'absence de panel . . . 141
D.5 Dispositifs de substitution . . . 141
D.6 Relectures de praticiens . . . 142
D.7 Coût de l'absence et réversibilité . . . 143
E Paramètres et notations 144
E.1 Nature et sensibilité des paramètres . . . 144
E.2 Table des notations . . . 145
F Pistes pour de futurs mémoires d'actuariat 148
F.1 Exécuter l'élicitation structurée . . . 148
F.2 Documenter la dépendance entre gouvernance et gestion des incidents . . . 148
F.3 Le second codage en aveugle du corpus . . . 148
F.4 Calibrer l'amplitude des liens, et non leur seul sens . . . 149
F.5 Dérive d'échelle et passage à l'entité . . . 149
F.6 Le coût d'un sinistre multi-piliers . . . 149
F.7 La contagion entre entités, par le prestataire partagé . . . 149
G Usage de l'intelligence artificielle générative 150
G.1 Usage déclaré . . . 150
G.2 Part de l'auteur . . . 151
G.3 Vérification des résultats . . . 151
G.4 Limite du dispositif . . . 151

Glossaire

Sigle ou terme	Signification
AMRAE	Association pour le management des risques et des assurances de l'entreprise, qui publie l'étude LUCY
AMDEC / RPN	Analyse des modes de défaillance, de leurs effets et de leur criticité ; indice de priorité obtenu en multipliant gravité, occurrence et détection
Bootstrap	Réestimation sur des échantillons tirés avec remise ; paramétrique si les nouvelles observations sont simulées sous la loi ajustée
Bonferroni	Correction qui divise le seuil d'un test par le nombre de comparaisons menées simultanément
BSCR	*Basic Solvency Capital Requirement*, capital de solvabilité de base de la Formule Standard
Calibration	Estimation des paramètres sur les observations ; une valeur posée est une hypothèse de scénario
Cascade	Propagation d'une défaillance entre piliers ; l'amorce est le premier pilier atteint
Copule / marge	La marge est la loi d'une variable seule ; la copule décrit comment plusieurs marges forment une loi jointe
Crédibilité	Un intervalle de crédibilité contient le paramètre avec la probabilité annoncée sous la loi a posteriori, qui met à jour la loi a priori par les observations ; la loi bêta, sur $[0, 1]$, a deux paramètres de forme
Downscaling	Descente à l'échelle d'une entité : adaptation de la fréquence et des pertes à ses actifs, puis recalcul du quantile annuel
DORA	*Digital Operational Resilience Act*, règlement (UE) 2022/2554 sur la résilience opérationnelle numérique du secteur financier
Effet de fermeture	Capital retiré en corrigeant un seul canal à partir de l'état non conforme
Effet isolé	Capital ajouté par un seul canal à partir de l'état conforme
État absorbant	État qu'une chaîne de Markov ne quitte plus une fois atteint
Fisher	L'information de Fisher est la courbure moyenne de la log-vraisemblance ; son inverse approche la variance de l'estimateur du maximum de vraisemblance
Frobenius	Le produit de Frobenius de deux matrices somme les produits de leurs entrées de même position
GPD	*Generalized Pareto Distribution*, loi de Pareto généralisée, loi des excès au-dessus d'un seuil élevé
GEV	*Generalized Extreme Value*, famille limite des maxima de blocs
Hackmageddon	Recensement public d'incidents cyber, utilisé pour la répartition par vecteur d'attaque
IC	Intervalle de confiance d'un paramètre ; son niveau est la couverture obtenue en répétant le protocole. Un intervalle de prévision porte sur une réalisation future
Identification partielle	Caractérisation de valeurs admissibles sous des observations et des hypothèses. Ici, la force des liens reste posée et le capital est exploré aux sommets
Indicatrice	$\mathbf{1}\{E\}$ vaut un si l'événement E se produit, zéro sinon
KS / AD	Tests de Kolmogorov–Smirnov et d'Anderson–Darling, qui comparent une répartition observée à une loi ajustée : le premier retient le plus grand écart, le second pondère davantage les extrémités

Sigle ou terme	Signification
EMV / PWM	Maximum de vraisemblance ; moments pondérés par les probabilités de rang, deux méthodes d'estimation
Log-score / nat	Logarithme de la probabilité, ou de la densité, attribuée à l'observation réalisée, plus élevé pour une meilleure prévision ; le nat est son unité en logarithme naturel
Logit	$\mathrm{logit}(p) = \ln[p/(1-p)]$, qui envoie $]0,1[$ sur la droite réelle
Markov	Propriété d'un processus dont l'état présent suffit à décrire les probabilités de transition futures
LUCY	*Lumière sur la cyberassurance*, étude annuelle du marché français de la cyberassurance
MFA	*Multi-Factor Authentication*, authentification multifacteur
Monte-Carlo	Estimation par tirages pseudo-aléatoires ; une graine permet de reproduire les tirages
$\mathcal{N}(0,1)$, Φ	Loi normale de moyenne nulle et de variance unité ; Φ est sa fonction de répartition, Φ^{-1} sa fonction quantile
ORSA	*Own Risk and Solvency Assessment*, évaluation interne des risques et de la solvabilité
P1 à P5	Les cinq piliers de DORA : gouvernance du risque TIC, gestion des incidents, tests de résilience, risque lié aux prestataires tiers, partage d'informations
POT	*Peaks Over Threshold*, méthode d'estimation de queue par les dépassements d'un seuil
PD	Probabilité de défaut sur un horizon donné dans le modèle de crédit ; l'analogie cyber emploie un seuil latent d'incident majeur
PRC	*Privacy Rights Clearinghouse*, base publique de notifications de violations de données
Probit ordonné	Classement en états par des seuils posés sur une variable normale non observée
Puissance	Probabilité qu'un test détecte une déviation donnée
p-value	Probabilité, sous la loi testée, d'une statistique au moins aussi défavorable que celle observée
Rayon spectral	Plus grand module des valeurs propres d'une matrice
SAS OpRisk Global	Base commerciale de pertes opérationnelles publiques, en montants
SCR	*Solvency Capital Requirement*, capital de solvabilité requis sous Solvabilité II : VaR à 99,5 % de la variation des fonds propres de base sur un an ; le quantile de perte du mémoire en est un substitut ORSA
SFCR	*Solvency and Financial Condition Report*, rapport public sur la solvabilité et la situation financière
Shapley	Règle d'attribution qui partage un écart entre plusieurs causes en moyennant leurs contributions sur tous les ordres d'introduction
TIC	Technologies de l'information et de la communication
Sévérité / queue	Montant d'une perte ; partie de la distribution correspondant aux pertes élevées
TVaR	*Tail Value-at-Risk*, moyenne de la perte au-delà de la VaR
VaR	*Value-at-Risk*, quantile de la loi de perte ; dans ce mémoire, réservée à la charge annuelle agrégée
VERIS	*Vocabulary for Event Recording and Incident Sharing*, schéma de description d'incidents ; VCDB en est la base communautaire

Note de synthèse

Contexte et objectif

Comment le besoin de capital varie-t-il entre états de conformité supposés ? Nous calculons cet écart, puis examinons ce qui en subsiste quand la direction de la contagion et les coûts par pilier ne sont pas observés. Les montants restent conditionnels à ces hypothèses. Le règlement européen DORA distingue cinq domaines, appelés ici piliers : gouvernance (P1), incidents (P2), tests (P3), prestataires tiers (P4) et partage d'informations (P5). La charge de risque opérationnel de la Formule Standard ne dépend pas directement de leur conformité.

Le risque mesuré est le risque opérationnel d'origine informatique de l'entité. Les pénalités réglementaires et le risque de souscription des polices cyber qu'un assureur vend ne sont pas modélisés. Nous répartissons l'écart entre les cinq piliers et entre quatre paramètres du modèle que la non-conformité modifie, que nous appelons canaux : la fréquence des incidents, leur détection, leur propagation d'un pilier à l'autre et la dépendance à un prestataire commun. Le résultat est un besoin de capital au sens de l'ORSA (évaluation interne des risques), non un SCR réglementaire.

Les montants sont en millions d'euros et valent pour le périmètre financier étudié (21,6 incidents par an), non pour un assureur ; l'ordre de grandeur d'une entité de 20 000 M$ d'actifs figure avec les résultats. Le niveau change d'un facteur 22 selon la seule source de sévérité. Sous la construction additive et les sensibilités étudiées, nous interprétons l'écart entre états et l'ordre des piliers ; le niveau reste illustratif.

Démarche

La base SAS OpRisk Global fournit 570 pertes informatiques d'institutions financières de 2000 à 2026. Une loi de Pareto généralisée, ajustée au-delà de 20,03 M€ sur 86 excès, décrit les pertes élevées (indice de queue 0,5954). Le nombre annuel d'incidents suit une loi binomiale négative. Un incident naît sur un pilier, puis se transmet aux autres selon une matrice d'influence dirigée, posée à dire d'expert puis bornée. Le capital est le quantile à 99,5 % de la charge annuelle, calculé dans chaque état.

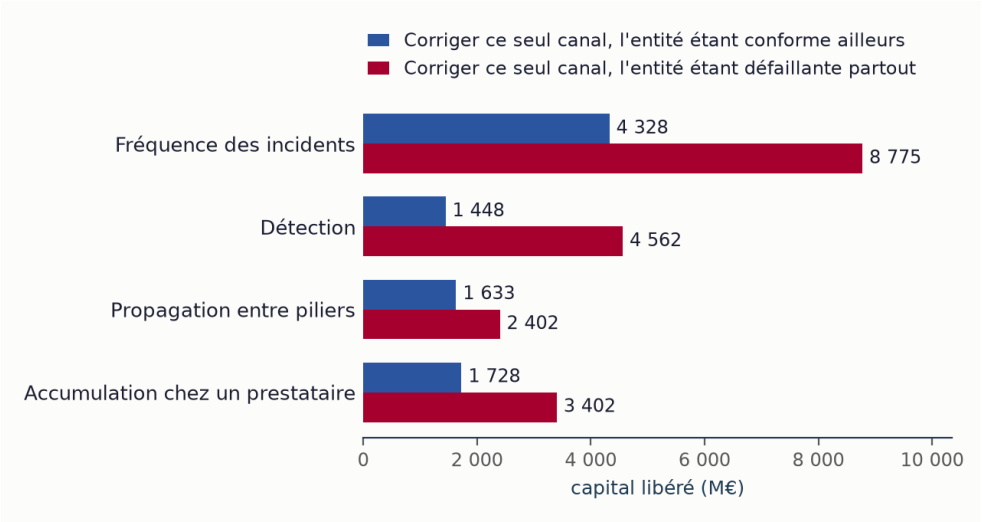
La conformité modifie les paramètres du calcul. Les parts de vecteurs d'attaque Hackmageddon pondèrent le multiplicateur de fréquence. La détection règle la probabilité qu'une perte élémentaire dépasse le seuil ; elle s'applique à chaque pilier touché. La propagation règle la poursuite de la marche entre piliers. Enfin, une amorce chez le prestataire P4 peut toucher plusieurs autres piliers par un choc commun. Le tableau donne les valeurs retenues.

Ces différences entre états sont des hypothèses de scénario. Les tests de sensibilité du chapitre 6 examinent leurs effets ; les multiplicateurs de détection ne sont pas balayés. Le calcul distingue l'effet d'un canal isolé et celui de sa correction quand les autres restent dégradés.

Canal	Paramètre	Conforme	Non conforme	Effet isolé	Effet de fermeture
Fréquence	incidents par an	21,6	53,6	4 328	8 775
Détection	dépassement par pilier	0,128	0,181	1 448	4 562
Propagation	gain de la cascade	0,45	0,90	1 633	2 402
Accumulation	prestataire commun	0	0,68	1 728	3 402
Besoin de capital (M€)		6 049	20 188		

Résultats

À l'échelle du périmètre financier étudié, le besoin de capital est multiplié par 3,34 entre l'entité conforme et l'entité non conforme sur les quatre canaux, soit un écart de 14 139 M€. Les canaux pris un à un en expliquent 9 138 M€, et leurs interactions 5 001 M€, soit 35 %. L'effet isolé est le capital ajouté par un canal seul, depuis l'état conforme. L'effet de fermeture est le capital retiré en corrigeant ce canal seul, depuis l'état non conforme sur les trois autres : un plan de remédiation doit citer ce second effet.



Capital libéré en corrigeant un seul canal (M€, périmètre financier étudié) : en bleu depuis une entité conforme ailleurs (effet isolé), en rouge depuis une entité défaillante partout (effet de fermeture). Les effets de fermeture ne s'additionnent pas.

La figure montre l'ordre des canaux. La fréquence domine dans les deux lectures. Corriger un canal rapporte toujours davantage à une entité défaillante partout, car le canal ferme aussi les interactions qu'il partageait avec les autres. Pour une entité, la priorité de remédiation dépend donc de son état de départ, et non du seul effet isolé de chaque canal.

Cet écart dépend du coût de l'incident. À calage fixé, le calcul par Fourier donne 13 946 M€ sous la règle additive, à moins d'une erreur type (367 M€) de l'estimation de Monte-Carlo, contre 5 946 avec une perte unique. Sous la règle additive, le bootstrap conjoint de la sévérité donne une bande nominale à 95 % de [4 872 ; 90 361] M€ pour l'écart, mais de [3,04 ; 5,22] pour le facteur entre états (chapitre 10). La queue rend le niveau très incertain et le facteur beaucoup moins ; ces bandes restent conditionnelles à la fréquence et aux autres paramètres posés.

Les données publiques ne disent pas quel pilier entraîne l'autre : nous calculons le capital aux 1 024 sommets de l'ensemble des matrices d'influence admissibles, la structure symétrique étant

posée à dire d'expert. Dans le calage de référence (fréquence conforme, gain 0,90), les valeurs aux sommets vont de 6 858 à 8 697 M€ ; recalculée sur quatre graines, la largeur de cette plage a un écart-type de 189 M€. La matrice se décompose en une partie symétrique, la force commune des liens, posée ici, et une partie antisymétrique, leur sens, qu'aucune des sources examinées ne fixe. Cette plage n'est ni un intervalle de confiance ni une borne démontrée : elle mesure ce que coûte l'ignorance du sens, à force posée. Pour une entité notionnelle de 20 000 M$ d'actifs, le capital du secteur est ramené à sa taille, la fréquence croissant avec les actifs selon un exposant estimé sur les grandes institutions : le besoin est de l'ordre de 24 M€ (de 15,8 à 27,5 M€ aux sommets admissibles), une extrapolation d'ordre de grandeur qui dépend de la structure d'expert et de la calibration.

Limites et recommandations

La fréquence de référence inclut douze pertes d'avant 2000, soit 2,1 % de plus que l'échantillon étudié. Le chapitre 10 examine ce décalage. La propagation et l'accumulation sont posées. Les correspondances testées conservent le signe de l'écart sous la règle additive ; la perte par pilier reste non observée. Les bandes de calibration laissent fixes la fréquence, les multiplicateurs et la cascade d'expert.

Le test du rapport de vraisemblance rejette la loi de Poisson (statistique de 130,5) au profit de la binomiale négative. Un backtest sur 2004–2025 place ensuite 11 années sur 12 dans l'intervalle à 90 % de la loi binomiale négative, contre 9 sur 12 pour Poisson, ce qui conforte le choix sans le démontrer sur douze années. Le backtest rejette le niveau de la charge annuelle ; une dérive de l'échelle de queue est explorée, sans confirmation statistique. Détecter un doublement du taux de dépassement avec 80 % de puissance demanderait 1 811 années à 99,5 %.

Le modèle sert d'abord à comparer des scénarios et leurs effets de fermeture. Arrêter un capital ou un investissement réel exige de mesurer les états, les coûts et l'exposition de l'entité. Un registre daté, classé par domaine de contrôle et consignant tous les piliers touchés renseignerait la direction. VERIS prévoit ces champs ; ils sont renseignés ensemble dans un incident sur 10 591.

Executive summary

Context and objective

How does capital need vary between assumed compliance states? We calculate this gap, then examine what survives when contagion direction and pillar-level costs are unobserved. The amounts remain conditional on these assumptions. The European DORA regulation distinguishes five areas, called pillars here: governance (P1), incidents (P2), testing (P3), third-party providers (P4) and information sharing (P5). The Standard Formula operational risk charge does not directly depend on their compliance.

The risk measured is the entity's own IT-related operational risk, that is its own incidents. Regulatory penalties and the underwriting risk of the cyber policies an insurer sells are not modelled. We split the gap across the five pillars and across four model parameters that non-compliance changes, which we call channels: incident frequency, detection, propagation from one pillar to another, and dependence on a shared provider. The result is a capital need in the ORSA sense, the internal assessment of risks and solvency. It is not a regulatory SCR.

The amounts are in millions of euros and are for the financial sample taken as a whole (21.6 incidents a year in the loss database), not for one insurer. The order of magnitude for an entity with 20 000 M$ of assets is given with the results. The level changes by a factor of 22 with the severity source alone. Under the additive construction and the sensitivities examined, we interpret the gap between states and the ordering of pillars; the level remains illustrative.

Approach

SAS OpRisk Global provides 570 IT losses at financial institutions from 2000 to 2026. A generalised Pareto distribution, fitted above 20.03 M€ on 86 exceedances, describes the high losses (tail index 0.5954). The annual incident count is negative binomial. An incident starts in one pillar, then spreads to the others through a directed influence matrix, posited by expert judgement and then bounded. Capital is the 99.5 % quantile of the annual loss, computed in each state.

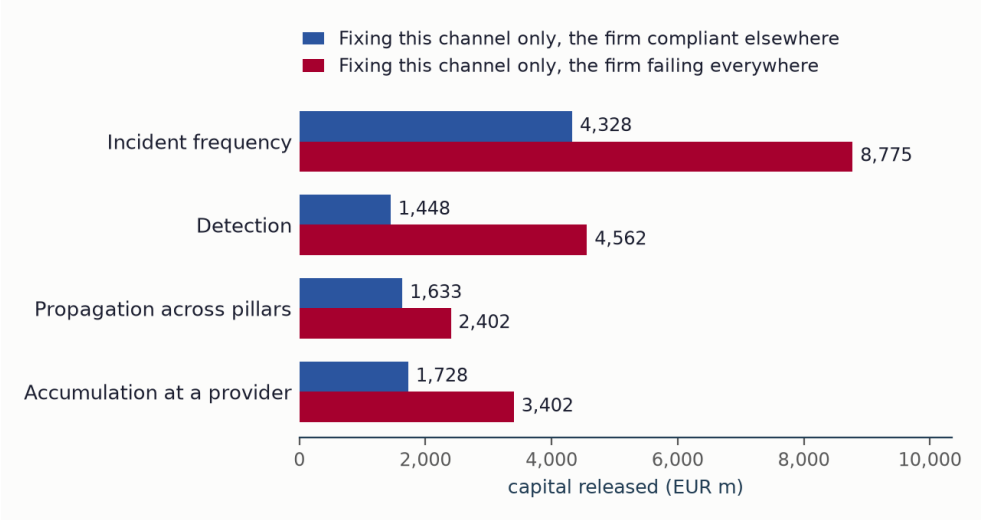
Compliance changes the calculation parameters. Hackmageddon attack-vector shares weight the frequency multiplier. Detection sets the probability that an elementary loss exceeds the threshold, applied to each affected pillar. Propagation sets the probability of continuing the walk between pillars. Finally, an incident starting at provider pillar P4 can affect several other pillars through a common shock. The table gives the values used.

These differences between states are scenario assumptions. The sensitivity tests in Chapter 6 examine their effects; detection multipliers are not swept. The calculation distinguishes a standalone channel effect from the effect of correcting that channel while the others remain degraded.

Channel	Parameter	Compliant	Non-compliant	Standalone	Closure
Frequency	incidents per year	21.6	53.6	4 328	8 775
Detection	exceedance share	0.128	0.181	1 448	4 562
Propagation	cascade gain	0.45	0.90	1 633	2 402
Accumulation	shared provider	0	0.68	1 728	3 402
Capital need (M€)		6 049	20 188		

Results

At the scale of the financial sample, capital need is multiplied by 3.34 between the compliant entity and the entity that is non-compliant on all four channels, a gap of 14 139 M€. The channels taken one by one explain 9 138 M€, and their interactions 5 001 M€, or 35 %. The standalone effect is the capital added by one channel alone, from the compliant state. The closure effect is the capital removed by fixing that channel alone, from the state that is non-compliant on the other three: a remediation plan should quote the second.



Capital released by fixing a single channel (M€, financial sample): in blue from an entity compliant elsewhere (standalone effect), in red from an entity failing everywhere (closure effect). Closure effects do not add up.

The figure shows the ranking of channels. Frequency dominates under both readings. Fixing a channel always releases more capital for an entity failing everywhere, because the channel also closes the interactions it shared with the others. For an entity, the remediation priority therefore depends on its starting state, not only on the standalone effect of each channel.

The gap depends on incident cost. At fixed calibration, Fourier computation gives 13 946 M€ under the additive rule, within one standard error (367 M€) of the Monte Carlo estimate, against 5 946 with a single incident loss. Under the additive rule, the joint bootstrap of severity gives a nominal 95 % band of $[4\,872; 90\,361]$ M€ for the gap, but of $[3.04; 5.22]$ for the factor between states (Chapter 10). The tail makes the level highly uncertain and the factor much less so; both bands remain conditional on frequency and on the other posited parameters.

Public data do not say which pillar drives the other: we compute capital at the 1 024 vertices of the set of admissible influence matrices, the symmetric structure being set by expert judgement. In the reference calibration (compliant-state frequency, gain 0.90), the vertex values range from

6 858 to 8 697 M€; recomputed over four seeds, the width of this range has a standard deviation of 189 M€.

The matrix splits into a symmetric part, the common strength of the links, posited here, and an antisymmetric part, their direction, which none of the sources examined pins down. This range is neither a confidence interval nor a proven bound: it measures the cost of not knowing the direction, at posited strength. For a notional entity with 20 000 M$ of assets, sector capital is scaled down to its size, frequency growing with assets at an exponent estimated on large institutions: the need is about 24 M€ (15.8 to 27.5 M€ at the admissible vertices), an extrapolated order of magnitude that depends on the expert-set structure and on the calibration.

Limitations and recommendations

Reference frequency includes twelve losses from before 2000, 2.1 % more than the calibration sample; Chapter 10 explains this convention. Propagation and accumulation are posited. The tested mappings preserve the sign of the gap under the additive rule; pillar-level loss remains unobserved. Calibration bands hold frequency, multipliers and the expert-set cascade fixed.

A likelihood ratio test rejects the Poisson distribution (statistic of 130.5) in favour of the negative binomial. A backtest over 2004–2025 then places 11 years out of 12 inside the 90 % interval of the negative binomial, against 9 out of 12 for the Poisson. This supports the choice without proving it over twelve years. The backtest rejects the annual aggregate level; a drift in tail scale is explored without statistical confirmation. Detecting a doubling of the exceedance rate with 80 % power would require 1 811 years at 99.5 %.

The model primarily supports comparisons of scenarios and closure effects. Setting an actual capital amount or investment requires measuring the entity's states, costs and exposure. A dated register, classified by control domain and recording every pillar hit, would inform direction. VERIS provides these fields; they are filled in together in only one incident out of 10 591.

Introduction

Le règlement européen sur la résilience opérationnelle numérique (DORA), applicable depuis 2025, organise les exigences de résilience informatique des entités financières autour de cinq domaines, appelés ici piliers. Il rend observable un niveau de maîtrise que le calcul prudentiel ignore. Dans la Formule Standard de Solvabilité II, la charge de risque opérationnel ne dépend que de grandeurs de volume : deux entités de même volume reçoivent la même charge quel que soit leur état de conformité (§1.6.2). La question étudiée est donc la suivante : *comment la distribution des pertes informatiques d'une entité, puis son besoin de capital, varient-ils lorsque son état de conformité aux cinq piliers se dégrade ?*

La contribution est de calculer un écart de capital entre états supposés, puis d'examiner ce qui en subsiste lorsque le sens de la contagion et les coûts par pilier ne sont pas observés. Les lois de fréquence et de pertes, les cascades et l'identification partielle viennent de la littérature. Leur adaptation aux domaines de contrôle et l'analyse de leurs limites constituent l'apport du travail, précisé au chapitre 2. Le modèle compare des scénarios et précise les données manquantes ; il ne valide pas un capital d'entité. La figure 1 relie données, agrégation, identification et décision.

Les pertes modélisées sont celles du risque opérationnel d'origine informatique de l'entité ; les pénalités réglementaires et le risque des polices cyber qu'un assureur vend ne sont pas modélisés. La

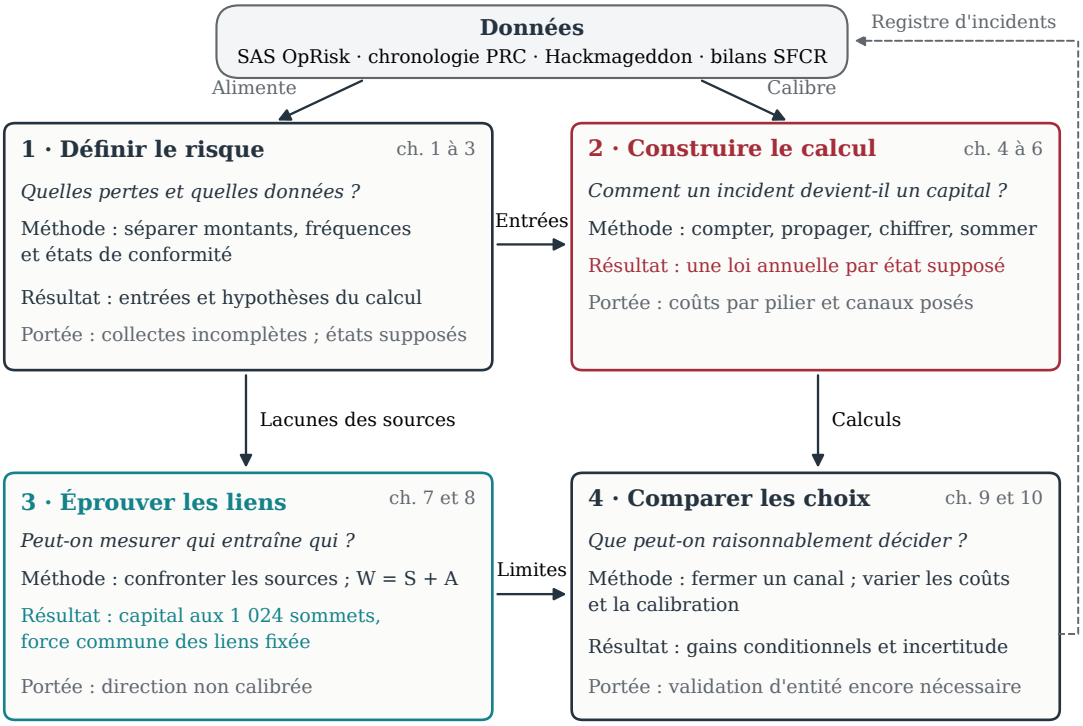


FIGURE 1. Le fil du mémoire : une question, une méthode et un résultat transmis à la suite. Les limites indiquent ce que chaque étape laisse à établir. Le registre proposé au chapitre 10 renseignerait les entrées manquantes ; la figure 4.1 détaille le calcul annuel.

Value-at-Risk (VaR) est le plus petit montant que la perte ne dépasse pas avec la probabilité choisie. Le capital de solvabilité requis (SCR) est une VaR à 99,5 % de la variation des fonds propres de base sur un an ; nous en retenons un substitut, le quantile à 99,5 % de la charge annuelle de pertes.

Faute de module DORA dans la Formule Standard, le quantile retenu est un besoin de capital au sens de l'évaluation interne des risques et de la solvabilité (ORSA), non un SCR réglementaire. Les montants sont exprimés en millions d'euros (M€), les actifs sources en millions de dollars (M$).

Le calcul suit une année d'incidents. Leur nombre est tiré selon une loi binomiale négative, puis le pilier sur lequel chacun commence. La propagation détermine les autres piliers touchés. Pour chacun d'eux, une perte est tirée, de loi de Pareto généralisée au-delà d'un seuil ; les pertes sont additionnées par incident, puis sur l'année. Une année simulée peut ainsi compter trois incidents, dont l'un, parti de la gestion des prestataires tiers, atteint ensuite la gouvernance puis la gestion des incidents. Cet incident compte une fois dans le nombre annuel, mais sa perte additionne celles des trois piliers touchés.

Nous suivons ce même exemple aux figures 4.1 et 5.1, puis au §10.7.1. Le calcul est répété sur un grand nombre d'années simulées pour estimer ce quantile annuel (méthode de Monte-Carlo). La conformité modifie les paramètres de fréquence, de détection, de propagation et de choc commun ; une chaîne de Markov décrit séparément son évolution sur plusieurs années.

SAS OpRisk Global fournit les pertes et les nombres d'incidents. La base *Privacy Rights Clearinghouse* (PRC) sert à comparer fréquence et sévérité. Les parts par vecteur d'Hackmageddon pondèrent le multiplicateur de fréquence entre états. Trois résultats en découlent.

1. *Un écart de capital entre états de conformité* (chapitres 5 à 9). L'état de conformité agit par quatre canaux : fréquence des incidents, dépassement du seuil de sévérité, propagation et accumulation par un prestataire commun ; les valeurs de ces canaux sont posées pour chaque état. Pour le périmètre financier étudié, le besoin passe alors de 6 049 à 20 188 M€, soit un facteur 3,34, et l'écart de 14 139 M€ présente un écart-type de 734 M€ entre quatre graines. Ces montants comparent deux états supposés ; leur amplitude dépend des paramètres posés et de l'addition des coûts entre piliers. À l'échelle d'une entité, fréquence et pertes sont lues à sa taille ; l'effet du métier n'est pas estimé.
2. *Une direction non identifiable* (chapitre 7). Sur les trois sources agrégées, le sens des liens entre piliers n'est pas identifiable ; le corpus de rapports post-incident n'en donne qu'un ordre partiel.
3. *Une plage de capital sur les directions admissibles* (chapitre 8). La force commune des liens est posée à dire d'expert, et leur sens varie dans un ensemble admissible. Aux 1 024 sommets de cet ensemble, le capital du calage de référence va de 6 858 à 8 697 M€ (écart-type de la largeur : 189 M€ entre quatre graines). Cette plage, conditionnelle à la force posée, n'est ni une borne globale démontrée ni un intervalle de confiance. Documenter le sens des six dépendances décrites par les rapports post-incident la réduirait de 32,7 % en moyenne, de 22 à 44 % selon la graine (§10.8).

Ce travail a été mené chez Nexialog Consulting, de juin à novembre 2026, sous la direction de Hugo Rapior. Les choix de modélisation relèvent de l'auteur ; l'usage de l'IA est décrit en annexe G.

1

Risque cyber, DORA et cadre prudentiel

1.1 Pertes, propagation et dépendance

1.1.1 Définition et périmètre du risque cyber

Le risque cyber désigne les pertes liées à une défaillance des systèmes d'information, malveillante ou non, qui touche la confidentialité des données, leur intégrité ou la disponibilité des services. L'*incident* couvre tout événement qui affecte la sécurité d'un système, erreurs humaines et pannes comprises, tandis que la *cyberattaque* en désigne le sous-ensemble intentionnel, abouti et à impact significatif (OpinionWay et CESIN, 2026). DORA retient la notion la plus large. Son champ, celui de l'incident lié aux technologies de l'information et de la communication, couvre ainsi une mise à jour défectueuse qui immobilise un système, même en l'absence de tout adversaire. Nous retenons les pertes propres à l'entité, quelle que soit l'intention, dans le périmètre défini en introduction.

Les conséquences financières dépendent de l'incident : interruption d'activité, restauration des systèmes ou gestion d'une fuite de données. Un même événement peut en produire plusieurs. La défaillance d'un prestataire ajoute une dépendance commune entre ses clients.

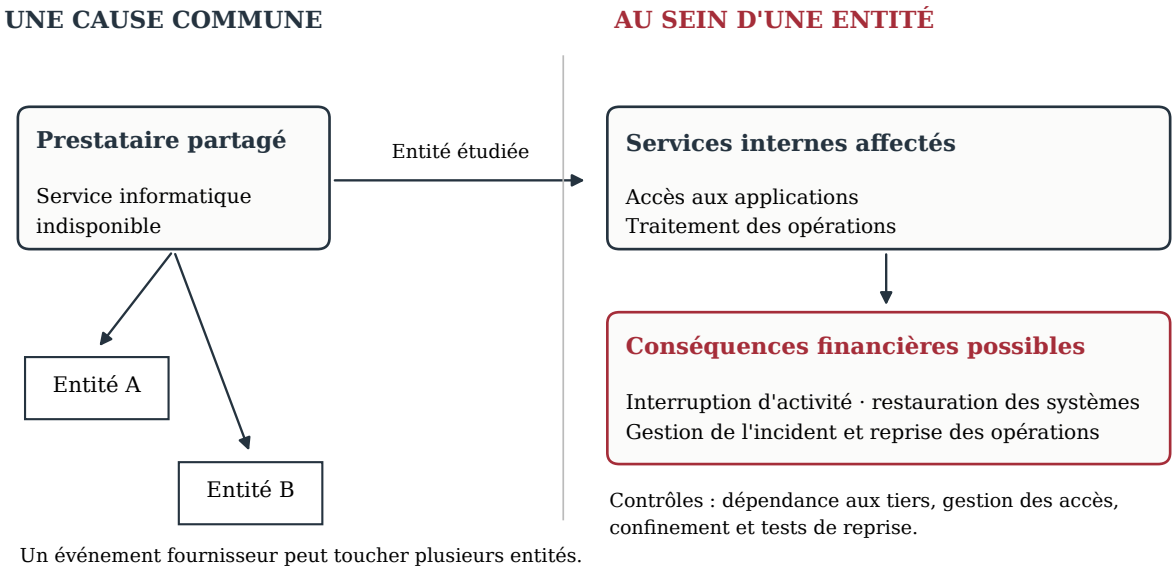


Figure 1.1. Du service informatique indisponible aux pertes opérationnelles. Ce scénario générique distingue un fournisseur commun à plusieurs entités des conséquences à l'intérieur d'une entité. Les contrôles cités peuvent en limiter les effets ; leur efficacité n'est pas estimée par ce dessin.

La figure 1.1 sépare deux niveaux. À gauche, une cause commune peut atteindre plusieurs clients. À droite, une seule entité peut subir plusieurs conséquences du même événement. C'est ce second niveau que décrit la propagation entre piliers ; l'événement doit rester compté une seule fois dans sa fréquence annuelle.

1.1.2 Incidents individuels et chocs de cause commune

La compromission d'un prestataire partagé peut produire une *accumulation* : plusieurs entités sont touchées par la même cause. À l'intérieur d'une entité, les contrôles peuvent aussi se dégrader ensemble. Une dépendance mal maîtrisée au prestataire, des tests de reprise insuffisants et une détection tardive peuvent ainsi aggraver les conséquences d'un événement. Nous représentons cette dépendance entre contrôles par les piliers, au niveau de l'entité étudiée.

La propagation a un sens. Un pilier dont la défaillance entraîne les autres n'appelle pas la même remédiation qu'un pilier qui subit la leur, alors que les statistiques disponibles n'enregistrent qu'une co-occurrence. Nous construisons au chapitre 5 la propagation dirigée qui distingue ces deux situations, avant d'étudier au chapitre 7 ce que les données permettent d'en identifier.

1.1.3 Quatre cas de référence

Les quatre incidents publics suivants illustrent la propagation, les causes communes et la dépendance à un prestataire. Ils servent à préciser le périmètre ; ils ne calibrent pas à eux seuls la matrice de transmission entre piliers.

WannaCry, en 2017, montre l'échelle de la propagation. Ce rançongiciel auto-propagable exploitait une faille du protocole de partage de fichiers de Windows. Il a touché en quelques jours des organisations de dizaines de pays, dont des hôpitaux britanniques et des chaînes de production. Près d'un an après la divulgation de la faille, un éditeur de sécurité bloquait encore des dizaines de millions de tentatives d'exploitation (Avast Threat Labs, 2018). Ces tentatives ne sont pas des sinistres : elles montrent qu'une vulnérabilité unique crée une exposition commune et durable.

NotPetya, en 2017, montre la propagation par un prestataire. Ce logiciel destructeur, diffusé par la mise à jour d'un logiciel comptable ukrainien, a paralysé pendant plusieurs semaines les réseaux de groupes internationaux. L'incident naît chez un prestataire (P4, prestataires tiers), se propage faute de cloisonnement des accès (P1, gouvernance) et met la gestion de crise à l'épreuve (P2, gestion des incidents). Son traitement assurantiel a donné lieu à des contentieux sur l'exclusion de guerre : un sinistre cyber peut être avéré sans être couvert.

MOVEit, en 2023, montre l'accumulation. Une vulnérabilité d'un logiciel de transfert de fichiers, exploitée par un groupe criminel, a permis de dérober des données chez des milliers d'organisations, souvent atteintes par leurs propres prestataires. Une seule défaillance tierce produit de nombreux sinistres simultanés. Nous l'utilisons comme expérience naturelle au chapitre 7.

CrowdStrike, en 2024, montre la dépendance sans adversaire. Une mise à jour défectueuse d'un logiciel de sécurité a bloqué des millions de postes dans le transport aérien, la banque et la santé. L'incident relève de la dépendance à un prestataire (P4, prestataires tiers) et de l'absence de déploiement progressif (P3, tests de résilience). Il entre dans le champ de DORA, et un périmètre restreint

aux attaques manquerait une part du risque que le règlement vise.

Ces cas motivent une représentation de la propagation et des causes communes. Pour un incident, décrire les domaines touchés ensemble et décrire leur ordre d'atteinte sont deux informations distinctes ; le modèle du chapitre 5 les sépare.

1.2 LIMITES DE L'ASSURABILITÉ ET DE LA CAPITALISATION DU RISQUE CYBER

1.2.1 Fréquence, sévérité et contrat d'assurance

On décompose la charge annuelle d'un risque en un nombre d'événements et un coût par événement, c'est-à-dire la fréquence et la sévérité. Les mêmes mesures ne réduisent pas les deux, la sensibilisation des collaborateurs agissant sur la fréquence et une capacité de reprise sur la sévérité. Nous appliquons cette décomposition à l'écart de capital entre états de conformité (chapitre 9).

Le contrat d'assurance transforme la perte. La *franchise* laisse à l'assuré la première tranche du sinistre et la *capacité* plafonne l'engagement de l'assureur, si bien qu'une charge indemnisée et une perte brute ne se comparent ni en niveau ni en quantile. Sur des données agrégées, une baisse de franchise et une aggravation de la menace produisent le même signal, à savoir une charge indemnisée qui monte. On retrouve cette situation au chapitre 7, à l'échelle des piliers, et nous la traitons de la même façon, en bornant ce que la donnée ne sépare pas.

1.2.2 Conditions d'assurabilité et asymétrie d'information

Le risque cyber met à l'épreuve les conditions de l'assurabilité. La défaillance d'un prestataire commun accroît la dépendance des pertes et limite la mutualisation. Une attaque ciblée reste incertaine pour la victime ; son caractère intentionnel ne supprime pas à lui seul l'aléa assurable. L'historique manque en outre là où se joue la quantification. L'asymétrie d'information entre assureur et assuré sur l'état réel du système d'information renforce enfin l'aléa moral et l'anti-sélection. DORA agit sur ce dernier point, car le registre des accords avec les prestataires, la notification des incidents majeurs et les tests de résilience rendent la maîtrise du risque observable. Une méthode qui traduit cette maîtrise en capital pourra exploiter cette information.

1.2.3 Rareté des données extrêmes et limite de l'historique français

Le besoin ORSA étudié est le quantile à 99,5 % de la charge annuelle, dépassé une année sur deux cents. Il dépend donc des sinistres les plus lourds, pour lesquels la donnée française est presque vide (section 1.3). Pour estimer une queue par dépassement de seuil, on ne retient que les pertes au-dessus d'un montant élevé, et il faut un effectif suffisant au-delà de ce seuil, ce que l'historique national n'offre pas. Une estimation sur cette base serait instable et sous-estimerait le risque, faute d'avoir observé les pertes qui le déterminent. C'est pourquoi nous calibrons la sévérité sur une base internationale (chapitre 3).

Cette rareté ne traduit pas une protection du marché français. Les sinistres cyber européens ont certes reculé d'environ 20 % en 2024, mais restent près d'un tiers au-dessus des exercices 2020 à

2022 (Marsh, 2025), et le marché britannique est décrit comme plus exposé aux sinistres sévères (UK Government, Department for Science, Innovation and Technology, 2025).

1.3 Marché français de la cyberassurance

L'étude LUCY de l'AMRAE, dont l'édition 2026 couvre l'exercice 2025, observe le marché français sur 20 996 polices et 1 251 sinistres déclarés, recueillis auprès de douze courtiers et d'un assureur (AMRAE, 2026). La série, engagée en 2019, compte sept exercices comparables. Nous avons co-écrit l'analyse actuarielle de cette édition (Rapior et Kaddouri, 2026). Ses valeurs sont reprises comme des citations externes, que nous ne pouvons pas recalculer, et n'entrent ni dans le modèle ni dans le calcul d'un montant de capital.

Un script du dépôt contrôle toutefois la fidélité de la recopie. Le rapport des sinistres aux primes redonne la série publiée des ratios, la somme des classes de taille redonne la charge annuelle sur les sept exercices, et chaque multiplicateur cité se retrouve à partir des niveaux qui l'encadrent. Ces contrôles ne portent ni sur la collecte ni sur le périmètre de l'étude, qui relèvent de ses auteurs.

La charge indemnisée s'élève à 83,2 M€ en 2025 contre 54,5 l'exercice précédent, soit +53 %. Nette de franchise et plafonnée par la capacité, elle ne se compare pas à la perte brute d'une entité, que nous modélisons. Entre 2024 et 2025, le nombre d'entreprises assurées croît de 49 %, mais les primes reculent de 3 %. Le ratio sinistres sur primes remonte depuis deux exercices, de 12 % en 2023 à 27 %, loin des 169 % de 2020. Le marché se diffuse donc par le volume plutôt que par le budget : davantage d'entreprises sont couvertes, pour une prime moyenne plus faible, au moment où la sinistralité remonte (figure 1.2). Le recul du taux de prime atteint 33 % pour les grandes entreprises et 23 % pour les entreprises de taille intermédiaire. Cet assouplissement ne repose sur aucune amélioration mesurée de la maîtrise du risque.

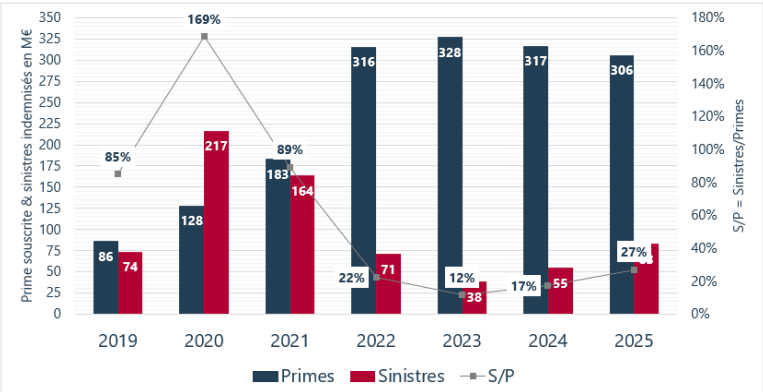


Figure 1.2. Primes souscrites, sinistres indemnisés et ratio sinistres sur primes, 2019–2025. La sinistralité remonte depuis deux exercices alors que les primes reculent. Source : rapport LUCY 2026, Nexialog Consulting (Rapior et Kaddouri, 2026).

La hausse du ratio recouvre deux régimes opposés. En 2024, les sinistres sont moins nombreux (×0,73) mais deux fois plus lourds (×1,96). En 2025, ils sont presque trois fois plus nombreux (×2,79) pour un coût moyen divisé par deux (×0,55). Seule la décomposition de la charge en nombre et coût moyen sépare ces deux situations, qui n'appellent pas les mêmes mesures. Le tableau donne

chaque terme sous la forme d'un multiplicateur de la valeur de l'année précédente.

	nombre	**sinistre moyen**	**charge**	**régime**
Marché, exercice 2024	×0,73	×1,96	×1,43	sévérité
Marché, exercice 2025	×2,79	×0,55	×1,53	fréquence
Exercice 2025, par bloc				
grandes entreprises	×1,24	×0,82	×1,02	absorbé
bloc intermédiaire	×2,14	×1,65	×3,53	les deux
micro-entreprises	×9,52	×0,73	×6,97	nombre seul

Le bloc intermédiaire est le seul segment où le nombre et le coût moyen augmentent ensemble, d'où une charge multipliée par 3,53. Ces multiplicateurs portent sur le *nombre* de sinistres, un total, et non sur la fréquence, qui le rapporte au nombre d'assurés. L'égalité charge = nombre × coût moyen n'est exacte qu'avec le nombre.

La divergence entre le prix et le risque ne se répartit pas uniformément : le segment dont la sinistralité progresse le plus n'est pas celui dont le tarif se redresse. Les multiplicateurs les plus forts portent sur les micro-entreprises, dont la part dans la charge totale reste marginale ; un multiplicateur hiérarchise des dynamiques, non des enjeux.

La limite qui engage notre modélisation se situe dans la queue. Deux exercices sur sept ne comptent aucun sinistre de la classe de 10 à 40 M€, et un exercice y enregistre 135 M€. En 2025, cette classe représente 19 M€, pour un seul sinistre au-delà de 10 M€ (figure 1.3). L'historique national s'arrête avant le haut de la distribution.

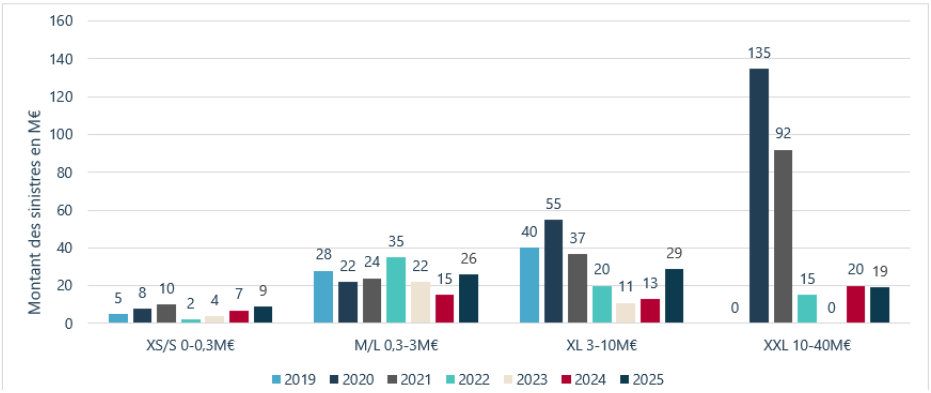


FIGURE 1.3. Charge indemnisée par classe de taille de sinistre, 2019–2025. La classe la plus haute est vide deux exercices sur sept : l'historique national s'arrête avant le haut de la distribution. Source : rapport LUCY 2026, Nexialog Consulting (Rapior et Kaddouri, 2026).

1.4 LE RÈGLEMENT DORA

1.4.1 Cadre réglementaire européen du cyber

Quatre textes européens encadrent le risque cyber. La directive NIS 2 (Union européenne, 2022b), relative à la sécurité des réseaux et des systèmes d'information, impose des exigences de sécurité et de notification aux entités essentielles et importantes. Elle rend également l'organe de

direction responsable des mesures de gestion du risque. Le règlement général sur la protection des données (Union européenne, 2016) encadre les données personnelles, la directive sur la résilience des entités critiques (Union européenne, 2022c) la continuité des fonctions sociétales vitales. Le règlement sur la cyberrésilience (Union européenne, 2024) couvre enfin la sécurité des produits numériques. Aucun n'est propre au secteur financier.

Le règlement DORA (Union européenne, 2022a) comble ce manque. Entré en application le 17 janvier 2025, il s'adresse à une vingtaine de catégories d'entités financières, dont les entreprises d'assurance, et leur demande de résister à l'incident, d'y réagir et de s'en rétablir.

Nous ne modélisons que DORA, car il est le seul de ces textes à découper la résilience en piliers dont la défaillance pourra se lire dans les incidents notifiés. Les cadres de l'intelligence artificielle et de l'identité numérique ne sont pas traités. Le règlement sur la cyberrésilience, applicable à partir de décembre 2027, agira sur la fréquence future des vulnérabilités. Notre calibration l'estime sur l'historique et ne la projette pas.

1.4.2 Les cinq piliers de DORA

Le règlement organise la résilience en cinq domaines, notés P1 à P5, que nous appelons *piliers*.

— P1, gouvernance du risque lié aux technologies (articles 5 à 16) : responsabilité non délégable de l'organe de direction, cartographie des actifs et des dépendances critiques, contrôle interne continu.

— P2, gestion, classification et notification des incidents (articles 17 à 23) : notification initiale dès que possible, sous quatre heures après classification majeure et au plus tard vingt-quatre heures après prise de connaissance. Si la classification intervient après ce délai, la notification suit sous quatre heures. Le rapport intermédiaire est dû sous soixante-douze heures après la notification initiale, le rapport final sous un mois après le rapport intermédiaire ou sa dernière mise à jour (Commission européenne, 2025a).

— P3, tests de résilience opérationnelle numérique (articles 24 à 27), dont des tests de pénétration guidés par la menace (TLPT), au moins tous les trois ans, pour les entités significatives (article 26).

— P4, gestion du risque lié aux prestataires tiers (articles 28 à 44) : registre d'informations des contrats, clauses impératives de l'article 30, stratégie de sortie et surveillance des prestataires critiques. Leur chaîne de sous-traitance est prise en compte sans limite générale au troisième rang.

— P5, partage d'informations sur les cybermenaces (article 45), volontaire et encadré, le pilier le moins utilisable dans un calibrage actuariel.

Ces piliers ne sont pas indépendants, car un incident qui touche l'un dégrade la capacité de l'entité à tenir les autres (sous-section 1.1.2). Nous formalisons cette dépendance au chapitre 5.

1.4.3 Prestataires TIC, concentration et propagation du risque

La sous-traitance informatique du secteur financier est concentrée sur un petit nombre de fournisseurs, si bien qu'une défaillance chez l'un d'eux atteint de nombreuses entités sans faute de leur part. DORA instaure pour cette raison une surveillance directe des prestataires critiques, ce qui est nouveau dans l'architecture prudentielle européenne. Le premier bilan des notifications montre le poids des prestataires. En 2025, les sociétés de gestion ont adressé à l'Autorité des marchés financiers 47 notifications initiales, dont 31 incidents majeurs confirmés, parmi lesquels 27, soit 87 %, trouvent leur origine chez un prestataire (Autorité des marchés financiers, 2026).

Cette part dit d'où viennent les incidents ; elle ne fournit pas de probabilité de transfert entre piliers et ne calibre aucun paramètre du modèle. Les notifications initiales précèdent la confirmation du caractère majeur : l'écart avec les incidents confirmés est celui d'un seuil de matérialité, et la collecte réglementaire ne retiendra que les incidents au-dessus de ce seuil.

Pour la modélisation, l'exigence la plus utile est le registre d'informations. En recensant les contrats TIC critiques et leurs chaînes de sous-traitance, il produit une donnée sur la concentration technologique que l'évaluation interne des risques ne savait pas chiffrer. Il ne couvre que la dépendance déclarée et ne dit rien de l'ordre dans lequel les défaillances s'enchaînent (section 10.8).

1.4.4 Autorités françaises et supervision

À notre connaissance, les autorités de supervision ne publient pas de probabilité de propagation entre piliers. Elles publient des attentes prudentielles et des échelles de maturité, qui sont d'une autre nature. Les valeurs de propagation du modèle sont donc posées à dire d'expert, puis bornées, et nous ne les présentons pas comme calibrées sur une source officielle.

1.5 PERCEPTION DU RISQUE ET TRAITEMENT PRUDENTIEL

1.5.1 Perception prospective selon France Assureurs et le CESIN

La cartographie prospective de France Assureurs classe le risque cyber au premier rang pour le huitième exercice consécutif, avec un score de 4,1 sur 5 (France Assureurs, 2026). Ce score a culminé à 4,48 en 2022 et revient à 4,10 en 2026. Entre 2025 et 2026, il recule de 0,45 point en fréquence anticipée et progresse de 0,25 point en sévérité : moins d'événements attendus, mais plus lourds. Le cyber n'est pas seul dans ce régime.

Deux risques seulement de la cartographie gagnent en sévérité tout en reculant en fréquence. Ce sont le cyber, à +0,25 point de sévérité pour −0,45 de fréquence, et la qualité des données et la conformité des processus informatiques, à +0,30 pour −0,20. Le déplacement le plus fort de l'édition en sévérité appartient à l'environnement politique, à +0,32, mais il s'accompagne d'une hausse de fréquence de +0,30 et relève d'un autre régime. La cartographie fait par ailleurs figurer un risque de non-conformité et de sanctions ainsi qu'un risque lié à l'intelligence artificielle. La préoccupation de la profession se déplace de la menace vers sa gouvernance, qui est l'objet de DORA.

D'après le baromètre du CESIN (Club des experts de la sécurité de l'information et du numérique), qui en donne le constat déclaré (OpinionWay et CESIN, 2026), 40 % des entreprises interro-

gées ont subi au moins une cyberattaque significative en 2025. Parmi les 159 qui en ont constaté une, l'hameçonnage est cité par 55 %, l'exploitation d'une faille par 41 %. Chaque entreprise attaquée cite en moyenne 3,3 vecteurs, contre 4,0 à la vague précédente, car une attaque n'emprunte presque jamais un chemin unique (figure 1.4). L'attaque indirecte par un tiers pèse 35 %, et sa part monte à 43 % dans les grandes entreprises. On reconnaît là le pilier P4, vu par une source indépendante de ce travail.

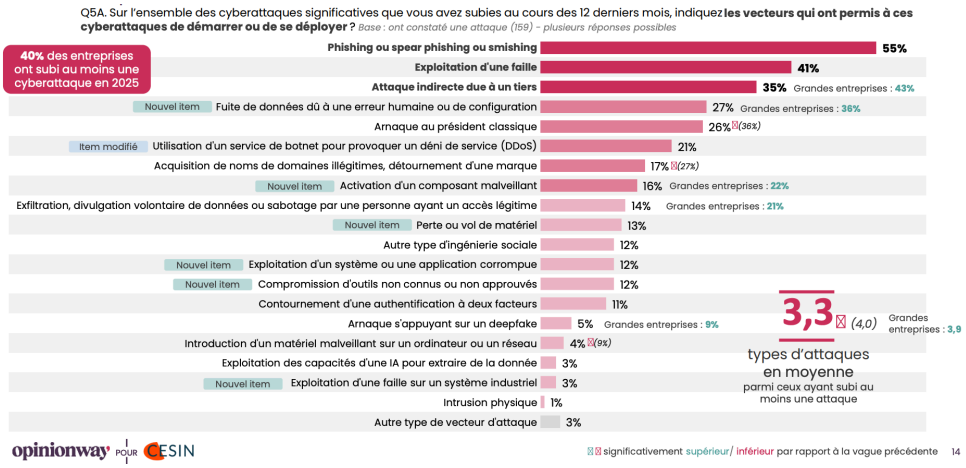


FIGURE 1.4. Vecteurs ayant permis aux cyberattaques de démarrer ou de se déployer, exercice 2025. Les mentions de droite donnent la part dans les grandes entreprises lorsqu'elle diffère significativement de la moyenne. Source : baromètre de la cybersécurité des entreprises, OpinionWay pour le CESIN (OpinionWay et CESIN, 2026).

Quatre entreprises attaquées sur cinq, soit 81 %, déclarent un impact sur leur activité. Les conséquences dominantes sont la perturbation de la production, à 28 %, et la perte d'image, à 26 %, devant la compromission de savoir-faire et la perte de chiffre d'affaires, à 18 % chacune. La sanction d'une autorité ne concerne que 3 % des cas. Nous ne modélisons donc pas les pénalités : la non-conformité coûte, dans le modèle, par les incidents qu'elle laisse passer. La déconnexion de l'entité par ses propres partenaires, citée dans 12 % des cas, montre enfin que la dépendance joue dans les deux sens, avec des coûts et des préventions différents.

1.6 CADRE PRUDENTIEL ET ARTICULATION AVEC DORA

Le risque opérationnel reçoit la même définition dans la banque et dans l'assurance. Il s'agit du risque de perte résultant de l'inadaptation ou de la défaillance de procédures, de personnels et de systèmes internes, ou d'événements extérieurs. Il comprend le risque juridique et exclut les risques stratégique et de réputation.

Les modes de quantification ont cependant divergé. Le secteur bancaire a abandonné les modèles internes de mesure avancée au profit d'une approche standardisée (Comité de Bâle sur le contrôle bancaire, 2017), sans invalider l'approche par distribution des pertes (LDA, *Loss Distribution Approach*) comme outil de modélisation. Nous en reprenons les deux marges, fréquence et sévérité, et remplaçons son agrégation par une cascade dirigée. L'assurance conserve sous Solvabilité II le choix entre la Formule Standard, des paramètres propres à l'entreprise et un modèle interne, partiel

ou global, approuvé par l'autorité de contrôle.

Dans la Formule Standard, l'exigence pour risque opérationnel (SCR_{Op}) s'ajoute au capital de solvabilité requis de base ($BSCR$), ajusté de la capacité d'absorption des pertes :

$$SCR = BSCR + Adj + SCR_{Op}, \qquad SCR_{Op} = \min(0{,}3 \times BSCR,\ Op) + 0{,}25 \times Exp_{ul}, \quad (1.1)$$

où Adj est l'ajustement pour la capacité d'absorption des pertes, Exp_{ul} les frais annuels des contrats en unités de compte et $Op = \max(Op_{premiums}, Op_{provisions})$ applique des coefficients forfaitaires aux primes et aux provisions. Cette forme est simplifiée, car l'article 204 du règlement délégué 2015/35 ajoute des termes de croissance, de la forme $\max(0;\ 0{,}04 \times \Delta)$, qui pénalisent les hausses de primes supérieures à 20 % d'un exercice à l'autre.

Fondée sur des indicateurs de volume, l'approche attribue la même exposition à deux assureurs de même volume, quelles que soient la qualité de leur informatique et leur dépendance à des prestataires critiques. Le SCR_{Op} réglementaire s'ajoute au BSCR sans diversification. Cela n'implique pas qu'un quantile ORSA supplémentaire doive être ajouté en entier : il faut éviter le double compte du risque informatique déjà couvert (§9.7).

Le SCR_{Op} relève des exigences quantitatives (forfaitaires) de Solvabilité II. Les exigences de gouvernance imposent l'évaluation interne des risques et de la solvabilité (*Own Risk and Solvency Assessment*, ORSA). Elle confronte le profil de risque réel aux besoins de solvabilité et admet les scénarios stochastiques que la Formule Standard ne produit pas. Notre modélisation se situe dans ce cadre. ORSA et DORA partagent un objet, le risque opérationnel d'origine technologique, l'ORSA pour la continuité financière, DORA pour la continuité opérationnelle. Nous partons d'états de conformité posés pour quantifier dans l'ORSA ce que celui-ci ne savait que décrire (chapitres 6 et 9).

1.6.1 De l'approche de mesure avancée à l'approche standardisée

Sous Bâle II, les établissements bancaires d'envergure internationale étaient encouragés à développer des modèles internes, regroupés sous le nom d'approche de mesure avancée (*Advanced Measurement Approaches*, AMA). Ces modèles reposaient surtout sur l'approche par distribution des pertes (LDA) ou sur des scénarios. Leur flexibilité a produit des actifs pondérés par le risque très variables d'un établissement à l'autre, et difficiles à justifier, ce qui a érodé la confiance des superviseurs dans les ratios déclarés.

La finalisation de Bâle III, souvent appelée Bâle IV, remplace les modèles AMA par une approche standardisée. Dans l'Union européenne, CRR III s'applique depuis le 1er janvier 2025. Il faut distinguer ce texte du standard international de Bâle (Union européenne, 2024). Dans ce dernier, l'exigence de capital opérationnel combine une composante de volume d'activité, le *Business Indicator Component* (BIC), et un facteur d'échelle fondé sur l'historique des pertes internes, l'*Internal Loss Multiplier* (ILM) :

$$ORC = BIC \times ILM, \qquad RWA_{Op} = 12{,}5 \times ORC. \quad (1.2)$$

Le *Business Indicator* résume la taille de l'établissement à partir de trois composantes comptables (intérêts et dividendes, services, activité financière), auxquelles s'appliquent des coefficients marginaux croissants par tranches. Le profil de risque propre revient par l'ILM, qui compare le BIC à la composante de pertes historiques LC, égale à quinze fois la moyenne des pertes opérationnelles annuelles significatives des dix dernières années. Lorsque la sinistralité est faible par rapport à l'activité ($LC < BIC$), l'ILM est inférieur à l'unité et réduit l'exigence. Lorsqu'elle est élevée, il agit comme une pénalité en fonds propres.

Dans l'Union européenne, l'article 312 de CRR III retient au contraire $ORC = BIC$, sans ajustement par l'ILM. La collecte des pertes subsiste, mais ne multiplie pas cette exigence. Le retrait de l'AMA n'invalide pas la LDA comme outil de modélisation interne. Nous en reprenons la logique de distribution des pertes en ORSA, sans la présenter comme une règle bancaire européenne.

1.6.2 Critique du module de risque opérationnel de la Formule Standard

La charge de l'équation (1.1) est examinée ici au regard d'une question précise : traduire en capital une différence d'état de conformité DORA entre deux entités. Ce n'est pas la question que le module cherche à résoudre. Il vise une charge simple, comparable d'une entité à l'autre et peu exposée au risque de modèle, ce qui justifie sa forme forfaitaire au pilier 1. Les limites relevées ci-dessous portent donc sur son adéquation à l'objet étudié, non sur sa légitimité réglementaire. Faute de sous-module cyber, l'évaluation de cet objet revient aux modèles internes et à l'ORSA. Deux propriétés de la formule fondent la critique.

Proposition 1.1 (Invariance et homogénéité de la charge forfaitaire)**.** *Soit v le vecteur des grandeurs de volume d'une entité : primes acquises de l'exercice et de l'exercice précédent, provisions techniques, BSCR et Exp_{ul}. Soit θ les paramètres de sa loi de perte opérationnelle : fréquence, détection, propagation et accumulation.*

(i) SCR_{Op} est une fonction de v seule : à v fixé, il ne dépend pas de θ.

(ii) SCR_{Op} est positivement homogène de degré un : $SCR_{Op}(c\,v) = c\,SCR_{Op}(v)$ pour tout $c > 0$, termes de croissance et plafond compris.

Démonstration. (i) L'article 204 du règlement délégué 2015/35 n'emploie comme arguments que les composantes de v. (ii) Chaque terme de $Op_{premiums}$ et de $Op_{provisions}$ est de la forme αx ou $\max(0, \alpha x - \beta y)$. Ici $\alpha, \beta \geq 0$ sont fixés et x, y sont des composantes de v. Ces fonctions sont positivement homogènes de degré un. Le maximum, le minimum et la somme de telles fonctions le restent, d'où l'homogénéité de $\min(0{,}3\,BSCR,\ Op) + 0{,}25\,Exp_{ul}$. □

La propriété (i) implique qu'à volume égal l'écart de charge entre un état conforme et un état non conforme est nul. La propriété (ii) fixe à un l'élasticité de la charge lorsque tous les volumes, $BSCR$ compris, sont multipliés par le même facteur. Le tableau 1.1 en déduit six limites pour la question étudiée et indique, pour chacune, la réponse étudiée dans la suite du mémoire. Les valeurs citées sont établies aux chapitres de renvoi.

Limite	Constat (texte réglementaire)	Conséquence pour la question étudiée	Réponse étudiée
L1 · Indicateur de volume	Arguments : primes, provisions, BSCR et frais des unités de compte ; le terme de croissance pénalise une hausse des primes, non du risque.	Écart de charge nul entre états de même volume (proposition 1.1, tableau 9.4) ; une remédiation ne modifie pas le capital.	Quatre canaux de conformité dans la loi de perte (chapitre 6).
L2 · Proportionnalité à la taille	Charge homogène de degré un en volume.	Lien taille–charge fixé par convention. Le modèle lit la taille dans deux entrées (exposant de fréquence estimé sur les grandes institutions, 0,087 en sévérité) ; le capital s'obtient en recalculant le quantile.	Fréquence et sévérité lues à la taille, exposant de fréquence estimé sur les grandes institutions (§9.5).
L3 · Absence de loi de perte	Coefficients fixés par le règlement, sans modèle de perte propre à l'entité.	Le quantile à 99,5 % de la perte opérationnelle n'est pas lisible ; la queue lourde ($\hat{\xi} = 0{,}595$) n'est pas représentée.	Modèle fréquence-sévérité à queue de Pareto généralisée (chapitre 4).
L4 · Plafond relatif	Composante hors frais des unités de compte plafonnée à 0,3 $BSCR$.	Pour l'assureur non-vie A ($Adj = 0$ posé), la marge sous le plafond, 50,8 M€, est dépassée par le besoin non conforme (112,1) mais pas par l'écart de contagion (34,9, soit 0,69 fois).	Agrégation de l'écart en ORSA (§9.7).
L5 · Absence de structure de dépendance	Charge scalaire ajoutée au BSCR, sans dépendance entre domaines de contrôle.	Le comparateur à copule gaussienne figée construit ici restitue 62 % de l'écart simulé (§9.4) ; deux matrices transposées, non distinguées par les statistiques disponibles, donnent des capitaux différents.	Cascade dirigée et identification partielle (chapitres 5 et 8).
L6 · Absence d'historique de pertes	Aucun terme de sinistralité, à la différence du standard de Bâle avec ILM ; CRR III ne le retient pas (§1.6.1).	Les notifications et registres produits au titre de DORA n'ont pas d'effet sur la charge.	Valeur d'information d'un registre d'incidents (§10.8).

Tableau 1.1. Six limites du module de risque opérationnel pour la question étudiée, et réponses examinées dans le mémoire. L1 et L2 découlent de la proposition 1.1 ; L3 à L6 tiennent à la construction du module.

La figure 1.5 illustre la différence d'objet entre les deux approches. La charge forfaitaire est une

fonction du volume ; le besoin de capital de l'ORSA est un quantile d'une loi de perte que l'état de conformité déplace.

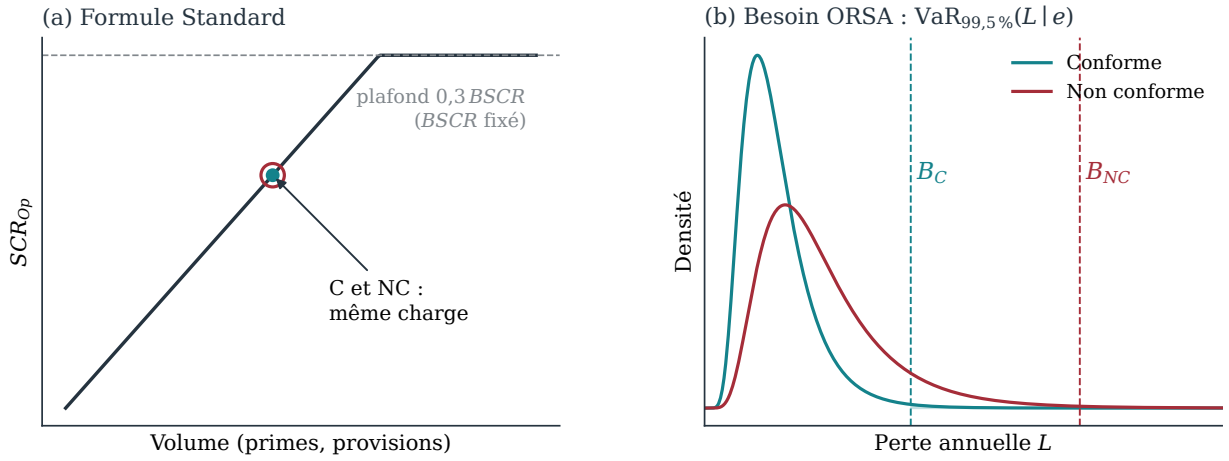


FIGURE 1.5. Deux objets distincts. (a) Charge de la Formule Standard en fonction du volume, à $BSCR$ fixé (le plafond 0,3 $BSCR$ ne bouge donc pas) : deux entités de même volume reçoivent la même charge, quel que soit leur état de conformité. (b) Besoin de capital au sens de l'ORSA : quantile à 99,5 % de la perte annuelle, déplacé par l'état de conformité. Illustration sans valeur estimée ; les valeurs du périmètre étudié figurent au tableau 9.4.

Ces limites ne plaident pas pour remplacer le forfait du pilier 1, dont la comparabilité entre entités reste un objectif prudentiel propre. Elles délimitent ce qu'il ne peut pas exprimer : la réponse étudiée relève du pilier 2, où l'ORSA admet une loi de perte propre à l'entité et des scénarios de conformité.

1.6.3 Recouvrement de Solvabilité II et de DORA

Outre leur finalité, financière pour l'un et opérationnelle pour l'autre, les deux cadres diffèrent par leurs critères de proportionnalité. Le forfait de Solvabilité II utilise des volumes ; DORA tient aussi compte de la taille, du profil de risque et de la complexité des activités (article 4). La petite taille ne suffit pas à ouvrir le cadre simplifié : le champ et les exclusions de DORA se lisent aux articles 2 et 16.

DORA apporte à l'ORSA trois éléments décrits au §1.4.2 : un cadre de gestion des contrôles, une notification standardisée des incidents majeurs et un registre des dépendances aux prestataires. Ils répondent à trois limites des ORSA fondés sur des cartographies d'experts. Ces ORSA traitent les risques informatiques à part des risques financiers et assurantiels, sans corrélation modélisée. Ils manquent de données de sinistralité qualifiées pour les événements rares et lourds, et leurs tests de résistance omettent la propagation d'une panne chez un fournisseur partagé. Ce travail se place dans ce recouvrement. Il croise plusieurs sources indépendantes (PRC, SAS OpRisk Global, Hackmageddon) en déclarant l'incertitude résiduelle, et représente la propagation entre domaines de contrôle.

2

Revue de littérature et positionnement

Les travaux mobilisés étudient l'assurabilité et la rareté des données (Biener et al., 2015), les pertes extrêmes, la contagion entre entités et les arrivées dans le temps. Nous reprenons leurs lois et leurs états successifs pour étudier la propagation entre les domaines de contrôle d'une même entité.

2.1 Comparaison aux approches existantes

Le tableau 2.1 distingue ces objets. Notre articulation entre contrôles d'une même entité et incertitude sur la direction n'est pas traitée conjointement dans les références comparées. Les chapitres suivants la construisent à partir de ces briques.

	Modélisation du risque		**Structure et décision**		
Références	Lois de pertes	Dynamique temporelle	Piliers d'une même entité	Identification partielle	Remédiation
Sévérité et dépendance cyber					
Böhme et Kataria (2006) ; Herath et Herath (2011)	✓ *Copules*				
Eling et Wirfs (2019) ; Farkas et al. (2021)	✓ *GPD*				
Hillairet et Lopez (2021) ; Hillairet et al. (2022)		✓ *États SIR*			
Bessy-Roland et al. (2021) ; Boumezoued et al. (2023)		✓ *Hawkes*			
Information incomplète et quantité d'intérêt					
Manski (1990) ; Tamer (2010)				✓ *Ensembles*	
Ce travail	✓ *GPD reprise*	✓ *États posés*	✓ *Cascade*	✓ *Exploration*	✓ *Scénarios*

Tableau 2.1. Objets traités par les références comparées. Une case vide ne signifie pas une impossibilité générale de la méthode. La dernière ligne rassemble les briques reprises et leur adaptation aux piliers DORA.

Les matrices de risque et l'analyse des modes de défaillance, de leurs effets et de leur criticité (AMDEC) classent les risques. L'indice RPN (*Risk Priority Number*) multiplie gravité, occurrence

et détection. Une copule relie les lois individuelles, appelées marges, pour former une loi jointe de pertes. Ni ce classement ni cette loi des seules pertes ne décrivent l'ordre d'atteinte des piliers.

Les modèles de réseau représentent des transmissions entre entités, sous une structure et des taux d'infection qui ne sont pas observés ici. Nous en reprenons l'idée d'états successifs, appliquée aux contrôles d'une même entité. Les processus de Hawkes répondent à une autre question : un incident augmente-t-il le taux d'arrivée d'autres incidents ? Les réseaux bayésiens décrivent des liens dirigés sur un graphe acyclique avec des probabilités conditionnelles. La section 2.3 détaille ces références ; le chapitre 9 compare les effets de modèles de dépendance sur le capital et le chapitre 10 examine l'information temporelle disponible.

2.2 Dépendance dirigée et dépendance à l'ordre

L'objet propre à la cascade peut maintenant être précisé. La matrice W de contagion entre piliers, posée à dire d'expert puis bornée au chapitre 8, donne par W_{jk} la propension d'une défaillance de j à entraîner celle de k. La ligne désigne l'émetteur, la colonne le récepteur. Elle est dirigée, au sens où $W_{jk} \neq W_{kj}$, et autorise des cycles comme P1→P2→ $\cdots$ →P1. La normalisation de Leontief les stabilise ($\rho(W) \leq g < 1$, forme réduite $(I - W)^{-1}$).

Avec le score de criticité du modèle, de 1 à 10 et construit à partir des barèmes d'expert (chapitre 5), 22 des 26 sous-ensembles d'au moins deux piliers changent de score selon l'ordre. L'écart atteint 6 points : 8 pour P1→P2, contre 2 pour P2→P1. Un score statique invariant par permutation ne peut pas reproduire cette propriété. La non-transitivité de la dominance, testée sous trois formulations, ne se vérifie pas et n'est pas revendiquée (chapitre 5).

2.3 Travaux par thème

Dépendance et contagion

La corrélation entre risques cyber a d'abord été traitée par copules (Böhme et Kataria, 2006 ; Herath et Herath, 2011). Sur la chronologie PRC, l'indice de Gini de la charge journalière vaut 0,69 (2 922 jours, 4 614 événements) : les sinistres se concentrent sur peu de jours, ce qui est compatible avec une accumulation par cause commune. Hillairet et Lopez (2021) couplent des processus de comptage à un modèle épidémiologique compartimental de type SIR (susceptibles, infectés, rétablis), et Hillairet et al. (2022) y ajoutent une structure de réseau. Xu et Hua (2019) et Baldwin et al. (2017) modélisent la contagion entre cibles.

Dynamique temporelle

Bessy-Roland et al. (2021) ajustent des processus de Hawkes aux données PRC, l'une de nos sources, puis Boumezoued et al. (2023) ajoutent un terme exogène. Hillairet et al. (2021) en développent la théorie pour le pricing de dérivés, et Peng et al. (2017) les appliquent à des taux d'attaque horodatés.

Fréquence, sévérité et queue

Edwards et al. (2016) ajustent une binomiale négative au nombre journalier de brèches, et Lu et al. (2024) séparent fréquence et nombre de brèches par événement, une structure compatible avec la loi de fréquence retenue ici (binomiale négative, chapitre 4). Farkas et al. (2021) tarifent par arbres de régression GPD. La queue lourde des pertes cyber est documentée (Maillart et Sornette, 2010 ; Wheatley et al., 2016), et Eling et Loperfido (2017) comparent plusieurs familles de lois sur les brèches de données. Eling et Wirfs (2019) étudient les pertes cyber de la base SAS OpRisk Global par les valeurs extrêmes, et leur étude est le précédent le plus proche pour la sévérité.

Travaux sur les mêmes sources

Ranguin (2024) modélise le risque cyber des entreprises françaises pour la Caisse Centrale de Réassurance, à partir de PRC, VCDB, Hackmageddon et de l'étude LUCY. La sévérité y est construite par arbres de régression GPD sur le volume de données compromises. La sinistralité d'un portefeuille fictif est simulée, sinistres courants compris. Les lois sont ensuite reparamétrées dans un cadre bayésien sur le marché français. Cette étude ne produit pas de mesure de capital à un quantile réglementaire. L'objet étudié ici est le besoin de capital d'une entité financière selon son état de conformité, avec une sévérité calibrée sur des pertes en montants et une dépendance modélisée entre piliers.

Sur PRC, Kher et al. (2023) estiment la gravité d'un incident à partir de sa description textuelle par réseaux de neurones, et Dountio Zaboue (2026) prolonge cette démarche. Ces travaux classent la sévérité d'un incident en volume de dossiers compromis.

Cadre structurel et identification partielle

Le facteur latent commun vient du modèle à facteur de Vasicek (2002), et la normalisation qui stabilise une contagion avec cycles provient de l'analyse entrées-sorties de Leontief (1936).

L'identification partielle caractérise des valeurs admissibles puis leurs conséquences sur une quantité d'intérêt (Manski, 1990, 1995 ; Tamer, 2010). Ce principe est repris pour explorer le capital à direction inconnue, conditionnellement à la force des liens posée. Le chapitre 8 précise l'ensemble admissible et l'échelle de contraintes de structure.

Cascade de risques climatiques

Le réseau de cascade climatique de Karimi et al. (2026) sépare le temps calendaire des pas de propagation. Cette architecture, le protocole de comparaison et l'expérience d'ablation en sont repris. Ses valeurs synthétiques n'entrent dans aucune calibration de ce travail.

2.4 Positionnement

Le tableau 2.2 relie chaque question à une méthode et au résultat qui permet d'en juger. Il sert de guide aux chapitres suivants : construire le calcul, l'éprouver quand l'information manque, puis comparer les choix de remédiation.

Question à résoudre	**Méthode et apport**	**Résultat à examiner et limite**
Comment représenter l'effet d'un état de conformité que le forfait ne distingue pas ?	Relier un état supposé aux paramètres d'une même chaîne de pertes (chapitres 4 à 6).	Comparer les capitaux annuels (§9.1) ; les écarts entre états sont posés, sans effet causal établi.
Que reste-t-il du calcul si les données ne donnent pas le sens des transmissions ?	Examiner les sources, séparer force et asymétrie, puis explorer les directions admissibles (chapitres 7 et 8).	Une plage aux sommets, à force commune fixée ; ni intervalle de confiance ni borne globale démontrée.
Quelle correction comparer, et quelles données manquent pour décider ?	Calculer les effets de fermeture, puis éprouver les coûts et la calibration (chapitres 9 et 10).	Gains conditionnels et besoins de collecte ; l'efficacité réelle d'une remédiation reste à mesurer.

Tableau 2.2. Les questions qui guident le mémoire et les réponses à vérifier. Les renvois indiquent où la méthode est construite puis éprouvée ; la dernière colonne en délimite la portée.

La première étape consiste donc à déterminer les entrées réellement observées. Le chapitre suivant distingue les pertes disponibles des états et des transmissions qui resteront posés.

3

Données

Quelles entrées du calcul les données permettent-elles d'estimer ? Nous séparons les montants de pertes, les nombres d'incidents et les parts des vecteurs d'attaque. Le tableau suivant attribue à chaque source son rôle. Les états de conformité et les transmissions entre piliers ne sont observés dans aucune de ces bases : ils resteront des hypothèses du calcul.

3.1 Sources et rôles

Source	Effectif retenu	Rôle dans le modèle	Justification / limite
PRC 2025	15 053 incidents, 2019 à 2025	Sévérité alternative via conversion Jacobs ; nombre annuel de notifications λ_{ref}, décrit et non utilisé par le moteur	Périmètre défini, mais sévérité dérivée d'un modèle log-log
SAS OpRisk Global	41 975 pertes, dont 570 en cyber × finance de 2000 à 2026	Sévérité (montants réels) et nombre annuel d'incidents du moteur (λ)	Montants observés, mais biais vers les grandes entités financières
Hackmageddon	1 041 incidents, premier semestre 2026	Parts par vecteur d'attaque (structure du risque)	Ne fixe aucun niveau : pondère le multiplicateur qui fait passer λ d'un état de conformité à l'autre

Les articles 19 et 231 du règlement délégué (UE) 2015/35 exigent des données exactes, exhaustives et appropriées, pour les provisions techniques et pour un modèle interne ; nous prenons ces critères pour référence. Aucune des bases que nous avons examinées ne remplit ces trois exigences. Nous documentons les biais de chaque source et leurs retraitements.

3.2 Biais statistiques des sources

Trois biais affectent les bases PRC et OpRisk. Le *biais de sélection* touche OpRisk, qui recense surtout des pertes rendues publiques, donc celles des grandes entités ou des montants exceptionnels.

Il surreprésente les événements extrêmes. Nous adaptons les pertes à la taille par une élasticité de sévérité, variation relative de la perte associée à une variation relative de taille, estimée (§3.5).

Pour la fréquence, le §9.5 distingue l'exposant estimé sur tout le registre et celui, retenu, des grandes institutions. Le *biais de déclaration* touche la PRC, car la notification des fuites de données personnelles est obligatoire dans la plupart des États américains, pas celle d'un rançongiciel qui n'exfiltre rien. Le niveau de fréquence est donc lu sur OpRisk, et la répartition par vecteur sur Hackmageddon.

Un *biais de survie* pourrait sous-représenter les entités disparues, mais les pertes qui ont conduit à une faillite sont souvent publiques. Ces bases n'en donnent ni l'existence ni le signe, et il ne figure pas parmi les écarts mesurés du chapitre 10.

3.3 Hétérogénéité temporelle et actualisation des sinistres

Le sous-échantillon cyber-finance OpRisk contient des pertes de 1979 à 2026, période sur laquelle les montants nominaux dérivent. Pour chaque perte, la base donne le montant de l'année de l'événement et sa valeur courante, corrigée de l'inflation générale. Leur rapport, égal à un pour les années récentes, atteint 1,747 en 2004, d'où une inflation implicite de 2,19 % par an. Nous calibrons cependant sur le premier, c'est-à-dire sur des montants *nominaux*. Ce choix minore les sinistres anciens ramenés en euros courants, donc la queue et le capital. Son effet sur la dérive des pertes est mesuré au §4.7.

La PRC fournit la fréquence de référence λ_{ref}, qui compte des notifications sans seuil de matérialité et ne fixe pas le niveau du capital. Elle sert aussi de source de sévérité indirecte : la conversion de Jacobs (2014), $\ln(L) = 7{,}68 + 0{,}76\ \ln(X)$, donne la perte L en dollars d'un incident à partir de son nombre X d'enregistrements. Calibrée sur les 15 053 incidents 2019–2025 dont le volume touché est renseigné (la figure 3.1 compte toutes les notifications), la queue PRC a un paramètre de forme $\hat{\xi}_{\text{PRC}} = 1{,}03$ (intervalle à 90 % : [0,97 ; 1,09]). À cette valeur, l'espérance est infinie. On ne la lit qu'avec le plafond de sévérité propre à cette source *(voir le Matériel Complémentaire en ligne)*.

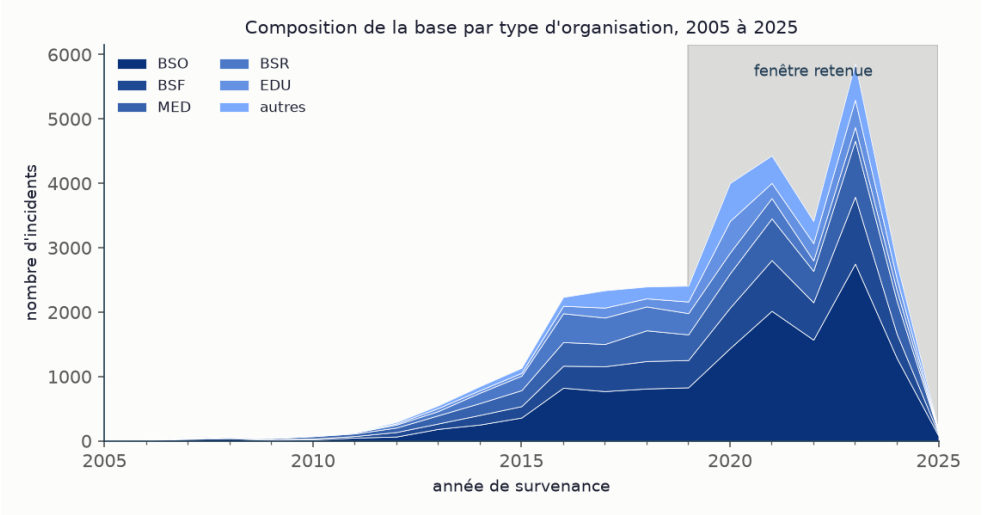


FIGURE 3.1. Composition de la chronologie PRC par type d'organisation et par année. La zone grisée est la fenêtre retenue. La hausse d'avant 2019 suit l'extension de la collecte. La baisse de 2025 traduit le manque de recul. BSF : organisations financières ; les autres codes sont ceux de la base.

3.4 FRÉQUENCES ET SEUILS DE COLLECTE

La valeur de la fréquence dépend du périmètre de comptage de la source. Sur le panel firme-année du SAS OpRisk (sous-catégories TIC, 2005–2022), le taux est de 0,10 événement par firme et par an toutes firmes confondues, et 0,21 pour les firmes à au moins dix événements.

Au chapitre 9, nous estimons λ comme une fonction de la taille de firme afin de le lire à celle de l'entité notionnelle, ce qui donne 0,021 avec l'exposant estimé sur les grandes institutions. Ces taux sont par firme ; celui du moteur compte le périmètre financier étudié. Le panel d'entité retient cinq sous-catégories TIC, plus larges que le filtre cyber-finance de sévérité : leur réconciliation reste nécessaire. Tous ne retiennent que les pertes au-dessus du seuil de collecte d'OpRisk. Ils comptent donc les incidents TIC *matériels*, pas tous les incidents au sens du reporting DORA.

Le taux par firme est une propriété d'entité, lisible sur un panel. Le tableau 9.5 traduit ces échelles en capital.

Le terme de fréquence recouvre trois taux, à trois niveaux d'observation :

Symbole	Source	Valeur	Ce qu'il compte
λ_{ref}	PRC	341/an	notifications de violation de données des *organisations financières* de la base PRC (code `BSF`), et non de la base entière, qui en compte 2 150 par an. Décomposée par vecteur d'attaque ; n'entre pas dans le moteur et ne fixe aucun niveau de capital.
λ	OpRisk	21,6/an	incidents TIC *matériels* du périmètre financier étudié. C'est l'entrée du moteur pour les capitaux de ce périmètre.
$\lambda_{\text{entité}}$	OpRisk	0,021/an	les événements TIC du panel, rapportés à *une* firme et lus *à la taille* de l'entité notionnelle. C'est l'échelle de lecture d'une entité soumise à DORA.

Le facteur 16 307 entre λ_{ref} et $\lambda_{\text{entité}}$ sépare trois comptages, ceux des notifications, des pertes matérielles du secteur et des pertes matérielles par entité. Les capitaux du périmètre financier reposent sur λ ; les besoins d'entité utilisent la fréquence $\lambda(A)$ du panel (§9.5).

3.5 EFFET CHIFFRÉ DE DEUX BIAIS

Corrigée de la troncature au seuil de collecte, l'élasticité de la sévérité à la taille est de $b = 0{,}087$, et la sévérité transposée à l'entité notionnelle n'est multipliée que par 0,861. Le biais de taille est mesuré dans le registre. Sous les hypothèses du chain-ladder, les 97 événements observés sur 2023–2025 deviennent 255 à l'ultime, soit 85,0 par an contre 74,1 sur 2015–2022, et la fréquence est relevée d'un facteur 1,147. Cette projection suggère un retard de remontée, sans établir l'évolution du risque TIC réel. Les régressions et le triangle de développement sont déportés *(voir le Matériel Complémentaire en ligne)*.

Les deux corrections se compensent presque sur la perte moyenne, $0{,}861 \times 1{,}147 = 0{,}987$, soit un effet net de 1,3 %, inférieur à l'incertitude d'estimation de chacune, mais elles ne se compensent pas sur le capital. À queue lourde, le quantile à 99,5 % répond à la sévérité bien plus qu'à la fréquence. Leur effet net sur le capital n'est pas chiffré. La correction de taille agit sur la sévérité et celle de troncature sur la fréquence ; leur compensation sur la moyenne ne détermine pas le signe de l'effet sur le quantile.

3.6 HACKMAGEDDON ET LA STRUCTURE DU RISQUE

Hackmageddon donne la *structure* du risque, jamais son niveau. Le décompte retenu couvre le semestre janvier–juin 2026, avec 1 041 incidents, dont 840 à vecteur d'accès initial identifié (81 %). Le jeu consulté n'a pas été conservé ; relu en octobre 2026 avec une autre grille, il ne redonne pas ces

décomptes à l'unité. Ce sont des citations datées. Ils fixent les parts de répartition par vecteur, qui pondèrent le multiplicateur de fréquence entre états de conformité (§6.3). Ce multiplicateur hérite donc de leur statut de citation.

Vecteur d'attaque	**Part**	**Exigence DORA**
Hameçonnage / ingénierie sociale	38,8 %	Art. 13, sensibilisation & formation
Exploitation vuln. exposée	33,8 %	Art. 26, tests TLPT ; Art. 8–10
Chaîne d'approvisionnement / tiers TIC	15,8 %	Art. 28–44, gestion du risque tiers
Identifiants compromis	6,3 %	Art. 9, contrôle d'accès & MFA

Deux parts structurent les scénarios du chapitre 6 : 15,8 % des attaques empruntent le vecteur tiers, objet des articles 28 à 44, et 49,6 % (dont ces 15,8 %) relèvent de vecteurs qu'un test TLPT est censé détecter en amont. La base recense des incidents rendus publics, ce qui interdit d'en tirer un niveau de fréquence, et sa taxonomie est instable. La catégorie rançongiciel n'existait pas en 2023, et une lecture naïve lui prête une hausse de 11 points là où, après reclassement, elle recule de 23 points. Seules les motivations se comparent directement dans le temps. Les catégories bâloises de la base SAS informent trop faiblement la sévérité pour fonder une segmentation (§3.8).

3.7 OpRisk Global et la sévérité en euros

OpRisk Global est la base de référence historique du risque opérationnel au sens de Bâle. Le risque cyber y est reconstruit à partir des catégories « Systems Security » et « Business Disruption and System Failures », et le périmètre cyber × finance retient 570 pertes de 2000 à 2026, soit 27 années. La base courante en compte douze de plus, antérieures à 2000. La fréquence gelée, $582/27 = 21{,}56$ incidents par an, les compte, alors que l'échantillon de sévérité n'en compte que 570 ($570/27 = 21{,}11$). Elle dépasse ainsi de 2,1 % celle de l'échantillon. Le dénominateur de 27 ans compte l'année 2026, incomplète à la date de l'extraction (cinq pertes), si bien que le sens de l'écart sur le niveau de fréquence n'est pas établi ; nous le déclarons sans corriger la valeur (§10.5.1). Eling et Wirfs (2019) en extraient également les pertes d'origine informatique. Cette base alimentait les modèles internes de mesure avancée (section 1.6), qui calibraient la sévérité extrême sur des pertes observées sans passer par un indicateur de volume. Nous reprenons cette logique.

Sur la population de la fréquence (secteur financier, catégories TIC, 2005–2022, 1 476 observations), la sévérité se décrit ainsi :

Indicateur	**Valeur**	**Indicateur**	**Valeur**
Médiane	1,20 M$	P99	419,3 M$
Moyenne	33,8 M$	Maximum	10 970,8 M$
P90	25,3 M$	Total cumulé	49,8 Md$

Les montants de ce tableau sont en dollars ; le moteur les convertit en euros au taux fixe de 0,92. Le décile supérieur concentre 92,3 % de la perte totale et le centile supérieur 65,1 %, ce qui justifie la théorie des valeurs extrêmes du chapitre 4.

Nous ajustons la loi de Pareto généralisée sur les 570 pertes cyber × finance au-delà d'un seuil $u = 20$ M€, qui est le percentile 85 des montants et où le graphique des excès moyens devient linéaire (figure au supplément, §S4.6). Avec 86 excès, soit un taux de dépassement de $86/570 = 0{,}1509$, on obtient :

$$\hat{\xi} = 0{,}595 \quad (\mathrm{IC}_{90\%} = [0{,}30\,;\,0{,}83]), \qquad \hat{\sigma} = 58{,}0\ \text{M€}, \qquad q_{99{,}5\%}(X) = 663\ \text{M€}.$$

Le dernier terme est le quantile de la sévérité d'un sinistre, pas un capital, car le besoin de capital est le quantile de la charge annuelle agrégée, obtenu par composition avec la fréquence. L'intervalle bootstrap de ce quantile, [411 ; 1037] M€, couvre un facteur 2,5. L'écart avec la PRC ($\hat{\xi}_{\mathrm{PRC}} = 1{,}03$) ne mesure pas une différence de risque : la sévérité PRC est une puissance de pente 0,76 du nombre d'enregistrements, et une puissance multiplie l'indice de queue par son exposant. Les deux indices sont positifs ($\xi > 0$), sur deux objets différents.

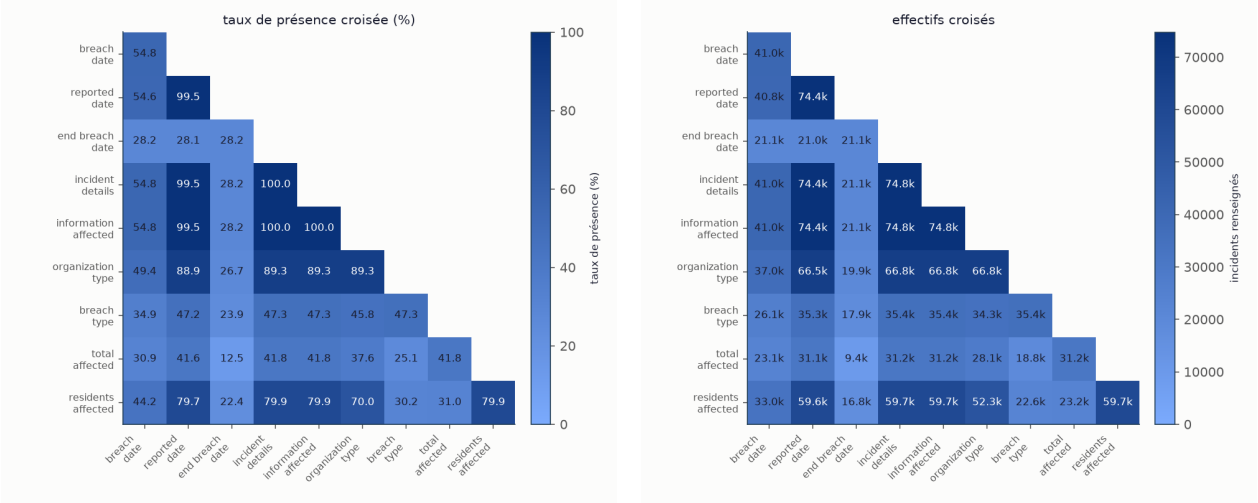
3.8 Analyse exploratoire et profilage des variables

Les variables disponibles ne permettent pas de segmenter la sévérité, ce qui justifie la queue commune ajustée ci-dessus. Le profilage, détaillé dans le supplément, montre d'abord que, dans la chronologie PRC, un champ non renseigné prend la valeur `UNKN` au lieu d'être vide. Le nombre d'enregistrements touchés n'est ainsi documenté que dans 41,77 % des cas. De plus, la base n'agrège pas les notifications, si bien qu'un même incident déclaré à plusieurs autorités y figure plusieurs fois. La déduplication retire 1 643 lignes, soit 10,9 % des lignes, une borne basse. Nous n'additionnons jamais ces volumes, mais les doublons pèsent encore sur les comptages et sur l'ajustement de la sévérité ; leur effet n'est pas chiffré.

La chronologie PRC compte 74 783 incidents, dont 31 217 documentent un volume touché positif. La base SAS compte 41 976 lignes brutes et 41 975 pertes après retrait d'une aberration de saisie, dont 1 099 en catégories TIC et 570 dans le croisement cyber × finance retenu pour la sévérité. Le tableau donne pour chaque variable son type, son rôle et la part de lignes renseignées, `UNKN` compté comme un manquant.

Variable	Type	Rôle dans le modèle	Base	Renseignée
total_affected	quantitative	enregistrements touchés, seule mesure d'impact de la base	PRC	41,77 %
residents_affected	quantitative	sous-ensemble territorialisé du précédent	PRC	79,88 %
breach_date	temporelle	date de survenance, support de la fréquence annuelle	PRC	54,82 %
reported_date	temporelle	date de notification, support du délai de détection	PRC	99,54 %
end_breach_date	temporelle	fin d'exposition, support de la durée d'incident	PRC	28,18 %
organization_type	qualitative	classe d'organisation, huit modalités	PRC	89,29 %
breach_type	qualitative	vecteur de la brèche, huit modalités	PRC	47,31 %
Loss Amount	quantitative	montant de perte avérée, source de la sévérité	SAS	100 %
Event Risk Category	qualitative	catégorie bâloise de niveau 1, sept modalités	SAS	100 %
Sub Risk Category	qualitative	sous-catégorie, définit le périmètre TIC	SAS	100 %
Basel Business Line	qualitative	ligne métier, dix modalités	SAS	100 %
Industry Sector Name	qualitative	secteur, définit le périmètre financier	SAS	100 %
Revenue	quantitative	chiffre d'affaires, mesure de taille	SAS	87,82 %
Assets	quantitative	actif total, mesure de taille prudentielle	SAS	83,51 %

Le volume touché est la variable d'impact la moins bien renseignée, et ce n'est pas un hasard de collecte. Les champs qu'impose l'obligation de notification, la date de déclaration et la nature de l'organisation, sont remplis. Ceux qui demandent une enquête, le volume touché et la date réelle de survenance, ne le sont pas. Ce profil est compatible avec des difficultés d'enquête ; son lien à la gravité reste à établir. Il ne se confond pas avec le biais de déclaration de la section 3.2, qui joue sur les incidents entrant dans la base, alors que le manquant joue sur les champs remplis au sein d'incidents déjà entrés. Le signe de leur effet conjoint n'est pas établi. Seul le second se décrit sur les champs observés.



(a) (b)

FIGURE 3.2. Présence croisée des variables de la chronologie PRC, en taux (a) et en effectifs (b). Le volume touché n'est renseigné en même temps que le type de brèche que dans 25,1 % des cas, et en même temps que la date de fin d'exposition que dans 12,5 % des cas.

Les 12,5 % du croisement le plus pauvre représentent encore plus de neuf mille incidents. La matrice montre surtout que les lacunes se cumulent. Une analyse qui croiserait le volume touché, le type de brèche et la durée d'exposition ne disposerait plus que de 10,9 % de la base. Rien n'indique que cette fraction soit représentative, puisque les trois manques ont la même origine. Le modèle ne conditionne donc la sévérité sur aucune de ces variables.

3.8.1 Variables d'impact

Nous publions des quantiles de sévérité dans plusieurs chapitres. Le tableau suivant les réunit pour les quatre variables d'impact, de sorte qu'on puisse juger la queue avant de lire l'ajustement.

	PRC		SAS OpRisk	
	enregistrements (nombre)	**sévérité dérivée** (M€)	**toutes catég.** (M€)	**cyber × finance** (M€)
n	15 053	15 053	41 975	570
moyenne	102 646	6,07	69,98	24,18
écart-type	1 235 098	41,59	647,26	98,50
minimum	1	0,0020	0,0920	0,0920
q_{25}	69	0,0497	1,012	0,343
médiane	1 104	0,409	3,763	1,380
q_{75}	8 330	1,901	18,40	8,211
q_{85}	23 467	4,176	45,40	20,03
q_{90}	49 000	7,307	82,90	45,47
q_{95}	164 673	18,36	202,4	102,1
q_{99}	1 719 753	109,2	1 012	377,8
maximum	60 000 000	1 624	53 360	1 380
q_{99}/médiane	1 558	267	269	274
maximum/q_{99}	34,9	14,9	52,7	3,7
coef. de variation	12,03	6,85	9,25	4,07

La première colonne compte des enregistrements, les trois autres des euros, et elles ne se comparent ni en niveau ni en quantile. La quatrième porte la calibration publiée. Sur les quatre colonnes, la moyenne dépasse le troisième quartile : une distribution dans ce cas ne se décrit pas par sa moyenne, parce qu'une minorité d'observations en fait le niveau. Le rapport du q_{99} à la médiane est voisin de 270 sur les trois colonnes monétaires et monte à 1 558 sur les enregistrements. La queue ne se prolonge pas, elle change d'échelle. Le coefficient de variation atteint 4,07 sur le périmètre calibré et jusqu'à 12,03 sur les enregistrements, alors qu'il vaut exactement un pour une loi exponentielle.

Un détail évite un contresens. Le rapport du maximum au q_{99} vaut 3,7 sur le périmètre cyber × finance, contre 52,7 sur la base entière. Le périmètre retenu est donc le moins extrême des deux, car le sinistre le plus lourd du fichier ne relève pas du risque informatique. Ce sinistre n'entre donc pas dans le périmètre calibré ; la dépendance de la queue calibrée à ses plus grosses pertes est mesurée au chapitre 4.

3.8.2 Plus gros incidents et concentration

Une queue lourde reste abstraite tant qu'on ne voit pas les événements qui la forment. Le tableau liste les plus gros incidents de la chronologie PRC, comptés en enregistrements. Il illustre la forme de la queue, mais pas le quantile publié, qui est calibré en euros sur OpRisk.

Organisation	Secteur	Survenance	Enregistrements
Progress Software, Ipswitch, Inc.	services	2023-05-27	60 000 000
T-Mobile USA, Inc.	services	2021-08-13	53 700 000
AT&T Inc.	services	2024-03-26	51 226 382
Logan Health Medical Center	santé	2021-11-22	40 000 000
T-Mobile	services	2022-11-25	37 000 000
Comcast Cable Communications LLC	services	2023-10-16	35 879 455
Zoosk, Inc.	services	2020-01-12	24 200 000
CafePress, Inc.	détail	2019-02-19	23 000 000
Texas Dow Employees Credit Union	finance	2023-05-29	20 000 000
Evite, Inc.	services	2019-02-22	18 571 486
loanDepot.com, LLC	finance	2024-01-03	16 924 071
ClearVoiceResearch.com, LLC	services	2021-04-16	15 700 000

Le premier incident est la compromission du logiciel de transfert de fichiers évoquée au chapitre 1 comme choc de cause commune. La base le range sous le nom de l'éditeur, et non sous celui des milliers d'organisations atteintes à travers lui. Deux entrées distinctes concernent le même opérateur de télécommunications, à quinze mois d'intervalle. Les deux incidents financiers, un établissement de crédit et un prêteur hypothécaire, dépassent chacun quinze millions d'enregistrements.

La moitié du volume de sept années tient dans 31 incidents sur 13 410, soit 0,23 % de la base. Quatre-vingts pour cent tiennent dans 209 incidents, et quatre-vingt-dix pour cent dans 491. Un modèle qui décrirait cette distribution par son centre manquerait son objet, puisque le niveau vient d'une poignée d'événements et non du régime courant. L'ajustement par dépassement de seuil formalise cette idée, et c'est aussi pourquoi le quantile qui fonde le besoin de capital est atteint par un sinistre unique plutôt que par une accumulation.

Des doublons de notification restent visibles dans le tableau. La déduplication du début de section exige une égalité exacte sur l'organisation, le volume et la date ; elle ne rapproche ni deux graphies d'une même raison sociale ni deux notifications décalées d'un jour.

Avant 2015, la chronologie ne porte que 2 152 incidents, soit 6,5 % de la période 2005–2025. Le maximum est atteint en 2023 avec 5 866 incidents, et l'exercice 2025 n'en compte que 174, soit 3,0 % du pic, faute de notifications déjà enregistrées (figure 3.1). Ces deux déformations vont en sens contraire, et aucune ne signale un risque. Une fenêtre plus large fabriquerait un régime calme au début et un effondrement à la fin, et un modèle de tendance ajusté dessus mesurerait la maturation d'une base de données. Nous nous en tenons donc à la fenêtre grisée, comme pour la validation hors échantillon.

Compter les incidents et sommer les volumes ne classent pas les catégories dans le même ordre. La figure 3.3 met en regard le nombre d'incidents et le volume touché par type d'organisation. Les deux ordres divergent sur quatre types sur sept. Le commerce de détail est sixième en nombre et quatrième en volume, l'enseignement quatrième en nombre et cinquième en volume.

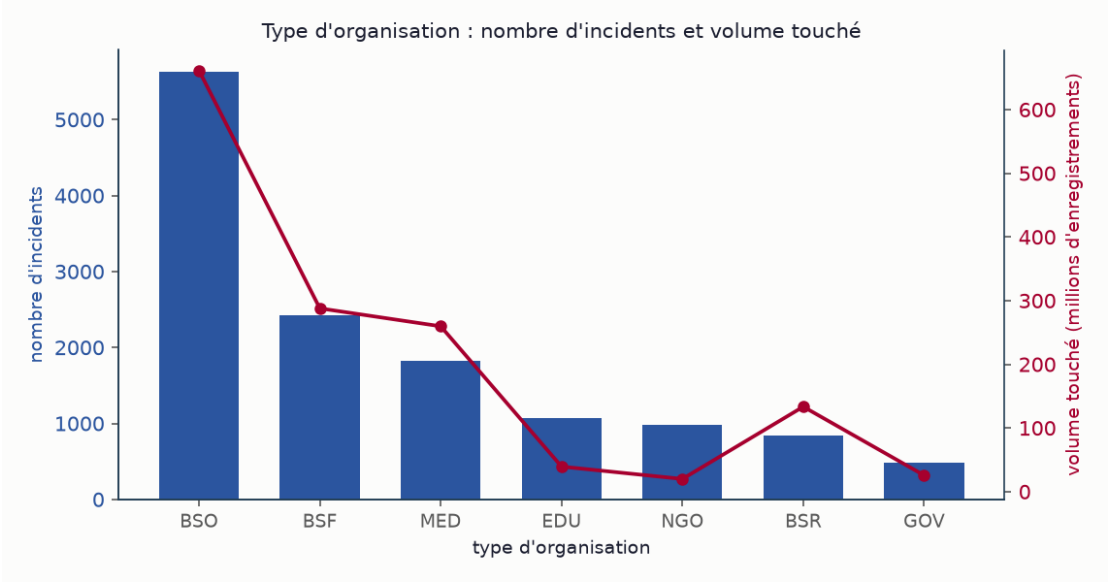


FIGURE 3.3. Nombre d'incidents (barres) et volume touché (courbe) par type d'organisation. Les deux classements ne coïncident pas.

Le même décalage entre nombre et volume s'observe entre sources de notification. Une source qui ne déclare que vingt-sept incidents en concentre plus de deux cents millions d'enregistrements : un indicateur agrégé serait dominé par le régime déclaratif de quelques juridictions.

La figure 3.4 sépare ce que le seul comptage confond. Le piratage domine la fréquence, avec 7 430 incidents et un impact médian de 836 enregistrements : c'est le seul type à la fois fréquent et lourd. La divulgation involontaire est deuxième en fréquence, mais la plus légère en médiane, à 61 enregistrements. À l'opposé, la fraude à la carte ne compte que quatorze incidents pour une médiane de 860, la plus haute du tableau. Un type rare peut donc porter une sévérité unitaire élevée sans peser sur la charge, et l'inverse est vrai.

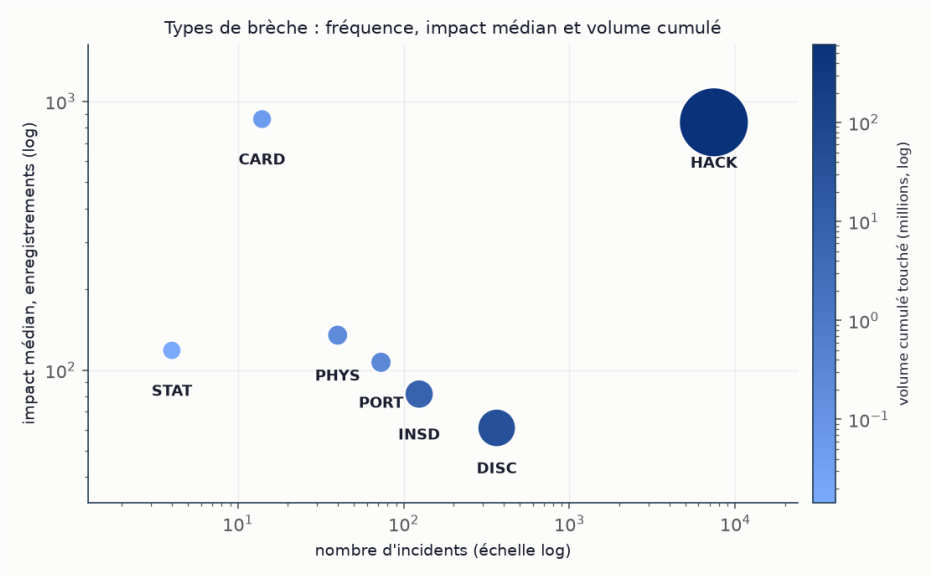


FIGURE 3.4. Types de brèche dans le plan fréquence contre impact médian. La taille et la teinte des disques donnent le volume cumulé, et les deux axes sont logarithmiques.

3.8.3 Association des variables qualitatives au dépassement du seuil

Un actuaire qui envisage de segmenter se demande si le type d'incident ou la classe d'organisation permettent de prédire qu'une perte dépasse un seuil élevé. Nous binarisons l'impact au troisième quartile de chaque base, soit 8 330 enregistrements pour la PRC et 20,00 M$ pour SAS. Nous testons ensuite l'indépendance par un χ^2 et mesurons la force du lien par un V de Cramér à correction de Bergsma.

Base	**Variable croisée au dépassement**	χ^2	**ddl**	V **de Cramér**
PRC	type de brèche	43,1	6	0,068
PRC	type d'organisation	296,4	6	0,148
SAS	catégorie bâloise	1 301,9	6	0,176
SAS	ligne métier bâloise	1 238,5	9	0,171
SAS	secteur d'activité	711,9	20	0,128

Les cinq tests rejettent l'indépendance, mais ce rejet n'apprend rien. Avec quinze mille et quarante mille observations, le χ^2 détecte des écarts sans portée pratique, et sa p-valeur mesure l'effectif autant que l'association. Le renseignement est dans le V, une taille d'effet bornée par un qui ne croît pas avec n.

Aucune des cinq associations n'atteint 0,20, alors que 0,30 marque conventionnellement une association moyenne. La plus forte, la catégorie bâloise dans SAS, vaut 0,176. Ces nombres autorisent à dire que la catégorie d'un incident informe la probabilité qu'il soit lourd. Ils n'en font pas une variable de segmentation. Segmenter par la catégorie bâloise, qui compte sept modalités, ramènerait les 86 excès de la calibration à une douzaine par modalité, effectif sur lequel l'ajustement d'une queue serait très instable. C'est le premier argument en faveur d'une queue commune.

3.8.4 Forme, dépendance de rang et hétérogénéité des variables quantitatives

Nous avons chiffré la non-normalité par un test de Shapiro-Wilk, appliqué à l'échelle brute puis à l'échelle logarithmique, sur un tirage plafonné à 5 000 observations à graine fixée, car la statistique est calculable au-delà, mais sa p-valeur moins fiable. À l'échelle brute, W vaut 0,037 sur la PRC et 0,071 sur SAS, pour une référence de un, et le rejet est total. Les moments confirment ce résultat : sur la PRC, l'asymétrie est de 29,4 et l'aplatissement de 1 083, contre trois pour une loi normale. Le passage au logarithme améliore nettement la statistique sans la sauver, W montant à 0,970 et 0,986. La normalité est rejetée aux deux échelles. Ce test ne démontre pas une queue plus lourde que celle d'une lognormale. Le recours à la GPD repose sur les diagnostics de dépassement de seuil du chapitre 4, plutôt que sur ce seul rejet global.

La corrélation de rang de Spearman mesure le lien entre le montant de perte et la taille, sur 33 769 pertes à profil financier complet. Elle vaut 0,159 pour le chiffre d'affaires, 0,139 pour l'effectif et 0,068 pour l'actif total. Ces faibles liens de rang ne suffisent pas à estimer une élasticité en présence d'hétérogénéité. L'actif total est la moins liée des trois mesures, alors que le bilan porte la mise à l'échelle prudentielle du chapitre 9. Mesurer la taille par l'actif est donc une hypothèse du modèle, non un résultat de ces données.

Ce constat ne suppose aucune forme de loi et repose sur un effectif plus de vingt fois supérieur à celui de la descente d'échelle. Il va dans le sens de l'élasticité de 0,087 mesurée par ailleurs, sans la confirmer au sens statistique, puisque les deux grandeurs diffèrent. Il rend cette faible élasticité moins surprenante. Il corrobore aussi, par un chemin indépendant, la limite d'une sévérité non plafonnée à l'échelle d'entité, inscrite au registre des limites du chapitre 10. C'est cette limite qui fait lire le besoin de capital de l'entité notionnelle comme une extrapolation d'ordre de grandeur.

Le test de Kruskal-Wallis ne dépend pas de la normalité qui vient d'être écartée. Il rejette l'égalité des distributions de sévérité entre classes dans les quatre configurations testées. La taille d'effet ε^2 mesure l'écart : 0,0100 pour le type d'organisation et 0,0123 pour le type de brèche dans la PRC, 0,0720 pour la catégorie bâloise et 0,0785 pour la ligne métier dans SAS. La classe est associée à de faibles différences de rang ; ces tailles d'effet ne sont pas des parts de variance des montants.

Trois diagnostics complémentaires convergent : le V de Cramér reste sous 0,20, l'ε^2 sous 0,08 et les corrélations de rang sous 0,16. La catégorie d'un incident et la taille de l'entité qui le subit informent faiblement sa sévérité, et segmenter la queue sur l'une ou l'autre coûterait des degrés de liberté sans pouvoir explicatif en retour. Nous ajustons donc une queue commune. Ce choix repose sur des tailles d'effet mesurées. Il reste une hypothèse : l'indice varie selon la catégorie bâloise, et aucune base n'observe la sévérité par pilier.

3.9 Limites des données

Les sources ne mesurent pas le niveau de conformité DORA d'une entité, d'où des états par pilier posés (chapitre 6). Aucune base d'incidents n'est harmonisée, exhaustive et exempte de biais de visibilité ; faute d'événements joints, la corrélation entre les pertes des piliers ne s'estime pas, et le chapitre 5 la remplace par une structure de dépendance explicite. Le registre des incidents majeurs que DORA instaure atténuera ces limites sans les lever : limité aux incidents au-dessus d'un seuil de matérialité, il restera tronqué.

S'il renseigne la taille de l'entité et le prestataire en cause, il permettra de conditionner la sévérité à la taille et de cartographier les tiers (chapitre 8), sans changer la structure du modèle.

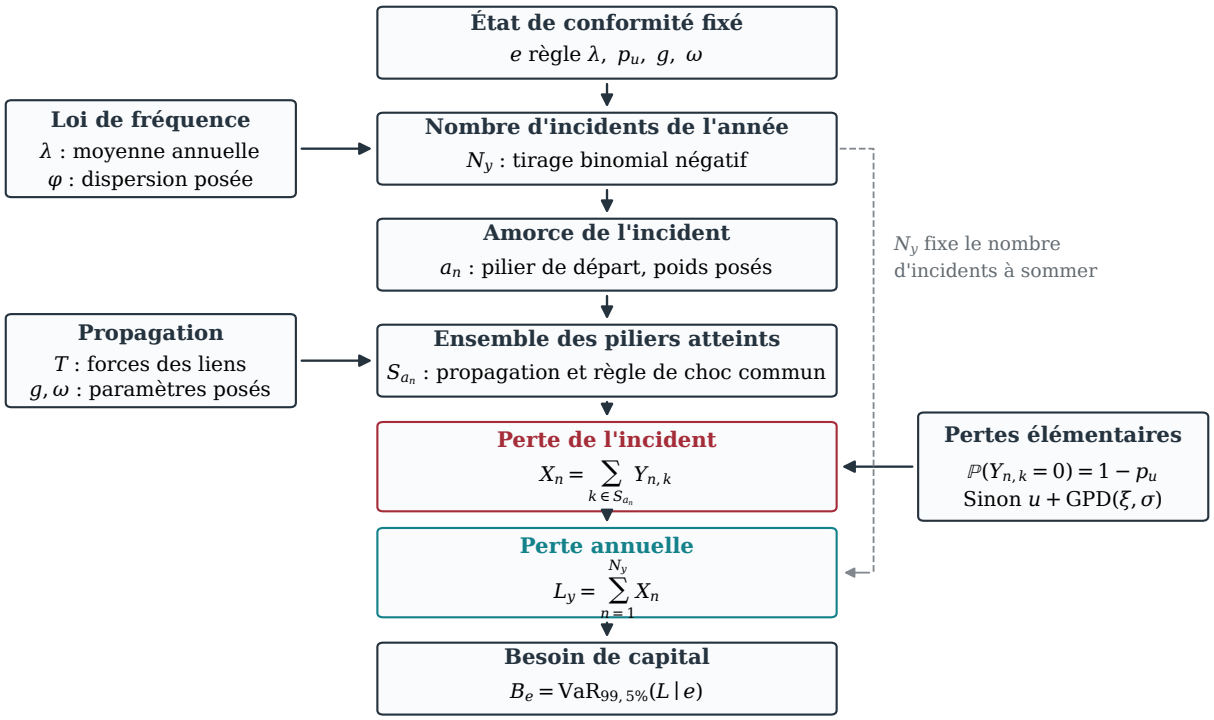
D'autres bases, sinistres assurantiels ou enquêtes sectorielles, auraient leurs propres biais. L'indice de queue domine l'incertitude du modèle (chapitre 10) : une base de plus ne la réduirait que si elle apportait des pertes en montant au-delà du seuil. Les parts par vecteur tirées de Hackmageddon sont du même ordre dans le rapport *ENISA Threat Landscape 2025* (ENISA, 2025), collecté autrement *(voir le Matériel Complémentaire en ligne)*.

Les entrées transmises au chapitre 4 sont donc la fréquence λ et les pertes qui servent à ajuster la queue ($\hat{\xi} = 0{,}595$ sur OpRisk). Elles permettent de compter et de chiffrer les incidents, sans dire quels piliers ils atteignent. Cette dernière question exige la cascade du chapitre 5, puis l'examen de son identification aux chapitres 7 et 8.

4

Modèle fréquence-sévérité

Le calcul distingue trois montants : la perte d'un pilier touché, celle d'un incident qui peut atteindre plusieurs piliers et la somme des pertes d'une année. Le nombre annuel d'incidents suit une loi binomiale négative, les pertes élémentaires une loi de Pareto généralisée au-delà d'un seuil. Leur agrégation dépend de la propagation décrite au chapitre 5. La figure 4.1 relie ces étapes au quantile annuel qui définit le capital.



Trait plein : étape du calcul. Pointillés : quantité réutilisée. Les pertes sont exprimées en M€.

FIGURE 4.1. Flux de calcul d'une perte annuelle à état fixé. y, n et k indexent l'année simulée, l'incident et le pilier. u est le seuil monétaire ; ξ et σ sont la forme et l'échelle de la GPD. Le chapitre 5 détaille la loi des ensembles atteints.

Reprenons l'incident de l'introduction : il part de P4 et touche P1 puis P2. Si ses pertes élémentaires sont a, b et c, sa contribution à l'année vaut $a + b + c$ sous la règle additive. Les pertes des autres incidents de cette année s'y ajoutent pour former L_y. Le capital est un quantile des sommes L_y répétées en simulation ; ce n'est pas le quantile de $a+b+c$ seul. Les branches latérales indiquent les paramètres des étapes. Le tableau 4.1 en précise les sources et le statut, puis indique ce qui change pour une entité.

Étape	Entrée	Sortie	Statut
Données	pertes SAS OpRisk cyber × finance ; parts Hackmageddon	λ, u, ξ, σ, p_u ; parts π_v	estimés (ch. 3 et 4) ; π_v cité
État	multiplicateurs, détection, g, ω	valeurs des quatre canaux par état	posés (§6.3)
Incident	amorce, matrice W, gain g	ensemble atteint, somme des pertes de ses piliers	W posée ; direction non identifiée (ch. 7)
Année	nombre N_y, binomiale négative de surdispersion φ	charge annuelle L_y	φ posé
Quantile	charges annuelles simulées	besoin $B = \mathrm{VaR}_{99,5\,\%}(L)$	bruit de simulation publié
Entité	panel d'entités, élasticités de fréquence et de sévérité	besoin $B(A)$, cascade indépendante sans choc P4	élasticité de sévérité estimée ; b_λ estimé sur les grandes institutions, extrapolé (§9.5)

TABLEAU 4.1. La chaîne de calcul, étape par étape. Les étapes Incident à Quantile sont celles de la figure 4.1 ; l'étape Entité change de moteur.

4.1 THÉORÈMES DE L'EXTRAPOLATION DE QUEUE

Théorème 4.1 (Fisher–Tippett–Gnedenko)**.** *Soit $(X_i)_{i\geq 1}$ indépendantes et de même loi (i.i.d.), de fonction de répartition F et $M_n = \max(X_1, \ldots, X_n)$. S'il existe des suites $a_n > 0$, $b_n \in \mathbb{R}$ et une loi non dégénérée H telles que $(M_n - b_n)/a_n \xrightarrow{d} H$, alors H est, à un changement d'échelle et de position près, une loi des valeurs extrêmes généralisée (GEV) H_ξ. Le signe de ξ détermine le domaine d'attraction : Fréchet ($\xi > 0$, queue lourde), Gumbel ($\xi = 0$) ou Weibull ($\xi < 0$, support borné).*

L'approche par maxima de blocs ne retient qu'une observation par bloc. Nous lui préférons l'approche par dépassement de seuil, qui permet d'exploiter toutes les pertes au-delà d'un seuil u. Celle-ci repose sur le théorème suivant, où $G_{\xi,\sigma}(y) = 1 - (1 + \xi y/\sigma)^{-1/\xi}$ désigne la loi de Pareto généralisée (GPD). L'excès $y = X - u$ est le montant au-dessus du seuil monétaire u ; $\sigma > 0$ en règle l'échelle, dans la même unité, et ξ la forme, sans unité. Pour $\xi > 0$, la queue décroît en puissance, ce qui définit ici une queue lourde.

Théorème 4.2 (Pickands–Balkema–de Haan)**.** *Soit F dans le domaine d'attraction d'une GEV H_ξ (Théorème 4.1). Alors il existe une fonction $\sigma(u) > 0$ telle que la loi des excès converge uniformément vers une GPD lorsque le seuil approche la borne supérieure x_F du support :*

$$\lim_{u \to x_F} \sup_{0 \leq y < x_F - u} \left| F_u(y) - G_{\xi,\sigma(u)}(y) \right| = 0, \tag{4.1}$$

où $F_u(y) = \mathbb{P}(X - u \leq y \mid X > u)$ et $G_{\xi,\sigma}$ est la fonction de répartition de la GPD. L'indice de queue ξ est identique à celui de la GEV limite.

Pour $\xi > 0$, la queue est lourde (figure 4.2). La variance de la sévérité devient infinie dès $\xi \geq 1/2$,

et son espérance dès $\xi \geq 1$ (McNeil et al., 2015) : avec $\hat{\xi} = 0{,}595$ ci-dessous, la variance est infinie et l'espérance finie. Les énoncés développés et les démonstrations figurent à l'annexe B.

4.2 Estimation de l'indice de queue

L'estimateur de Hill étant biaisé hors du régime asymptotique strict, nous estimons la GPD par maximum de vraisemblance sur les N_u excès y_i au-delà du seuil u. Pour $\xi \neq 0$, la log-vraisemblance s'écrit

$$\ell(\xi, \sigma) = -N_u \ln(\sigma) - \left(1 + \frac{1}{\xi}\right) \sum_{i=1}^{N_u} \ln\left(1 + \frac{\xi y_i}{\sigma}\right) \tag{4.2}$$

et se maximise numériquement par Nelder-Mead : c'est l'estimation par maximum de vraisemblance (EMV). L'information de Fisher donne pour l'indice de queue un intervalle de confiance asymptotique à 90 % égal à $[0{,}312\,;0{,}878]$, qui recoupe l'intervalle bootstrap $[0{,}304\,;0{,}831]$.

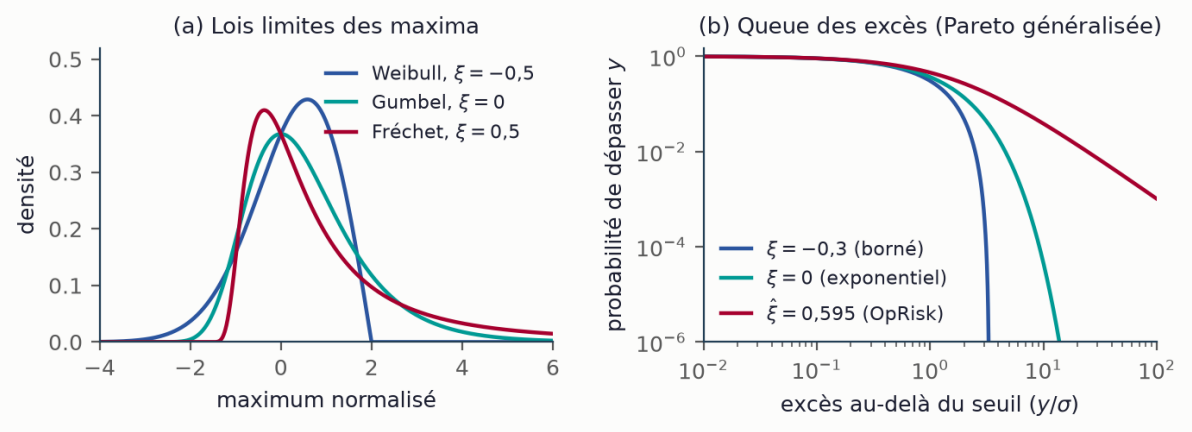


Figure 4.2. Domaines d'attraction des maxima et queue calibrée. (a) Densités des lois des valeurs extrêmes généralisées de type Weibull ($\xi = -0{,}5$, support borné), Gumbel ($\xi = 0$) et Fréchet ($\xi = 0{,}5$, queue lourde), valeurs d'illustration. (b) Probabilité qu'un excès dépasse y sous une loi de Pareto généralisée d'échelle unité, en échelles logarithmiques. Les excès sont bornés pour $\xi = -0{,}3$, et leur probabilité de dépassement décroît exponentiellement pour $\xi = 0$, en puissance pour l'indice calibré sur OpRisk, $\hat{\xi} = 0{,}595$, qui relève du domaine de Fréchet.

En notant $\zeta_u = \mathbb{P}(X > u)$ la probabilité de dépassement du seuil (le taux p_u du moteur), on dispose de formes fermées classiques pour le quantile d'*un* sinistre et sa moyenne de queue (McNeil et al., 2015). Ce quantile n'est pas un besoin de capital, car celui-ci n'apparaît qu'après agrégation annuelle et propagation dans la cascade.

Proposition 4.3 (Quantile et moyenne de queue d'une sévérité GPD)**.** *Sous le modèle POT, pour α tel que $\mathrm{q}_\alpha(X) > u$ et $\xi \in (0, 1)$:*

$$\mathrm{q}_\alpha(X) = \boxed{u + \frac{\sigma}{\xi}\left[\left(\frac{1-\alpha}{\zeta_u}\right)^{-\xi} - 1\right]}, \tag{4.3}$$

$$\overline{\mathrm{q}}_\alpha(X) = \mathbb{E}[X \mid X > \mathrm{q}_\alpha(X)] = \boxed{\frac{\mathrm{q}_\alpha(X)}{1-\xi} + \frac{\sigma - \xi u}{1-\xi}}. \tag{4.4}$$

Lorsque $\xi \geq 1$, l'espérance $\mathbb{E}[X]$ est infinie et $\overline{\mathrm{q}}_\alpha$ n'est pas définie.

La calibration OpRisk ($u = 20{,}03$, $\sigma = 57{,}97$, $\xi = 0{,}595$, $\zeta_u = 0{,}151$) donne par (4.3) un quantile de sévérité $\mathrm{q}_{99{,}5\%}(X) = 663{,}0$ M€ et par (4.4) une moyenne de queue $\overline{\mathrm{q}}_{99{,}5\%}(X) = 1\,752{,}4$ M€. Ces deux nombres décrivent un sinistre et ne se comparent jamais à un besoin de capital. Celui-ci est $\mathrm{VaR}_{99{,}5\,\%}(L)$, quantile de la charge annuelle agrégée L, de l'ordre de plusieurs milliards d'euros pour le périmètre financier étudié. Nous réservons VaR et TVaR à L, q et $\overline{\mathrm{q}}$ à X. À $\lambda \simeq 21{,}6$ sinistres par an, il faut un quantile par sinistre de l'ordre de 99,98 % pour atteindre le quantile annuel à 99,5 %. Les deux échelles sont confrontées au §9.5.

Deux grilles coexistent. Le vecteur d'attaque, comme l'hameçonnage, l'exploitation de vulnérabilité ou la chaîne d'approvisionnement, décrit comment un incident entre, tandis que le pilier DORA décrit quel contrôle a cédé. Le vecteur détermine la fréquence d'arrivée des incidents ; le pilier touché en premier suit les parts d'amorce du chapitre 5. La cascade règle ensuite la propagation entre piliers. Nous ne supposons aucun appariement entre vecteurs et piliers : les parts π_v ne servent qu'à répartir la fréquence.

4.3 Loi de fréquence

L'entrée du moteur est la fréquence des événements TIC collectés par OpRisk, $\lambda \simeq 21{,}6$ par an pour le périmètre financier étudié ; tous les capitaux de ce périmètre reposent sur elle. Les calculs d'entité définissent leur fréquence à partir d'un autre panel (§9.5). Les parts π_v de Hackmageddon la répartissent entre vecteurs d'attaque : 38,8 % hameçonnage, 33,8 % exploitation de vulnérabilités, 15,8 % chaîne d'approvisionnement, 6,3 % identifiants compromis, 5,3 % autres.

Un défaut de conformité sur une exigence n'agit ainsi que sur la sous-fréquence $\lambda\,\pi_v$ du vecteur qu'elle atténue. La fréquence PRC du périmètre financier, $\lambda_{ref} = 341$ notifications américaines par an (2 150 pour la base entière), sans seuil de matérialité, se décompose de la même façon, $\lambda_v = \lambda_{ref}\,\pi_v$, mais n'entre pas dans le moteur.

Nous avons relu les parts π_v sur quatre jeux : premier trimestre 2025, premier semestre 2026, juillet à octobre 2026 et année 2026 entière, qui recouvre les deux précédents. Notre grille diffère de celle des décomptes publiés ; les écarts mêlent donc classement et période. Le multiplicateur non conforme va de 2,318 à 2,471, contre 2,487 publié, soit 6,8 % d'écart au plus. Cette plage représente 0,138 de celle des fourchettes posées (1,933 à 3,042) : les multiplicateurs restent la principale incertitude du canal. Les parts publiées restent des citations datées. Le champ d'accès initial n'existe que depuis 2025, et la nomenclature MITRE ATT&CK introduite en 2026 laisse 46,5 % des vecteurs identifiés de juillet à octobre.

La surdispersion signifie que la variance du nombre d'incidents dépasse sa moyenne ($\sigma^2/\mu > 1$, avec μ la moyenne et σ^2 la variance du comptage). Pour la représenter, nous modélisons par une loi binomiale négative la fréquence agrégée $\lambda_{S_x} = \lambda_{\mathrm{C}} \sum_v \pi_v\, m_{v,S_x}$ d'un scénario S_x. Ici $\lambda_{\mathrm{C}} \simeq 21{,}6$ est la fréquence de l'état conforme et m_{v,S_x} le multiplicateur posé du vecteur v dans ce scénario, égal à un à l'état conforme. Nous posons $\phi = \sigma^2/\mu = 9{,}2$, constant d'un scénario à l'autre, et le paramètre

r est recalculé :

$$r_{S_x} = \frac{\lambda_{S_x}}{\phi - 1}, \qquad p_{S_x} = \frac{r_{S_x}}{r_{S_x} + \lambda_{S_x}}. \tag{4.5}$$

Ici $r > 0$ est le paramètre de forme du comptage et p son paramètre de probabilité : sa moyenne vaut $r(1-p)/p$, sa variance $r(1-p)/p^2$. Ce p diffère du taux de dépassement p_u. La surdispersion en régime de forte dégradation n'est pas observée, faute d'historique de crise DORA.

Pour un mélange de Poisson, l'indice de dispersion vaut $1+\lambda/r$, si bien qu'il croît avec le niveau de fréquence auquel on le lit. Il est de 1,19 sur les 14 944 cellules firme-année du panel, de 2,24 sur la série annuelle sectorielle détendancée (IC 95 % [1,24 ; 5,18], dix-huit points), et nous retenons 9,20 dans le moteur.

Cette dernière valeur est un choix de prudence sur la queue de fréquence, pas une calibration. Il en va de même de la charge systémique $a = 0{,}60$ du mélange de la fréquence (supplément), qui dépasse la borne haute de l'intervalle de la charge empirique $a = 0{,}122$ (IC 95 % [0,054 ; 0,223]). La charge a est le coefficient du facteur dans le mélange lognormal $\exp(aY - a^2/2)$. Passer du Poisson à la binomiale négative posée relève le besoin de capital du périmètre financier étudié de +9 %, la queue restant déterminée au 99,5 % par la perte unique dominante.

Les comparaisons annuelles fixent un scénario et leurs tirages sont indépendants entre années. La distribution des états et leur évolution sont décrites séparément au chapitre 6.

4.4 Loi de sévérité

La sévérité élémentaire, tirée pour chaque pilier touché, vaut zéro avec probabilité $1 - p_u$, et $u+Y$ sinon, Y suivant la GPD : le corps de la loi sous le seuil est négligé. La perte totale d'un incident est la somme des sévérités élémentaires de ses piliers touchés. La fréquence compte les événements avant ce tirage, ce qui évite de filtrer deux fois.

Les excès suivent la GPD ajustée sur OpRisk au chapitre 3 : $u = 20{,}0$ M€, 86 excès, $\hat{\xi} = 0{,}595$, $\hat{\sigma} = 58{,}0$ M€. L'intervalle bootstrap du quantile de sévérité, [411 ; 1037] M€, représente un facteur 2,5 entre les bornes, dû à la seule incertitude de paramètre. Nous plaçons le seuil là où l'indice de forme quitte la zone $\xi \geq 1$, dans laquelle l'espérance n'existe pas, tout en gardant assez d'excès pour l'estimation ($n = 86 > 30$). Cet argument ne tient qu'au voisinage du seuil, l'indice décroissant sur toute la plage (§4.6).

4.5 Comparer les estimateurs à population fixée

Le tableau suivant compare les estimateurs sur les mêmes 86 excès parmi 570 pertes de 2000 à 2026, au seuil fixé de 20,03 M€. Les intervalles percentiles reposent sur 2 000 rééchantillonnages des excès ; ils ne couvrent pas le choix du seuil.

Estimateur	$\hat{\xi}$	IC bootstrap à 95 %
EMV	0,595	[0,252 ; 0,897]
PWM	0,505	[0,254 ; 0,622]
Hill	1,402	[1,208 ; 1,605]
Moments	0,863	[0,498 ; 1,092]

Hill estime la forme par les logarithmes des pertes rapportées au seuil. L'EMV et les moments pondérés par les probabilités de rang (PWM, *probability-weighted moments*) portent sur les excès. La ligne Moments utilise les deux premiers moments des logarithmes des pertes rapportées au seuil. Hors d'une Pareto pure, ces estimateurs ne coïncident pas à seuil fini. Hill et les moments ne fournissent pas seuls une échelle GPD. Cette réestimation ne remplace pas les constantes gelées. L'annexe B conserve le diagnostic historique de Hill.

4.6 Adéquation des lois

Pour la sévérité, les tracés quantile-quantile et probabilité-probabilité s'alignent sur la diagonale, et la vie résiduelle moyenne est linéaire au-delà du seuil (figure 4.3). Du percentile 85 au percentile 93, l'estimation $\hat{\xi}$ décroît de 0,60 à 0,51 sur les seuils comptant chacun au moins trente excès. Au percentile 95, qui n'en compte que 29, elle vaut 0,34. Ces valeurs restent dans l'intervalle à 90 % publié, [0,30 ; 0,83]. Sous le seuil retenu, elle remonte jusqu'à 1,03 et sort de cet intervalle. Ce diagnostic motive le maintien du seuil, sans démontrer qu'un seuil inférieur serait inadmissible.

Sur les mêmes 86 excès à 20,03 M€, les tests de Kolmogorov–Smirnov et d'Anderson–Darling, ce dernier plus sensible aux extrémités, ne rejettent pas la GPD. Sur 1 000 réplications paramétriques avec réestimation, Kolmogorov–Smirnov bilatéral donne $p = 0{,}907$ et Anderson–Darling $p = 0{,}983$; chaque réplication simule la loi ajustée puis réestime ses paramètres. Le balayage ne démontre pas un seuil optimal. Mesurée par simulation, la couverture réelle de l'intervalle à 90 % de ξ est de 87 %, donc l'intervalle est trop étroit et l'élargir d'environ 8 % rétablirait le nominal. La sous-couverture concerne l'incertitude de l'estimation ; elle n'établit pas le signe d'un biais du capital. La fréquence gelée et la dérive d'échelle font l'objet de diagnostics distincts (§10.5.1 et §4.7).

Le test du rapport de vraisemblance rejette le Poisson au profit de la binomiale négative (statistique 130,5, $p \approx 10^{-30}$ sur 14 944 cellules firme-année), bien que $\mathrm{Var}/\mathbb{E} = 1{,}19$ reste proche de un. Ce p traite les cellules comme indépendantes et ignore la dépendance par firme ; le rejet ne calibre pas non plus le facteur 9,2 du moteur.

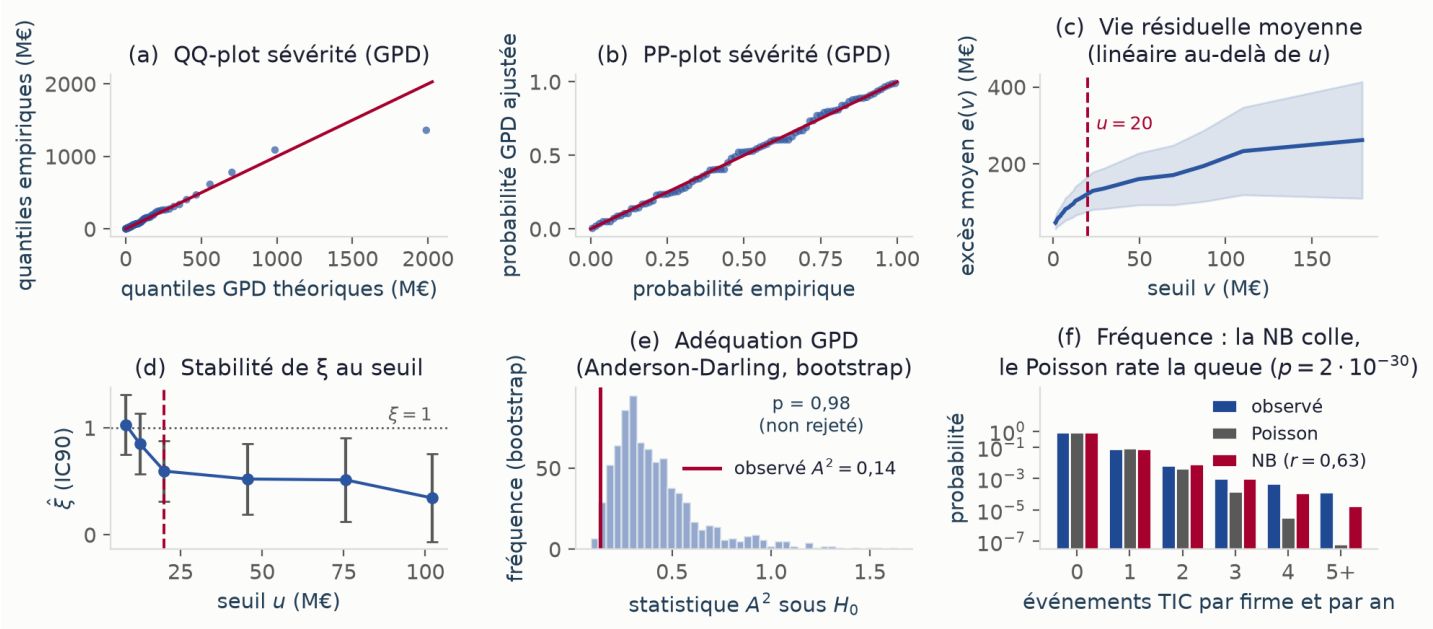


FIGURE 4.3. Adéquation du socle. (a-b) Diagrammes quantile-quantile et probabilité-probabilité de la sévérité contre la GPD ajustée. (c) vie résiduelle moyenne, linéaire au-delà de u. (d) stabilité de $\hat{\xi}$ au seuil. (e) test d'Anderson-Darling, loi nulle par bootstrap paramétrique et statistique observée ($p = 0{,}98$). (f) adéquation de la fréquence : la binomiale négative colle aux comptes firme-année, le Poisson rate la queue.

Une règle de stabilité appliquée à dix percentiles candidats (annexe B) retient 19,32 M€ contre 20,03 publiés, avec un quantile supérieur de 1,5 %. Le seuil publié est compatible avec ces diagnostics ; une p-value élevée n'établit pas son optimalité. La règle la plus permissive descendrait à 15,53 M€ et donnerait un quantile de sévérité supérieur de 10,3 %.

Retirer chaque excès à son tour laisse le quantile dans l'intervalle publié ; le maximum, 1 380 M€, le déplace de −16,0 %. Retirer les trois plus grosses pertes le fait sortir par le bas ; en retirer cinq le ramène de 662,8 à 326,8 M€. Le quantile dépend donc de quelques pertes. Ce diagnostic ne valide pas le niveau du capital.

4.7 BACKTEST HORS ÉCHANTILLON

Pour chaque année d'origine, nous ajustons les deux lois sur les seules observations antérieures et évaluons la prévision de l'année suivante, puis l'origine avance d'un an. La fenêtre va de 2004 à 2025 (539 incidents, douze années notées), car avant 2004 la base compte de un à neuf incidents par an, et 2026 n'en compte que cinq. Le seuil est ré-estimé sur chaque échantillon d'apprentissage par la règle du percentile 85.

L'intervalle de prévision à 90 % du nombre annuel d'incidents couvre 11 années sur 12 sous la binomiale négative, contre 9 sous le Poisson ; son log-score cumulé gagne 3,054 nats. Ce résultat ne valide pas la surdispersion posée dans le moteur. La forme GPD n'est pas rejetée ($p = 0{,}4087$), mais le test de Kupiec, qui compare les nombres de dépassements observé et attendu, rejette la couverture des quantiles de sévérité à 99 % ($p = 0{,}0078$) et 99,5 % ($p = 0{,}0140$). La dérive d'échelle estimée, 3,40 % par an, reste non significative ($p = 0{,}1786$). Le niveau de charge annuelle est aussi rejeté sur les dernières années notées, sans cause établie. L'annexe B.8 détaille ces tests et l'effet conditionnel

d'une échelle variable ; le registre des limites (§10.5.1) en conserve la portée, sans changer le capital publié.

Détecter un doublement du taux de dépassement avec 80 % de puissance demanderait 1 811 années à 99,5 %, 905 à 99 % et 78 à 90 %. Douze années ne permettent donc pas de valider le quantile de capital.

4.7.1 Comparaison à des modèles d'apprentissage statistique

Aucun modèle à caractéristiques n'améliore la tendance temporelle seule avec un intervalle à 90 % excluant zéro. Le boosting obtient le meilleur log-score ; son gain de 0,0193 a pour intervalle [−0,0371 ; +0,0571], par bootstrap des années évaluées.

Nous appliquons le script `131` aux 570 pertes, dont 86 au-dessus de 20,03 M€, en excluant les cinq pertes de l'année 2026, incomplète. L'évaluation en origine glissante, de 2014 à 2025, porte sur 280 pertes, dont 60 dépassements. La cible est conditionnelle à l'enregistrement d'une perte ; elle n'est pas une fréquence annuelle d'incident.

Nous comparons un taux constant (M0), une régression logistique sur l'année (M1), une régression logistique pénalisée L_2 (M2) et un boosting d'arbres de gradient (M3). M2 et M3 ajoutent le métier bâlois, la région de domicile, la catégorie d'événement et le logarithme des actifs à l'année. La pénalisation L_2 limite la taille des coefficients ; le boosting combine des arbres successifs pour corriger leurs erreurs. Leurs réglages, appelés hyperparamètres, sont fixés avant l'évaluation. Les log-scores moyens, plus élevés quand la prévision est meilleure, sont :

Modèle	M0	M1	M2	M3
Log-score	−0,5605	−0,5214	−0,5436	−0,5021

Le bootstrap par années ne distingue pas non plus la tendance M1 du taux constant M0. L'information financière est postérieure à l'événement pour 37 % des pertes. Masquer les actifs postérieurs à l'année de l'événement laisse l'intervalle du gain du boosting inclure zéro.

La GPD DX, dont l'échelle ajoute le logarithme des actifs et la catégorie à la tendance, attribue une densité nulle à une perte observée. Sa forme négative borne le support, ensemble des pertes possibles sous la loi, sous cet excès. Sur les 59 autres excès, son écart de log-score contre l'échelle en tendance seule (D) vaut −0,0645, d'intervalle à 90 % [−0,1738 ; +0,0691]. Cette moyenne conditionnelle omet l'échec de support.

Ces résultats restent compatibles avec la queue commune retenue au §3.8. Dans cette chaîne, l'extrapolation des montants extrêmes reste confiée à la GPD ; les classifieurs n'estiment que le dépassement du seuil. Le registre n'observe pas l'exposition, et 35 pertes notées viennent d'une firme déjà présente dans l'apprentissage. Les intervalles ne reposent que sur douze blocs annuels.

Les lois ajustées permettent de compter les incidents et de tirer leurs pertes élémentaires. Pour l'exemple P4→P1→P2, elles fournissent les coûts a, b et c ; l'atteinte de ces piliers relève de la propagation (chapitre 5).

5

Cascade dirigée entre piliers

Pour calculer la perte d'un incident, il faut déterminer les piliers qu'il atteint. Nous appelons amorce le pilier où il commence, et ensemble atteint les piliers touchés avant son arrêt. La matrice W donne le sens et la probabilité des transmissions. Dans les capitaux par état, l'incident suit une marche auto-évitante. Depuis le pilier j, il passe au pilier k avec la probabilité W_{jk} et s'arrête sinon, ce qui arrive avec la probabilité $1 - \sum_k W_{jk}$. Il s'arrête aussi lorsqu'il revient sur un pilier déjà touché. Le choc commun du prestataire P4 suit une règle distincte.

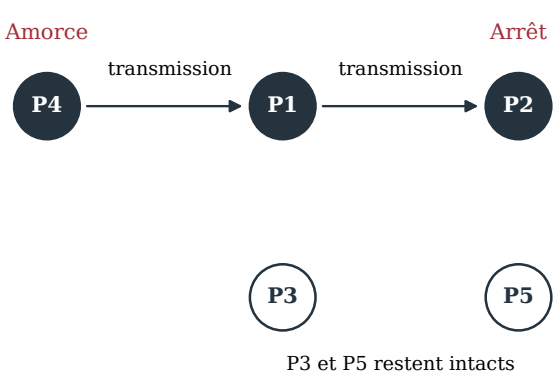
Le tableau 5.1 distingue ce moteur fini du système latent et du branchement auxiliaire utilisés pour interpréter la dépendance et sa stabilité.

Mécanisme	**Ce qu'il décrit**	**Rôle dans le mémoire**
Système latent, matrice W	Stress transmis entre piliers ; forme réduite $(I - W^\top)^{-1}$	Cadre structurel et propriétés de stabilité
Branchement auxiliaire, matrice M	Nombre de descendants engendrés par un incident	Diagnostic de descendance ; M et W sont distinctes
Cascade indépendante	Plusieurs arêtes peuvent transmettre ; un pilier est compté une fois	Exploration des matrices (chapitre 8), contrôle en g (§6.4) et besoins d'entité (§9.5), sans choc commun P4
Marche auto-évitante	Un successeur à chaque pas ; arrêt ou retour sur un pilier atteint	Capitaux par état et quatre canaux, avec choc commun P4 ; configurations par pilier, sans ce choc (§6.5.1)

Tableau 5.1. Les mécanismes de propagation et leur usage. Les calculs de marches de l'inverse de Leontief ne sont pas le décompte des piliers distincts d'un incident.

Un incident, puis une année de pertes

La figure 5.1 détaille l'exemple du flux annuel : l'incident part de P4, atteint P1 puis P2 et s'arrête. C'est une marche possible sans choc commun, où P4 est une amorce ordinaire. Elle compte pour un incident dans l'année, avec un coût $a + b + c$; les pertes élémentaires peuvent être nulles. Dans la variante à perte unique, le même ensemble atteint reçoit un seul coût tiré : toucher davantage de piliers n'ajoute alors aucun coût. La comparaison au §10.7.1 mesure ce que cette convention change au capital.



$S_4 = \{P4, P1, P2\}$

$Y_4 = a, \quad Y_1 = b, \quad Y_2 = c$

$X_n = a + b + c$

Un pilier touché est compté une fois.
La perte entre dans la somme de son année.

FIGURE 5.1. Exemple de lecture, sans calibration nouvelle : une marche P4→P1→P2 donne un ensemble atteint et une perte. Sous le choc commun, P4 peut toucher directement plusieurs autres piliers ; la règle de perte reste additive.

Étape	Pseudo-code d'une configuration de conformité
Préparer	Fixer $(\lambda, p_u, g, \omega)$, les lois de pertes et les probabilités d'amorce ; calculer la loi des ensembles atteints par amorce.
Compter	Tirer le nombre N_y d'incidents de chaque année y selon la binomiale négative.
Propager	Pour chaque incident, tirer l'amorce puis l'ensemble atteint selon sa loi. Pour P4, appliquer le choc commun si cette configuration le prévoit.
Chiffrer	Tirer les pertes élémentaires, masquer les piliers intacts, puis sommer : $X_n = \sum_{k \in S_a} Y_{n,k}$.
Agréger	Affecter chaque incident à son année : $L_y = \sum_{n=1}^{N_y} X_n$.
Comparer	Calculer le quantile annuel à 99,5 % pour chaque graine, puis comparer les configurations.

TABLEAU 5.2. Calcul du scénario à quatre canaux. Le pseudo-code décrit le calcul ; le code tire les sévérités par lots et utilise les lois d'ensembles pré-calculées. Source : `canaux_conformite.py`, fonctions `pertes_annuelles` et `metriques_par_graine`.

5.1 MODÈLE DE VASICEK À UN FACTEUR

Le modèle structurel de Merton-Vasicek associe à chaque entité une variable latente X, qui mesure le stress. Nous l'utilisons sous la probabilité historique : aucun prix ni aucune valeur de firme n'est calculé. Le modèle s'écrit

$$X_i = \sqrt{\rho}\, Y + \sqrt{1-\rho}\, \varepsilon_i, \qquad \mathrm{Var}(X_i) = 1, \tag{5.1}$$

où $Y \sim \mathcal{N}(0,1)$ est le facteur systémique commun, $\varepsilon_i \sim \mathcal{N}(0,1)$ le choc idiosyncratique, propre à l'entité et indépendant du facteur commun. $\rho \in [0,1]$ est la part de variance systémique, commune à toutes les entités. L'incident survient lorsque le stress franchit un seuil, $D_i = \mathbf{1}\{X_i \geq K_i\}$. Dans le modèle de crédit classique, PD_i désigne la probabilité de défaut sur l'horizon considéré. Le seuil correspondant est $K_i = \Phi^{-1}(1 - \mathrm{PD}_i)$, où Φ est la répartition normale standard.

Le facteur commun décrit une dépendance symétrique. Nous cherchons aussi à représenter des transmissions orientées entre contrôles : la norme de l'écart entre la matrice posée à dire d'expert et sa transposée vaut 81 % de celle de la matrice. Par ailleurs, les bases examinées ne fournissent pas une probabilité annuelle d'incident par entité et par pilier qui permettrait de calibrer le seuil. Nous reprenons la construction latente du crédit ; son application aux incidents informatiques exige des hypothèses supplémentaires.

5.2 Facteur systémique par pilier

Nous indexons désormais par entité i et pilier $j \in \{1, \dots, 5\}$, et remplaçons le facteur unique par un facteur systémique par pilier Y_j et une sensibilité propre ρ_{ij} :

$$X_{ij} \;=\; \sqrt{\rho_{ij}}\, Y_j \;+\; \sqrt{1-\rho_{ij}}\, \varepsilon_{ij}. \tag{5.2}$$

Les Y_j sont corrélés entre eux par une matrice Σ_Y, qui décrit les dépendances croisées au niveau systémique. Elle prolonge les modèles latents gaussiens du crédit (copule des temps de défaut, Li (2000)).

Les données étudiées ne permettent pas d'estimer une sensibilité ρ_{ij} pour chaque entité. La probabilité marginale de non-conformité reste égale à 0,35 quelle que soit cette sensibilité ; seules les variations conjointes de cellules partageant un facteur la renseigneraient. Nous retenons donc une sensibilité commune dans le calcul publié.

L'expérience de puissance précise la difficulté. Même avec Y_j connu, distinguer un écart de 0,10 sur ρ_{ij} demande environ 813 périodes indépendantes pour une puissance de 80 %. Au niveau du pilier, les ordres de grandeur deviennent 474 périodes à quatre entités et 81 sur une population entière. Sur une coupe unique, le double log-rapport de vraisemblance moyen vaut seulement 0,47, même pour $\rho_{ij} = 0{,}99$; cette moyenne ne se compare pas au seuil de 3,84.

Une structure hiérarchique partagerait l'information : $\rho_{ij} = \rho_j + u_{ij}$. Sa variante $\operatorname{logit}(\rho_{ij}) = \operatorname{logit}(\rho_j) + u_{ij}$, où u_{ij} est l'écart propre à l'entité et au pilier, respecte $[0\,;\,1]$, contrairement à l'addition directe, qui en sort dans 1,40 % des cas pour une dispersion de 0,20. Cette extension n'entre pas dans les résultats. Le chapitre 6 retient un facteur propre à l'entité ; dans ce cadre, l'approximation locale demande environ 374 entités observées une fois.

5.3 Propagation dirigée

La propagation repose sur un modèle qualitatif de cascade, qui note les chaînes d'effondrement entre piliers à partir de trois barèmes posés par l'auteur à dire d'expert (figure 5.2). Aucune de leurs valeurs n'est mesurée. Elles sont ancrées sur la structure du règlement, et nous n'en défendons que l'ordre.

— ROOT_p est la propension du pilier p à amorcer une chaîne. Elle vaut 1,00 pour la gouvernance, qui fonde les autres contrôles, 0,90 pour les tiers, surface d'attaque externe, et 0,30 pour le partage d'informations, rarement déclencheur. Dans le moteur, un incident naît sur le pilier p avec

une probabilité proportionnelle à ROOT_p, soit des parts d'amorce de 30 % (P1, gouvernance), 27 % (P4, tiers), 18 % (P2), 15 % (P3) et 9 % (P5, partage d'informations).

— $T = (t_{jk})$: t_{jk} est la force avec laquelle la défaillance du pilier j (la source, qui émet) entraîne celle du pilier k (la cible, qui reçoit). Ses vingt entrées vont de 0,10 à 0,80 et sont asymétriques : la gouvernance entraîne la gestion des incidents à 0,80, l'inverse ne vaut que 0,20. Ce sont des forces d'entraînement et non des probabilités, si bien que les lignes ne somment pas à un. Normalisée par l'équation (5.4), T devient la matrice de contagion W.

— GBASE_p est le score de gravité (au sens de l'AMDEC) du pilier p s'il cède seul, sans rapport avec le gain de propagation g. Sur cette échelle ordinale, il vaut 7 pour les tiers, qui transmettent la contagion, 6 pour la gouvernance, 4 et 3 pour la gestion des incidents et les tests, 1 pour le partage d'informations, qui est volontaire.

Dans le modèle qualitatif, le score de vraisemblance d'une chaîne ordonnée est le produit de ROOT au pilier d'amorce et de T le long de ses maillons. Sa gravité part du GBASE le plus élevé et croît avec les autres piliers touchés et avec la force moyenne des maillons. Sa criticité, notée de 1 à 10, est la moyenne géométrique des deux. C'est elle que mesure la dépendance à l'ordre du §5.9. Le moteur de capital n'emploie que ROOT et T. La sévérité y suit la même loi pour tous les piliers : c'est une hypothèse, aucune base n'observant la sévérité par pilier, et les tests du §3.8 montrent seulement un effet faible des catégories de la base.

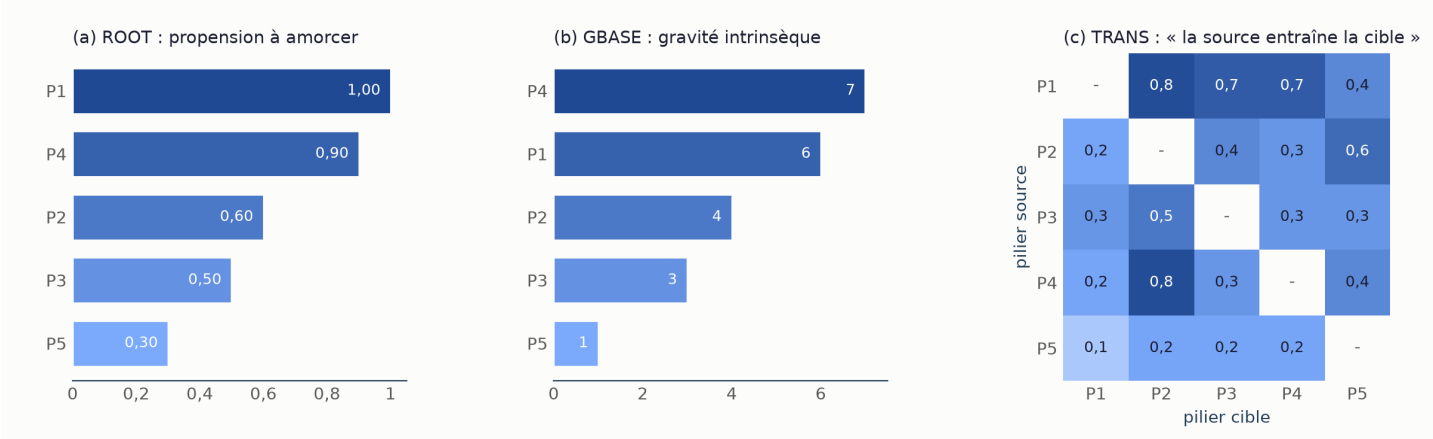


FIGURE 5.2. Les trois barèmes d'expert du modèle qualitatif. (a) ROOT, propension de chaque pilier à amorcer une chaîne. (b) GBASE, gravité du pilier s'il cède seul. (c) T, force avec laquelle le pilier source entraîne le pilier cible, asymétrique.

Dans tout le rapport,

$$W_{jk} \;=\; \text{propension du pilier } j \text{ (source) à entraîner la défaillance du pilier } k \text{ (cible).}$$

La ligne j décrit ce que j émet, la colonne k ce que k reçoit, comme dans le graphe d'arêtes vivantes (définition 5.1). Dans T, P1 a la plus grande somme de ligne (2,6) et une somme de colonne trois fois inférieure à celle de P2 : il émet fort et reçoit peu, et W en garde les proportions. Le stress de j

subit celui des autres piliers de la même entité, et somme donc les colonnes :

$$X_{ij} \;=\; \underbrace{\sum_{k\neq j} W_{kj}\, X_{ik}}_{\text{contagion dirigée, } k\to j} \;+\; \sqrt{\rho_{ij}}\, Y_j \;+\; \sqrt{1-\rho_{ij}}\, \varepsilon_{ij}, \tag{5.3}$$

d'où, en forme matricielle sur les cinq piliers, la forme réduite $\mathbf{X}_i = (I - W^\top)^{-1}(\text{systémique} + \text{idio})$. Cette forme suppose $\rho(W) < 1$, le rayon spectral étant invariant par transposition. Si $W = 0$, on retombe sur le modèle à facteur par pilier, puis, avec un facteur unique, sur le Vasicek standard. Les trois modèles s'emboîtent strictement (figure 5.3).

5.4 NORMALISATION DE LEONTIEF ET STABILITÉ

La matrice d'expert T ne peut pas servir telle quelle : $(I - W)^{-1}$ ne représente une cascade que si la série de Neumann $(I - W)^{-1} = I + W + W^2 + \cdots$ converge, ce qui équivaut à $\rho(W) < 1$. Le terme $(W^n)_{jk}$ somme les produits des poids sur les marches de j à k en n pas, y compris celles qui répètent un pilier. L'inverse cumule ces contributions d'ordres $0, 1, 2, \ldots$; le moteur fini, lui, compte chaque pilier touché une seule fois. Pour T, on a $\rho(T) = 1{,}461 > 1$, et $(I - T)^{-1}$ contient 21 entrées négatives sur 25, si bien qu'un choc positif produirait un stress négatif ailleurs.

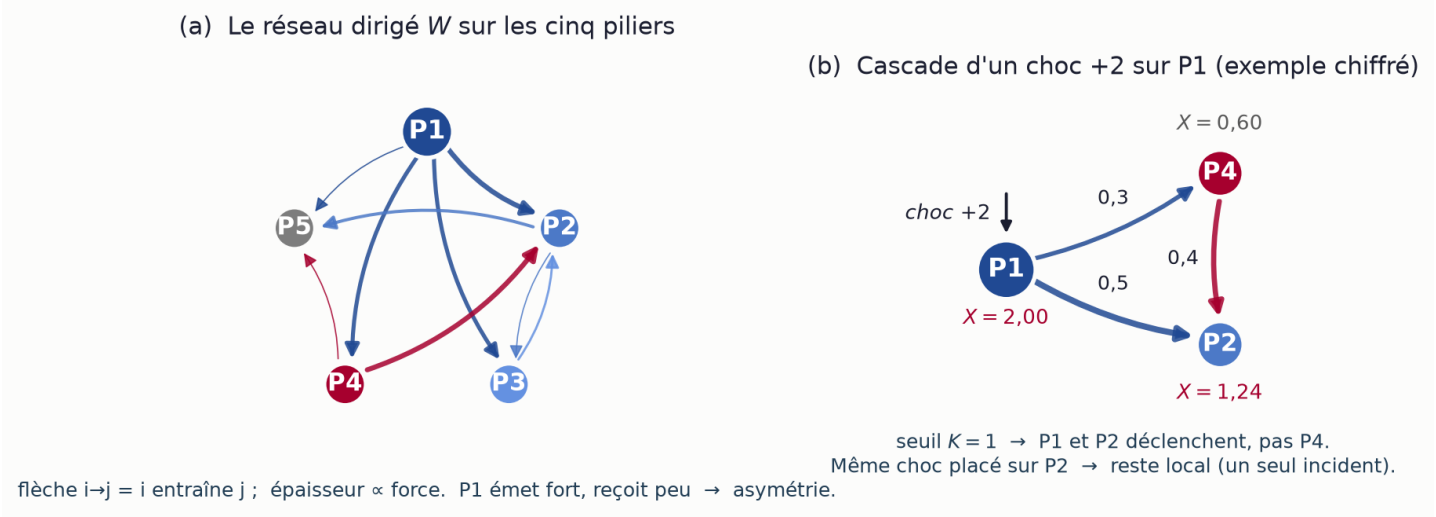


FIGURE 5.3. Structure dirigée de W sur les cinq piliers (P1 émet fort et reçoit peu) et propagation d'un choc sur un sous-réseau.

Le correctif vient du modèle entrées-sorties de Leontief, dont l'inverse $B = (I - A)^{-1} = \sum_{k\geq 0} A^k$ n'explose jamais parce que A est une matrice de parts. Ses colonnes somment à moins de un, la différence étant la valeur ajoutée, strictement positive. Nous appliquons la même règle en lisant la ligne j de W comme les parts du stress que j *émet* vers les autres piliers :

$$\boxed{W \;=\; g \cdot \frac{T}{s_{\max}}\,, \qquad s_{\max} = \max_j \sum_k t_{jk}\,, \qquad g \in (0,\, 1]} \tag{5.4}$$

où g, le gain de propagation, est la part de contagion émise par le pilier le plus émetteur (P1, dont la somme de ligne $s_{\max} = 2{,}6$ est la plus grande de T). Le paramètre g est posé, non estimé (valeurs 0,45, 0,68 et 0,90 au chapitre 6). W est positive et chaque ligne somme à au plus g. Pour le rayon spectral $\rho(W)$, le théorème de Perron–Frobenius donne

$$\rho(W) \;\le\; \max_j \sum_k W_{jk} \;\le\; g \;\le\; 1, \tag{5.5}$$

avec $\rho(W) < 1$ pour $g < 1$. Numériquement, $\rho(W) = 0{,}562\,g$, ce qui garde $\rho(W) < 1$ à la borne $g = 1$: $(I - W)^{-1}$ existe sur tout le domaine admissible. La division par un même scalaire pour toutes les lignes préserve l'hétérogénéité de ce que reçoit chaque pilier.

5.5 Processus de branchement

Nous utilisons un branchement multitype pour étudier la descendance d'un incident : un incident sur le pilier j engendre, à la période suivante, un nombre aléatoire d'incidents sur les autres piliers. Ce diagnostic auxiliaire emploie la matrice M des nombres moyens de descendants, distincte du noyau fini utilisé pour les capitaux par état :

$$M_{jk} \;=\; \Phi(\text{base}_k + W_{jk}) - \Phi(\text{base}_k), \tag{5.6}$$

où $\Phi(\text{base}_k)$ est l'incidence de fond du pilier cible, et base_k son seuil sur l'échelle normale. Un type désigne ici un pilier ; M_{jk} est le nombre moyen de descendants directs de type k produits par un incident de type j. Le rayon spectral $\rho(W)$ détermine le système latent simultané, tandis que $R_0 = \rho(M)$ détermine le branchement auxiliaire, dont $R_0 < 1$ garantit l'extinction avec une descendance moyenne finie. La cascade du modèle, qui ne revient jamais sur un pilier touché, s'arrête de toute façon.

Avec une incidence de fond de 4,5 % et $g = 0{,}9$, valeurs posées, on obtient $\rho(W) = 0{,}506$ et $R_0 = 0{,}054$. Les seuils critiques, $\rho(W) = 1$ à $g = 1{,}78$ et $R_0 = 1$ à $g = 8{,}1$, sont hors du domaine admissible $g \le 1$ (figure 5.4). La forme simultanée approche par conséquent son seuil plus de quatre fois plus vite que la cascade.

La progéniture est le nombre moyen d'incidents que cause un incident sur chaque pilier ($(I - M)^{-1}$ moins l'identité). Elle vaut 0,109 (P1), 0,069 (P4), 0,058 (P2), 0,054 (P3) et 0,026 (P5), et reproduit le classement du barème ROOT (Spearman = 1,00) pour toute valeur de g. ROOT et T venant du même expert, cet accord est un test de cohérence interne et ne constitue pas une validation externe. On pourrait donc déduire ROOT de T et économiser cinq paramètres d'expert ; nous gardons ROOT, posé séparément.

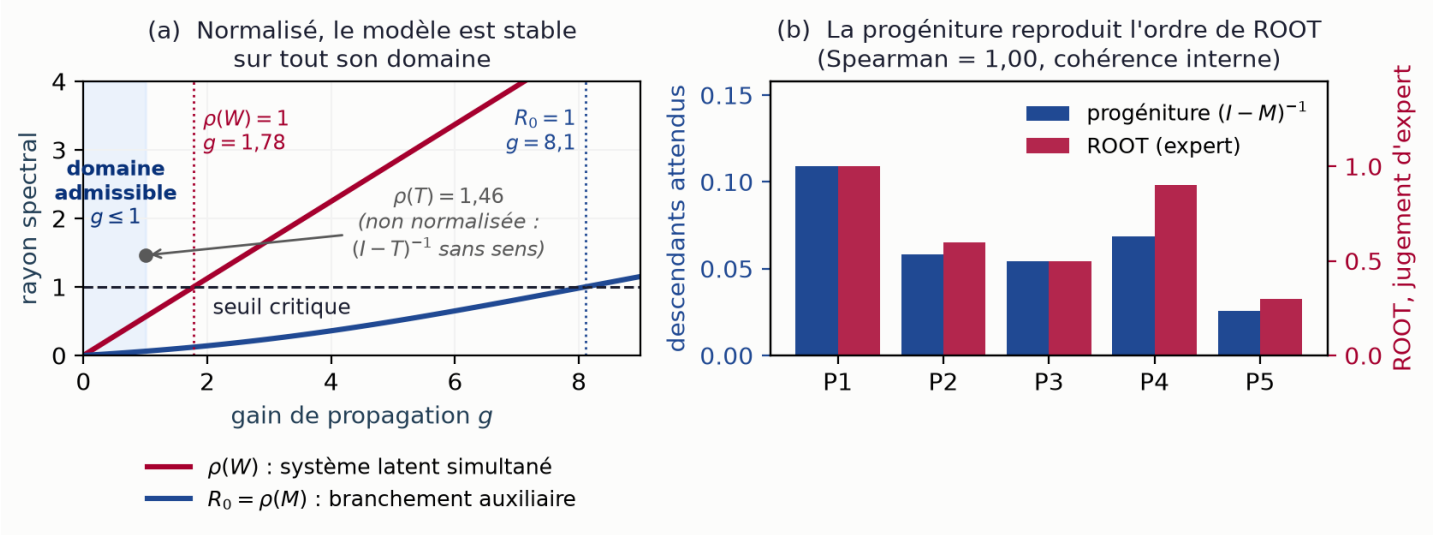


FIGURE 5.4. Stabilité de la cascade et progéniture. (a) Sur le domaine admissible $g \leq 1$, les deux rayons spectraux restent inférieurs à 1 ; les seuils critiques ($\rho(W) = 1$ à $g = 1{,}78$; $R_0 = 1$ à $g = 8{,}1$) sont hors domaine. (b) La progéniture $(I - M)^{-1}$ reproduit le classement ROOT du jugement d'expert.

5.6 SEUIL K_j, SUBSTITUT DE $\Phi^{-1}(\mathrm{PD})$

Le seuil monétaire u_j de la méthode POT et le seuil latent K_j, sans unité, sont distincts des critères de classement d'un incident majeur selon DORA. Pour une entité i et un pilier j, le cadre général s'écrit, sous une marge continue :

$$\boxed{K_{ij} = F_{ij}^{-1}(1 - p_{ij}), \qquad \mathbb{P}(X_{ij} > K_{ij}) = p_{ij}.} \tag{5.7}$$

La marge F_{ij} est celle du stress après propagation : si celui-ci est gaussien centré de variance v_{ij}, alors $K_{ij} = \sqrt{v_{ij}}\,\Phi^{-1}(1 - p_{ij})$. Une marge commune n'en découle pas. Faute de données entité–pilier, ces marges et probabilités ne sont pas estimées. Écrire $K_j = F_{\text{latent}}^{-1}(1 - p_j)$ suppose une marge de référence ; l'apparier à un dépassement monétaire reste une hypothèse. Le moteur simule directement fréquence, cascade et pertes, sans calibrer de seuils individuels. Son p_u élémentaire n'est pas une probabilité annuelle d'incident d'une entité.

Le biais sur K_j vient de la sous-déclaration. Si $q(s)$ est la probabilité qu'un incident de sévérité s soit déclaré, alors $\hat{p}_j^{\text{naïf}}/p_j = \mathbb{E}[q(S) \mid S \geq u_j] < 1$. Il en résulte une sous-estimation de p_j, qui conduit à surestimer K_j et à sous-provisionner. Ce biais s'effondre toutefois lorsque le seuil de matérialité monte dans la queue (biais sur K_j, sans unité, de +0,369 à $u = 0{,}5$ M€ contre +0,001 à $u = 40$ M€). Nous modélisons la sévérité au-dessus de ce seuil par la théorie des valeurs extrêmes. Dans une simulation où l'indice de queue vrai est connu ($\xi = 0{,}9$), le biais médian sur le capital est de −0,8 % pour cette méthode, d'écart interquartile 0,62, contre −63,9 % pour la lognormale.

5.7 FAISABILITÉ DE L'ESTIMATION SUR DONNÉES SIMULÉES

Cette expérience vérifie si une chronologie de défaillances permettrait de retrouver une matrice connue dans des données simulées. Elle utilise un probit, cohérent avec le bruit gaussien et le seuil

du modèle générateur ; dans cette expérience, un logit gonflerait les magnitudes d'un facteur 2,1. Les sources réelles examinées ne fournissent pas le panel requis. La loi complète des ensembles touchés constituerait une autre voie d'identification, sous des hypothèses sur la cascade et les amorces.

Sur un panel simulé de 800 entités et 60 périodes, le probit retrouve W dans ses unités (corrélation 0,905, pente 1,085) ; la corrélation tombe à 0,38 avec 50 entités. Il ne peut pas être estimé sur les sources réelles (chapitre 7), d'où le capital en bornes du chapitre 8.

5.8 Définitions et propriétés formelles

On note $P = \{1, \dots, 5\}$ les piliers, $W \in [0,1]^{P \times P}$ la matrice de contagion avec $W_{jj} = 0$, et $s_{\max} = \max_j \sum_k t_{jk}$. Les démonstrations sont rassemblées en annexe A.

Définition 5.1 (Cascade indépendante)**.** À chaque couple ordonné (j,k), $j \neq k$, on associe une variable de Bernoulli indépendante $B_{jk} \sim \mathcal{B}(W_{jk})$. Le *graphe d'arêtes vivantes* G possède l'arc $j \to k$ si et seulement si $B_{jk} = 1$. Pour un pilier d'amorce a, l'*ensemble atteint* est

$$S_a \;=\; \{a\} \cup \{k \in P : \text{il existe un chemin dirigé } a \rightsquigarrow k \text{ dans } G\}.$$

C'est la cascade indépendante standard (Kempe et al., 2003), une percolation de liens sur le graphe pondéré par W.

Proposition 5.2 (Forme réduite et descendance espérée)**.** *La somme, sur les marches dirigées de longueur n de a vers k, du produit des poids de leurs arêtes vaut $(W^n)_{ak}$, et la série de ces termes est*

$$\sum_{n \geq 0} (W^n)_{ak} \;=\; \left((I - W)^{-1}\right)_{ak},$$

convergente si et seulement si $\rho(W) < 1$. Un pilier atteint l'étant par au moins un chemin vivant sans pilier répété, on a la majoration $\mathbb{E}\,|S_a| \leq \left[(I - W)^{-1}\mathbf{1}\right]_a$, et l'écart mesure les marches qui répètent un pilier et les piliers atteints par plusieurs chemins.

Proposition 5.3 (Sous-criticité par normalisation de Leontief)**.** *Sous la normalisation* (5.4)*, $W = (g/s_{\max})\,T$, la matrice W est positive et chacune de ses lignes somme à au plus g ; par conséquent*

$$\rho(W) \;\leq\; \max_j \sum_k W_{jk} \;\leq\; g \;\leq\; 1.$$

Pour $g < 1$, cette borne garantit $\rho(W) < 1$, donc la convergence de $(I - W)^{-1}$ et la sous-criticité de l'enveloppe de branchement. La cascade finie sans réactivation s'arrête indépendamment de cette condition. À la borne $g = 1$ du domaine, elle ne donne que $\rho(W) \leq 1$: la stabilité tient alors par la valeur calculée de $\rho(W)$, strictement inférieure à 1.

Proposition 5.4 (Loi exacte de l'ensemble atteint)**.** *Pour tout $A \subseteq P$ avec $a \in A$,*

$$\mathbb{P}(S_a = A) \;=\; R(A)\,B(A), \qquad B(A) = \prod_{j \in A,\; k \notin A} (1 - W_{jk}),$$

où $B(A)$ est la probabilité qu'aucune arête ne fuie hors de A, et $R(A)$, la probabilité que a atteigne tout *A par les seules arêtes internes, vérifie $R(\{a\}) = 1$ et*

$$R(A) \;=\; 1 - \sum_{\substack{A' \subsetneq A \\ a \in A'}} R(A') \prod_{j \in A',\, k \in A \setminus A'} (1 - W_{jk}).$$

Les capitaux par état du périmètre financier (§9.1) sont calculés avec la variante à un successeur par pas, la marche auto-évitante. Depuis le pilier j, la cascade passe au pilier k avec la probabilité W_{jk}, et s'arrête sinon, ou dès qu'elle revient sur un pilier touché. Les deux constructions ont la même matrice moyenne et le même nombre moyen de descendants directs, et leurs lois se calculent sans approximation. Les bornes du chapitre 8 emploient la cascade indépendante, la seule définie pour les matrices admissibles dont une ligne somme à plus de un.

Passer de la marche au branchement déplace le besoin de capital du secteur de −4 %. La grille en g du §6.4 porte sur la cascade indépendante. Pour la marche, seul le passage de $g = 0{,}45$ à $g = 0{,}90$ est contrôlé : dans les seize configurations des quatre canaux, relâcher la propagation ne fait jamais baisser le capital (§C.4.2).

Proposition 5.5 (Monotonie stochastique)**.** *Si $W \le W'$ terme à terme, alors $S_a(W)$ est stochastiquement dominé par $S_a(W')$: on peut construire les deux ensembles sur les mêmes tirages avec le premier inclus dans le second. Toute fonctionnelle croissante de S_a, en particulier la perte agrégée et sa VaR, est donc croissante en chaque entrée de W. En revanche une perturbation* antisymétrique *A déplace W_{jk} et W_{kj} en sens opposés : le capital n'est pas monotone en A_{jk}, ce qui justifie de balayer les sommets de l'ensemble admissible (chapitre 8) sans revendiquer de bornes exactes.*

Proposition 5.6 (Dépendance à l'ordre)**.** *Soit la vraisemblance d'une chaîne ordonnée*

$$\ell(i_1, \dots, i_n) = \mathrm{ROOT}_{i_1} \prod_{k=1}^{n-1} t_{i_k i_{k+1}}.$$

Sur les chaînes de deux piliers, ℓ est invariante par permutation si et seulement si

$$\mathrm{ROOT}_i\, t_{ij} = \mathrm{ROOT}_j\, t_{ji}$$

pour tout couple (i, j). Cette condition est nécessaire à l'invariance pour toute longueur. Le barème la viole pour la paire (P1, P2), dont les deux ordres reçoivent des criticités différentes (chapitre 2). Un score ou une copule des seules indicatrices ne représente pas l'ordre d'atteinte.

Proposition 5.7 (Ce que la co-occurrence voit de la direction)**.** *Soit la décomposition unique $W = S + A$, avec $S = \frac{1}{2}(W + W^\top)$ et $A = \frac{1}{2}(W - W^\top)$.* (i) *Sous une amorce uniforme, de probabilité r pour chaque pilier, la probabilité qu'un même sinistre touche à la fois j et k vaut*

$$\sum_{a \in P} r\, \mathbb{P}\big(\{j, k\} \subseteq S_a\big) \;=\; r\,(W_{jk} + W_{kj}) + O\big(\|W\|^2\big) \;=\; 2r\, S_{jk} + O\big(\|W\|^2\big) :$$

au premier ordre, la co-occurrence ne dépend de W que par S ; W et $W^\top$ y sont indiscernables. (ii) *Au-delà du premier ordre, ou sous une amorce non uniforme, la loi de l'ensemble atteint dépend en général de A. W et $W^\top$ ne sont donc pas observationnellement équivalents pour la loi complète des ensembles de piliers touchés.* (iii) *En général, $B(W) \neq B(W^\top)$.*

5.9 Vérification numérique des propriétés

Sur les 26 sous-ensembles de taille au moins deux, 22 changent de criticité selon l'ordre, l'écart atteignant 6 points sur une échelle de 10, c'est-à-dire 60 % de l'échelle. Sur la paire $\{P_1, P_2\}$, $t_{12} = 0{,}80$ et $t_{21} = 0{,}20$ donnent des criticités de 8 et 2 pour le même ensemble. Ni une copule ni un score additif ne peuvent reproduire cet objet (proposition 5.6). La non-transitivité de la dominance entre piliers, testée sous trois formulations, ne se vérifie pas, avec zéro violation sur 420 triplets, une valeur propre minimale de +0,405 et zéro cycle. Nous ne la revendiquons donc pas.

Avec le classeur actuel, on a $\rho(W) = 0{,}506$. La majoration $\mathbb{E}\,|S_a| \leq [(I - W)^{-1}\mathbf{1}]_a$ tient sur les cinq amorces et sur 300 matrices de l'ensemble admissible. L'écart entre la borne et la valeur exacte, de 10,6 % (amorce P5) à 19,9 % (amorce P1), comprend les contributions des marches avec répétitions et des chemins multiples vers un même pilier. Nous gardons le calcul exact (proposition 5.4).

Sur les transitions annuelles OpRisk, le test de permutation de l'asymétrie ne rejette pas $A = 0$ (asymétrie 119 contre 128 ± 27, $z = -0{,}33$, aucune arête significative sur 18). Pour le périmètre financier étudié, aux paramètres de base, retourner la matrice déplace pourtant le capital de 3,6 % (295 M€) et la perte moyenne de 7,9 %, et le pilier à remédier en premier passe de P1 à P4. Sur l'ensemble admissible, l'écart entre une matrice et sa transposée atteint 1 173 M€.

À $g = 0{,}90$, hors choc commun P4, la loi des ensembles touchés distingue W et $W^\top$. Elle donne 1,931 contre 1,746 pilier en moyenne par sinistre, 62,31 % contre 50,77 % de sinistres multi-piliers, et une co-défaillance de P2 et P5 de 0,127 contre 0,066. Sous amorce uniforme et avec W divisée par cinquante, l'écart moyen est de 0,86 %. Les statistiques disponibles ne permettent pas cette distinction. Une matrice donnée détermine la loi des ensembles atteints ; si l'incident suit P4→P1→P2, sa perte vaut $a+b+c$. D'un état de conformité à l'autre, seuls les paramètres changent ; l'estimation de W relève du chapitre 7.

6

Modélisation multi-états de la conformité

6.1 Deux échelles de temps

Que change le passage d'un état non conforme (NC) à partiellement conforme (PC), puis conforme (C) ? Chaque état fixe les valeurs des quatre canaux du calcul annuel : les incidents et leurs pertes sont simulés sous ces paramètres. Les états sont supposés, sans observation par entité.

La variable latente ci-dessous décrit une distribution possible des états. Une chaîne de Markov traite ensuite une question distincte : leur évolution au cours de la remédiation, sur plusieurs années. Le temps d'une transmission entre piliers et celui d'une amélioration de conformité restent donc séparés. Cette distinction rejoint les migrations de rating en crédit (§6.7) et la séparation des échelles de propagation et de calendrier de Karimi et al. (2026).

Nous notons B_e le besoin de capital annuel calculé sous un état fixé e. La figure 6.1 montre comment les probabilités d'état au cours du temps pondèrent ces capitaux. La trajectoire obtenue est une moyenne de quantiles ; calculer le quantile d'une perte annuelle dont l'état est lui-même aléatoire demanderait d'agréger les distributions de pertes avant de prendre le quantile.

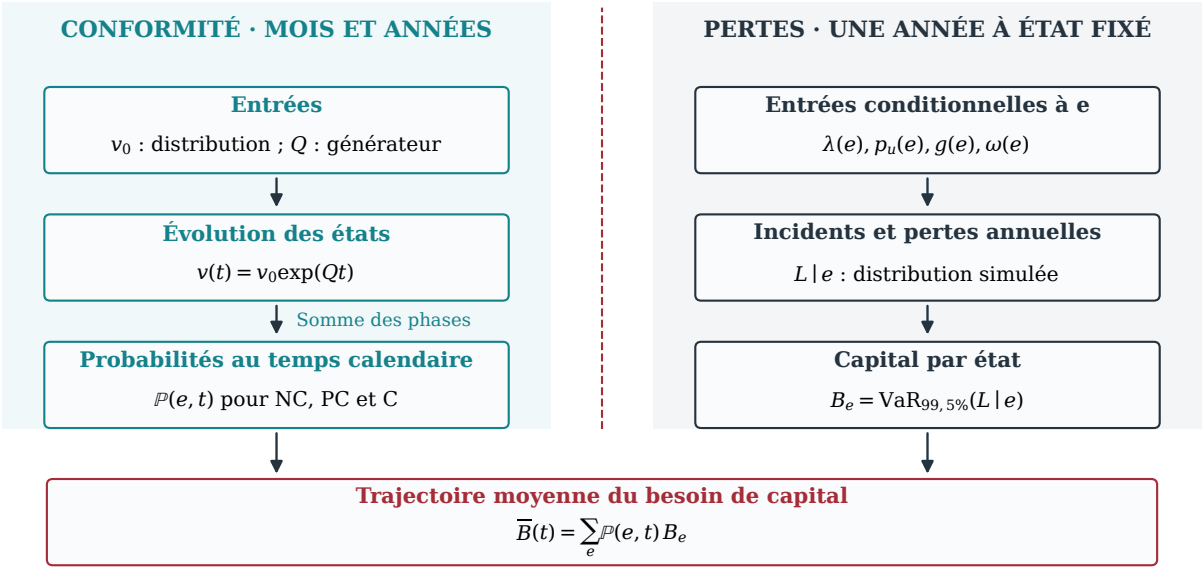


Figure 6.1. Deux échelles de temps et deux calculs. À gauche, v_0 et le générateur de phases Q donnent les probabilités d'état au temps t. À droite, chaque état fixe un calcul de pertes sur un an. Leur combinaison donne la moyenne des besoins conditionnels ; elle ne donne pas le quantile des pertes mélangées.

6.2 Vasicek multi-états à seuils ordonnés

Chaque pilier possède une capacité de conformité latente $C^\star \sim \mathcal{N}(0,1)$, que nous décomposons à la Vasicek en un facteur systémique commun Θ et un choc idiosyncratique ε propre au pilier. Ce sont deux variables normales centrées réduites et indépendantes, supposées par le modèle et non mesurées ; γ est la charge du facteur commun :

$$C^\star = \gamma\,\Theta + \sqrt{1-\gamma^2}\,\varepsilon, \qquad \gamma = 0{,}68. \tag{6.1}$$

Au lieu d'un unique seuil de défaut, nous en posons deux, ordonnés, qui découpent trois états :

$$\text{NC si } C^\star \le K_{\text{bas}}, \quad \text{PC si } K_{\text{bas}} < C^\star \le K_{\text{haut}}, \quad \text{C si } C^\star > K_{\text{haut}}. \tag{6.2}$$

Les seuils sont fixés par les probabilités d'état ancrées sur les enquêtes de conformité de fin 2025 (0,35, 0,35 et 0,30 pour NC, PC et C, annexe B), d'où $K_{\text{bas}} = \Phi^{-1}(p_{\text{NC}})$ et $K_{\text{haut}} = \Phi^{-1}(p_{\text{NC}} + p_{\text{PC}})$. Sur le score $U = \Phi(C^\star)$, uniforme sur $[0,1]$, ces seuils sont les coupures 0,35 et 0,70. Ce probit ordonné généralise la latente de défaut binaire en une latente de conformité à trois niveaux. Sachant l'environnement Θ, on obtient

$$\mathbb{P}(\text{NC} \mid \Theta) = \Phi\!\left(\frac{K_{\text{bas}} - \gamma\Theta}{\sqrt{1-\gamma^2}}\right), \qquad \mathbb{P}(\text{C} \mid \Theta) = 1 - \Phi\!\left(\frac{K_{\text{haut}} - \gamma\Theta}{\sqrt{1-\gamma^2}}\right). \tag{6.3}$$

Intégrée sur Θ, la marginale redonne l'ancrage, tandis qu'en crise systémique la masse bascule vers la non-conformité (figure 6.2).

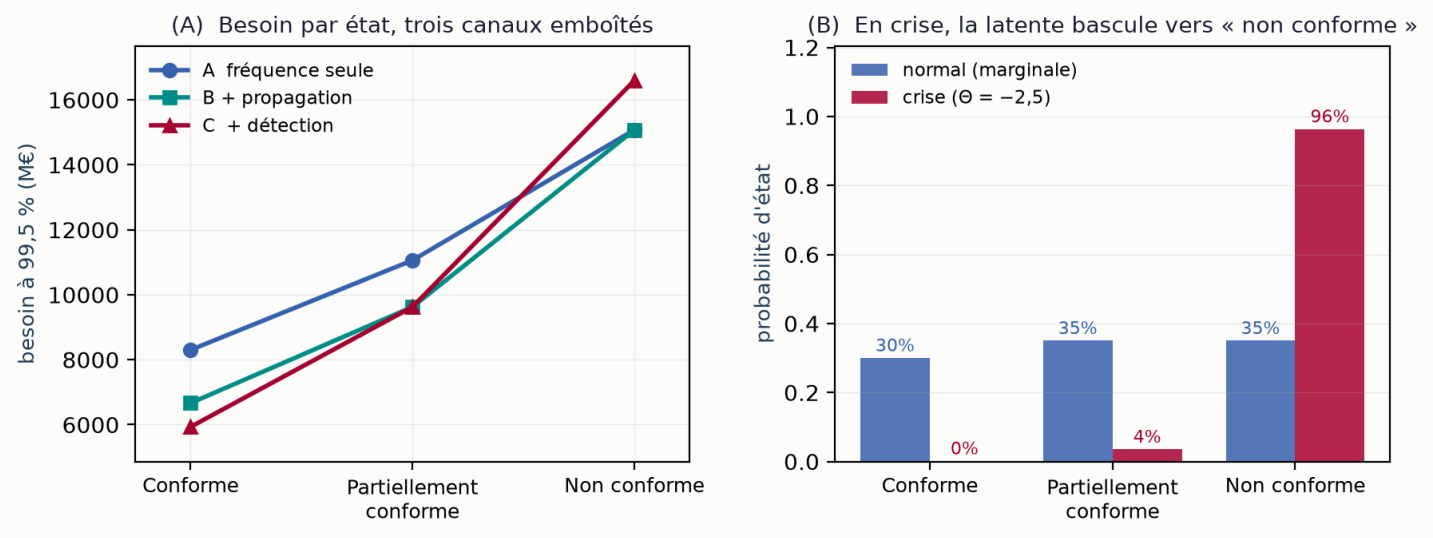


Figure 6.2. États de conformité et capital. (A) Besoin de capital du périmètre financier étudié par état, en cumulant la fréquence seule, puis la propagation, puis la détection, trois des canaux définis au §6.3. (B) Probabilités d'état en régime normal et en crise systémique : la masse bascule vers la non-conformité.

6.3 Quatre canaux de la conformité

Nous comparons les états en modifiant quatre entrées du même calcul annuel. La figure 6.3 donne leurs valeurs aux deux extrêmes, lorsque tous les piliers partagent le même état (§6.5). Les lois de perte de base et l'agrégation sont conservées ; les différences entre les entrées restent des scénarios.

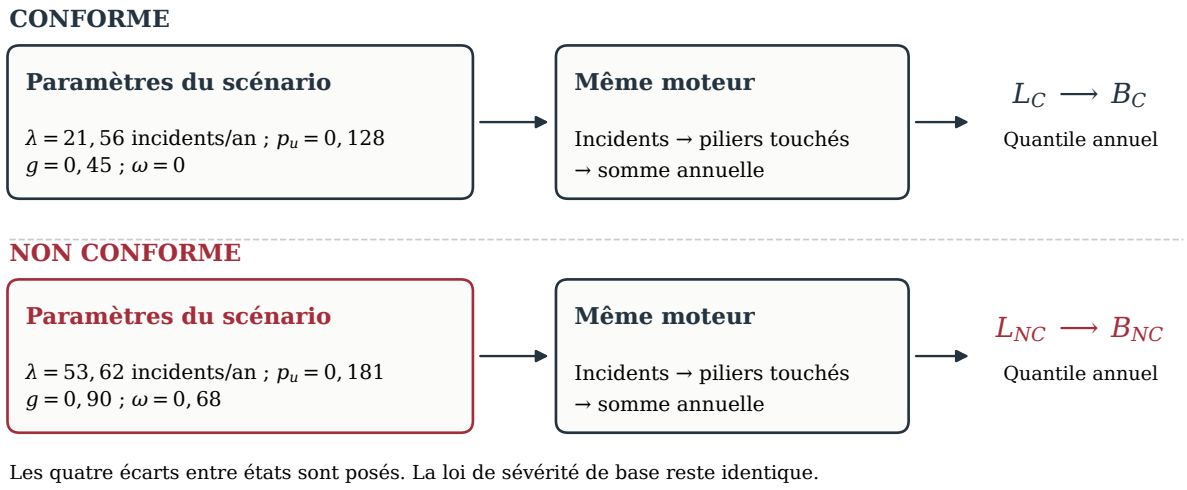


Figure 6.3. Deux états supposés, un même calcul annuel. λ règle le nombre d'incidents, p_u le dépassement par pilier, g la propagation et ω le choc commun. L désigne la perte annuelle et B son quantile à 99,5 %.

1. L'état module la *fréquence* λ des incidents amorcés par un multiplicateur de scénario, de 21,56 incidents enregistrés par an à l'état conforme à 53,62 à l'état non conforme.
2. Le gain de *propagation* g de la normalisation (5.4) baisse de 0,90 à 0,45, car une entité plus conforme contient mieux la contagion. La propension du pilier j à propager vaut $e_j = g(c_j)\, s_j / \max_k s_k$, où s_j est la somme de la ligne j de T et c_j l'état du pilier j.
3. La *détection* agit sur p_u, le taux de dépassement, c'est-à-dire la probabilité qu'une sévérité élémentaire dépasse le seuil u du chapitre 4 (notée ζ_u dans ce chapitre). Le moteur l'applique à chaque pilier touché, si bien que la probabilité de perte matérielle d'un incident est plus élevée et dépend aussi de la propagation. Le taux p_u varie avec l'état parce qu'une entité conforme intercepte et remédie tôt, de sorte qu'une moindre fraction des piliers touchés atteint la sévérité matérielle. Nous multiplions p_u par 0,85 à l'état conforme et par 1,20 à l'état non conforme, deux valeurs posées.
4. L'*accumulation par un prestataire commun* transforme, à l'état non conforme, un incident amorcé sur le pilier des tiers en choc commun. Ce choc touche chacun des autres piliers avec la probabilité ω, nulle à l'état conforme et égale à 0,68 à l'état non conforme. Cette borne haute est posée à la valeur de la charge γ, mais ω est une probabilité de choc et γ une charge de facteur : les deux paramètres sont distincts, et ω n'est pas identifiée (§C.2).

Le résultat principal du chapitre 9 relâche les quatre. Le multiplicateur de fréquence se compose vecteur par vecteur selon $\lambda_{\mathrm{NC}} = \lambda_{\mathrm{C}} \sum_v \pi_v\, m_v$, où π_v est la part du vecteur v dans le recensement

Hackmageddon (§3.6) et m_v le centre d'une fourchette de multiplicateur propre au scénario non conforme.

Vecteur	Part π_v	Fourchette	Centre	$\pi_v\, m_v$	Effet publié qui ancre la fourchette
Hameçonnage	0,388	[1,8 ; 3,0]	2,40	0,9312	réduction du risque par la formation (Ponemon/IBM)
Exploitation de vulnérabilité	0,338	[2,0 ; 2,6]	2,30	0,7774	écart de conversion en intrusion entre exploitation et hameçonnage (ENISA)
Chaîne d'approvisionnement	0,158	[1,9 ; 2,6]	2,25	0,3555	surcoût et progression des brèches d'origine tierce (IBM, SecurityScorecard)
Identifiants compromis	0,063	[3,0 ; 8,0]	5,50	0,3465	réduction de compromission par l'authentification forte (Microsoft Research)
Autres	0,053	[1,3 ; 1,6]	1,45	0,0769	aucune source dédiée
Multiplicateur agrégé, état non conforme				2,4875	$21{,}56 \times 2{,}4875 = 53{,}62$ incidents par an

Ce multiplicateur est posé, non calibré : les parts sont une citation externe, et chaque fourchette traduit un effet publié en multiplicateur prudent. Aux bornes des fourchettes, il va de 1,933 à 3,042, ce qui donne une fréquence non conforme de 41,7 à 65,6 incidents par an. Le vecteur des identifiants, avec 6,3 % des incidents, représente 13,9 % du multiplicateur.

6.4 Valeurs posées de g et invariance de l'ordre

Les trois valeurs du gain de propagation,

$$g = 0{,}45 \text{ (conforme)}, \qquad 0{,}68 \text{ (partiellement conforme)}, \qquad 0{,}90 \text{ (non conforme)},$$

sont posées, car l'état de conformité DORA des entités n'est pas publié, si bien qu'aucun échantillon ne donne la correspondance état $\rightarrow g$. À l'échelle de l'entité notionnelle (§9.5), le besoin de l'entité, de 13,2 à 24,1 M€ quand g passe de 0,45 à 0,90 (le 24,1 est une extrapolation d'ordre de grandeur), dépend donc de ces trois valeurs. La croissance du capital en g est contrôlée numériquement, avec la cascade indépendante de l'évaluateur du chapitre 8 et la seule contagion comme canal variable ; la marche auto-évitante des capitaux par état n'est pas couverte par ce contrôle.

Sur une grille de vingt points, à nombres aléatoires communs, aucun pas n'est décroissant, pour le capital comme pour la perte moyenne, à l'échelle d'entité comme du secteur. Les applications testées respectant $g_C < g_{PC} < g_{NC}$ donnent $B_C < B_{PC} < B_{NC}$. La grille ne démontre pas cette propriété pour toute valeur de g. L'existence et le sens de l'écart sont ainsi vérifiés numériquement sur ces vingt points et sur les cinq applications du tableau, et seule son amplitude est un scénario.

Application état $\rightarrow g$	**Conf.** M€	**Part.** M€	**Non conf.** M€	**Écart**	**Ordre**
étroite (0,70/0,80/0,90)	18,0	20,9	24,1	+33,8 %	oui
retenue (0,45/0,68/0,90)	**13,2**	**17,7**	**24,1**	**+83,0** %	oui
large (0,20/0,55/0,90)	10,1	15,7	24,1	+138,4 %	oui
conformité faible (0,45/0,55/0,65)	13,2	15,7	16,9	+27,9 %	oui
très étroite (0,85/0,875/0,90)	22,3	23,1	24,1	+8,1 %	oui
repère forfaitaire de Formule Standard	450	450	450	0 %	*plat*

Avec un déplacement de 0,05 sur g, l'écart est de +8,1 %, le forfait restant plat. L'hypothèse qui demeure est qualitative, $g_C < g_{NC}$, et signifie que se conformer à DORA réduit la propagation entre piliers. L'élasticité d'arc du capital au gain est de 0,59 sur $g \in [0{,}20\,;0{,}95]$, et un écart de 10 % ne demande qu'une baisse de g de 0,90 à 0,84. Nous présentons donc l'écart entre états comme un scénario sur l'écart entre les valeurs de g au chapitre 9.

6.5 État de conformité par pilier

Chaque pilier reçoit sa propre latente $C_j^\star$, les cinq étant corrélées par le facteur commun Θ. Un pilier non conforme propage alors plus et détecte moins que ses voisins conformes. Les canaux deviennent λ_j, g_j et $p_{u,j}$, indexés par pilier. Le moteur redonne la version globale lorsque tous les piliers partagent un état, et basculer un pilier à la fois permet de décomposer le surcoût de non-conformité par pilier (chapitre 9).

6.5.1 Dépendance entre états

Le recouvrement des dispositifs de contrôle fait qu'être conforme aux piliers 1 et 2 confère indirectement une conformité partielle au pilier 3. Le modèle ne représente pas ce recouvrement. Les cinq latentes partagent le facteur systémique avec une charge de 0,68, soit une corrélation de 0,462 entre deux piliers quelconques, mais cette dépendance est identique pour toutes les paires de piliers. Ajouter un surcroît de corrélation δ aux deux seules paires concernées, à marges fixées, est admissible jusqu'à $\delta = 0{,}38$.

Sur ce balayage, la probabilité que les cinq piliers soient non conformes passe de 0,068 à 0,088 et celle qu'aucun ne soit non conforme de 0,291 à 0,330. Ce diagnostic est binaire : son état C regroupe PC et C, contrairement au modèle à trois états. Le capital espéré, pour le périmètre financier étudié, ne varie que de 2 M€, soit 0,02 %.

Le capital des 32 configurations, chaque pilier étant conforme ou non conforme, va de 6 015 à 17 009 M€. Il est calculé avec la marche auto-évitante et trois canaux par pilier, sans le choc commun du prestataire : son coin tous non conformes ne reproduit donc pas le chiffre de tête. Ce capital s'ajuste par une forme additive en indicateurs de pilier, $R^2 = 0{,}9945$, avec des contributions de 3 524 (P1), 2 863 (P4), 2 022 (P2), 1 577 (P3) et 897 M€ (P5) au-dessus d'un socle tous conformes.

L'espérance d'une fonction additive ne dépendrait que des marges. L'ajustement n'est qu'approché, avec un résidu maximal de 461 M€ : la faible sensibilité de l'espérance vaut pour les dépen-

dances examinées, non pour toute structure à marges fixées. Cette quasi-additivité est le même fait que la faible interaction entre piliers, de signe non résolu (section sur la décomposition par pilier, chapitre 9). L'argument concerne une espérance et ne se transpose ni au quantile de la loi de perte mélangée, où l'invariance est seulement non détectée, ni au quantile de la loi des configurations, où l'effet est de quelques pour cent.

6.6 Chaîne de Markov et séjours de type phase

À l'échelle lente, l'état suit une chaîne de Markov à temps continu NC $\to$ PC $\to$ C, dont l'état conforme est absorbant dans le cas de base. Le retour vers un état moins conforme est traité en sensibilité. Nous retenons des séjours de type phase (Erlang-k), pour réduire la probabilité de séjours très courts.

Une Erlang de forme supérieure à un a une densité nulle à l'origine, mais n'impose aucune durée minimale strictement positive. Cette loi est posée. Une loi d'Erlang est la somme de k durées exponentielles indépendantes de même taux. Chaque état transitoire est développé en k phases. Le générateur Q contient les taux de passage hors diagonale ; sa diagonale est l'opposé de leur somme. L'exponentielle de matrice donne les probabilités de transition :

$$\big(\mathbb{P}(\mathrm{NC},t),\mathbb{P}(\mathrm{PC},t),\mathbb{P}(\mathrm{C},t)\big) \;=\; (\text{sommes de phases de})\;\; v_0\,\exp(Qt), \tag{6.4}$$

où v_0 est le vecteur-ligne des probabilités initiales et t le temps écoulé, dans l'unité des taux de Q. Cette distribution pondère les besoins de capital par état :

$$\overline{B}(t) \;=\; \sum_{e\in\{\mathrm{NC},\mathrm{PC},\mathrm{C}\}} \mathbb{P}(e,t)\,B_e. \tag{6.5}$$

Il s'agit d'une moyenne de quantiles, qui diffère du quantile à 99,5 % de la loi mélangée, dont la queue vient des composantes les plus lourdes. Sur le mélange des 32 configurations, l'écart mesuré est de l'ordre de 9,3 %. La trajectoire se lit donc comme l'espérance du besoin de capital sous l'incertitude d'état.

6.7 Couplage systémique et analogie de crédit

Le même facteur Θ agit sur les deux couches. Un environnement dégradé, où $\Theta < 0$, ralentit la remédiation par des taux de transition $\mu(\Theta) = \mu_0\, e^{\beta_{\mathrm{rem}}\Theta}$ et durcit la cascade par $B_e(\Theta) = B_e\, e^{-\beta_{\mathrm{casc}}\Theta}$, où μ_0 est le taux de remédiation en environnement moyen et les β mesurent la sensibilité au facteur. Ces formes exponentielles sont posées, avec $\beta_{\mathrm{rem}} = 0{,}35$ et $\beta_{\mathrm{casc}} = 0{,}1$. Elles introduisent la corrélation entre conformité et sinistralité, et la dispersion de Θ engendre la bande d'incertitude de la trajectoire. L'analogie de crédit associe la chaîne de Markov aux changements de notation, ou rating, et le Vasicek aux incidents conditionnels à cette notation.

7

Identifiabilité de la direction de contagion

Un paramètre est identifiable si deux valeurs distinctes ne produisent pas la même loi des observations retenues. Cette propriété du modèle diffère de la précision de son estimation. Peut-on ainsi estimer les liens dont dépend le calcul précédent ? La chaîne P4→P1→P2 de notre exemple est une réalisation possible sous W, sans être une séquence observée. Distinguer $j \to k$ de $k \to j$ exige une information directionnelle que les comptages agrégés ne fournissent pas ici. Le corpus de rapports n'apporte qu'un ordre partiel. Nous séparons donc structure générale, sens d'une paire et amplitude d'un coefficient, avant de mesurer leur effet sur le capital.

7.1 Conditions d'identification de W

Le coefficient W_{jk} mesure la propension d'une défaillance du pilier j à entraîner une défaillance du pilier k, la ligne émettant et la colonne recevant (chapitre 5). Pour l'identifier, il faut observer des co-occurrences, c'est-à-dire des défaillances de plusieurs piliers dans un même incident de l'entité. Il faut également distinguer W_{jk} de W_{kj}, par une antériorité temporelle fiable ou par la loi complète des ensembles de piliers touchés, sous des hypothèses sur la cascade et les amorces. Il faut enfin une taxonomie par domaine de contrôle, un classement par vecteur d'attaque ne suffisant pas.

Aucune des trois sources agrégées que nous avons examinées ne réunit ces conditions. La chronologie PRC n'a pas la taxonomie, SAS OpRisk n'a pas le pas de temps, et la base VERIS prévoit les deux dans son schéma sans les renseigner.

Pour lire ces conditions, nous décomposons toute matrice en $W = S + A$, où $S = (W + W^\top)/2$ est sa partie symétrique et $A = (W - W^\top)/2$ sa partie antisymétrique. S ne retient que l'intensité du lien entre deux piliers, quel que soit le sens ; A ne retient que l'asymétrie entre les deux sens. Sous amorce uniforme et à faible intensité, la co-occurrence dépend de S au premier ordre, ce qui ne suffit pas à identifier A (proposition 5.7). La loi complète des ensembles touchés peut en revanche distinguer W de sa transposée. La symétrie d'un comptage ne permet donc pas, à elle seule, de conclure à une impossibilité générale d'identifier la direction.

7.2 Trois sources agrégées

La première source, la chronologie américaine des fuites de données, est volumineuse (74 783 incidents, 25 009 organisations) mais manque de taxonomie et de volume informatif. La catégorie non déterminée (`UNKN`) représente en effet 52,7 % des incidents. La date de survenance n'est exploi-

table que dans 49,6 % des cas, de façon non aléatoire selon le type d'incident, et ordonner par date de déclaration mesurerait le délai de détection, pas la contagion. Restreinte aux types informatifs et aux trimestres consécutifs, la base ne donne que 71 transitions $j(t-1) \to k(t)$, c'est-à-dire 3,6 observations par cellule hors diagonale, et 34 dans le secteur financier.

La deuxième, SAS OpRisk, offre 4 329 transitions annuelles entre 7 catégories de risque, environ 103 par cellule, mais son pas de temps annuel est trop grossier pour saisir une antériorité. On note N la matrice des transitions observées, N_{jk} comptant les passages $j(t-1) \to k(t)$, et l'on pose

$$\Delta(N) \;=\; \tfrac{1}{2}\,\lVert N - N^{\top} \rVert_1 \;=\; \tfrac{1}{2}\sum_{j \neq k} \bigl| N_{jk} - N_{kj} \bigr|, \tag{7.1}$$

nulle si et seulement si N est symétrique. Nous permutons les années à l'intérieur de chaque firme afin de détruire l'antériorité en conservant la co-occurrence. Si μ_0 et σ_0 désignent la moyenne et l'écart-type de Δ sur ces permutations, l'écart réduit

$$z \;=\; \frac{\Delta(N) - \mu_0}{\sigma_0} \tag{7.2}$$

s'établit à $z = -0{,}33$, avec $\Delta(N) = 119$ contre $\mu_0 \pm \sigma_0 = 128 \pm 27$. Aucune des 18 paires suffisamment peuplées n'est significative à 5 %, avant ou après correction de Bonferroni. Le test du temps inversé, qui compare N à la matrice de la chronologie renversée, est dégénéré sur un comptage, cette matrice étant $N^{\top}$, et seul le placebo par permutation est donc utilisable.

La troisième, la VERIS Community Database, compte 10 591 incidents, dont 980 en secteur financier (NAICS 52). Son schéma prévoit les deux objets manquants, à savoir un champ `control_failure` qui nomme le domaine de contrôle défaillant, et une chronologie en quatre étapes. Le champ est renseigné dans 13 incidents (0,12 %), dont un seul en secteur financier, et la chronologie est datée sur au moins deux étapes dans 126 incidents (1,19 %), sur au moins trois dans 10. L'intersection des deux conditions compte 1 incident, extérieur au secteur financier. La spécification existe donc mais n'est pas remplie, et il s'agit d'en rendre le remplissage obligatoire (section 10.8).

7.3 Direction de contagion et réversibilité

Un comptage de co-occurrences ne renseigne pas la direction. Sous l'hypothèse que les sauts entre piliers forment une chaîne de Markov stationnaire, la théorie des processus réversibles en donne la raison. Nous utilisons la probabilité historique, sans prix, et aucun test de martingalité n'est conduit. Les parties de $W = S + A$ sont orthogonales pour le produit de Frobenius. Cette décomposition euclidienne de W ne s'identifie pas à celle d'une chaîne de Markov de loi stationnaire non uniforme.

Pour une chaîne auxiliaire, P_{jk} est la probabilité de passer de j à k. Sa loi stationnaire π, strictement positive, vérifie $\pi P = \pi$. Alors le noyau adjoint est $\tilde{P}_{jk} = \pi_k P_{kj} / \pi_j$ et $S_\pi = \tfrac{1}{2}(P + \tilde{P})$ est réversible. Avec $A_\pi = (P - \tilde{P})/2$, le courant vaut $J_{jk} = 2\pi_j (A_\pi)_{jk}$, nul à l'équilibre détaillé, où

chaque flux $\pi_j P_{jk}$ égale son flux inverse. La chaîne est alors réversible : à stationnarité, ses trajectoires ont la même loi dans les deux sens du temps. Pour une fonction f associant une valeur réelle à chaque pilier, la forme de Dirichlet s'écrit

$$\mathcal{E}(f,f) \;=\; \tfrac{1}{2}\sum_{j,k}\pi_j P_{jk}\,(f_k-f_j)^2 \;=\; \tfrac{1}{2}\sum_{j,k}\pi_j (S_\pi)_{jk}\,(f_k-f_j)^2, \tag{7.3}$$

la partie antisymétrique pondérée s'annulant par paires. L'énergie de fluctuation $\mathcal{E}(f,f)$ est donc aveugle à la direction (figure 7.1). L'invariance par renversement du temps n'interdit pas de détecter l'intensité d'une irréversibilité : Δ en est un exemple, puisqu'elle est elle-même invariante par transposition. Elle ne donne pas le signe du courant. Le placebo ne détecte pas d'asymétrie au pas annuel ; ce non-rejet n'établit pas la réversibilité.

Deux limites bornent cette lecture. La matrice W n'est pas un générateur de Markov au sens strict, et l'énoncé ne s'étend pas à la loi complète des ensembles de piliers touchés, qui dépend de la direction (proposition 5.7). La frontière tient aux statistiques que fournissent les sources.

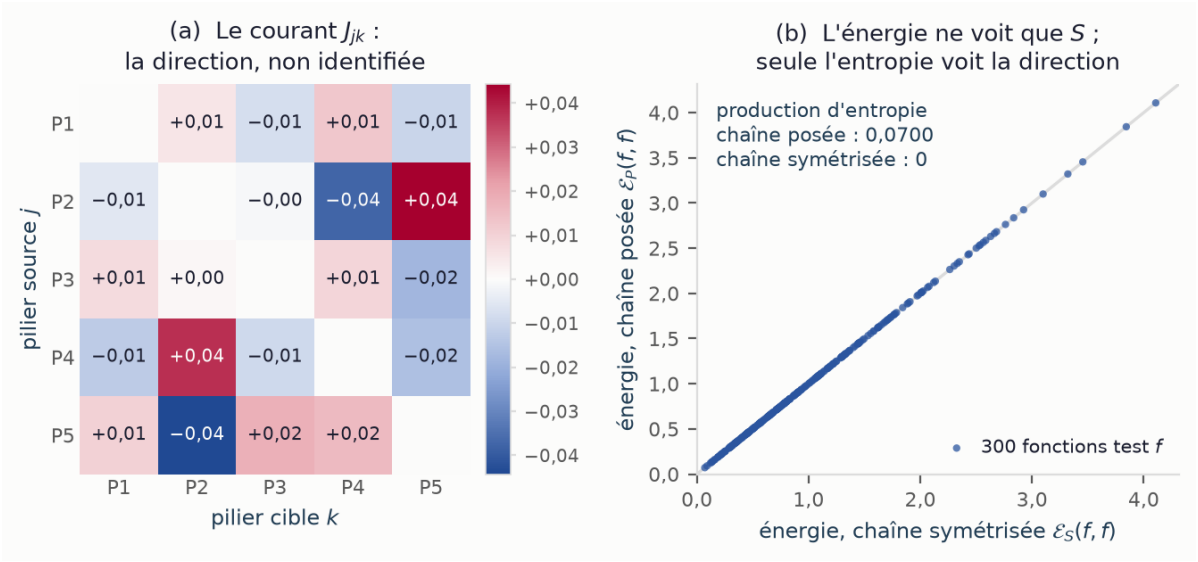


FIGURE 7.1. Direction et réversibilité. (a) Le courant $J_{jk} = \pi_j P_{jk} - \pi_k P_{kj}$ est non nul, donc le modèle a une direction. (b) Pour trois cents fonctions test tirées au hasard, l'énergie de fluctuation est la même pour la chaîne posée et pour sa symétrisée. La production d'entropie, mesure de dissymétrie des flux pondérés par leurs log-rapports, distingue ici les deux chaînes ; elle est nulle pour une chaîne réversible.

7.4 EXPÉRIENCE NATURELLE DU CHOC MOVEIT

En mai 2023, l'exploitation de masse de la faille du logiciel de transfert MOVEit frappe en même temps des centaines d'organisations. Si la contagion dirigée existe, ce choc exogène, daté et rattaché au pilier 4, doit élever dans les mois suivants, chez les organisations touchées, le risque de défaillances relevant d'autres piliers. Une différence de différences sur 188 organisations financières touchées, contre un groupe de contrôle apparié et sur des fenêtres de 180 jours, donne +1,17 jour de déclaration d'incident par organisation (IC bootstrap [+1,07 ; +1,27]).

Calé sur une fausse date un an plus tôt, le même dispositif donne +1,11. L'effet est donc compa-

tible avec une régression vers la moyenne du groupe de contrôle sélectionné, et l'effet net de +0,06 est indiscernable de zéro. La cible resterait de toute façon non attribuable, car la source classe les incidents par vecteur d'attaque, avec 32 % de non déterminés.

7.5 Corpus de rapports post-incident

Un rapport post-incident officiel reconstitue la séquence des défaillances de contrôle, ce qu'aucune base agrégée ne fait. Nous codons sept rapports (Cyber Safety Review Board, FCA et PRA, GAO, SEC, OCC), dont deux sur des entités financières régulées, en transitions dirigées $j \to k$ telles que le rapport les décrit. L'unité de codage est le couple (incident, paire de piliers).

Sur 17 transitions, l'asymétrie Δ de l'équation (7.1) vaut 17, contre $8{,}4 \pm 2{,}2$ sous un placebo par permutation, d'où $z = +3{,}93$ ($p = 0{,}0004$), là où le pas annuel d'OpRisk donnait $z = -0{,}33$. Toutes les transitions vont dans le sens dominant de leur paire. P1, la gouvernance, n'est jamais une cible (9 sorties, 0 entrée) et P2, la gestion des incidents, n'a aucune sortie (0 sortie, 7 entrées), structure que le classeur qualitatif (la matrice W posée à dire d'expert) posait par jugement.

Le placebo teste la cohérence du codage, mais pas l'exogénéité de la direction. Une enquête officielle, mandatée pour déterminer une cause racine, conclut en effet souvent à une défaillance de gouvernance, si bien que P1 peut ressortir comme source par convention d'écriture. S'y ajoutent un codeur unique, des sources en partie secondaires et un échantillon d'incidents notoires. Le corpus corrobore donc la structure sans la calibrer, et le coût du biais est borné au §7.7. Une mesure de fiabilité par second codeur en aveugle reste en attente.

Les trois relectures de praticiens reçues ne distinguent pas un ordre de propagation d'une cause commune, ce qui corrobore la frontière mais pas la matrice. Les deux dernières contestent le sens unique de deux arcs sans déplacer le capital publié (annexe D, §D.6).

7.6 Corpus étendu et matrice ordonnée

Nous ajoutons les trois rapports d'enquête publique sur CrowdStrike Falcon 2024, Log4Shell 2021–2022 et Raphaels Bank 2015. Le corpus compte alors 22 transitions et le signal se renforce, y compris lorsque l'on se restreint aux sources primaires ou à la perspective de l'entité.

Périmètre	**Rapports**	**Transitions**	**Asym. / nul**	z
Corpus initial (chapitre, ci-dessus)	7	17	17 / 8,4 ± 2,2	+3,93
Corpus étendu	10	22	22 / 9,5 ± 2,4	**+5,12**
Sources *primaires* seules	7	18	18 / 8,2 ± 2,4	+4,08
Perspective *entité* seule	6	16	16 / 8,0 ± 2,2	+3,62

Chaque incident déclare aussi l'ensemble des piliers défaillants, y compris ceux qui n'ont rien entraîné. On en tire le dénominateur manquant et la matrice ordonnée complète :

$$\begin{aligned} p_{jk} \;&=\; \mathbb{P}(\text{le rapport documente } j \to k \mid \text{le pilier } j \text{ a cédé}), \\ p_{jk} \mid \text{données} \;&\sim\; \mathrm{Beta}\big(1 + m_{jk},\; 1 + N_j - m_{jk}\big), \end{aligned} \tag{7.4}$$

où N_j compte les incidents où j a cédé et m_{jk} ceux où le rapport documente $j \to k$, sous un a priori uniforme. Sur les vingt liens ordonnés, douze ont un intervalle de crédibilité à 90 % situé sous 0,5 et aucun au-dessus, si bien que les transitions documentées y sont rares sans identifier les propagations fortes. Les liens les plus élevés, $P_3 \to P_2$ (0,77, intervalle $[0{,}48\,;0{,}95]$) et $P_1 \to P_4$ (0,68, $[0{,}40\,;0{,}89]$), recouvrent encore 0,5.

Les douze liens faibles comprennent les quatre sorties de P_2 et trois des quatre entrées de P_1, l'arc $P_5 \to P_1$ n'étant pas classé faible. La corrélation avec le classeur d'expert n'est pas significative ($\rho = +0{,}08$ sur la matrice, +0,31 sur sa partie antisymétrique, $p = 0{,}19$). Si l'on ajoute au dénominateur des défaillances non propagées, le niveau moyen de p_{jk} tombe de 0,27 à 0,07, mais la part de direction $\|A\|/\|W\|$ reste à 60 %. Ce postérieur porte sur la documentation des transitions dans le corpus sélectionné ; l'absence de mention ne prouve pas l'absence de propagation. Le corpus suggère un ordre, sans en fixer l'intensité.

7.7 Biais de narration

Onze des vingt-deux transitions codées partent de P_1, ce qu'une convention de cause racine pourrait produire. Nous chiffrons ce biais par une loi nulle exacte, obtenue par convolution, et par une borne adverse sur les 2^{11} sous-ensembles d'arêtes partant de P_1. Le jackknife retire successivement chaque rapport ; le signal ne tient pas à un rapport isolé.

Hypothèse sur les 11 **arêtes de** P_1	**Reste**	p **exacte**
Aucune (corpus tel qu'il est codé)	22 transitions	$1{,}5 \cdot 10^{-5}$
4 arêtes *retournées*, pire configuration	22 transitions	**0,084**
Les 11 arêtes *retirées*	11 transitions	0,0039
Les 7 *rapports* concernés retirés	3 transitions	0,50

Il faudrait que la convention narrative ait inversé quatre des onze arêtes, dans l'agencement le plus défavorable, pour perdre la significativité. Retirer tout le rôle de la gouvernance, la moitié du corpus, ne suffit pas, car la direction subsiste dans les chaînes $P_3 \to P_2$ et $P_4 \to P_2$, où P_1 ne figure pas. Retirer les sept rapports entiers écarte aussi des chaînes que le biais ne concerne pas.

En capital, nous dégradons l'émission de P_1 par $W_{1k} \to (1 - a)\, W_{1k}$ et recalculons la bande à chaque degré, avec la cascade indépendante des calculs d'entité. Le besoin extrapolé de l'entité notionnelle (§9.6) passe de 24,1 à 15,0 M€ lorsque les transmissions depuis P_1 sont annulées (−37,7 %). Ce déplacement de 9,1 M€ représente 0,78 fois la largeur de la bande d'identification, 11,7 M€, de sorte qu'admettre l'objection dans toute son ampleur coûte moins que l'ignorance directionnelle déjà publiée. Le pilier à remédier en premier passe toutefois de P_1 à P_4 dès $a = 0{,}50$. L'écart entre états de conformité descend de +83,0 % à $a = 0$ à +40,6 % à $a = 1$ sans s'annuler, car la conformité agit par g sur toutes les arêtes.

7.8 Formalisation bayésienne

Nous exploitons le même matériau dans un cadre bayésien, en posant un lien, que la donnée ne permet pas de vérifier, entre la fréquence d'une chaîne dans les rapports et le sens de la propagation. Pour chaque paire $\{lo, hi\}$ de piliers, on note θ la probabilité qu'une chaîne documentée aille de lo vers hi, reliée au coefficient antisymétrique par

$$A_{lo,hi} \;=\; S_{lo,hi}\,(2\theta - 1),$$

bijection croissante de $[0, 1]$ sur l'intervalle admissible $[-S_{lo,hi}, +S_{lo,hi}]$ du chapitre 8. Les indices lo et hi désignent les deux piliers par indice croissant. Les paramètres α_0, β_0 règlent l'a priori ; $\mathcal{B}$in est la loi binomiale des comptages de sens. Avec n_{lo} chaînes de lo vers hi et n_{hi} dans l'autre sens,

$$\begin{aligned} &\theta \sim \mathrm{Beta}(\alpha_0, \beta_0), \qquad n_{lo} \mid \theta \sim \mathcal{B}\mathrm{in}(n_{lo} + n_{hi},\, \theta) \\ \Longrightarrow \qquad &\theta \mid \text{données} \;\sim\; \mathrm{Beta}\big(\alpha_0 + n_{lo},\; \beta_0 + n_{hi}\big). \end{aligned} \tag{7.5}$$

Les quatre paires que le corpus ne documente pas gardent sous $\mathrm{Beta}(1, 1)$ un θ uniforme, donc un coefficient qui couvre tout l'intervalle admissible. Le postérieur reproduit l'identification partielle sans la poser. Le capital devient une loi, dont l'intervalle de crédibilité à 90 % est 81 % plus resserré que les bornes de pire cas (bornes du chapitre 8). Sous un prior sceptique, la médiane bouge à peine, mais seules deux des six paires documentées ont un intervalle de crédibilité à 90 % qui exclut $\theta = 1/2$. Nous retenons les bornes et publions l'intervalle à titre informatif.

7.9 Frontière d'identification

Objet	Ce que la donnée établit	Posture retenue
Structure (P1 amont, P2 aval)	17 transitions sur le corpus initial et 22 sur le corpus étendu, aucune à contre-sens, $z = +3{,}9$ puis $+5{,}1$; accord de la structure avec le classeur d'expert, non des coefficients ($\rho = +0{,}08$) ; codeur unique	**revendiquée**, avec son confondant déclaré
Direction paire par paire	2 paires sur 6 seulement ont un intervalle de crédibilité concluant	**non revendiquée** ; les bornes restent
Amplitude des coefficients	aucune information ; même les dix sens connus, une bande de 656 M€ subsisterait	**non identifiable** par cette voie

Le corpus ne calibre pas W. Le chapitre 8 explore les directions, puis la section 10.8 chiffre l'intérêt conditionnel d'un registre.

8

Identification partielle et bornes de capital

Nous faisons varier le sens des liens à fréquence, sévérité et partie symétrique fixées. Le diagnostic utilise la cascade indépendante du tableau 5.1, avec son calage propre. La chaîne reste incident, perte, somme annuelle, quantile. La plage des quantiles ainsi obtenus, conditionnelle aux liens posés, ne constitue pas un intervalle de confiance.

8.1 Modèle en couches

Le socle, indépendant de W, regroupe la fréquence d'entrée surdispersée, l'accumulation par cause commune et la sévérité GPD. Sans contagion ($W = 0$), le besoin de capital est de 5 275 M€ dans le calage de référence (sévérité OpRisk, fréquence de l'état conforme, gain de propagation $g = 0{,}90$).

Nous séparons la force commune que nous maintenons fixe et le sens que nous faisons varier. Cela revient à décomposer la matrice de façon unique :

$$W \;=\; S + A, \qquad S = \tfrac{1}{2}(W + W^{\top}), \qquad A = \tfrac{1}{2}(W - W^{\top}).$$

Le signe de A_{jk} indique le sens dominant de la paire : positif pour $j \to k$, négatif pour $k \to j$. Sous amorce uniforme et faible intensité, les co-occurrences renseigneraient S au premier ordre, sans identifier A (proposition 5.7). Faute de panel, S vient du barème d'expert et seul A varie, dans l'ensemble admissible

$$\mathcal{W}(t) \;=\; \big\{\, S + A \;:\; A^{\top} = -A,\;\; |A_{jk}| \le t\, S_{jk},\;\; \rho(S + A) < 1 \,\big\},$$

où la contrainte $|A_{jk}| \le S_{jk}$ découle des conditions de positivité $W_{jk} \ge 0$ et $W_{kj} \ge 0$. Le paramètre $t \in [0, 1]$ est un rayon d'ambiguïté posé qui limite l'asymétrie admise, l'ignorance totale $t = 1$ correspondant aux sources publiques actuelles. Pour chacune des 10 paires de piliers, A_{jk}/S_{jk} varie donc entre $-t$ et t : les contraintes de signe définissent un pavé, intersecté avec la contrainte spectrale. Ses $2^{10} = 1\,024$ sommets fixent chaque paire à un extrême : la force totale de la paire est conservée, mais placée entièrement dans un sens. Pour chacun, nous construisons W, contrôlons son admissibilité, calculons la loi des ensembles de piliers atteints, puis simulons les pertes annuelles et leur quantile. Les sommets recensent des directions extrêmes de liens, pas des permutations ou des trajectoires d'incidents.

8.2 Capital sur l'ensemble admissible

La plage calculée aux sommets va du minimum au maximum sur les sommets admissibles, notés $V(1)$. $\widehat{B}$ désigne le quantile estimé par simulation. Ces extrema ne constituent pas des bornes globales démontrées sur $\mathcal{W}(1)$. À $t = 1$, on obtient

$$\left[\min_{W\in V(1)} \widehat{B}(W),\ \max_{W\in V(1)} \widehat{B}(W)\right] \;=\; [\,6\,858\ ;\ 8\,697\,]\ \text{M€},$$

avec un facteur 1,27 entre les deux bouts. La contagion ajoute entre +30 % et +65 % au socle. Le point d'expert, 8 110 M€, n'est qu'un point de cet ensemble (figure 8.1).

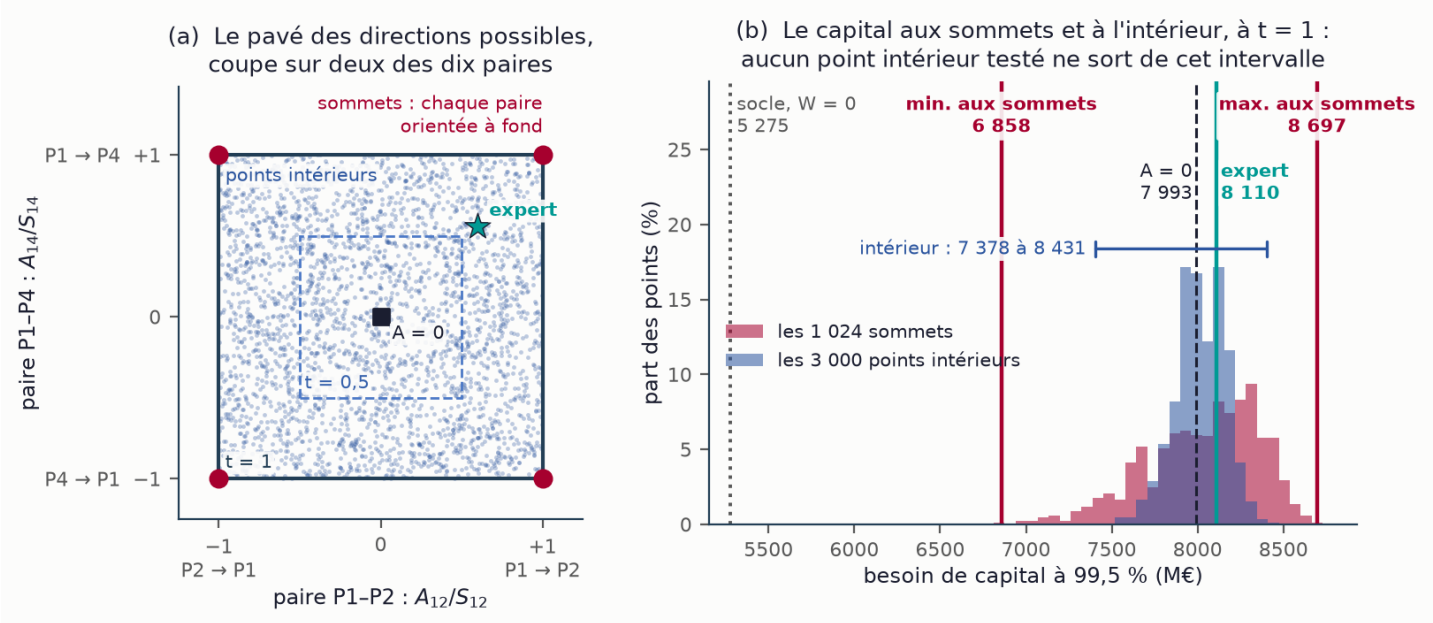


Figure 8.1. Le pavé admissible et le capital qu'il donne. (a) Coupe sur deux des dix paires : A_{jk}/S_{jk} va de -1, tout de k vers j, à $+1$, tout de j vers k. (b) Capital aux 1 024 sommets et aux 3 000 points intérieurs, à $t = 1$: aucun point intérieur testé ne sort de l'intervalle des extrema aux sommets.

Les sommets ne bornent le capital que si les extrêmes y sont atteints, ce que rien ne garantit *a priori*. Augmenter A_{jk} élève W_{jk} mais abaisse W_{kj}, si bien que la réponse n'est pas monotone en A_{jk}. Les 3 000 points intérieurs tirés uniformément restent tous dans cette plage, en VaR comme en perte moyenne.

Une recherche de contre-exemples n'en trouve pas : la perte moyenne lissée est un polynôme de degré deux en chaque coordonnée, et 172 ascensions depuis des sommets et des points intérieurs finissent toutes sur un sommet. Cette propriété reste vérifiée numériquement, mais non démontrée. Ces extrema numériques sont des quantiles de 40 000 années simulées. À indice de queue élevé, la VaR est peu sensible à la structure de cascade, la queue annuelle étant dominée par une perte unique. La perte moyenne, bornée dans [849 ; 1 100] M€ et moins bruitée, et l'ordre de remédiation en rendent mieux compte.

Le recalcul des 1 024 sommets sur quatre graines donne des largeurs de 1 461 à 1 871 M€, de moyenne 1 739 et d'écart-type 189 M€. Les écarts-types des minima et maxima sont respectivement

166 et 186 M€. Chaque graine sélectionne à nouveau les extrema sur toute la grille ; leurs matrices changent. Ces dispersions mesurent le bruit de Monte-Carlo à paramètres fixés, sans constituer un intervalle de confiance de calibration. Les quatre répétitions ne suffisent pas à estimer finement ce bruit ; la plage historique est conservée.

Ramener l'ignorance de $t = 1$ à $t = 0{,}5$, c'est-à-dire borner l'asymétrie à la moitié de la co-occurrence, réduirait la largeur de la plage de 1 839 à 695 M€, soit −62 %. Ce scénario donne l'ordre de grandeur de ce que le reporting de la section 10.8 permettrait de gagner, sans le garantir.

8.3 COMPARAISON D'UNE MATRICE POSÉE ET DE L'IDENTIFICATION PARTIELLE

	Régime A : on pose W	**Régime B : modèle en couches**
Sortie sur le capital	un point, 8 110 M€	socle : 5 275 ; capital total aux sommets : [6 858 ; 8 697]
Part insensible au sens	aucune, tout repose sur le classeur	79 % (socle 61 %, plancher commun aux sommets 18 %), à S posé
Panel biaisé	déplace le besoin de capital de 777 M€	la bande ne bouge pas si S reste fixé
Priorité de remédiation	P1, sans marge d'erreur	tête P1/P4, ordre interne ouvert
Si aucun expert ne répond	plus de matrice complète	exploration conditionnelle au S d'expert maintenu

Faire varier la direction posée à dire d'expert, depuis un panel qui confirmerait le classeur jusqu'à un panel qui dirait l'inverse au bord du pavé admissible, déplace le besoin de capital du régime A de 777 M€, soit 10 %. La priorité bascule alors entre trois piliers, sans signal pour l'utilisateur. La bande du régime B ne bouge pas à S fixé. Le regret d'une remédiation est son gain manquant par rapport au meilleur choix sous une même matrice ; le minimax retient le plus petit regret maximal parmi les matrices testées.

Sur 150 matrices admissibles tirées au hasard, P5 n'arrive jamais en tête, P3 dans moins de 10 % des cas, et P1 (45 %) et P4 (36 %) concentrent 81 % des tirages. Un panel d'experts servirait donc à départager P1 et P4 et à resserrer la bande ; le questionnaire diffusé est resté sans réponse.

8.4 NIVEAUX ET RAPPORTS DE CAPITAL

Calibration	**socle**	**bornes**	**haute/socle**	**% insensible au sens**
Référence (OpRisk)	5 275	[6 858 ; 8 697]	1,65	78,9 %
Sévérité PRC	239	[336 ; 424]	1,77	79,2 %
Fréquence ×3	11 709	[14 353 ; 17 405]	1,49	82,5 %

La borne haute explorée varie d'un facteur 41 entre PRC et fréquence triplée, sans rapport uniforme entre tous les niveaux de capital. Les rapports varient d'au plus 33 % de leur moyenne. Le moins stable, largeur de bande sur socle (32,9 %), diminue quand la fréquence augmente : la queue annuelle

est alors moins dominée par une perte unique. Les trois calibrations conservent l'ordre de grandeur des rapports au socle et P1 et P4 en tête, non le niveau du capital (figure 8.3).

8.5 Échelle de repli sur la direction

On peut écrire la direction par l'excès de propagation propre à la source, logit p_{ij} = logit $p_j + u_{ij}$ (p_j mesure l'attractivité de la cible j), puis limiter u par structures successives, jusqu'à la variante sans asymétrie où $u = 0$. Une direction de rang 1 capte 74 % de la variance de la direction posée et resserre les bornes de 25 %, au prix d'une hypothèse de structure. Elle n'a qu'un facteur de source et un facteur de cible, donc une seule valeur singulière non nulle de u (figure 8.2b). Sans asymétrie, P1 et P4 deviennent indiscernables (gains de remédiation 1 051 contre 1 052 M€), alors que 353 M€ les séparent avec la direction du barème d'expert. C'est donc la direction qui départage les deux piliers prioritaires.

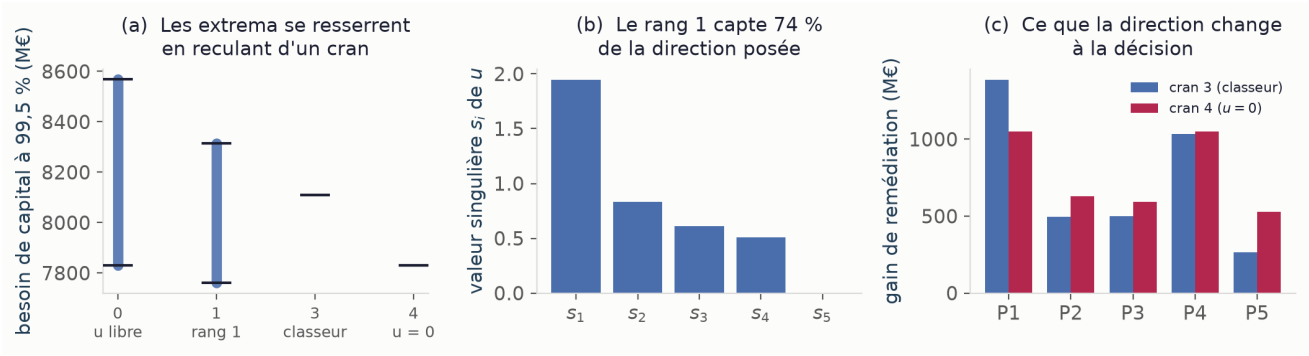


Figure 8.2. Échelle de repli sur la direction. (a) Les extrema du capital aux sommets se resserrent quand la structure est restreinte : u libre, rang 1, barème d'expert, puis absence d'asymétrie ($u = 0$). (b) Valeurs singulières de la direction posée : le rang 1 en capte l'essentiel. (c) Gains de remédiation par pilier avec la direction du barème d'expert et sans asymétrie.

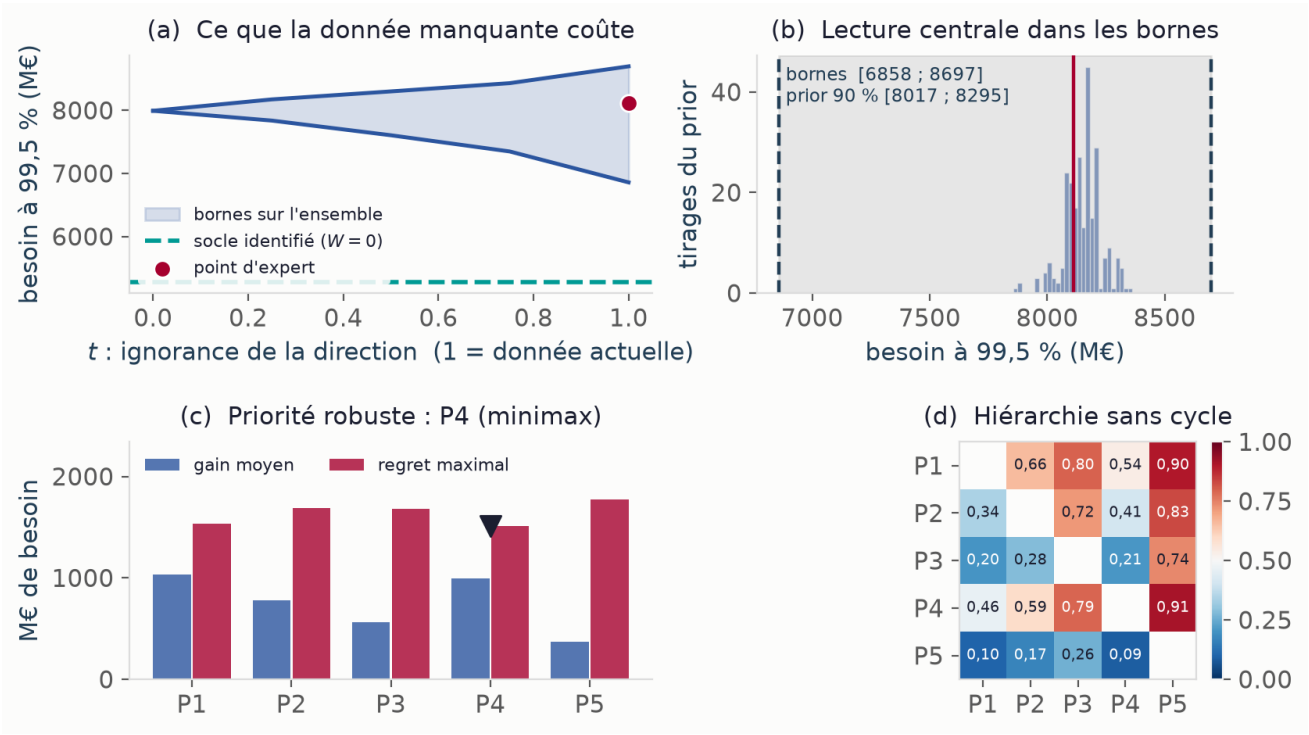


FIGURE 8.3. Identification partielle de la contagion dirigée. (a) Les bornes se resserrent quand l'ignorance directionnelle t diminue. (b) Le prior d'expert dans des bornes indépendantes du choix de direction, conditionnelles à la partie symétrique posée. (c) Priorité de remédiation (regret maximal). (d) Dominance des piliers sur des matrices admissibles tirées : P5 n'y arrive jamais en tête, et P1 et P4 concentrent 81 % des matrices testées.

Cette plage exprime ce que le sens des liens change, à force fixée, dans la cascade indépendante. Les écarts entre états du chapitre 9 reposent sur la marche auto-évitante et ses canaux ; ils ne se déduisent pas de cette plage.

9

Résultats

Pour chaque état de conformité, le moteur fixe quatre paramètres : la fréquence λ, la probabilité de dépassement p_u, le gain de propagation g et la probabilité de choc commun ω (chapitre 6). Il tire les incidents, les piliers atteints et leurs pertes, puis calcule le quantile à 99,5 % de la somme annuelle. Les comparaisons utilisent le même moteur, les mêmes graines et la même loi de sévérité de base dans le scénario principal ; les calculs d'entité emploient le protocole distinct du §9.5.

Trois lectures doivent accompagner le résultat : l'écart entre états quand les quatre canaux changent ensemble (§9.1), son déplacement quand on change le coût d'un incident (§10.7.1) et son incertitude de calibration (§10.7.2). Les attributions et les cas d'usage se lisent sous ces conditions. Les montants concernent le périmètre financier étudié : leur niveau varie d'un facteur 41 selon sévérité et fréquence, contre au plus 33 % de leur moyenne pour les rapports au socle (chapitre 8). Nous comparons OpRisk ($\hat{\xi} = 0{,}595$) et PRC ($\hat{\xi} = 1{,}03$), plafonnée à 40 M€ par perte élémentaire.

9.1 Besoin de capital par état de conformité

Scénario principal et remédiations partielles

La comparaison principale modifie les quatre canaux. Les autres lignes reprennent des protocoles partiels : le score seul garde g au niveau NC ; les combinaisons à deux et trois canaux correspondent aux lectures B et C du tableau 9.1. Ces niveaux ne sont pas les configurations intermédiaires du calcul à quatre canaux. À trois canaux, l'état conforme vaut 5 932 M€ ; à quatre canaux, 6 049 M€. Ces deux états conservent une contagion, ce qui les distingue du socle 5 275 M€ calculé sans contagion au chapitre 8.

Lecture (besoin à 99,5 %, M€, états posés)	**canaux**	**conforme**	**non conf.**	**facteur**
Score de conformité seul, g figé au niveau NC	1	7987	16 847	2,11
Fréquence + propagation (lecture B)	2	6664	15 074	2,26
+ détection (lecture C)	3	5932	16 595	2,80
+ accumulation P4 (les quatre canaux)	**4**	**6049**	**20 188**	**3,34**

Pour le périmètre financier étudié, la lecture à quatre canaux donne 6 049 → 20 188 M€, soit un facteur 3,34 et un écart de 14 139 M€ : écart-type 734 M€ entre quatre graines, erreur type de la moyenne 367 M€. Le score seul diffère de la lecture à fréquence variable (A) du tableau 9.1. Les lectures B et C excluent le choc commun P4. La détection ajoute 2 928 ± 343 M€ en Shapley,

4 562 ± 819 en fermeture (figure 9.1), signe constant sur seize graines. Le facteur compare deux états posés, sans mesurer un effet causal de DORA. Toute remédiation partielle s'évalue depuis l'état de départ, avec ses interactions.

Détail des lectures partielles

Le tableau 9.1 distingue la fréquence variable seule (A), l'ajout de la propagation (B), puis de la détection (C). Le besoin augmente de l'état conforme à l'état non conforme dans chaque lecture. Les lettres renvoient uniquement à ces combinaisons de canaux.

	OpRisk (M€)			**PRC** (M€)		
État	Fréq.	+ prop.	+ dét.	Fréq.	+ prop.	+ dét.
Conforme	8301	6664	5932	2589	1903	1642
Partiellement conforme	11059	9625	9625	3653	3118	3118
Non conforme	15074	15074	16595	5520	5520	6577

TABLEAU 9.1. Besoin de capital par état, trois lectures (A : fréquence ; B : + propagation ; C : + détection), sans le canal d'accumulation. Le canal détection ne joue qu'aux extrêmes (il abaisse l'état conforme et relève le non conforme), l'état partiel n'étant pas modulé.

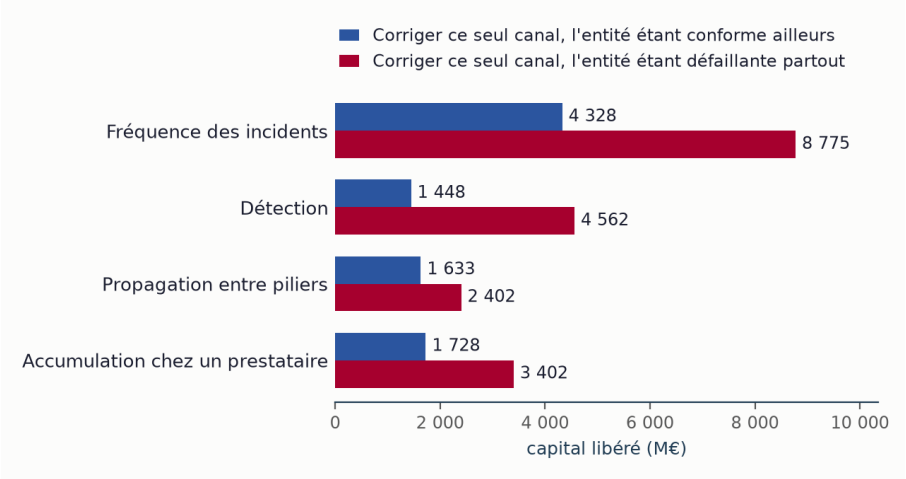


FIGURE 9.1. Capital libéré par la correction d'un seul canal, selon que l'entité est déjà conforme sur les trois autres canaux (effet isolé) ou défaillante partout (effet de fermeture), en M€ à l'échelle du secteur.

Les protocoles reposent sur des bases différentes. Du score seul à la combinaison fréquence et propagation, l'écart passe de 8 860 à 8 410 M€ alors que le facteur monte, la base conforme passant de 7 987 à 6 664 M€. Les canaux se multiplient presque, le produit des quatre facteurs isolés étant de 3,47 pour un facteur publié de 3,34 (figure 9.2). Les quatre effets isolés somment à 9 138 M€ et l'écart de 14 139 les dépasse de 5 001, l'interaction. Elle correspond à ce que donnerait un produit des facteurs (5 813 M€ pour un modèle purement multiplicatif) plus qu'à un effet propre de la cascade (§C.4.3). Les trajectoires et la priorisation restent conduites en lecture B, car elles concernent l'ordre de remédiation, que le canal ajouté ne déplace pas.

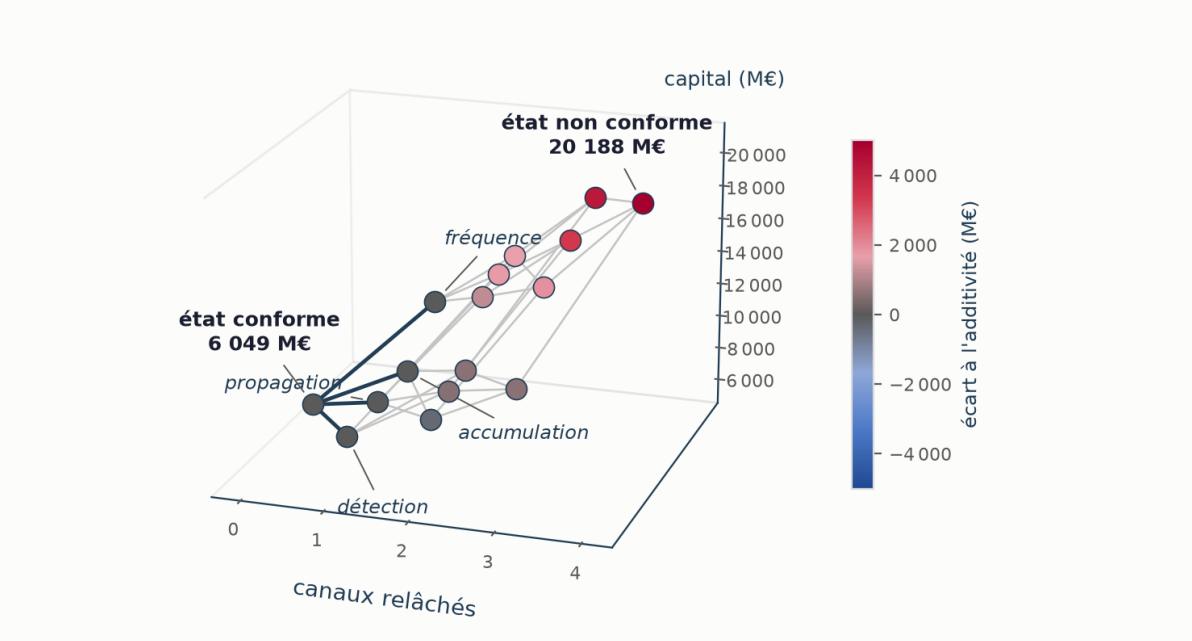


FIGURE 9.2. Les seize configurations des quatre canaux, rangées par nombre de canaux relâchés. La hauteur est le capital ; les deux extrémités sont les états publiés, 6 049 et 20 188 M€, et tout sommet intermédiaire est une remédiation partielle. Chaque arête monte. La couleur est l'écart à l'additivité, capital observé moins la somme des quatre effets isolés : +5 001 M€ au sommet complet, −330 sur la seule paire négative, propagation et accumulation. Le troisième axe sépare les configurations de même rang et ne porte aucune grandeur.

Nous obtenons le surcoût $\Delta_{\text{DORA}} = B(\text{NC}) - B(\text{C})$, à graine Monte-Carlo commune, par bootstrap à deux niveaux (multiplicateurs et sévérité), et 100 % des tirages sont positifs (tableau 9.2).

	médiane	IC90 %
Δ_{DORA} NC vs C (OpRisk)	6476	[2940 ; 47368]
Δ_{DORA} PC vs C (OpRisk)	2346	[1137 ; 13566]
Δ_{DORA} NC vs C (PRC)	3668	[3201 ; 4094]
Δ_{DORA} PC vs C (PRC)	1257	[1077 ; 1466]

TABLEAU 9.2. Surcoût de non-conformité (M€), lecture B, bootstrap deux niveaux. Côté OpRisk la sévérité de queue est ré-échantillonnée sur les 86 excès réels ; l'intervalle reste large parce que la queue l'est.

L'intervalle large côté OpRisk est la signature d'une queue d'indice 0,60, et le surcoût est positif dans tous les tirages. Il porte sur la lecture B. L'écart à quatre canaux est accompagné ici de sa dispersion entre graines (écart-type de 734 M€) ; le bootstrap conjoint de la section 10.7.2 traite son incertitude de calibration. Lorsqu'on réinjecte le résidu de la conversion de Jacobs (2014), 0,523 en logarithme, c'est-à-dire un facteur 2,4 à 90 % autour de la droite, l'intervalle PRC reste étroit et le niveau du surcoût bouge de 7 %.

9.2 DÉCOMPOSITION ET ALLOCATION PAR PILIER

Si l'on bascule un pilier à la fois de conforme à non conforme, le surcoût se décompose selon le classement $P1 > P4 > P2 > P3 > P5$, celui du classement ROOT du modèle qualitatif. Cet

accord est attendu et ne constitue pas une validation indépendante, car les amorces de la cascade sont semées selon ROOT, posé par le même expert que la matrice dont W est tirée (§5.3).

Les surcoûts isolés ne somment pas au surcoût total, la différence étant une interaction qu'un modèle sans propagation ne produit pas. Sur la VaR à 99,5 % OpRisk, son signe n'est pas résolu, de −137 à +1 395 M€ sur six graines de 60 000 années, positive quatre fois sur six. Elle est positive sur les six graines en perte moyenne, de +532 à +659 M€ côté OpRisk et +827 côté PRC, et dans la VaR du périmètre PRC, dont le plafond tronque la queue (+905 M€).

L'attribution par pilier exige donc une règle additive, la valeur de Shapley. Cette interaction entre piliers ne s'additionne pas à l'interaction de +5 001 M€ entre les quatre canaux, de signe résolu (§C.4). Elles décomposent l'écart selon deux axes, les piliers et les canaux, et l'attribution par pilier se lit sur le protocole du tableau 9.3.

Shapley répartit l'écart de capital entre les piliers dont la non-conformité est modifiée, en incluant les interactions. Euler, dans le calcul retenu ici, répartit la perte moyenne au-delà du quantile entre les piliers touchés ; ses contributions somment à cette moyenne de pertes extrêmes. Ces deux lectures portent sur des objets distincts et ne fournissent pas le même budget de remédiation.

9.2.1 Attribution par Shapley

On munit les piliers d'une fonction caractéristique

$$v(S) \;=\; B\big(S \text{ en NC},\ \text{reste C}\big) - B(\text{tous C}), \qquad S \subseteq \{P1, \ldots, P5\},$$

calculée par la cascade sur les 2^5 configurations à graine Monte-Carlo commune. La valeur de Shapley

$$\varphi_j \;=\; \sum_{S \subseteq \{P1,\ldots,P5\} \setminus \{j\}} \frac{|S|!\,\big(5 - |S| - 1\big)!}{5!}\,\big[v(S \cup \{j\}) - v(S)\big]$$

moyenne la contribution de j sur tous les ordres d'arrivée. Ici S est une coalition de piliers et $|S|$ son effectif ; ce S diffère de la partie symétrique de W. Ainsi $\sum_j \varphi_j = v(\text{tous}) = \Delta_{\text{DORA}}$ (Shapley, 1953). Son emploi en allocation de capital remonte à Denault (2001), et son usage actuariel sous Solvabilité II est documenté (Decupère, 2011). Avec cinq piliers, on énumère les 5! ordres, sans les algorithmes par échantillonnage (Castro et al., 2009 ; Song et al., 2016). Le tableau 9.3 en donne les valeurs.

	OpRisk			PRC		
pilier	marginal	φ_j	part	marginal	φ_j	part
P1 gouvernance	3481	3717	34,0 %	1375	1608	32,4 %
P4 tiers	2658	2810	25,7 %	1075	1252	25,3 %
P2 incidents	1634	1867	17,1 %	721	920	18,6 %
P3 tests	1094	1484	13,6 %	571	738	14,9 %
P5 partage	665	1048	9,6 %	311	438	8,8 %
somme	9531	10 927	100,0 %	4052	4957	100,0 %

TABLEAU 9.3. Valeur de Shapley du surcoût Δ_{DORA} (M€, périmètre financier étudié, trois canaux : fréquence, propagation, détection ; base conforme 6 085 du moteur par pilier, qui s'écarte de quelques pour cent de la lecture C du tableau 9.1).

Le classement de Shapley reproduit le classement ROOT sur les deux périmètres, en partie mécaniquement, les amorces étant semées selon ROOT (parts 30/27/18/15/9 %). La part de P1, 34 %, excède toutefois sa part d'amorce de 30 %, ce qui traduit l'effet propre de la propagation, P1 étant l'émetteur le plus fort de W.

9.2.2 Allocation par Euler

La règle d'Euler (Tasche, 1999) calcule $C_j = \mathbb{E}\big[L_j \mid L \geq \text{VaR}_{99,5\,\%}\big]$, où L_j est la perte annuelle attribuée au pilier j, avec $L = \sum_j L_j$. Ces contributions somment à $\text{TVaR}_{99,5\,\%}(L)$ et non au quantile : c'est une allocation de la moyenne de queue, lue comme diagnostic de la localisation du capital. Côté PRC, l'allocation est stable et presque plate (P2 23 %, P4 23 %, P1 20 %, P3 18 %, P5 17 %), le plafond de sévérité tronquant la queue (TVaR = 6 795 ≈ VaR = 6 573 M€). Côté OpRisk, les parts moyennes sont stables, mais l'allocation de la queue extrême ne l'est pas. En effet, avec $\xi \approx 0{,}6 > 0{,}5$, la sévérité est de variance infinie et le classement conditionnel bascule d'une résolution de simulation à l'autre. Nous retenons donc l'allocation du périmètre PRC.

Le besoin de capital publié est partout le quantile $\text{VaR}_{99,5\,\%}(L)$ non centré, la perte attendue d'une non-conformité n'étant pas couverte par une provision. Aucune grandeur de couverture n'est une TVaR. La mesure de queue ne sert qu'au diagnostic, à deux titres. Elle sert d'abord de base à l'allocation d'Euler, qui répartit la TVaR et non le quantile. Elle indique aussi la forme de la queue, le rapport $\text{TVaR}_{99,5\,\%}(L)/\text{VaR}_{99,5\,\%}(L) \approx 2{,}1$ se comparant à son asymptote $1/(1-\xi) = 2{,}5$. Ce rapport est de 2,10 à l'état tous non conforme et de 2,17 sur la calibration de référence. Sous la calibration PRC non plafonnée, $\hat{\xi} = 1{,}033 > 1$ rend l'espérance infinie : la mesure de queue n'existe pas et ne peut fonder un besoin de capital. L'allocation du périmètre PRC porte sur la sévérité plafonnée, dont les moments sont finis.

9.3 TRAJECTOIRE DU CAPITAL ET ORDRE DE REMÉDIATION

Le long de la mise en conformité, en lecture B, le capital OpRisk passe de 10 752 à 7 041 M€ en cinq ans, vers le besoin de l'état conforme. La trajectoire part d'une répartition supposée des

états (NC 35 %, PC 35 %, C 30 %). Le surcoût résiduel tend vers zéro, et son intégrale, à un coût de capital près, est le coût de portage de la non-conformité pendant la remédiation. La bande à 90 % reste haute en environnement dégradé, scénario où le capital importe le plus.

Sous budget contraint, un pilier remédié à la fois, nous énumérons les 120 ordres, dont l'optimal, $P1 \to P4 \to P2 \to P3 \to P5$, est égal à l'ordre ROOT et distinct de l'ordre glouton par valeur d'accélération. L'écart de capital intégré entre le pire ordre et l'optimal atteint 21 %. Remédier au coup par coup le pilier au plus fort gain immédiat coûte plus cher, car les interactions de cascade imposent de raisonner sur l'horizon entier.

Le test de résistance inverse fixe le capital et cherche les états qui le produisent, la monotonie du §C.4 rendant croissant l'ensemble des configurations atteignant une cible, donc décrit par ses éléments minimaux. Le canal de fréquence seul atteint 10 377 M€, soit 1,72 fois l'état conforme, et les trois autres canaux réunis n'atteignent que 11 413 (1,89 fois). Toute cible sous le premier seuil se produit par un canal unique, et toute cible au-dessus du second exige la fréquence. Aucun autre canal seul n'atteint 8 000 M€ (§C.4.3).

9.4 Comparaison aux copules et à la Formule Standard

Comme la cascade remplace l'agrégation par copule d'un modèle LDA, nous la confrontons à des modèles à copule de mêmes marges par pilier, à graines communes, sur le périmètre OpRisk. À corrélation calée, la copule gaussienne retombe sur le besoin de capital de la cascade (+0,1 % sur une graine, +4,8 % en moyenne sur quatre, sous son propre bruit). En queue lourde, le quantile annuel tient à la perte unique dominante, et le niveau n'identifie pas la dépendance. La Student ($\nu = 4$) le surestime de 17 % en forçant des co-extrêmes que la cascade ne produit pas (2,28 piliers extrêmes par année de queue contre 1,12). Le préprint de cascade climatique (Karimi et al., 2026) emploie le même protocole.

Basculer un pilier en non-conformité est cependant une intervention. Le comparateur construit ici garde la même matrice de corrélation dans tous les états ; il donne un surcoût inférieur de 38 %, 6 760 M€ contre 10 927 pour la cascade, faute de mécanisme de propagation dans cette spécification. Une copule dont la dépendance varierait avec l'état n'a pas été testée. Son interaction moyenne est nulle par construction, tandis que la cascade en produit +560 M€. La priorité qu'il implique s'inverse sur P2 et P3. Sa dépendance ne durcit pas non plus lorsque la conformité se dégrade, alors que c'est le canal de propagation que la non-conformité déplace (g de 0,45 à 0,90).

Sur le même écart de capital entre profil conforme et profil non conforme, trois cadres expriment des fractions différentes de l'effet de la conformité (tableau 9.4).

Cadre	Δ capital C→NC	part de l'effet cascade
Formule Standard (Solvabilité II)	0 M€	0 %
LDA-copule gaussienne figée (comparateur)	6 760 M€	62 %
Cascade dirigée	10 927 M€	100 % (référence)

TABLEAU 9.4. Fraction de l'effet DORA que chaque cadre sait exprimer (périmètre financier étudié, trois canaux, accumulation exclue, protocole du tableau 9.3).

La charge de risque opérationnel de l'équation (1.1) ne dépend que du volume. Elle est identique pour une entité exemplaire et pour une entité défaillante sur DORA. Le comparateur à copule figée restitue 62 % de l'écart simulé, par les canaux fréquence et détection, mais pas la propagation. Ce rapport caractérise cette spécification, non l'ensemble des modèles à copule.

9.5 MÉTHODE DE DESCENTE À L'ÉCHELLE D'UNE ENTITÉ

La descente d'échelle (*downscaling*) adapte le nombre d'incidents et le montant des pertes aux actifs de l'entité, puis recalcule la distribution annuelle et son quantile. Les actifs mesurent ici la taille ; les fonds propres mesurent la capacité d'absorption. Le métier n'a pas de coefficient estimé. Pour l'entité notionnelle, le repère forfaitaire de la Formule Standard est d'environ 450 M€. Le socle sans contagion du périmètre financier étudié vaut 5 275 M€ ; les deux ne se comparent pas.

9.5.1 Calibration de référence sur les actifs

Au niveau du sinistre unique, le quantile de sévérité (663 M€) et sa moyenne de queue (1 752 M€) sont en revanche du même ordre que les grandes pertes cyber observées (1 288 à 2 208 M€). Les calculs d'entité changent de protocole : ils emploient la cascade indépendante de l'évaluateur du chapitre 8, sans choc commun P4, et seul le gain de propagation y varie entre états. À matrice W inchangée, une entité d'actifs A reçoit une fréquence et une sévérité lues à sa taille :

$$\begin{aligned} \lambda(A) &= \lambda_0\Big(\frac{A}{A_0}\Big)^{b_\lambda}, \qquad m(A) = \Big(\frac{A}{A_m}\Big)^{b}, \\ X &= m(A)\sum_{k\in S_a} Y_k, \qquad B(A) = \mathrm{VaR}_{99{,}5\,\%}\Big(\sum_{n=1}^{N} X_n\Big), \end{aligned} \tag{9.1}$$

où le panel est formé des firmes du secteur financier dont les actifs sont connus, sur 2005–2022, et de leurs pertes des sous-catégories liées aux systèmes d'information et aux prestataires. La fréquence y est ajustée par une binomiale négative à lien logarithmique sur les seules firmes de plus de 100 Md$ d'actifs (6 048 lignes, 1 402 firmes) : $b_\lambda = 0{,}494$ (erreur-type 0,066 par grappes de firmes), $A_0 =$ 570 Md$ est la moyenne géométrique de leurs actifs et λ_0 la fréquence à cette taille.

N suit cette binomiale négative de moyenne $\lambda(A)$, S_a est l'ensemble des piliers touchés depuis l'amorce a, et les Y_k sont les sévérités élémentaires : la GPD calibrée au-delà du seuil, un tirage parmi les 484 pertes observées sous le seuil sinon. A_m est la taille médiane des pertes retenues, $b = 0{,}087$ l'élasticité de la sévérité, d'où $m = 0{,}854$ à la taille de l'entité notionnelle. Cette élasticité

est estimée sur les pertes TIC du panel, corrigée de la troncature (§3.5) ; l'appliquer à la sévérité cyber-finance du modèle est une hypothèse de transfert, qui s'ajoute à son incertitude d'estimation.

Sur tout le panel, b_λ vaut 0,074 : la fréquence dépendrait à peine des actifs. Une firme y est observée de la première à la dernière année où elle apparaît dans la base, pour un risque quelconque. Les firmes de moins de 1 Md$ d'actifs le sont 1,44 an en moyenne, celles de plus de 100 Md$ 4,31 ans, ce qui rend plausible un biais de fenêtre. Il n'est pas démontré : 57,8 % des grandes firmes ne sont observées qu'un an, et une année sans événement enregistré n'est pas une année sans incident. L'exposant monte avec le seuil de taille : 0,139 au-delà de 1 Md$, 0,269 au-delà de 10 Md$, 0,494 au-delà de 100 Md$ et 0,513 au-delà de 300 Md$. À fenêtre d'au moins cinq ans, il vaut 0,223 sur tout le panel et 0,530 sur les grandes firmes ; un effet fixe d'année ne le déplace pas (0,497). Nous retenons la valeur à 100 Md$ comme variante privilégiée sous ces hypothèses ; elle est extrapolée aux entités plus petites, et c'est la réserve principale de cette lecture. La sévérité ne croît pas avec la taille : sur les 521 pertes dont les actifs sont connus, la pente de la perte sur la taille est de −0,07 (erreur-type 0,03), et elle reste négative parmi les firmes de plus de 50 Md$.

Cette lecture remplace, après le dépôt du rapport ENSAE, la lecture du registre et les deux conventions d'exposition de la version précédente. Elle lève le gel de la calibration pour la seule partie entité ; les résultats du périmètre financier ne changent pas. Avec l'exposant et le moteur de la version précédente, le même script redonne les 169,0 M€ publiés.

Lecture	λ (an^{-1})	sévérité	Besoin à 99,5 %	Perte moyenne
Périmètre financier étudié	21,56	×1	8 123 M€	983 M€
Seuil « ≥ 10 événements »	0,210	×1	488 M€	9,7 M€
Seuil « toutes firmes »	0,100	×1	229 M€	4,6 M€
Registre, λ lu à la taille de la cible	0,092	×1	198 M€	4,3 M€
Registre, deux canaux composés	0,092	×0,854	169 M€	3,6 M€
Lecture retenue	**0,021**	**×0,854**	**24** M€	**0,85** M€

Tableau 9.5. Comparaison des lectures d'échelle. Les lignes historiques adaptent la fréquence et l'échelle de sévérité ; celles du registre emploient l'exposant 0,074. La dernière réestime la fonction de fréquence et la dispersion sur les grandes institutions et inclut les pertes observées sous le seuil. Les lignes sont des lectures d'échelle, non des entités observées.

Diviser λ par 1 031 divise la perte moyenne par 1 158 et le capital par 336. Le chiffre d'entité est une bande, [15,8 ; 27,5] M€ sur les 1 024 sommets admissibles, qui ne traduit que l'ignorance de la direction. Un bootstrap par firme réestimant intercept, pente et dispersion donne [8,3 ; 53,0] M€, à sévérité et graine fixées ; la pente seule, à ±1,96 fois l'ancienne erreur-type hessienne de 0,043, donne [12,3 ; 41,9]. Aucune de ces bandes ne corrige la sélection du registre. Estimée au-delà de 300 Md$, la fréquence donne 20,6 M€. Les 24 M€ restent une extrapolation d'ordre de grandeur (§9.6).

La baisse depuis 169 M€ ne tient pas à l'exposant seul. Sur les huit combinaisons de fréquence, de dispersion et de pertes sous le seuil, à nombres communs et sur quatre graines, la nouvelle fréquence avec la dispersion précédente donne un quantile nul, une perte n'ayant lieu que dans 0,29 % des années. Entre les deux protocoles complets, le quantile passe de 171,4 à 24,6 M€ et la moyenne

des pires années de 624 à 177 M€ (169 et 24,1 sur une graine).

À cette fréquence, une perte n'a lieu que dans 2,06 % des années : le quantile à 99,5 % se lit près du seuil de queue. L'indice de queue, parcouru sur son intervalle à 90 % ($\xi \in [0{,}304\,;0{,}831]$), ne le déplace que de 24,1 à 24,2 M€, mais fait varier la moyenne des 0,5 % pires années de 105,4 à 256,2 M€ (155,9 au point).

Le gain de propagation pris à ses trois valeurs d'état (0,45, 0,68, 0,90) fait passer le besoin de capital de l'entité de 13,2 à 17,7 puis 24,1 M€. Le seul canal de propagation l'augmente ainsi de 83 % (figure 9.3, en lecture du registre). Le repère forfaitaire reste à 450 M€. Les correspondances testées entre état et g conservent le signe de l'écart (§6.4) ; cette vérification sur grille porte sur la cascade indépendante et ne démontre pas la monotonie du moteur de marche.

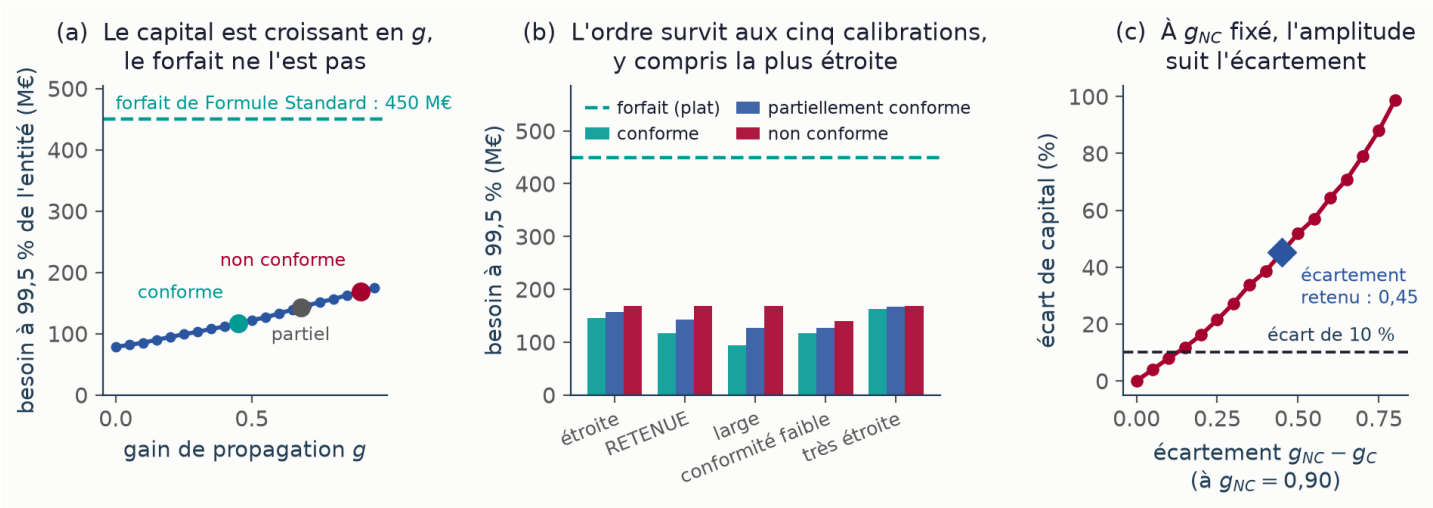


FIGURE 9.3. Capital d'entité et valeurs du gain de propagation g, en lecture du registre. (a) Le capital croît avec g, sur vingt points de grille à nombres aléatoires communs, quand la charge forfaitaire ne dépend pas de l'état. (b) Cinq correspondances entre état et g, de très étroite à large : toutes respectent l'ordre du capital, et le forfait reste plat. (c) À $g_{NC} = 0{,}90$ fixé, l'écart croît avec l'écartement $g_{NC} - g_C$; la valeur retenue est marquée, et elle seule relève du scénario.

9.5.2 Incident réel et incident enregistré

Une fréquence faible dans le registre peut venir d'incidents rares ou d'un enregistrement incomplet. Notons q_{obs} la probabilité qu'un incident du périmètre soit enregistré, supposée indépendante du montant. Avec une binomiale négative $\text{NB}(\mu, r)$ de moyenne μ et de forme r,

$$N_{\text{rel}} \sim \text{NB}\big(\mu/q_{\text{obs}}, r\big), \qquad N_{\text{enregistr}} \mid N_{\text{rel}} \sim \text{Binom}\big(N_{\text{rel}}, q_{\text{obs}}\big) \implies N_{\text{enregistr}} \sim \text{NB}(\mu, r). \quad (9.2)$$

La capture multiplie l'intensité du mélange Poisson–Gamma par q_{obs} sans changer r : plusieurs fréquences réelles donnent la même loi des comptes enregistrés, et le registre ne permet pas de choisir q_{obs}. Si la publication dépend du montant, capture et sévérité doivent être modélisées ensemble. Le rapport DORA sur les incidents majeurs (Autorités européennes de surveillance (ESAs), 2026) ne fixe pas non plus q_{obs} : un incident majeur s'y qualifie par son effet sur les services, sans perte monétaire comparable à celles de l'échantillon.

Ancrer cette fréquence demanderait une exposition effectivement suivie, par exemple les primes

d'un métier comme dans la segmentation de l'ACPR (Autorité de contrôle prudentiel et de résolution, 2025), et un historique interne combiné à celui des pairs par crédibilité (Shevchenko et Wüthrich, 2006). Avec un taux de loi a priori Gamma de paramètres (κ_h, ν_h) dans le métier h et n_i incidents enregistrés sur une exposition suivie H_i, la fréquence prévue pour une exposition e vaut $e\,(\kappa_h + n_i)/(\nu_h + q_{\text{obs}} H_i)$. Aucune de ces quantités n'est disponible ici, et la formule n'est pas appliquée.

9.6 Comparaison des entités et sensibilité à l'enregistrement

9.6.1 Comparaison à protocole de référence fixé

L'entité notionnelle est posée à 20 000 M$ d'actifs et 15 000 M€ de provisions. Les rapports SFCR de 2024 donnent les bilans et SCR des quatre assureurs comparés. Le tableau donne $B(A)$ de l'équation (9.1) au point d'expert et aux sommets admissibles, la moyenne des 0,5 % pires années, et le besoin de la lecture du registre pour comparaison. Le gain de propagation est supposé non conforme. Les entités sont désignées par leur classe : le modèle n'utilise que leur bilan. Le rapport du besoin ORSA au SCR publié sert de repère d'échelle.

Entité	**Actifs** M€	**SCR publié** M€	**Besoin retenu** M€	**Pires années** M€	**Registre** M€
Petite entité (posée)	500	–	nul	23	86
Assureur non-vie A	2 319	425	1,0 [1 ; 1]	51	112
Assureur non-vie B	5 305	812	4,7 [3 ; 5]	78	136
Entité notionnelle	19 231	–	**24,1** [**16** ; **28**]	156	169
Assureur vie C	37 845	1 587	47,8 [33 ; 54]	244	196
Assureur vie D	309 800	14 800	192,6 [156 ; 209]	591	294
Grand groupe (posé)	2 400 000	–	528,6 [437 ; 556]	1 326	398

Besoin retenu : quantile à 99,5 %, exposant $b_\lambda = 0{,}494$, point à la matrice d'expert et bande sur les 1 024 sommets admissibles. Pires années : moyenne des 0,5 % pires années. Registre : $b_\lambda = 0{,}074$, version précédente. État supposé : gain de propagation au niveau non conforme, autres paramètres à leur base. Nul : le quantile à 99,5 % est nul (taille de bascule, ci-dessous). Les tailles de la petite entité et du grand groupe sont posées.

Les quatre SCR sont publiés, les deux assureurs non-vie les donnant dans leur état S.25.01, à 425 et 812,5 M€. Seul le total d'actif de trois entités est déduit, par l'identité comptable, et l'approximation est conservatrice. Les mêmes états publient également le module de risque opérationnel. Le repère de 3 % des provisions donne 54,1 contre 59 publié sur la première entité non-vie, et 62,1 contre 39,7 sur la seconde, soit −8 % et +56 %. Ce repère n'est donc qu'un ordre de grandeur, jamais une borne.

La lecture du registre faisait peu varier le besoin avec les actifs : un facteur 134 sur la taille le multipliait par 2,6. La lecture retenue le multiplie par 194 entre l'assureur non-vie A et l'assureur vie D, et la moyenne des pires années par 11,7. Ce facteur ne valide rien : il dépend de la position du quantile près de la masse en zéro. Rapporté au SCR publié, le besoin vaut 0,2 %, 0,6 %, 3,0 % et 1,3 % de A à D. L'écart entre états subsiste, de +36 % à +85 %.

Le quantile à 99,5 % est nul lorsque la probabilité annuelle d'une perte est inférieure à 0,5 %. Toute perte d'incident étant positive, cette probabilité vaut $1-(r/(r+\lambda))^r$, d'où une taille de bascule de 1 076 M€ d'actifs, entre 1 053 et 1 145 en simulation sur quatre graines et entre 100 et 3 889 sous

le bootstrap par firme : un ordre de grandeur. Juste au-dessus, le quantile reste porté par les pertes courantes : 1,0 M€ pour l'assureur non-vie A, dont la probabilité annuelle de perte est de 0,74 %, et nul dans 18 % des tirages du bootstrap. Ce besoin quasi nul ne signifie pas l'absence de risque. Le risque d'une petite entité se lit mieux par la moyenne des pires années, qui croît régulièrement avec la taille (élasticité de 0,39 à 0,66 entre entités voisines). Cette bascule ne définit pas le domaine de validité statistique du modèle.

Au levier médian (10,0 %), le SCR de l'entité notionnelle serait de 1 932 M€ et le besoin en représenterait 1,2 %. Ce critère de poids ne définit pas une validité statistique.

La réserve d'extrapolation vient de deux sources. L'exposant de fréquence, estimé au-delà de 100 Md$, est appliqué à des entités plus petites. L'échelle de la sévérité est adaptée à la taille, mais sa forme reste celle de grandes institutions financières. Les 24 M€ ne constituent donc pas un majorant établi. Pour une entité, il faut comparer les lectures d'exposition et les écarts entre états ; un montant unique ne suffit pas. Un rapport entre états élimine une erreur d'échelle commune à leurs pertes, mais pas une erreur affectant différemment les états. Ceux-ci restent supposés.

La fréquence ne dépend ici que des actifs : deux entités de même taille reçoivent le même besoin, quel que soit leur métier. Un indicateur tiré des événements, la ligne de métier bâloise la plus fréquente de la firme, donne aux assureurs une fréquence enregistrée 2,6 fois plus faible à taille égale (effet −0,961, erreur-type 0,207), avec un gain hors échantillon par firme. Il peut traduire une moindre déclaration autant qu'un moindre risque. Nous ne l'intégrons pas ; il ramènerait l'entité notionnelle à 4,5 M€ et l'assureur vie D à 77,9 M€. Enfin, les 443 pertes de sévérité de 2005–2022 sont un sous-ensemble des 1 476 événements comptés en fréquence, qui couvrent des catégories plus larges (§3). La calibration sur les grandes institutions vise donc à réduire l'effet des fenêtres d'observation courtes ; son extrapolation aux petites entités reste à valider, et le métier n'est pas intégré.

9.6.2 Sensibilité à l'enregistrement

Appliquée à trois entités, sévérité et cascade inchangées, l'équation (9.2) donne la sensibilité à une capture de moitié, scénario et non estimation (moyennes sur quatre graines de 600 000 années, gain de propagation non conforme). La VaR passe de 0,9 à 8,9 M€ pour l'assureur A, de 23,1 à 74,0 M€ pour l'entité notionnelle et de 193,5 à 349,1 M€ pour l'assureur vie D ; la moyenne des pires années de la notionnelle passe de 160,6 à 282,4 M€. La loi des comptes enregistrés est la même dans les deux cas. La fréquence du périmètre financier vient du même registre : une capture incomplète la sous-estimerait aussi, et ne l'appliquer qu'aux entités fausserait la comparaison entre les deux échelles. À capture complète, ces valeurs retrouvent la référence au bruit près (23,1 contre 24,1 sur une graine).

9.7 AGRÉGATION AU CAPITAL TOTAL

Le SCR opérationnel s'ajoute au BSCR (§1.6). Pour un écart D, nous comparons deux conventions ORSA hypothétiques : addition intégrale ou agrégation avec le BSCR à corrélation ρ. Leur

application exige d'éviter le double compte du risque informatique déjà couvert.

$$\Delta\mathrm{SCR}_{\text{additif}} = D, \qquad \Delta\mathrm{SCR}_{\rho} = \sqrt{\mathrm{BSCR}^2 + 2\rho\,\mathrm{BSCR}\,D + D^2} - \mathrm{BSCR} = \tau(\rho, d)\,D, \tag{9.3}$$

$$\tau(\rho, d) = \frac{\sqrt{1 + 2\rho d + d^2} - 1}{d} = \rho + \frac{d}{2}\left(1 - \rho^2\right) + O(d^2), \qquad d = \frac{D}{\mathrm{BSCR}}. \tag{9.4}$$

Le facteur τ est la fraction de D retenue par la convention corrélée. Pour D petit devant le BSCR, elle vaut environ ρ, contre une prise en compte intégrale en convention additive. Le BSCR n'étant pas publié, nous le minorons par $\mathrm{SCR} - \mathrm{SCR}_{Op}$ si $\mathrm{Adj} \leq 0$, et par $\mathrm{SCR}/1{,}3$ si les frais des unités de compte sont nuls ($Exp_{ul} = 0$). Minorer le BSCR majore τ : les taux non-vie du tableau sont des majorants, leurs inverses des minorants. Pour les assureurs vie, où $Exp_{ul} = 0$ n'est pas vérifié, ces garanties ne s'appliquent pas.

Entité	**Écart D, contagion** M€	$d = D/\mathrm{BSCR}$	τ **à** $\rho = 0{,}25$	**additif / corrélé**
Assureur non-vie A	0,4	0,0010	$\leq 25{,}0\,\%$	$\geq 3{,}99$
Assureur non-vie B	2,2	0,0028	$\leq 25{,}1\,\%$	$\geq 3{,}98$
Assureur vie C	20,0	0,0164	$\approx 25{,}8\,\%$	$\approx 3{,}88$
Assureur vie D	50,8	0,0045	$\approx 25{,}2\,\%$	$\approx 3{,}97$

L'écart D ne retient que le canal de contagion, en cascade indépendante ; rien n'établit qu'il minore l'écart complet. À $\rho = 0{,}25$, le facteur $1/\tau$ va de 3,88 à 3,99 sur un facteur 134 de taille, et de 3,73 à 3,98 lu sur le niveau. Rapporté au SCR publié, l'écart entre états pèse de 0,08 % à 1,26 %, et ces écarts sont reconnus en entier sous la convention additive.

Pour l'assureur non-vie A, en posant $\mathrm{Adj} = 0$, le plafond de 0,3 BSCR laisse 50,8 M€ au-dessus du SCR opérationnel publié : le besoin calculé à l'état non conforme n'en vaut que 0,02 fois. Dans la lecture retenue, ce plafond ne contraint donc pas le besoin de cette entité. À $\rho = 0{,}25$ (posé), un euro d'écart pèse trois à quatre fois plus en convention additive qu'en corrélée. Pour apprécier un plan de remédiation, il faut donc annoncer la convention et le recouvrement avec le risque déjà couvert ; ces calculs ne déterminent pas une économie réglementaire.

9.8 Détention du capital et transfert du risque

Par convention, détenir un capital B coûte chaque année $\mathrm{CoC} \times B$, au taux de la marge de risque : 6 %, puis 4,75 % au 30 janvier 2027 (directive (UE) 2025/2). À un ratio sinistres sur primes de 48,5 %, la prime vaut environ 2,1 fois la perte attendue. Les 24,1 M€ de l'entité, pour 0,85 M€ de perte moyenne, donnent un multiple de 28,4, contre 8,3 sur le périmètre financier étudié.

Un traité en excès de perte annuel de portée ℓ, sans rétention, cède $\min(L, \ell)$ de la charge L, et le coût de financement de l'entité est

$$C(\ell) = \frac{\mathbb{E}\left[\min(L, \ell)\right]}{\mathrm{LR}} + \mathrm{CoC} \cdot \mathrm{VaR}_{99{,}5\,\%}\left(L - \min(L, \ell)\right), \tag{9.5}$$

où LR est le ratio de sinistralité et CoC le taux de coût du capital. Ce coût est minimal en $\ell^\star = B = 24{,}1$ M€ et passe alors de 1,15 à 0,39 M€ par an, soit −66 %. Pertes conservées comprises, il passe de 2,00 à 1,05 M€ (−47 %). Ce gain suppose un contrat idéal, que capacité, exclusions et contrepartie réduisent. Face au meilleur traité, le transfert reste préférable tant que moins de 65,8 % de la portée achetée reste sans allègement de capital, 82,4 % pertes conservées comprises. Si la conformité ramène λ de 0,021 à 0,0105 (valeur posée), ce coût optimal baisse de 55 %.

Le rapport entre coût de détention et prix de transfert est invariant à un changement d'échelle pur. La descente d'échelle modifie la forme de la perte, et le seul balayage disponible borne cet effet à +36 % (de 2,78 à 3,78).

9.9 Cas d'usage, de l'état de conformité à la décision

Pour un assureur notionnel de 19 231 M€ d'actifs, les résultats du chapitre répondent aux questions suivantes, sous les scénarios et protocoles indiqués.

Question	Réponse chiffrée	Section
Quel ordre de grandeur dans ce scénario ?	24 M€ à l'état non conforme, extrapolation d'ordre de grandeur, dans une bande de [15,8 ; 27,5] M€ (8,3 à 53,0 sous un bootstrap par firme). Le repère forfaitaire, 450 M€, ne dépend pas de l'état.	§9.5
Que change la conformité ?	Aux trois valeurs de g (0,45, 0,68, 0,90), le besoin passe de 13,2 à 17,7 puis 24,1 M€, soit +83 % par le seul canal de propagation. Le forfait reste à 450 M€.	§9.5
Ce niveau est-il fiable ?	C'est une extrapolation. Au levier médian (10,0 %), le SCR de l'entité serait de 1 932 M€ et le besoin en représenterait 1,2 %, sans validation statistique.	§9.6
Combien coûte de le détenir ?	De 1,15 à 1,45 M€ par an selon le taux, soit 1,35 à 1,71 fois la sinistralité attendue. Si la conformité divise λ par deux (valeur posée), le besoin tombe de 24,1 à 4,7 M€.	§9.8
Peut-on le transférer ?	Un traité en excès de perte de portée 24,1 M€ ramène le coût de 1,15 à 0,39 M€ par an (−66 % ; −47 % pertes conservées comprises), gain d'un contrat idéal. La détention redevient préférable si plus de 65,8 à 82,4 % de la portée reste sans allègement de capital.	§9.8
Par quel pilier commencer ?	Au point de calage : P1, puis P4, P2, P3 et P5. P1 et P4 sont presque à égalité (43,6 % et 37,7 % de 220 sommets tirés). L'écart de capital intégré entre le pire ordre et l'ordre optimal atteint 21 %.	§9.3

Le premier usage est la comparaison de scénarios à protocole fixé : effet de fermeture d'un canal et sensibilité de l'ordre de remédiation. La correspondance état–g reste posée ; le signe tient aux cinq correspondances testées, et P1 et P4 restent difficiles à départager.

Le chiffrage d'entité et le transfert exigent ensuite une convention explicite. Ils partent des 24 M€ extrapolés ; le multiple de capital vaut 28,4 à l'entité contre 8,3 au secteur. L'écart de contagion de l'assureur vie D, 50,8 M€, compte en entier ou à environ 25,2 % selon l'agrégation (§9.7). Ces montants éclairent un scénario. Pour arrêter un capital ou un investissement réel, il reste à mesurer les états, les coûts par pilier et l'exposition propre à l'entité ; le modèle ne valide pas ces entrées.

10

Robustesse, limites et recommandations

L'écart entre états du chapitre 9 dépend à la fois du coût attribué à un incident et de la calibration de sa sévérité. À calage fixé, le calcul par Fourier donne un écart de 13 946 M€ avec des pertes additives, à moins d'une erreur type (367 M€) des 14 139 M€ estimés par Monte-Carlo, contre 5 946 avec une perte unique (§10.7.1).

Sous la règle additive, le bootstrap conjoint de la sévérité donne une bande nominale à 95 % de [4 872 ; 90 361] M€ pour l'écart, mais de [3,04 ; 5,22] pour le facteur entre états, conditionnelles aux hypothèses maintenues fixes (§10.7.2). La queue rend le niveau très incertain et le facteur beaucoup moins. Les variantes qui suivent distinguent leur effet sur le niveau, l'écart et l'ordre de remédiation ; les paramètres figurent à l'annexe E.

10.1 Synthèse de robustesse

Le tableau rassemble les expériences et leur portée. Une conclusion conservée sous les variantes testées ne constitue pas une validation des hypothèses du modèle.

Conclusion examinée	**Variantes et protocole**	**Constat et portée**
L'écart Δ_{DORA} entre état non conforme et état conforme reste positif	source de sévérité (OpRisk / PRC), famille de copule ($\theta \in [1, 4]$)	plusieurs milliers de M€ sur le périmètre étudié ; facteur ~1,9 entre sources ; Δ_{DORA} varie $< 1{,}4$ % sur θ
P1 et P4 restent prioritaires à direction fixée	cadre de dépendance (cascade vs copule), branchement vs marche	P1 et P4 en tête dans les cadres testés ; besoin ±4 % (branchement) ; leur ordre dépend de la direction
L'asymétrie de W départage P1 et P4	suppression de la partie antisymétrique (3 000 tirages), placebo par permutation (chapitre 7)	sans asymétrie, P1 et P4 ne se distinguent plus ; l'essentiel du surcoût vient de la partie symétrique, maintenue fixe
La cascade est retenue sans couche de Hawkes	noyau exponentiel puis à retard, logique en deux phases	modèles non distinguables à la résolution disponible (§10.4.1) ; pic à 3,3 h ; endogénéité de 0,551 à ~0 si les co-occurrences du jour passent en exogène ; choix de parcimonie
Le comptage et la forme de queue sont évalués hors échantillon	origine glissante, douze années évaluées	couverture : 91,7 % sous binomiale négative contre 75,0 % sous Poisson, log-score en sa faveur ; forme de queue non rejetée ($p = 0{,}4087$) ; puissance limitée
Le multiplicateur varie peu sur les périodes testées de Hackmageddon	parts par vecteur de quatre jeux, du premier trimestre 2025 à octobre 2026, dont l'année 2026 entière	de 2,318 à 2,471 contre 2,487 publié, soit 6,8 % au plus ; 0,138 de la largeur due aux bornes posées

Conclusion examinée	Variantes et protocole	Constat et portée
Le besoin de capital réagit à la conformité et à la contagion	score $q \in [0,1]$, gain $g \in [0{,}05\,;\,0{,}90]$	facteur 3,34 de C à NC sur les quatre canaux (-53 % sur le seul score) ; $\times 1{,}6$ sur la plage de g ; réponse prévue par la construction
L'incertitude de calibration élargit les quantiles	bootstrap deux niveaux	facteur $\sim$2,5 sur le quantile d'un sinistre ; ce facteur ne mesure pas l'effet sur le capital annuel
Le niveau de sévérité ne tient pas hors échantillon	évaluation d'une année à la fois, seuil ré-estimé sur l'apprentissage	quantiles dépassés trois fois trop souvent ; dérive de queue estimée à 3,40 % par an, non significative ; +16,9 % sur le quantile dans cette variante
L'écart reste positif sur la plage d'additivité testée	exposant $\theta \in [0{,}70\,;\,1{,}30]$ sur le nombre de piliers touchés	écart de 9 706 à 20 487 M€ : signe et ordre conservés, amplitude non (76 % de l'écart publié) ; plage d'exposants posée

Le signe de l'effet DORA et la tête de la hiérarchie des piliers tiennent sous les variantes testées ; l'ordre entre P1 et P4 dépend de la direction posée (§10.2). Les choix assumés sont déclarés avec leur effet mesuré, dont 6,8 % pour la période de Hackmageddon. Trois limites restent : la queue de sévérité domine l'incertitude de niveau, la dérive d'échelle relève ici le quantile de sévérité de 16,9 % (§4.7), et l'additivité des coûts pèse sur l'amplitude de l'écart sans en renverser le signe (§10.6).

10.2 ORDRE DE REMÉDIATION ET SENSIBILITÉ À LA PROPAGATION

10.2.1 Ordre de remédiation sous les variantes

Le niveau du capital varie beaucoup avec les leviers testés, l'indice de queue dominant avec un facteur de l'ordre de 6. Le signe du surcoût et la priorité de P1 tiennent pourtant sur tous ces leviers. L'ordre est conservé dans les variantes de taux testées. Ce constat ne prouve pas son invariance à des durées de remédiation propres à chaque pilier, qui changeraient le capital intégré.

Nous menons ces tests à matrice W fixée. Sur 220 sommets de l'ensemble admissible tirés au hasard (chapitre 8), P1 et P4 sont presque à égalité. P1 arrive premier dans 43,6 % des tirages et P4 dans 37,7 %, avec un écart de regret maximal observé de 1,5 %. Dans ces tirages, P1 et P4 arrivent le plus souvent en tête, et P5 n'arrive jamais en tête ; ce diagnostic sur échantillon ne couvre pas l'énumération des 1 024 sommets.

Les rapports post-incident sur-attribuant à la gouvernance, nous dégradons l'émission de P1 par $W_{1k} \to (1-a)W_{1k}$, et le classement tient jusqu'à $a = 0{,}25$ puis bascule vers P4 à $a = 0{,}50$. Même à $a = 1$, le niveau d'entité ne perd que 37,7 %, l'équivalent de 0,78 fois la largeur de la bande d'identification.

10.2.2 Sensibilité aux probabilités de propagation

Nous faisons varier séparément le niveau de propagation, fixé par hypothèse, et sa direction, non identifiée par les sources étudiées. Mesurée en élasticités, à perturbation relative de 10 % d'un paramètre à la fois, la sensibilité classe les leviers comme suit.

Levier	Statut	Élasticité
Indice de queue ξ	estimé	3,79
Échelle σ	estimé	0,97
Taux de dépassement p_u	estimé	0,82
Fréquence λ	estimé	0,45
Sur-dispersion φ	posé	−0,44
Gain de propagation g	**posé**	**0,37**
Seuil u seul	choix de méthode	0,03

La propagation a l'élasticité la plus faible des leviers substantiels, 0,37 contre 3,79 pour l'indice de queue. Le même classement ressort de l'ablation, qui fait tomber la VaR de 20 % en retirant la propagation et de 76 % en retirant la queue lourde. Les correspondances état–g testées conservent l'ordre du capital dans la cascade indépendante (§6.4) ; l'amplitude reste conditionnelle aux valeurs retenues. À ignorance totale, la largeur de l'ensemble admissible s'élève à 1 839 M€, soit 34,9 % du socle. Elle croît avec le degré d'ignorance : 336, 695, 1 083 puis 1 839 M€ pour des degrés de 0,25, 0,50, 0,75 et 1. Le déplacement conjoint du seuil et des paramètres de queue réajustés (ξ, σ, p_u) fait passer le surcoût de 4 862 à 12 944 M€, dans le calage du diagramme de sensibilité, distinct du résultat principal. Le seuil seul pèse peu (0,03), et l'incertitude numérique tient d'abord à l'ajustement de la queue.

10.3 Données manquantes et choix du modèle

Les limites d'observation et les conventions du calcul appellent des suites différentes. Les sources examinées ne réunissent pas les observations nécessaires pour estimer la direction (chapitre 7). Dans VERIS, le domaine de contrôle est renseigné pour 0,12 % des 10 591 incidents, une chronologie datée pour 1,19 ‰. Un seul incident, hors secteur financier, réunit les deux. Il s'agit d'une lacune de collecte ; la section 10.8 décrit les champs nécessaires.

Les sources ne renseignent pas le coût par pilier d'un incident. La sévérité cyber en euros provient ici du risque opérationnel bancaire (chapitre 4), d'où les réserves d'extrapolation du §9.6, sans seuil de validité démontré. Les extrema calculés aux sommets et les points intérieurs testés répondent à la non-identifiabilité. Sous la construction additive, le signe et l'ordre tiennent sur les variantes étudiées ; l'amplitude reste un scénario.

L'élicitation diffusée est restée sans réponse (annexe D). Les paramètres de référence sont conservés afin de comparer les variantes au même calcul. Les parts Hackmageddon sont des citations datées dont la recopie exacte n'est pas reproductible avec la grille actuelle. Les sections 10.5.1 et 10.5.2 examinent les écarts de calibration et de transposition.

10.4 Incertitude du besoin de capital

10.4.1 Incertitude en trois étages

L'incertitude sur le besoin de capital se répartit sur trois étages. Au premier, celui du paramètre, l'intervalle de confiance de ξ dilate le quantile d'un sinistre d'un facteur 2,5. Le deuxième est l'iden-

tification, la direction de W se lisant en bande (chapitre 8), et le troisième le modèle, c'est-à-dire le choix de la famille. Lus sur la même grandeur, la charge annuelle agrégée du périmètre financier étudié, au calage de référence (sévérité OpRisk), les trois étages donnent, en M€ :

Étage, lu sur la charge annuelle	**Bande**	**Facteur**
Paramètre (ξ sur son IC_{90})	[3 042 ; 27 152]	8,93
Identification (direction de W)	[6 858 ; 8 697]	1,27
Modèle, axe dépendance	[5 322 ; 9 806]	1,84
Modèle, axe famille de queue	[4 146 ; 39 901]	9,62

Le quantile annuel amplifie l'incertitude de paramètre, si bien que le facteur 2,5 ne mesure pas l'effet du paramètre sur le capital. L'étage de modèle est du même ordre que l'étage de paramètre, et les deux dominent l'identification. Sur l'axe de dépendance, la cascade (8 318 M€ dans cette simulation, 8 123 au §9.5 : même calage, deux tirages) se place entre une copule gaussienne et une copule de Gumbel. Ces plages font varier ξ seul, σ restant fixé : sans leur covariance, elles ne forment ni des majorants ni un intervalle de confiance conjoint, et nous ne les cumulons pas. La plage des familles est un scénario de modèle, qu'on ne pourrait moyenner qu'avec des poids que rien ne justifie ici. L'ordre d'amorce $P1 > P4 > P2 > P3 > P5$, posé par ROOT, ne dépend pas de la famille.

Le diagnostic disponible ne permet pas d'attribuer fiablement le regroupement temporel à une auto-excitation. Une cascade sans auto-excitation, ajustée comme une chronologie réelle, donne un ratio de branchement, nombre moyen d'incidents déclenchés par un incident, de 0,480 au jour contre 0,551 mesuré. Nous retenons la cascade par parcimonie, puisqu'elle décrit aussi la structure entre piliers.

10.4.2 Contrôle du moteur d'agrégation

La charge annuelle est une somme composée, addition d'un nombre aléatoire de pertes. Son quantile peut se calculer sans simuler. L'inversion de Fourier de sa fonction génératrice, méthode numérique distincte de la récursion de Panjer (1981), donne 5 945 et 19 890 M€ contre 6 049 et 20 188 par Monte-Carlo. L'écart, de 0,75 et 0,59 erreur type de la référence simulée, n'est donc pas résolu. L'approximation par perte unique (Böcker et Klüppelberg, 2005) reste à moins de dix pour cent au second ordre. Ce contrôle, qui ne teste pas la vérité du modèle, vérifie l'agrégation : le quantile publié ne diffère pas du quantile calculé sans simulation au-delà du bruit de simulation.

10.4.3 Quantile de sévérité prédictif et robuste

Prendre le quantile à 99,5 % d'une loi estimée en un point, le *plug-in*, est fragile, car le quantile d'un objet incertain, cité seul, ne rend pas compte de son incertitude. Le quantile de sévérité prédictif intègre l'incertitude de paramètre avant le quantile, par mélange des lois sur la distribution bootstrap de (ξ, σ), et donne 658 M€ contre 663 pour le *plug-in*, avec un bruit de simulation de 7 M€. Le risque d'estimation n'est donc pas un biais de point à ce niveau, mais il le devient en profondeur (+4 % à 99,9 %).

Le quantile robuste, qui prend la borne haute du quantile de sévérité sur l'ensemble d'ambiguïté, atteint 1 024 M€ à 95 % (1,5 fois le *plug-in*) et 1 338 M€ pour le pire cas de famille lourde. Le

quantile robuste à 95 % est aussi la borne haute de l'intervalle publié, les deux étant le quantile 95 % de la même loi bootstrap, à leur bruit de simulation près.

Nous publions donc le *plug-in* avec sa bande, le quantile robuste restant un choix prudentiel explicite, pour trois raisons. Le capital de solvabilité est défini comme un quantile de la loi de perte, et une borne haute sur une famille de lois répond à une autre question. Le quantile prédictif intègre le risque de paramètre et se distingue peu du *plug-in*, son écart n'excédant pas deux fois le bruit de simulation, et l'écart de sa moyenne au point (5 M€) étant du même ordre que ce bruit. Enfin, les quantiles robustes ont le plus fort bruit de simulation, avec des écarts-types de simulation de 15, 12 et 32 M€, le calcul à paramètres fixés n'ayant pas de bruit de rééchantillonnage.

Le quantile robuste pourrait dimensionner une couverture, ce que la section 9.8 ne fait pas. Un écart durable entre le quantile prédictif et le *plug-in* rouvrirait ce choix.

10.5 Écarts de calibration et de transposition

10.5.1 Calibration de référence et écarts connus

Le modèle POT combine le seuil u, le taux empirique de dépassement p_u et les paramètres (ξ, σ) des excès. À seuil et échantillon fixés, p_u se calcule par comptage ; il ne constitue pas un paramètre libre supplémentaire. La calibration publie $u = 20{,}03$ M€ et $p_u = 0{,}1509$, qui sont ceux de l'échantillon 2000–2026 : le seuil en est le percentile 85 et laisse 86 excès sur 570 pertes. Le taux recompté vaut $86/570 = 0{,}1509$ et le quantile de sévérité à 99,5 % recalculé à ce taux est de 662,71 M€, contre 662,78 publiés. Une version antérieure déclarait ici un écart de taux, venu d'un décompte sur la base courante, qui contient douze pertes d'avant 2000.

L'écart qui reste porte sur la fréquence. Son numérateur compte ces douze pertes : $582/27 = 21{,}56$ incidents par an contre $570/27 = 21{,}11$ sur l'échantillon, soit 2,1 % de plus. Le capital croît avec la fréquence, mais le dénominateur de 27 ans compte l'année 2026, incomplète à la date de l'extraction : le sens de l'écart de niveau n'est pas établi. Le tableau donne le sens des écarts connus.

Écart	Sens	Taille
Écarts de calibration et d'incertitude		
Fréquence de référence (582/27 contre 570/27)	sens non établi	+2,1 % sur λ ; le dénominateur compte 2026, année incomplète
Couverture réelle de l'IC_{90} de ξ	incertitude sous-estimée	87 % au lieu de 90 % ; demi-largeur à élargir d'environ 8 %
Taux p_u, calibré par incident, appliqué à chaque pilier touché	majore	3,66 incidents matériels par an à l'état conforme, 5,67 aux paramètres de base, contre 3,19 dans la donnée
Échelle de sévérité non stationnaire	sous-estime, si elle est réelle	dérive de 3,40 % par an dans la queue ($p = 0{,}1786$, non significative), 3,30 % corrigée de l'inflation ; +16,9 % sur le quantile dans cette variante, sans borne démontrée (§4.7)

Écart	Sens	Taille
Choix posés, tous deux prudents		
Charge systémique a	majore	0,60 posé, au-delà de la borne haute empirique 0,22
Sur-dispersion du moteur φ	majore	9,20 posé contre 2,24 mesuré
Limites de périmètre et de transposition, de sens opposés		
Attritionnel absent de la donnée	sous-estime	non chiffrable : la base est tronquée à son seuil de collecte, les petits sinistres n'y figurent pas
Sévérité non plafonnée à l'échelle d'entité	majore	élasticité sévérité/taille 0,087 [0,026 ; 0,148], presque nulle ; affecte le *niveau* d'entité, et peut modifier les écarts entre états
Hypothèse dont le sens n'est pas déterminable		
Additivité des coûts au sein d'un sinistre multi-piliers	**indéterminé**	élasticité de l'écart 1,20 ; [9 706 ; 20 487] M€ pour $\theta \in [0{,}70 ; 1{,}30]$, soit 76 % de l'écart publié (§10.6)

À autres paramètres fixés, la dérive d'échelle ferait sous-estimer le capital, tandis que la fréquence de référence n'a pas de sens établi ; la sous-couverture de l'intervalle porte sur l'incertitude, non sur le niveau. Les choix posés vont du côté prudent, sans garantir que le capital majore le risque réel. La dérive de l'échelle déplace ici de 16,9 % le quantile de sévérité, contre 2,1 % pour la fréquence. Son effet sur l'écart entre états est de −3,5 %, non résolu. Le plafond de sévérité qui diviserait par deux le besoin d'une entité vaut de 53 à 74 M€ pour des entités dont la taille varie d'un facteur 134.

10.5.2 Transposition et plafonnement des pertes

Sans plafond, une variation de la seule échelle laisse presque inchangé le rapport entre états : 0,9968 pour des niveaux relevés de 32 %. Un changement de forme de queue déplace en revanche le facteur de −4,9 %. L'ajustement avec dérive change les deux, et l'invariance d'échelle ne garantit donc pas l'invariance à la dérive.

Les limites de périmètre vont en sens contraire, sans compensation établie. La troncature de collecte exclut l'attritionnel, ce qui sous-estime la charge sans taille mesurable. À l'entité, toutefois, la fréquence de 0,021 par an donne 97,9 % d'années sans incident matériel, et le quantile à 99,5 % y dépend surtout d'un sinistre unique. À l'inverse, la sévérité transposée à une petite entité n'est pas plafonnée. Un plafond adossé à son exposition, comme celui de PRC pour $\hat{\xi} > 1$, modifierait le niveau et peut modifier l'écart entre états ; il reste une sensibilité distincte, sans recalibration des résultats d'entité.

Dans la lecture retenue, le besoin ne dépasse pas 0,13 % du bilan, contre 4,83 % pour le plus petit assureur en lecture du registre. Un plafond de 0,059 % des actifs sur chaque sévérité élémentaire, soit 11 et 22 M€, divise par deux le besoin de l'entité notionnelle et de l'assureur vie C. Pour les assureurs A, B et D, il faudrait un plafond inférieur à 0,05 % du bilan. La réserve d'extrapolation dépend donc de la fraction du bilan qu'un sinistre peut coûter, hypothèse économique à documenter.

Un plafond par sinistre ne borne pas la charge annuelle : il supprime la queue lourde et rend le cumul pertinent. En lecture du registre, pour $\kappa = 0{,}1\,\%$, un plafond de 19 M€ donne un quantile annuel de 38 M€, soit le double. Le préprint climatique Karimi et al. (2026) propose un plafond par exposition et une saturation renchérissant les atteintes simultanées. Ces formes rejoignent nos limites de transposition et d'additivité (§10.6). Leurs paramètres synthétiques ne sont pas repris, et les résultats historiques ne sont pas recalibrés.

10.6 Défaillances simultanées et additivité des coûts

La cascade produit pour chaque sinistre un ensemble de piliers touchés, si bien que la défaillance simultanée en est la sortie même. À l'état non conforme, elle est majoritaire : 62,31 % des sinistres touchent plus d'un pilier par la cascade seule, hors choc commun P4 (73,25 % avec lui), contre 31,15 % à l'état conforme. Nous distinguons alors trois énoncés d'additivité. Au sein d'un sinistre, l'addition des coûts des piliers touchés est une hypothèse de construction, non testée. Chaque pilier y tire sa perte dans la loi calibrée sur des incidents complets.

Par la cascade seule, hors choc commun P4, un sinistre simulé touche en moyenne 1,38 pilier (état conforme) ou 1,93 (non conforme). À taux de dépassement élémentaire de base fixé, son quantile à 99,5 % vaut alors 1,27 ou 1,58 fois celui d'un incident. Avec le choc commun P4 du moteur des quatre canaux, l'état non conforme touche 2,44 piliers en moyenne et ce rapport vaut 1,85. Ce n'est pas un effet sur le capital annuel : le double comptage est chiffré, non corrigé. En fonction des piliers non conformes, le capital est presque additif, comme le mesure un $R^2 = 0{,}9945$ sur les 32 configurations. En fonction des quatre canaux, il est super-additif en euros, +5 001 M€ d'interaction sur 14 139 (+35 %, chapitre 9), car les canaux se composent presque multiplicativement (§C.4.3).

Nous relâchons la première hypothèse par un exposant. La perte d'un sinistre touchant k piliers devient $\left(\sum_j X_j\right) k^{\,\theta-1}$, et $\theta = 1$ redonne le modèle publié. Pour θ dans $[0{,}70\,;\,1{,}30]$, l'écart entre états parcourt $[9\,706\,;\,20\,487]$ M€, soit 76 % de l'écart publié et 15 fois l'écart-type de 734 M€ entre quatre graines. La plage de θ est posée, non estimée : les élasticités valent sur cette plage, une autre amplitude demande un nouveau calcul. L'hypothèse n'est pas neutre entre les deux états, avec des élasticités de 0,95 à l'état non conforme contre 0,39 à l'état conforme (facteur 2,42), car l'exposant agit uniquement sur les incidents touchant plusieurs piliers. Elle interagit donc avec le canal de propagation.

Sur toute la plage, l'écart garde son signe et son ordre de grandeur. Son sens n'est pas déterminable, car la mutualisation de la remédiation et la saturation de la capacité de réponse tirent en sens contraire, et aucune source ne les sépare. Croisée avec un plafond de sévérité adossé à l'exposition, appliqué par sévérité élémentaire, l'incidence de l'additivité diminue sans s'annuler ; le plafond amortit l'écart sans le compenser.

10.7 Unité de perte et incertitude jointe

Les pertes historiques décrivent des incidents complets ; la construction additive en tire une par pilier touché. Nous comparons quatre constructions, sans coûts observés par pilier pour les

départager, à fréquence, dispersion et canaux communs.

10.7.1 Constructions de la perte d'un incident

Notons K le nombre de piliers touchés et Y une perte nulle avec probabilité $1 - p_u$, égale à $u + \mathrm{GPD}(\xi, \sigma)$ sinon. La perte additive est $\sum_{j=1}^{K} Y_j$, avec des Y_j indépendantes. La perte moyenne divise cette somme par K. L'incident unique ne tire qu'un Y ; l'incident amplifié vaut $K^{\eta}Y$, avec $\eta = 1$ posé. La loi exacte de K inclut le choc P4 actif. L'inversion de Fourier donne les capitaux des seize configurations, leurs attributions de Shapley et l'interaction.

Perte	Conforme	Non conforme	Écart	Rapport	Interaction
Additive	5 944	19 890	13 946	3,35	4 410
Moyenne	4 468	8 718	4 250	1,95	292
Unique	4 774	10 720	5 946	2,25	976
Amplifiée	6 908	27 746	20 838	4,02	7 148

Montants en M€ pour le périmètre financier étudié. Les quatre règles utilisent le calage historique ; l'incident amplifié a un exposant posé égal à un. Les déplacements sous raffinement de grille restent de l'ordre du M€.

La moyenne garde plusieurs Bernoulli et peut être inférieure à u. La propagation et l'accumulation y contribuent négativement, en diluant une perte extrême. Avec une perte unique, ces contributions sont nulles par construction : elles modifient K, sans modifier Y. Cela ne réfute pas ces canaux ; leur effet financier exige de mesurer le coût selon les piliers touchés.

L'interaction additive calculée sans simulation garde le signe de son estimation Monte-Carlo. Ces comparaisons isolent l'unité de perte, sans remplacer les résultats historiques.

Les constructions additive et amplifiée diffèrent par la dépendance entre les K composantes d'un incident, à marges égales. Un mélange les relie : avec probabilité ρ, un choc commun les rend comonotones, c'est-à-dire déterminées par le même rang aléatoire dans leur loi marginale ; sinon elles sont indépendantes. De $\rho = 0$ à $\rho = 1$, le capital croît de 16 % à l'état conforme et de 39 % à l'état non conforme. Le rapport entre états passe de 3,35 à 4,02 (+20 %), avec 3,74 à $\rho = 0{,}5$. La croissance est monotone sur 21 valeurs de ρ (constat numérique), et la perte annuelle moyenne ne change pas.

Entre l'incident unique et la comonotonie, la dépendance porte 45 % de l'écart de capital à l'état conforme et 46 % à l'état non conforme, le reste venant du nombre de composantes. La marge de l'incident complet, réutilisée pour chaque composante, n'est pas testée.

10.7.2 Bootstrap conjoint de calibration

À seuil fixé, nous rééchantillonnons les pertes entières de 2000–2026. Chaque réplication recompte p_u, ajuste conjointement ξ et σ, puis applique ce triplet aux deux états et aux quatre constructions. Les percentiles portent sur leurs écarts et rapports appariés, jamais sur une soustraction de bornes marginales.

L'échantillon compte 570 pertes et 86 excès. L'ajustement donne $\hat{\xi} = 0{,}59523$, $\hat{\sigma} = 57{,}98$ M€ et $\hat{p}_u = 0{,}150877$. Nous retenons 2 000 réplications, sans échec.

Perte	Écart (M€)		Rapport	
	Ajustement	Bande à 95 %	Ajustement	Bande à 95 %
Additive	13 933	[4 872 ; 90 361]	3,35	[3,04 ; 5,22]
Moyenne	4 248	[1 401 ; 30 606]	1,95	[1,77 ; 2,97]
Unique	5 940	[1 782 ; 33 719]	2,25	[1,97 ; 3,11]
Amplifiée	20 821	[6 718 ; 100 660]	4,02	[3,48 ; 5,51]

Bandes percentiles nominales à 95 %, calculées directement sur les paires. La corrélation bootstrap entre ξ et σ vaut −0,603. Les 12 ajustements avec $\xi \geq 1$ sont conservés : leur moyenne est infinie, leur quantile reste défini. Le raffinement numérique des ajustements extrêmes et d'un ajustement médian ne déplace aucun capital de plus de 0,08 %.

Ces bandes supposent les pertes échangeables, dont la loi jointe ne dépend pas de leur ordre, et le seuil fixé ; elles excluent sélection et non-stationnarité, et laissent fixes la fréquence historique, la dispersion, les multiplicateurs et la cascade d'expert. La dispersion des rapports montre que la forme de queue ne s'annule pas entre états.

10.7.3 Mélange prédictif annuel

Pour chaque calibration du bootstrap, nous recalculons la loi annuelle complète aux deux états, puis nous moyennons ces 2 000 lois. Le quantile du mélange est une construction prédictive empirique, et non une loi prédictive bayésienne.

Perte	Conforme (M€)		Non conforme (M€)		Rapport	
	Central	Mélange	Central	Mélange	Central	Mélange
Additive	5 940	7 030	19 872	28 991	3,35	4,12
Moyenne	4 463	5 217	8 712	12 314	1,95	2,36
Unique	4 770	5 478	10 710	14 040	2,25	2,56
Amplifiée	6 904	7 832	27 725	35 520	4,02	4,54

Quantiles annuels à 99,5 %, périmètre financier étudié. Le mélange moyenne les lois annuelles de 2 000 calibrations ; la lecture se fait sur une grille de résolution relative 0,26 %.

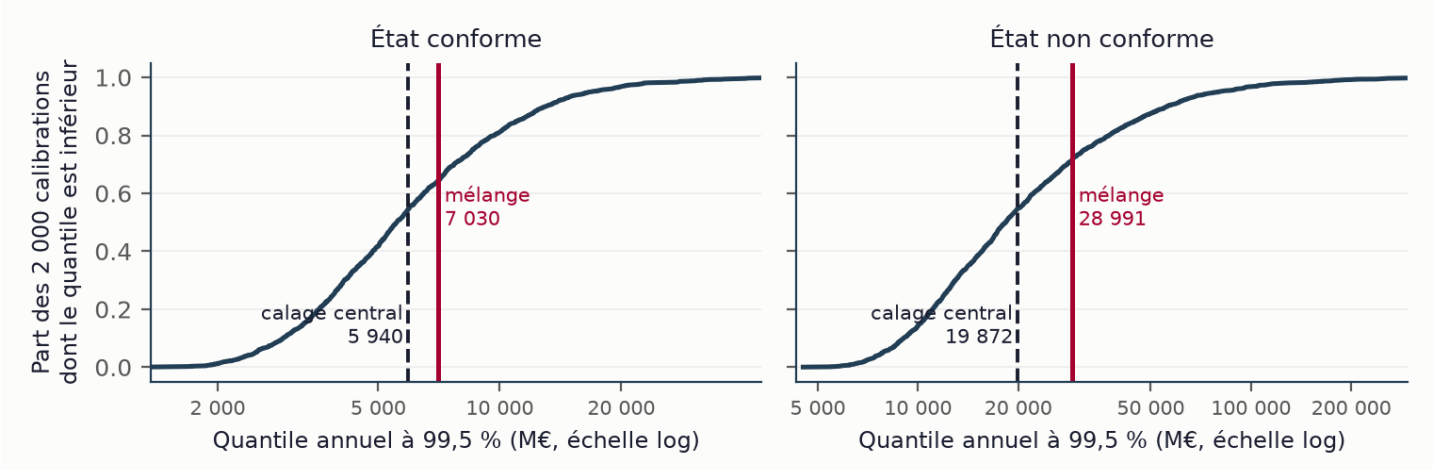


FIGURE 10.1. Quantile annuel à 99,5 % sous la règle additive : fonction de répartition des quantiles conditionnels des 2 000 calibrations, calage central (pointillé) et quantile du mélange (trait plein).

Sous la règle additive, le quantile du mélange dépasse le calage central de 18 % à l'état conforme et de 46 % à l'état non conforme. L'écart grandit avec le niveau : à 99,9 %, l'état non conforme passe de 43 734 à 87 360. Les 12 ajustements avec $\xi \geq 1$ n'en sont pas la cause : sans eux, le rapport du mélange vaut 4,05. Le rapport 3,35 est celui de deux points de calage ; celui des quantiles du mélange vaut 4,12. Aucun des deux ne mesure un facteur vrai. Le mélange garde les hypothèses du bootstrap conjoint, et n'est pas un backtest du quantile à 99,5 %.

10.7.4 Validation chronologique

Sur les années complètes 2000–2025, soit 565 pertes dont 84 excès au-dessus du seuil fixé, nous évaluons en origine glissante, de 2014 à 2025, trois lois de sévérité des excès : stationnaire, à échelle variable et à deux régimes. Aucune loi variable n'améliore le score moyen de la stationnaire. L'écart de score logarithmique moyen par excès vaut −0,008 pour l'échelle variable, d'intervalle bootstrap à 90 % [−0,057 ; 0,043], et −0,025 pour les deux régimes, [−0,073 ; 0,025].

Pour le taux de dépassement du seuil, le gain moyen de la tendance logistique sur le taux constant est de 0,039 par perte évaluée, [0,001 ; 0,076], avec une pente de 0,107 par an. Cet intervalle exploratoire rééchantillonne les pertes individuellement. Le contrôle par blocs annuels du §4.7.1 donne un intervalle contenant zéro : l'incertitude sur le gain dépend du rééchantillonnage.

Loi retenue	Conforme	Non conforme	Rapport
Stationnaire	5 958	20 268	3,40
Échelle variable	6 417	21 037	3,28
Deux régimes	5 585	18 241	3,27
Taux en tendance	10 782	37 647	3,49
Échelle variable et taux en tendance	11 446	38 887	3,40

Capital annuel à 99,5 % pour 2026 (M€, règle additive, périmètre financier étudié), après ajustement sur 2000–2025.

Le niveau du capital varie de −10 % à +92 % selon la loi retenue, le rapport entre états de −4,0 % à +2,6 %. Le taux de dépassement prévu pour 2026 atteint 0,349 contre 0,149 : extrapolation d'une tendance, sans validation. Les excès d'une même année sont traités comme indépendants, avec un à onze excès par an : la puissance est faible, et ce n'est pas un backtest du quantile à 99,5 %.

10.7.5 Rééchantillonnage par années

Nous tirons des années complètes de 2000 à 2025, avec leurs pertes, ou des blocs de trois années consécutives, puis nous réestimons à chaque tirage le taux de dépassement et la queue. Le nombre annuel de pertes enregistrées, de 4 à 39, module aussi la fréquence par $\lambda_b = \lambda_{\text{ref}}\, n_b / n_{\text{ref}}$, ce qui conserve la référence historique.

Tirage	Fréquence	Rapport médian	Bande à 90 %	Non conforme, bande à 90 %
Années	fixée	3,36	[3,01 ; 4,23]	[7 259 ; 51 189]
Années	propagée	3,36	[3,00 ; 4,22]	[7 192 ; 52 139]
Blocs de trois années	fixée	3,19	[2,95 ; 4,06]	[4 710 ; 46 968]
Blocs de trois années	propagée	3,19	[2,96 ; 4,07]	[4 644 ; 50 377]

Règle additive, périmètre financier étudié, 600 tirages par schéma (capital en M€).

Propager la fréquence change peu. Le facteur n_b/n_{ref} reste entre 0,855 et 1,145 à 5 et 95 %. La bande du rapport entre états est inchangée avec des années échangeables (+0 %) et varie de −1 % avec des blocs. Celle du capital non conforme s'élargit de 2 %, puis de 8 %. Il s'agit de pertes enregistrées, non d'une fréquence par entité ; la hausse du nombre annuel de pertes n'est pas modélisée.

10.7.6 Précision numérique

L'inversion de Fourier calcule la loi de la somme annuelle à partir des transformées des pertes et du comptage. La grille rend les convolutions calculables par produits. L'inclinaison exponentielle atténue les masses lointaines, puis est retirée ; elle réduit leur repliement artificiel en début de grille. La masse hors portée est omise, sans report dans la dernière case ni renormalisation. Le pas et la portée s'adaptent aux ajustements extrêmes ; les contrôles les font varier avec l'inclinaison. Pour $K = 1$, les quatre règles coïncident. Une sévérité déterministe redonne la binomiale négative amincie ; les moments tronqués restent compatibles avec les moyennes analytiques finies.

10.8 Recommandations à l'entité et au superviseur

Pour comparer des scénarios, et non pour arrêter un capital d'entité, trois règles découlent des résultats.

1. Juger une remédiation par l'effet de fermeture d'un canal depuis l'état de départ, sans additionner les gains de plusieurs canaux (chapitre 9).
2. Traiter d'abord la gouvernance et la gestion des prestataires tiers, leur ordre dépendant de l'émission retenue pour la gouvernance (§10.2).
3. Arbitrer entre remédier, détenir et transférer en euros par an (§9.8).

Pour le superviseur, la priorité est la donnée manquante. Les trois sources agrégées échouent pour des raisons distinctes. La chronologie américaine manque de taxonomie et de volume informatif, SAS OpRisk de résolution temporelle, et VERIS possède les bons champs sans les renseigner. La proposition 5.7 précise la donnée qui identifierait W.

Un registre d'incidents TIC devrait horodater la survenance au mois ou à la semaine et classer par domaine de contrôle au lieu du vecteur d'attaque. Il devrait de plus consolider une cause commune en un événement à N victimes, et consigner pour chaque incident les piliers qui ont cédé. Même sans horodatage, cette loi jointe distingue une matrice de sa transposée. Sur la matrice publiée, la part des sinistres multi-piliers passe de 62,31 % sous W à 50,77 % sous $W^\top$.

Le registre d'information du règlement d'exécution (Commission européenne, 2024) identifie les prestataires et leur sous-traitance, ce qui sert la consolidation des causes communes.

Les deux premières exigences sont déjà des champs du schéma VERIS, presque jamais renseignés (§10.3). Le formulaire DORA de notification des incidents majeurs (Commission européenne, 2025b) n'en porte pas l'équivalent codé (§10.9) : l'ajout y serait obligatoire là où une base déclarative volontaire ne l'impose pas.

On chiffre cette information en restreignant l'ensemble admissible du chapitre 8 aux configura-

tions compatibles avec elle, puis en mesurant le rétrécissement de la bande de capital.

Définition 10.1 (Valeur d'information d'une contrainte)**.** Soit $\mathcal{W}$ l'ensemble admissible et $B : \mathcal{W} \to \mathbb{R}_+$ la fonctionnelle de capital. Pour un sous-ensemble non vide $\mathcal{V} \subseteq \mathcal{W}$, la largeur de bande est

$$L(\mathcal{V}) \;=\; \sup_{W \in \mathcal{V}} B(W) \;-\; \inf_{W \in \mathcal{V}} B(W). \tag{10.1}$$

Une information $\mathcal{I}$ qui restreint l'ensemble à $\mathcal{W}_{\mathcal{I}} \subseteq \mathcal{W}$, non vide, a pour valeur, si $0 < L(\mathcal{W}) < \infty$, le rétrécissement relatif :

$$V(\mathcal{I}) \;=\; 1 - \frac{L(\mathcal{W}_{\mathcal{I}})}{L(\mathcal{W})} \;\in\; [0, 1]. \tag{10.2}$$

Les rapports post-incident du chapitre 7 documentent le sens de six dépendances, dont deux seulement sont concluantes au §7.8. Un sens connu laisse le coefficient libre entre zéro et son maximum. Sur une grille commune ($-S$, 0 ou S par coefficient) filtrée selon ces six sens, la plage se réduit de 32,7 % en moyenne sur quatre graines, de 22 à 44 % : un indicateur, non une promesse. La largeur de référence varie de 1 572 à 1 894 M€ selon la graine, et la grille ne garantit pas les extrema ; même les dix sens connus (57,9 %), l'amplitude resterait inconnue.

En fixant le sens d'une dépendance à la fois, on classe les données manquantes (figure 10.2). Quatre dépendances lèvent chacune de 11,2 à 13,3 % en moyenne, dont les deux premières, hors du corpus ; leur ordre varie entre graines, et les cinq dernières n'en lèvent que de 0,7 à 2,3 %.

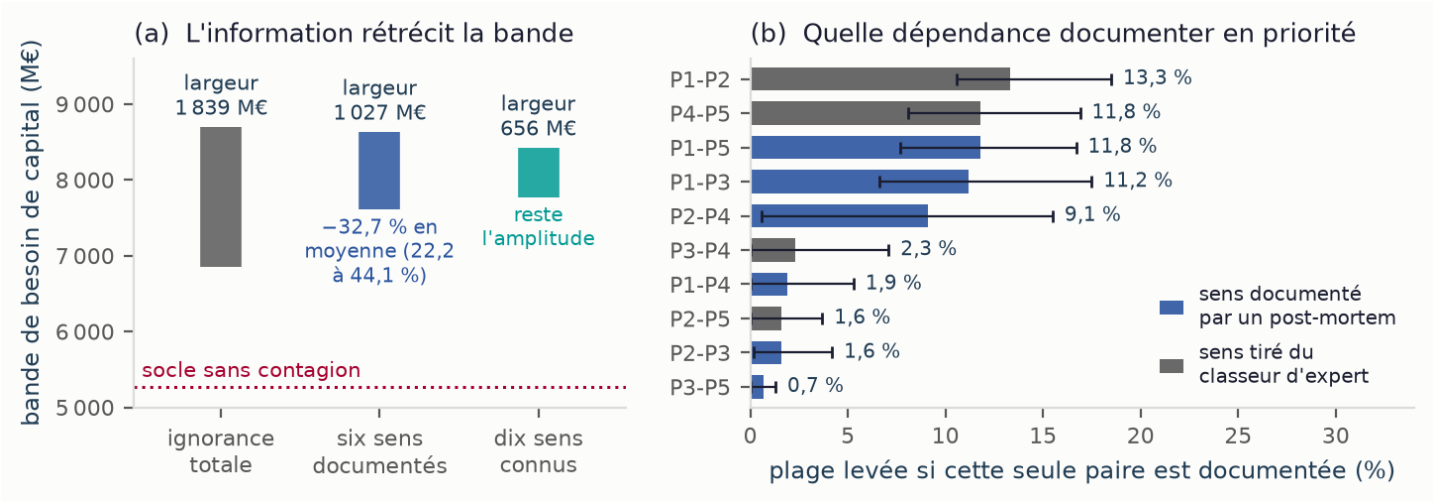


Figure 10.2. La valeur de l'information sur quatre graines. (a) grille commune, chaque coefficient à $-S$, 0 ou S : six sens connus réduisent la plage de 32,7 % en moyenne ; barres de la graine de référence. (b) quelle dépendance documenter en priorité, moyenne et étendue ; en bleu, celles que le corpus couvre déjà.

10.9 Spécification d'un registre d'incidents utile à la modélisation

Le formulaire DORA de notification renseigne déjà une partie des variables du modèle. Le registre ajouterait ce qu'il ne code pas, en précisant sa qualification.

10.9.1 Champs minimaux

Un incident majeur est notifié en trois temps (chapitre 1). Le modèle distingue la date de survenue, qui fixe la fréquence, la date de détection, qui renseigne la qualité de la détection (chapitre 6), et la date de déclaration, qui reflète le comportement déclaratif. L'annexe II du règlement d'exécution (Commission européenne, 2025b) porte déjà la détection (champ 2.2), la classification (2.3), la survenue (3.2), la reprise (3.3), le traitement de la cause (4.7) et la résolution (4.8). Le tableau relie chaque variable du modèle aux champs existants, à leur limite et à l'ajout nécessaire.

Variable du modèle	**Champ DORA existant**	**Limite**	**Ajout nécessaire**
Fréquence d'entrée, détection	dates 2.2, 2.3, 3.2 ; mode de découverte 2.7	une horloge par incident, incidents majeurs seuls	date de défaillance par domaine
Piliers touchés (loi jointe)	zones fonctionnelles 3.27 ; causes détaillées 4.2 et 4.3, dont le suivi des prestataires	zones fonctionnelles et causes ne sont pas les domaines de contrôle qui ont cédé	domaines P1 à P5, plusieurs valeurs, domaine de première défaillance
Direction de la contagion	séquence d'événements 4.5, mesures temporaires 3.34	texte libre, sans ordre codé	ordre des domaines ayant cédé, sur au moins deux étapes
Cause commune, accumulation (P4)	origine tierce, nom et code du prestataire 2.8 ; code de l'autorité 3.1	code propre à chaque entité, tiers renseigné seulement s'il est l'origine	identifiant d'événement commun, attribué par l'autorité ou le prestataire
Sévérité	coûts et pertes bruts 4.13, recouvrements 4.14	un montant par incident, non réparti entre piliers	répartition par domaine, ou déclaration d'un total indivisible

Le formulaire ne code ni les domaines de contrôle défaillants ni leur ordre. Une horloge par incident (champs 2.2 à 4.8) n'est pas une séquence de défaillances par domaine : la première date l'incident, la seconde ordonnerait les domaines. Ces notifications vont aux autorités compétentes : nous ne les supposons pas publiques et n'y avons pas eu accès.

10.9.2 Règles de qualification

Un champ n'a de valeur que s'il se remplit de la même façon d'une entité à l'autre. Les praticiens consultés ont signalé trois difficultés (annexe D).

La première, le classement parfois subjectif d'un incident par domaine, se traite en renseignant le domaine de première défaillance puis les domaines ensuite touchés, comme dans la cascade.

La deuxième, la reconnaissance d'une cause commune, demande que l'identifiant d'événement commun soit attribué par l'autorité ou le prestataire, non par chaque victime.

La troisième est la frontière entre occurrence et maîtrise relevée par un praticien. Consigner séparément l'événement déclencheur et les mesures de confinement permettrait de trancher, sur données, entre un arc de la matrice de propagation et un effet sur le canal de détection.

10.10 Gouvernance du modèle

Les données étant sous licence, le lecteur dispose des sorties agrégées versionnées. Un programme rattache chaque nombre publié au script qui l'imprime ; citations externes et valeurs posées sont déclarées avec leur motif, et tout nombre hors contrôle non déclaré constitue un défaut. Ce contrôle confirme l'origine d'un nombre, non son interprétation : la relecture a trouvé des erreurs de sens parmi des nombres confirmés. La calibration est gelée : les erreurs sont corrigées, le prix des entrées conservées est déclaré (§10.5.1).

Sur le modèle de la validation qu'impose l'article 124 de la directive Solvabilité II, une validation indépendante devrait examiner trois points. Les hypothèses structurelles non testées viennent d'abord, l'additivité des coûts d'un sinistre multi-piliers étant la plus lourde (§10.6). Vient ensuite la correspondance entre états de conformité et gain de propagation, posée sans calibration (chapitre 6). Le dernier point est l'échelle de sévérité, dont le backtest rejette le niveau (§4.7). Aucun tiers n'a revu le code ni les calculs : les trois relectures de praticiens (annexe D) portent sur des affirmations qualitatives. Cette validation reste nécessaire avant tout pilotage par le modèle.

Conclusion

Apports et résultats

Ce travail calcule des écarts conditionnels de capital entre états de conformité supposés, puis examine leur dépendance à la direction de la contagion et au coût des piliers touchés. Sur le périmètre financier étudié, et non pour un assureur, le besoin de capital lié au risque opérationnel informatique passe de 6 049 à 20 188 M€ entre l'état conforme et l'état non conforme, soit un facteur 3,34. Les deux états diffèrent sur quatre canaux : la fréquence, la détection, la propagation et l'accumulation. Cet écart, 14 139 M€, a un écart-type de 734 M€ entre quatre graines ; il ne mesure pas un effet causal de DORA. Les canaux se composent presque multiplicativement : l'effet d'une correction dépend de l'état des autres contrôles. Un plan de remédiation doit donc citer l'effet de fermeture depuis son état de départ, en incluant les interactions.

La cascade distingue des ordres d'atteinte qu'un score statique des seuls piliers touchés ne représente pas : 22 des 26 ensembles de piliers changent de criticité (note de 1 à 10) selon l'ordre d'atteinte. La normalisation de Leontief garantit la stabilité du système latent, cycles compris. Un processus de Hawkes ne se distingue pas de la cascade à la résolution disponible, et nous retenons la cascade par parcimonie.

La queue de sévérité et la fréquence d'entrée sont ajustées sur les données ; la propagation et l'accumulation sont posées. Hors échantillon, la binomiale négative couvre davantage d'années que le Poisson et la forme de queue n'est pas rejetée, mais douze années donnent peu de puissance. Le niveau de la charge annuelle est rejeté (Kolmogorov-Smirnov, $p = 0{,}0042$), sans que la dérive de l'échelle de queue soit confirmée. La Formule Standard n'exprime pas l'écart entre états : à volume égal, sa charge ne dépend pas de la conformité, et ses six limites pour cette question (tableau 1.1) trouvent chacune une réponse conditionnelle dans les chapitres 4 à 10.

Non-identifiabilité de la direction

La direction de la contagion n'est pas identifiable sur les trois sources étudiées (chronologie américaine, SAS OpRisk, VERIS), pour des raisons distinctes. L'expérience MOVEit ne distingue pas son effet net de zéro après le placebo. Les deux champs manquants existent dans le schéma VERIS, mais ne sont renseignés ensemble que dans *un* incident sur 10 591.

Le socle sans contagion ne dépend pas de la direction, mais conserve des paramètres posés (surdispersion, accumulation). Dans le calage de référence (sévérité OpRisk), le capital total se situe entre 6 858 et 8 697 M€ sur les 1 024 sommets de l'ensemble admissible. Cette plage, large de 1 839 M€, est calculée aux sommets ; recalculée sur quatre graines, sa largeur a un écart-type de 189 M€. Elle n'intègre pas l'incertitude sur la partie symétrique posée par l'expert.

Conséquences pour le régulateur et pour l'entité

Un registre mieux renseigné permettrait d'éprouver la contagion : survenance à la semaine, classement par domaine de contrôle, consolidation des causes communes et ensemble des piliers touchés. Dans le modèle, leur loi jointe peut distinguer une matrice de sa transposée.

La notification DORA pourrait rendre obligatoires les deux premiers champs, déjà prévus dans VERIS. Fixer les six sens documentés par sept rapports post-incident réduirait la plage de 32,7 % en moyenne, de 22 à 44 % selon la graine, ordre de grandeur et non promesse. Les dépendances les plus utiles, dont gouvernance–incidents, en lèveraient chacune 11 à 13 %, sans ordre résolu.

Remédier, détenir ou transférer le risque se comparent ensuite en euros par an, avec une prime de réassurance calculée sur un ratio de sinistralité de 48,5 %. Pour l'entité notionnelle de 20 000 M$ d'actifs, dont le besoin de capital (24 M€) est une extrapolation d'ordre de grandeur, le coût annuel de détention représente 1,35 à 1,71 fois la sinistralité attendue. Dans le scénario de traité en excès de perte idéalisé, le coût de financement baisse d'environ deux tiers, et de près de moitié pertes conservées comprises ; la capacité du marché, les exclusions et le risque de contrepartie l'entament. Plusieurs fréquences réelles restent compatibles avec les mêmes comptes du registre (§9.6.2).

Limites

L'élicitation structurée a été préparée et diffusée, mais elle est restée sans réponse (annexe D). La lecture centrale de la direction repose donc sur un barème d'expert qualitatif. Deux hypothèses pèsent le plus sans être testables sur la donnée : les niveaux de propagation, posés, et l'additivité des coûts entre piliers touchés. L'élasticité de cette dernière atteint 0,95 à l'état non conforme contre 0,39 à l'état conforme (§10.6). Ces sensibilités évaluent l'effet des conventions, sans déterminer leur valeur empirique.

Dans la construction additive, sur les sensibilités étudiées, le signe du surcoût et les deux piliers les plus coûteux, la gouvernance et la gestion des prestataires tiers, sont conservés. L'ordre de remédiation entre ces deux piliers dépend en revanche du niveau d'émission de la gouvernance : il tient tant que celle-ci n'est dégradée que du quart, et bascule à la moitié. Le niveau de capital reste illustratif ; les bandes de calibration en montrent l'incertitude, conditionnellement aux autres hypothèses.

L'unité de perte modifie l'amplitude et l'attribution de l'écart (§10.7.1) : une perte unique neutralise financièrement les canaux agissant sur le nombre de piliers. Le bootstrap conjoint propage l'incertitude de calibration de la sévérité (§10.7.2) ; ses bandes restent conditionnelles à la fréquence et aux hypothèses d'expert.

La comparaison de scénarios est l'usage accessible sous ces conventions. Pour chiffrer un investissement ou arrêter un capital propre à l'entité, il reste à confronter les états et les coûts par pilier à des observations indépendantes. Un panel renseignerait le barème ; des séquences d'incidents et des coûts ventilés permettraient d'éprouver la contagion et sa traduction financière.

Bibliographie

AMRAE. LUCY 2026 : Lumière sur la cyberassurance. Rapport technique, Association pour le Management des Risques et des Assurances de l'Entreprise, 2026. Édition 2026, exercice 2025 ; 20 996 polices et 1 251 sinistres déclarés. https://www.amrae.fr/lucy-lumiere-sur-la-cyberassurance-edition-2026.

Autorité de contrôle prudentiel et de résolution. Synthèse de l'enquête déclarative de 2024 sur la gestion de la sécurité des systèmes d'information des organismes d'assurance. Rapport technique 168, ACPR, 2025. https://acpr.banque-france.fr/system/files/2025-02/20250212_Synthese_enquete_gestion_systeme_securite_organismes_assurance.pdf.

Autorité des marchés financiers. Rapport sur les incidents majeurs DORA déclarés à l'AMF en 2025. Rapport technique, Autorité des marchés financiers, septembre 2026. https://www.amf-france.org/fr/actualites-publications/publications/rapports-etudes-et-analyses/rapport-sur-les-incidents-majeurs-dora-declares-lamf-en-2025, consulté le 28 septembre 2026.

Autorités européennes de surveillance (ESAs). Premier rapport annuel sur les incidents liés aux TIC au titre de DORA, 2026. Rapport JC 2026 16 du 3 juin 2026, 3 383 incidents TIC majeurs en 2025. https://www.esma.europa.eu/sites/default/files/2026-06/JC_2026_16_ESAs_2025_report_on_major_ICT-related_incidents.pdf.

Avast Threat Labs. WannaCry, un an après : bilan des attaques bloquées dans le monde. Laboratoire des menaces Avast, 2018. Période observée : 12 mai 2017 – 1er avril 2018.

Adrian Baldwin, Iffat Gheyas, Christos Ioannidis, David Pym et Julian Williams. Contagion in cyber security attacks. *Journal of the Operational Research Society*, 68(7), 2017.

Banque centrale européenne. Analyse des registres d'externalisation des établissements importants, 2024. Plus de 30 % du budget d'externalisation sur 10 prestataires ; 50 % du budget critique sur 30 ; 19 prestataires TIC critiques désignés par les ESAs (novembre 2025). https://www.bankingsupervision.europa.eu/ecb/pub/pdf/ssm.outsourcing_horizontal_analysis_202402~2b85022be5.en.pdf.

Jan Beirlant, Yuri Goegebeur, Johan Segers et Jozef Teugels. *Statistics of Extremes: Theory and Applications*. Wiley, 2004.

Yannick Bessy-Roland, Alexandre Boumezoued et Caroline Hillairet. Multivariate Hawkes process for cyber insurance. *Annals of Actuarial Science*, 15(1):14–39, 2021. doi: 10.1017/S1748499520000093.

Christian Biener, Martin Eling et Jan Hendrik Wirfs. Insurability of cyber risk: An empirical analysis. *The Geneva Papers on Risk and Insurance – Issues and Practice*, 40:131–158, 2015.

Klaus Böcker et Claudia Klüppelberg. Operational VaR: a closed-form approximation. *Risk Magazine*, 18(12):90–93, 2005.

Rainer Böhme et Gaurav Kataria. Models and measures for correlation in cyber-insurance. Dans *Workshop on the Economics of Information Security (WEIS)*, 2006.

Alexandre Boumezoued, Yousra Cherkaoui et Caroline Hillairet. Cyber risk modeling using a two-phase Hawkes process with external excitation, 2023. arXiv:2311.15701. https://arxiv.org/abs/2311.15701.

Javier Castro, Daniel Gómez et Juan Tejada. Polynomial calculation of the Shapley value based on sampling. *Computers & Operations Research*, 36(5):1726–1730, 2009. doi: 10.1016/j.cor.2008.04.004.

Comité de Bâle sur le contrôle bancaire. Bâle III : finalisation des réformes de l'après-crise. Rapport technique, Banque des règlements internationaux, décembre 2017.

Commission européenne. Règlement d'exécution (UE) 2024/2956 établissant les modèles du registre d'information des accords contractuels portant sur l'usage de services TIC fournis par des prestataires tiers (DORA). Journal officiel de l'Union européenne, 2024. Modèles B_01.01 à B_99.01 ; chaîne de sous-traitance, criticité, substituabilité.

Commission européenne. Règlement délégué (UE) 2025/301 : contenu et délais des notifications et rapports d'incidents majeurs liés aux TIC. Journal officiel de l'Union européenne, 2025a. Article 5. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj.

Commission européenne. Règlement d'exécution (UE) 2025/302 : formulaires, modèles et procédures de notification des incidents majeurs liés aux TIC. Journal officiel de l'Union européenne, 2025b. Annexes I et II. https://eur-lex.europa.eu/eli/reg_impl/2025/302/oj.

Roger M. Cooke. *Experts in Uncertainty: Opinion and Subjective Probability in Science*. Oxford University Press, New York, 1991.

Sébastien Decupère. Agrégation des risques et allocation de capital sous Solvabilité II, 2011. Mémoire d'actuariat, ENSAE. Déposé sur https://www.ressources-actuarielles.net.

Michel Denault. Coherent allocation of risk capital. *Journal of Risk*, 4(1):1–34, 2001.

Franck Osée Dountio Zaboue. Modélisation de la sévérité du risque cyber en assurance : apports du NLP et de

l'IA générative face au déséquilibre des données, 2026. Mémoire d'actuariat, ENSAE. Déposé sur https://www.ressources-actuarielles.net.

Benjamin Edwards, Steven Hofmeyr et Stephanie Forrest. Hype and heavy tails: a closer look at data breaches. *Journal of Cybersecurity*, 2, 2016.

Martin Eling et Nicola Loperfido. Data breaches: Goodness of fit, pricing, and risk measurement. *Insurance: Mathematics and Economics*, 75:126–136, 2017.

Martin Eling et Jan Wirfs. What are the actual costs of cyber risk events? *European Journal of Operational Research*, 272(3):1109–1119, 2019.

Paul Embrechts, Claudia Klüppelberg et Thomas Mikosch. *Modelling Extremal Events for Insurance and Finance*. Springer, 1997.

ENISA. ENISA Threat Landscape 2025. Rapport technique, European Union Agency for Cybersecurity, octobre 2025. https://www.enisa.europa.eu/topics/cyber-threats/threat-landscape.

Sébastien Farkas, Olivier Lopez et Maud Thomas. Cyber claim analysis using generalized Pareto regression trees with applications to insurance. *Insurance: Mathematics and Economics*, 98:92–105, 2021.

France Assureurs. Cartographie prospective des risques de la profession de l'assurance et de la réassurance. Rapport technique, France Assureurs, Paris, 2026. Édition 2026 ; le risque de cyberattaques est premier pour le huitième exercice consécutif. https://www.franceassureurs.fr/wp-content/uploads/2026-fa-cartographie-prospective.pdf.

Hemantha Herath et Tejaswini Herath. Copula-based actuarial model for pricing cyber-insurance policies. *Insurance Markets and Companies*, 2, 2011.

Bruce M. Hill. A simple general approach to inference about the tail of a distribution. *The Annals of Statistics*, 3(5): 1163–1174, 1975.

Caroline Hillairet et Olivier Lopez. Propagation of cyber incidents in an insurance portfolio: counting processes combined with compartmental epidemiological models. *Scandinavian Actuarial Journal*, 2021(8):671–694, 2021.

Caroline Hillairet, Anthony Réveillac et Mathieu Rosenbaum. An expansion formula for Hawkes processes and application to cyber-insurance derivatives, 2021. arXiv:2104.01579, Stochastic Processes and their Applications (2023). https://arxiv.org/abs/2104.01579.

Caroline Hillairet, Olivier Lopez, Louise d'Oultremont et Brieuc Spoorenberg. Cyber-contagion model with network structure applied to insurance. *Insurance: Mathematics and Economics*, 2022.

Bertrand Iooss et Clémentine Prieur. Shapley effects for sensitivity analysis with correlated inputs: Comparisons with Sobol' indices, numerical estimation and applications. *International Journal for Uncertainty Quantification*, 9(5): 493–514, 2019. doi: 10.1615/Int.J.UncertaintyQuantification.2019028372.

Jay Jacobs. Analyzing Ponemon cost of data breach. Data Driven Security, 2014.

N. Karimi, E. Salavati et F. Shokrollahi. Climate-conditioned cascade modeling for multi-peril reinsurance: Analysis and controlled numerical applications. Prépublication arXiv:2608.09456v1 [q-fin.RM], 2026. Déposée le 10 août 2026.

David Kempe, Jon Kleinberg et Éva Tardos. Maximizing the spread of influence through a social network. Dans *Proceedings of the Ninth ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 137–146, 2003.

Justin Kher, Olivier Lopez et Hugo Rapior. Cyber incident reports: extrapolating severity using neural networks, 2023. Document de travail. https://detralytics.com/en/publications/cyber-incident-reports-extrapolating-severity-using-neural-networks/.

Wassily Leontief. Quantitative input and output relations in the economic system of the United States. *The Review of Economics and Statistics*, 18(3), 1936.

David X. Li. On default correlation: A copula function approach. *The Journal of Fixed Income*, 9(4):43–54, 2000.

Yang Lu, Yaodi Zhang et Wenjun Zhu. Cyber risk modeling: a discrete multivariate count process approach. *Scandinavian Actuarial Journal*, 2024(6), 2024.

Thomas Maillart et Didier Sornette. Heavy-tailed distribution of cyber-risks. *The European Physical Journal B*, 75(3): 357–364, 2010.

Charles F. Manski. Nonparametric bounds on treatment effects. *American Economic Review*, 80(2):319–323, 1990.

Charles F. Manski. *Identification Problems in the Social Sciences*. Harvard University Press, 1995.

Marsh. European Cyber Claims Report 2025. Rapport technique, Marsh, avril 2025. https://www.marsh.com/en-gb/services/cyber-risk/insights/cyber-claims-report-2025.html.

Alexander J. McNeil, Rüdiger Frey et Paul Embrechts. *Quantitative Risk Management: Concepts, Techniques and Tools*. Princeton University Press, revised édition, 2015.

Johanna Nešlehová, Paul Embrechts et Valérie Chavez-Demoulin. Infinite mean models and the LDA for operational risk. *Journal of Operational Risk*, 1(1):3–25, 2006.

OpinionWay et CESIN. 11e baromètre de la cybersécurité des entreprises. Rapport technique, Club des Experts de la Sécurité de l'Information et du Numérique, 1 2026. En-

quête auprès des entreprises membres. https://www.opinion-way.com/fr/publications/barometre-de-la-cybersecurite-des-entreprises-francaises-2026-22229/.

Art B. Owen. Sobol' indices and Shapley value. *SIAM/ASA Journal on Uncertainty Quantification*, 2(1):245–251, 2014. doi: 10.1137/130936233.

Harry H. Panjer. Recursive evaluation of a family of compound distributions. *ASTIN Bulletin*, 12(1):22–26, 1981.

Chen Peng, Maochao Xu, Shouhuai Xu et Taizhong Hu. Modeling and predicting extreme cyber attack rates via marked point processes. *Journal of Applied Statistics*, 44(14):2534–2563, 2017. doi: 10.1080/02664763.2016.1257590. Première publication en ligne en 2016.

Anna Ranguin. Modélisation du risque cyber des entreprises françaises, 2024. Mémoire d'actuariat, ISUP, Institut des actuaires. Déposé sur https://www.ressources-actuarielles.net.

Hugo Rapior et Kélian Kaddouri. Rapport LUCY 2026 : analyse actuarielle du marché français de la cyberassurance. Rapport technique, Nexialog Consulting, Paris, juin 2026. Analyse de l'édition 2026 de l'étude LUCY de l'AMRAE, portant sur l'exercice 2025. https://www.nexialog.com/publication/rapport-lucy-2026-analyse-marche-cyberassurance/.

Lloyd S. Shapley. A value for n-person games. Dans Harold W. Kuhn et Albert W. Tucker, éditeurs, *Contributions to the Theory of Games, Volume II*, numéro 28 de la collection Annals of Mathematics Studies, pages 307–317. Princeton University Press, 1953.

Pavel V. Shevchenko et Mario V. Wüthrich. The structural modelling of operational risk via Bayesian inference: combining loss data with expert opinions. *The Journal of Operational Risk*, 1(3):3–26, 2006. doi: 10.21314/JOP.2006.016. Prépublication : https://arxiv.org/abs/0904.1067.

Richard L. Smith. Estimating tails of probability distributions. *The Annals of Statistics*, 15(3):1174–1207, 1987.

Eunhye Song, Barry L. Nelson et Jeremy Staum. Shapley effects for global sensitivity analysis: Theory and computation. *SIAM/ASA Journal on Uncertainty Quantification*, 4(1):1060–1083, 2016. doi: 10.1137/15M1048070.

Elie Tamer. Partial identification in econometrics. *Annual Review of Economics*, 2:167–195, 2010. doi: 10.1146/annurev.economics.050708.143401.

Dirk Tasche. Risk contributions and performance measurement. Rapport technique, Zentrum Mathematik, TU München, 1999. https://www.semanticscholar.org/paper/002fb9788abeab17fe54a7703303c95a252d05a7.

UK Government, Department for Science, Innovation and Technology. Survey on the state of UK cyber insurance market. Rapport technique, DSIT, janvier 2025. https://www.techuk.org/resource/survey-on-the-state-of-uk-cyber-insurance-market.html.

Union européenne. Règlement (UE) 2016/679 du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD). Journal officiel de l'Union européenne, 2016. https://eur-lex.europa.eu/eli/reg/2016/679/oj.

Union européenne. Règlement (UE) 2022/2554 du 14 décembre 2022 sur la résilience opérationnelle numérique du secteur financier (DORA). Journal officiel de l'Union européenne, 2022a. Applicable depuis le 17 janvier 2025. https://eur-lex.europa.eu/eli/reg/2022/2554/oj.

Union européenne. Directive (UE) 2022/2555 du 14 décembre 2022 concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS 2). Journal officiel de l'Union européenne, 2022b. Abroge la directive (UE) 2016/1148. https://eur-lex.europa.eu/eli/dir/2022/2555/oj.

Union européenne. Directive (UE) 2022/2557 du 14 décembre 2022 sur la résilience des entités critiques. Journal officiel de l'Union européenne, 2022c. https://eur-lex.europa.eu/eli/dir/2022/2557/oj.

Union européenne. Règlement (UE) 2024/2847 du 23 octobre 2024 concernant des exigences horizontales de cybersécurité pour les produits comportant des éléments numériques (*cyber resilience act*). Journal officiel de l'Union européenne, 2024. Applicable à partir du 11 décembre 2027. https://eur-lex.europa.eu/eli/reg/2024/2847/oj.

Union européenne. Règlement (UE) 2024/1623 modifiant le règlement 575/2013 (CRR III), 2024. Risque opérationnel, articles 312 et suivants. https://eur-lex.europa.eu/eli/reg/2024/1623/oj.

Oldrich Vasicek. The distribution of loan portfolio value. *Risk*, 2002.

Thomas Verma et Judea Pearl. Equivalence and synthesis of causal models. Dans *Proceedings of the Sixth Conference on Uncertainty in Artificial Intelligence*, 1990.

Spencer Wheatley, Thomas Maillart et Didier Sornette. The extreme risk of personal data breaches and the erosion of privacy. *The European Physical Journal B*, 89(1):7, 2016.

Maochao Xu et Lei Hua. Cybersecurity insurance: modeling and pricing. *North American Actuarial Journal*, 23(2):220–249, 2019. doi: 10.1080/10920277.2019.1566076.

Organisation des annexes et matériel complémentaire

Ce mémoire garde en annexe les démonstrations du modèle de cascade (A), celles de la théorie des valeurs extrêmes avec les détails de validation (B), les adaptations par pilier et le cas d'usage (C), le protocole d'élicitation et les relectures de praticiens (D), la table des paramètres et des notations (E), les pistes pour de futurs mémoires (F) et l'inventaire de l'usage de l'intelligence artificielle générative (G).

Le *matériel complémentaire*, qui réunit les pièces justificatives, les compléments de chapitres et les diagnostics secondaires, est déposé de façon pérenne sur Zenodo, sous l'identifiant `10.5281/zenodo.22874524` : `https://doi.org/10.5281/zenodo.22874524`

Le renvoi numéroté S4.6, au chapitre des données, conduit au supplément de la version rédigée pour l'ENSAE, déposé au même identifiant dans le fichier `supplement_rapport_ENSAE.pdf`.

A

Démonstrations du modèle de cascade

Les propriétés énoncées à la section 5.8 se démontrent avec les notations du chapitre 5 : $P = \{1, \dots, 5\}$, $W \in [0,1]^{P \times P}$ avec $W_{jj} = 0$, et la cascade indépendante de la définition 5.1.

Forme réduite et descendance espérée (proposition 5.2)

Démonstration. Par définition du produit matriciel, la somme sur les marches dirigées $a = v_0 \to v_1 \to \cdots \to v_n = k$ de $\prod_t W_{v_{t-1}v_t}$ vaut $(W^n)_{ak}$. La série $\sum_{n \geq 0} W^n$ est la série de Neumann de W ; elle converge vers $(I - W)^{-1}$ si et seulement si $\rho(W) < 1$.

Soit $C_n(a,k)$ le nombre de chemins vivants de longueur n de a vers k, un chemin étant une marche sans pilier répété. Les arêtes d'un chemin sont distinctes, donc indépendantes, et un chemin est vivant avec probabilité $\prod_t W_{v_{t-1}v_t}$. Ce n'est pas le cas d'une marche qui repasse par une arête, celle-ci n'étant tirée qu'une fois. Les chemins formant une partie des marches, $\mathbb{E}\, C_n(a,k) \leq (W^n)_{ak}$. L'indicatrice $\mathbf{1}\{k \in S_a\}$ vaut 1 dès qu'*au moins un* chemin vivant relie a à k, donc $\mathbf{1}\{k \in S_a\} \leq \sum_{n \geq 0} C_n(a,k)$ presque sûrement. En prenant l'espérance puis en sommant sur k,

$$\mathbb{E}\,|S_a| = \sum_k \mathbb{P}(k \in S_a) \leq \sum_k \big((I-W)^{-1}\big)_{ak} = \big[(I-W)^{-1}\mathbf{1}\big]_a .$$

L'inégalité est stricte dès que la série compte des marches qui répètent un pilier, ou deux chemins distincts vers un même pilier : l'écart mesure ces deux contributions. □

Sous-criticité par normalisation (proposition 5.3)

Démonstration. Par construction (5.4), $W = (g/s_{\max})\,T \geq 0$ et, pour toute ligne j, $\sum_k W_{jk} = (g/s_{\max}) \sum_k t_{jk} \leq (g/s_{\max})\, s_{\max} = g$, puisque $s_{\max}$ est la plus grande somme de ligne de T. Pour une matrice à coefficients positifs, le rayon spectral est majoré par toute norme d'opérateur subordonnée, en particulier la norme infinie, qui est le maximum des sommes de lignes : $\rho(W) \leq \|W\|_\infty = \max_j \sum_k W_{jk} \leq g \leq 1$. Pour $g < 1$, on a $\rho(W) < 1$ et la série de Neumann converge donc et $(I-W)^{-1} = \sum_{n \geq 0} W^n$ existe, à coefficients positifs. À la borne $g = 1$ du domaine, cette majoration ne donne que $\rho(W) \leq 1$: la convergence tient alors par la valeur calculée de $\rho(W)$, strictement inférieure à 1 (chapitre 5). □

Loi exacte de l'ensemble atteint (proposition 5.4)

Démonstration. Fixons $A \ni a$. L'événement $\{S_a = A\}$ est l'intersection de deux événements portant sur des arêtes disjointes, donc indépendants. Selon (i), aucune arête ne relie A à son complémentaire (sans quoi S_a dépasserait A) ; selon (ii), a atteint tout A par les seules arêtes internes à A. L'événement (i) ne concerne que les arêtes $j \to k$ avec $j \in A$, $k \notin A$, chacune absente avec probabilité $1 - W_{jk}$ indépendamment ; sa probabilité est $B(A) = \prod_{j\in A, k\notin A}(1 - W_{jk})$. L'événement (ii) ne concerne que les arêtes internes à A ; notons $R(A)$ sa probabilité. Par indépendance, $\mathbb{P}(S_a = A) = R(A)\, B(A)$.

Pour $R(A)$, on partitionne selon le sous-ensemble A' atteint par les arêtes internes. A' contient a, et il est *propre* ($A' \subsetneq A$) si et seulement si A n'est pas atteint tout entier. Sachant que les arêtes internes atteignent exactement A', aucune arête ne va de A' vers $A \setminus A'$: cet événement a pour probabilité $\prod_{j\in A', k\in A\setminus A'}(1 - W_{jk})$ et il est indépendant de la réalisation interne à A'. On somme les probabilités de ces sous-ensembles propres, puis on passe au complémentaire :

$$R(A) = 1 - \sum_{\substack{A' \subsetneq A \\ a \in A'}} R(A') \prod_{j\in A', k\in A\setminus A'} (1 - W_{jk}),$$

avec $R(\{a\}) = 1$. La récursion sur les sous-ensembles emboîtés est finie et détermine R de proche en proche. □

Monotonie stochastique (proposition 5.5)

Démonstration. On construit un *couplage*. Soit (U_{jk}) une famille de variables uniformes sur $[0, 1]$ indépendantes, commune aux deux matrices. Pour une matrice M, déclarons l'arête $j \to k$ vivante si $U_{jk} < M_{jk}$; le graphe obtenu a la bonne loi (arête vivante avec probabilité M_{jk}). Si $W \le W'$ terme à terme, alors $U_{jk} < W_{jk} \Rightarrow U_{jk} < W'_{jk}$: toute arête vivante sous W l'est sous W'. Le graphe sous W est donc un sous-graphe de celui sous W', et l'accessibilité étant croissante par ajout d'arêtes, $S_a(W) \subseteq S_a(W')$ presque sûrement.

Pour toute fonctionnelle φ croissante pour l'inclusion, $\varphi(S_a(W)) \le \varphi(S_a(W'))$ p.s., d'où la domination stochastique et la monotonie de l'espérance et des quantiles. Enfin, pour une perturbation antisymétrique A, l'entrée W_{jk} croît quand W_{kj} décroît : les deux effets jouent en sens contraire sur S_a, la monotonie en A_{jk} n'a plus lieu, et aucune monotonie coordonnée ne garantit l'optimum aux sommets du pavé $\{|A_{jk}| \le t\, S_{jk}\}$. Leur exploration exhaustive reste un contrôle numérique limité. □

Dépendance à l'ordre et co-occurrence (propositions 5.6 et 5.7)

Démonstration. Ordre. Pour une chaîne de deux piliers, $\ell(i, j) = \mathrm{ROOT}_i\, t_{ij}$ et $\ell(j, i) = \mathrm{ROOT}_j\, t_{ji}$: l'invariance par permutation équivaut à $\mathrm{ROOT}_i\, t_{ij} = \mathrm{ROOT}_j\, t_{ji}$. Une invariance valable pour toute

longueur l'impose en particulier aux chaînes de deux piliers, d'où la nécessité. Au-delà de deux piliers, la condition ne suffit pas : même avec T symétrique et des poids d'amorce égaux, $\ell(1,2,3)$ et $\ell(1,3,2)$ diffèrent dès que $t_{12}t_{23} \neq t_{13}t_{32}$. Le barème donne $\mathrm{ROOT}_1\, t_{12} \neq \mathrm{ROOT}_2\, t_{21}$, donc l'ordre de la paire (P1, P2) change la vraisemblance. La différence des criticités arrondies se vérifie séparément dans l'exemple numérique ; elle ne découle pas en général d'une différence de vraisemblance.

Un score additif est une fonction de l'ensemble. Une copule, échangeable ou non, décrit la loi jointe des indicatrices de défaillance, donc elle aussi une fonction de l'ensemble atteint et non de l'ordre d'atteinte. Aucun des deux ne reproduit cette dépendance.

Co-occurrence. La décomposition $W = \frac{1}{2}(W + W^\top) + \frac{1}{2}(W - W^\top) = S + A$ est unique car S est symétrique, A antisymétrique, et cette somme directe est celle des matrices en parties symétrique et antisymétrique.

(i) Pour que j et k soient tous deux atteints depuis une amorce $a \notin \{j,k\}$, il faut au moins deux arêtes vivantes, événement de probabilité $O(\|W\|^2)$. Depuis l'amorce j, le pilier k est atteint par l'arête directe avec la probabilité W_{jk}, et par tout autre chemin, de longueur au moins deux, avec une probabilité $O(\|W\|^2)$; symétriquement depuis l'amorce k. En sommant sous l'amorce uniforme, la probabilité de co-occurrence vaut $r\,(W_{jk} + W_{kj}) + O(\|W\|^2)$, et le terme d'ordre un, $2r\,S_{jk}$, est le même pour W et pour $W^\top$.

(ii) Deux contre-exemples suffisent. Sous une amorce non uniforme de poids r_a, le terme d'ordre un devient $r_j W_{jk} + r_k W_{kj}$, qui change par transposition dès que $r_j \neq r_k$ et $W_{jk} \neq W_{kj}$. Sous l'amorce uniforme, prenons trois piliers avec $W_{12} = W_{13} = w > 0$ et toutes les autres entrées nulles. Sous W, une amorce en 1 touche 2 et 3 ensemble avec la probabilité w^2, si bien que la paire $\{2,3\}$ co-occurre avec la probabilité $r\,w^2 > 0$. Sous $W^\top$, les seules arêtes vont de 2 et de 3 vers 1, et aucun sinistre ne touche 2 et 3 ensemble. Les deux matrices ont la même partie symétrique : la co-occurrence d'ordre deux distingue la fourche du collisionneur, ce qui est la structure en V de l'identification des graphes causaux (Verma et Pearl, 1990).

(iii) Un changement de signe de A modifie la loi de l'ensemble atteint, donc la loi de la perte et le SCR en général ; la section 5.9 en donne la mesure sur la matrice publiée. □

Efficience de la valeur de Shapley

Le chapitre 9 attribue le surcoût de capital aux piliers par la valeur de Shapley, dont les parts somment à cent. Cette somme est la propriété d'efficience (Shapley, 1953). Elle permet de présenter l'attribution comme une *partition* du surcoût, et non comme une pondération arbitraire.

Proposition A.1 (Efficience)**.** *Soit v une fonction caractéristique sur $\{1,\dots,n\}$ avec $v(\emptyset) = 0$, et*

$$\varphi_i \;=\; \frac{1}{n} \sum_{u \subseteq \{1,\dots,n\} \setminus \{i\}} \binom{n-1}{|u|}^{-1} \big[v(u \cup \{i\}) - v(u) \big].$$

Alors $\sum_{i=1}^{n} \varphi_i = v(\{1,\dots,n\})$.

Démonstration. La démonstration repose entièrement sur la réécriture du poids. Pour $|u| = s$,

$$\frac{1}{n}\binom{n-1}{s}^{-1} \;=\; \frac{1}{n}\cdot\frac{s!\,(n-1-s)!}{(n-1)!} \;=\; \frac{s!\,(n-s-1)!}{n!}, \tag{A.1}$$

de sorte que φ_i est exactement la moyenne, sur les $n!$ permutations de $\{1,\dots,n\}$, de la contribution marginale de i à l'ensemble de ses prédécesseurs. En effet, un sous-ensemble u de cardinal s ne contenant pas i est l'ensemble des prédécesseurs de i dans exactement $s!\,(n-s-1)!$ permutations : $s!$ ordres pour les éléments de u, puis $(n-s-1)!$ pour ceux qui suivent i. En notant Π l'ensemble des permutations et $P_i(\pi)$ les prédécesseurs de i dans π,

$$\varphi_i \;=\; \frac{1}{n!}\sum_{\pi\in\Pi}\big[v\big(P_i(\pi)\cup\{i\}\big) - v\big(P_i(\pi)\big)\big].$$

Sommons alors sur i *à permutation fixée*. Si $\pi = (\pi(1),\dots,\pi(n))$, posons $S_0 = \emptyset$ et $S_j = \{\pi(1),\dots,\pi(j)\}$ pour $1 \le j \le n$. Ainsi $P_{\pi(j)}(\pi) = S_{j-1}$, et la somme des contributions marginales est télescopique :

$$\sum_{i=1}^{n}\big[v\big(P_i(\pi)\cup\{i\}\big) - v\big(P_i(\pi)\big)\big] \;=\; \sum_{j=1}^{n}\big[v(S_j) - v(S_{j-1})\big] \;=\; v(\{1,\dots,n\}) - v(\emptyset),$$

et cette valeur ne dépend pas de π. En moyennant sur les $n!$ permutations, $\sum_i \varphi_i = v(\{1,\dots,n\})$, puisque $v(\emptyset) = 0$. □

L'efficience fait de l'attribution une partition du surcoût, quels que soient l'interaction et son signe : rien n'est perdu ni compté deux fois. Elle ne fait pas de la part d'un joueur une prédiction de ce qu'on obtiendrait en l'écartant seul ; cette prédiction est la contribution marginale, qui ne somme pas au total. Le chapitre 9 tient cette distinction entre les lectures d'un même canal, et l'annexe C donne l'identité correspondante pour chaque colonne. Une part de Shapley est donc une convention d'attribution, pas un budget de remédiation : deux des quatre canaux du modèle sont bornés et non calibrés.

La réécriture (A.1) rend aussi le calcul praticable : elle ramène l'évaluation à une moyenne sur les permutations, forme sur laquelle reposent les algorithmes d'approximation en temps polynomial (Castro et al., 2009 ; Song et al., 2016), nécessaires quand la dimension croît. Avec cinq piliers, les $5!$ permutations et les 2^5 valeurs de v sont énumérées en entier : les valeurs publiées sont exactes au bruit de simulation de v près, sans erreur d'approximation combinatoire.

B

Démonstrations et compléments sur la théorie des valeurs extrêmes

Les preuves de stabilité de la cascade et de la propriété de branchement sont à l'annexe A. Les preuves complètes des théorèmes de valeurs extrêmes sont données par Embrechts et al. (1997) ; nous n'en rappelons que les arguments.

B.1 Théorème de Fisher-Tippett-Gnedenko

La loi limite H des maxima normalisés est max-stable. Pour tout $t > 0$, on a $H^t(x) = H(a_t x + b_t)$, par passage à la limite des maxima de blocs pour les entiers, puis extension en t. En posant $g(x) = -\ln H(x)$, la max-stabilité devient l'équation fonctionnelle $t\, g(x) = g(a_t x + b_t)$. Sa résolution, par la classification des lois max-stables, donne, après normalisation, $g(x) = (1+\xi x)^{-1/\xi}$ sur $1+\xi x > 0$, avec $g(x) = e^{-x}$ si $\xi = 0$. C'est la famille H_ξ.

Le domaine d'attraction se lit ensuite sur la queue de F. On a $F \in \mathrm{DA}(H_\xi)$ avec $\xi > 0$ si et seulement si $\bar{F}$ est à variation régulière d'indice $-1/\xi$, soit $\bar{F}(tx)/\bar{F}(x) \to t^{-1/\xi}$. Les lois lognormale et gamma relèvent du cas $\xi = 0$ (Gumbel). Un support borné ne suffit pas à imposer $\xi < 0$: le domaine Weibull requiert une condition de variation régulière à la borne.

B.2 Théorème de Pickands-Balkema-de Haan

Pour $F \in \mathrm{DA}(H_\xi)$, il existe une fonction positive $a(\cdot)$ telle que, pour $y \geq 0$ tel que $1 + \xi y > 0$, $\lim_{u \to x_F} \bar{F}(u + y\, a(u))/\bar{F}(u) = (1 + \xi y)^{-1/\xi}$. Le quotient vaut $\mathbb{P}(X > u + ya(u) \mid X > u) = 1 - F_u(y\, a(u))$, et sa limite est la survie $\bar{G}_{\xi,1}(y)$ de la GPD. En posant $\sigma(u) = a(u)$, on obtient une approximation GPD des excès ; pour $\xi = 0$, la survie limite vaut e^{-y}.

Le théorème de Pólya s'applique aux fonctions de répartition des excès normalisés $F_u(a(u)y)$, prolongées au-delà de leur support, car leur limite $G_{\xi,1}$ est continue. Le changement de variable redonne la convergence uniforme de l'énoncé du chapitre 4.

B.3 Information de Fisher et normalité asymptotique de l'EMV de la GPD

Nous partons de la log-vraisemblance (4.2), écrite par observation avec $W_i = 1 + \xi Y_i/\sigma$:

$$\ell_i(\xi, \sigma) = -\ln \sigma - \left(1 + \tfrac{1}{\xi}\right) \ln W_i. \tag{B.1}$$

La transformation de probabilité intégrale donne $W_i^{-1/\xi} = \bar{G}(Y_i) \sim \mathcal{U}(0,1)$, donc $W_i \overset{d}{=} U^{-\xi}$ avec $U \sim \mathcal{U}(0,1)$. Quatre moments suffisent alors au calcul :

$$\mathbb{E}[W^{-1}] = \mathbb{E}[U^{\xi}] = \tfrac{1}{1+\xi}, \quad \mathbb{E}[W^{-2}] = \tfrac{1}{1+2\xi}, \quad \mathbb{E}[\ln W] = -\xi\,\mathbb{E}[\ln U] = \xi, \quad \mathbb{E}[(\ln W)^2] = 2\xi^2. \tag{B.2}$$

Ils sont tous finis dès que $\xi > -\frac{1}{2}$, condition qui assure $\mathbb{E}[W^{-2}] < \infty$. En dérivant ℓ_i, on obtient le score

$$\partial_\xi \ell_i = \tfrac{1}{\xi^2} \ln W_i - \left(1 + \tfrac{1}{\xi}\right) \tfrac{Y_i/\sigma}{W_i}, \qquad \partial_\sigma \ell_i = -\tfrac{1}{\sigma} + \left(1 + \tfrac{1}{\xi}\right) \tfrac{\xi Y_i/\sigma^2}{W_i}.$$

L'espérance de l'opposé des dérivées secondes, calculée avec les moments ci-dessus, donne l'information de Fisher par observation

$$\mathcal{I}(\xi, \sigma) = \frac{1}{(1+\xi)(1+2\xi)} \begin{pmatrix} 2 & \sigma^{-1} \\ \sigma^{-1} & \sigma^{-2}(1+\xi) \end{pmatrix}, \qquad \mathcal{I}^{-1} = (1+\xi) \begin{pmatrix} 1+\xi & -\sigma \\ -\sigma & 2\sigma^2 \end{pmatrix}. \tag{B.3}$$

On vérifie que le déterminant de $\mathcal{I}$ vaut $\sigma^{-2}/\big((1+\xi)^2(1+2\xi)\big)$, ce qui reproduit l'inverse indiqué.

La variance asymptotique de $\hat{\xi}$ est le terme $(1,1)$ de $\mathcal{I}^{-1}$ divisé par N_u, soit $(1+\xi)^2/N_u$. Celle de $\hat{\sigma}$ vaut $2\sigma^2(1+\xi)/N_u$. Le terme hors diagonale $-\sigma(1+\xi)$ est négatif : $\hat{\xi}$ et $\hat{\sigma}$ sont corrélés négativement, ce qui interdit de traiter deux stress séparés comme un intervalle de confiance conjoint. La condition $\xi > -\frac{1}{2}$ assure la finitude des moments utilisés dans le score et correspond au régime de normalité asymptotique classique de l'EMV (Smith, 1987), sans rendre finis les moments de la sévérité.

Appliquée à la calibration OpRisk ($\hat{\xi} = 0{,}595$, $N_u = 86$ excès), cette variance donne un écart-type asymptotique $(1+\hat{\xi})/\sqrt{N_u} = 0{,}172$. L'intervalle de Wald à 90 % est alors $[0{,}312\,;\,0{,}878]$. Il est proche de l'intervalle bootstrap $[0{,}304\,;\,0{,}831]$, obtenu par rééchantillonnage et non par un calcul asymptotique : les deux méthodes donnent des intervalles de même ordre.

B.4 Loi asymptotique de l'estimateur de Hill

Supposons $\bar{F}(x) = x^{-1/\xi}\ell(x)$ avec ℓ à variation lente. En notant ici les statistiques d'ordre par ordre décroissant, les log-espacements $\log X_{(i)} - \log X_{(i+1)}$ des k plus grandes statistiques d'ordre sont, à la limite, des variables exponentielles indépendantes d'espérance ξ/i (représentation de Rényi). L'estimateur $\hat{\xi}_{Hill}(k) = \frac{1}{k}\sum_{i=1}^{k}(\log X_{(i)} - \log X_{(k+1)})$ est alors une moyenne empirique d'espé-

rance ξ et de variance ξ^2/k. Le théorème central limite donne

$$\sqrt{k}\left(\hat{\xi}_{Hill}(k) - \xi\right) \xrightarrow{d} \mathcal{N}(0, \xi^2), \tag{B.4}$$

sous la condition de second ordre $\sqrt{k}\,A(n/k) \to 0$, qui contrôle le biais dû à ℓ. L'écart-type $\xi/\sqrt{k}$ décroît en $1/\sqrt{k}$, d'où le compromis biais-variance qui gouverne le choix de k dans le graphique de Hill. Un k trop grand mêle des observations du corps de la loi, un k trop petit donne une variance explosive.

B.5 Formes fermées du quantile de sévérité et de sa moyenne de queue

Ces objets portent sur la sévérité X d'un sinistre unique, et non sur la charge annuelle agrégée. Nous écrivons donc q et $\overline{\mathrm{q}}$, et réservons VaR et TVaR à la mesure de capital. La forme fermée du quantile vient de l'inversion de la survie POT $\bar{F}(x) = \zeta_u(1 + \xi(x-u)/\sigma)^{-1/\xi}$, posée égale à $1-\alpha$.

Pour la moyenne de queue, on écrit $\overline{\mathrm{q}}_\alpha = \frac{1}{1-\alpha}\int_\alpha^1 \mathrm{q}_s\,\mathrm{d}s$. La GPD est stable par franchissement de seuil : l'excès au-delà de tout $v > u$ reste GPD de forme ξ et d'échelle $\sigma + \xi(v-u)$. On en tire $\mathbb{E}[X - \mathrm{q}_\alpha \mid X > \mathrm{q}_\alpha] = \frac{\sigma + \xi(\mathrm{q}_\alpha - u)}{1-\xi}$ pour $\xi < 1$, puis (4.4) en ajoutant q_α. Pour $\xi \geq 1$, on a $\int_u^\infty \bar{F} = \infty$ et la moyenne de queue diverge. La calibration PRC, avec $\hat{\xi} = 1{,}033 > 1$, est dans ce cas : la moyenne de queue diverge, mais tout quantile de niveau inférieur à un reste calculable. Le plafond de sévérité PRC est une hypothèse économique ; il rend aussi les moments finis.

B.6 Hill contre maximum de vraisemblance

L'estimateur de Hill (Hill, 1975) estime l'indice de queue à partir des k plus grandes statistiques d'ordre $X_{(1)} \leq \cdots \leq X_{(n)}$, sans ajuster de loi :

$$\hat{\xi}_{\mathrm{Hill}}(k) = \frac{1}{k}\sum_{i=1}^{k} \ln X_{(n-i+1)} - \ln X_{(n-k)}. \tag{B.5}$$

Contrairement au maximum de vraisemblance sur la GPD, qui estime ξ et σ ensemble dans le cadre de Pickands-Balkema-de Haan, il est asymptotiquement valable pour une queue régulièrement variable et ne donne pas seul d'échelle GPD (Beirlant et al., 2004). Son compromis biais-variance est piloté par k : trop petit, il est instable ; trop grand, il peut intégrer des observations hors du régime asymptotique, et son biais peut croître (Embrechts et al., 1997 ; Beirlant et al., 2004).

Le diagnostic de Hill utilise le seuil d'ordre, dernier montant sous le seuil POT, tandis que le chapitre 4 utilise le seuil POT fixé. Cela explique l'écart entre les deux valeurs de Hill, pas celui entre Hill et l'EMV. Sur le périmètre cyber × finance, le graphique de Hill (figure B.1) montre une croissance de l'estimateur avec k, de $\hat{\xi} \approx 0{,}5$ pour k faible à $\hat{\xi} \approx 1{,}8$ pour $k = 200$. La référence EMV (0,595) est compatible avec la bande asymptotique de Hill pour k de 2 à 25, puis en sort pour tout $k \geq 26$. À $k = 86$, Hill vaut 1,42, soit 138,6 % au-dessus de l'EMV.

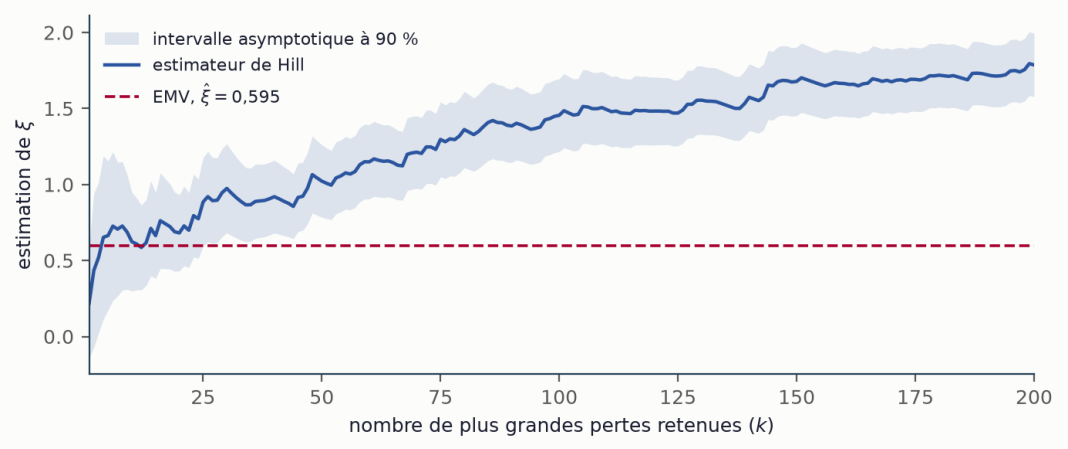


FIGURE B.1. Graphique de Hill avec intervalle de confiance asymptotique à 90 % sur OpRisk Global. La référence du maximum de vraisemblance ($\hat{\xi} \approx 0{,}595$, pointillés rouges) n'est compatible avec l'estimateur de Hill que pour $k \leq 25$. Au-delà, la dérive est compatible avec un biais à seuil fini, sans suffire à en identifier la cause.

Dire que Hill est biaisé en échantillon fini est vrai en général, mais cela relève de l'argument d'autorité. Cela ne dit pas si cet écart, sur ces données, vient du biais ou d'un désaccord réel. L'enjeu est pourtant réel. À $\hat{\xi} = 0{,}595$, la variance de la sévérité est infinie mais l'espérance existe. À $\hat{\xi} = 1{,}42$, l'espérance cesse d'exister, mais la perte annuelle et ses quantiles restent définis. La simulation suivante vérifie si cet écart d'estimateurs est compatible avec le modèle retenu.

Nous simulons 2 000 échantillons sous le modèle publié, c'est-à-dire le corps observé sous le seuil et une queue GPD de paramètres $(\hat{\xi}, \hat{\sigma}) = (0{,}595\,; 57{,}97)$ au-dessus. Nous appliquons à chacun le même estimateur de Hill, aux mêmes k. Si un monde où ξ vaut 0,595 reproduit les valeurs observées, celles-ci ne prouvent rien : elles sont ce qu'un tel ξ produit.

k	$\hat{\xi}_{\text{Hill}}$ observé	simulé (moyenne)	intervalle simulé à 90 %
30	0,974	0,835	[0,620 ; 1,083]
50	1,022	0,987	[0,787 ; 1,195]
86	1,421	1,423	[1,249 ; 1,598]
91	1,403	1,405	[1,241 ; 1,570]
120	1,483	1,484	[1,360 ; 1,610]
200	1,786	1,787	[1,713 ; 1,863]

Les six valeurs observées tombent dans l'intervalle simulé, et les moyennes simulées sont proches des valeurs observées, sauf pour $k = 30$, où l'écart est plus net. L'écart de 138,6 % est donc compatible avec le modèle simulé. C'est ce que donne Hill sur des pertes brutes, décalées du seuil, pour un échantillon de cette taille. Les données ne contredisent pas la calibration publiée : elles lui sont compatibles par un troisième chemin, après Anderson-Darling et Kolmogorov-Smirnov.

Ces diagnostics restent conditionnels au modèle simulé. Un plateau stable sur le tracé de Hill serait un argument de choix du seuil, alors qu'ici l'estimateur croît sans s'arrêter, de 0,97 à $k = 30$ jusqu'à 1,79 à $k = 200$. Il monte à mesure que l'on descend dans le corps de la loi. Le balayage de seuil va dans l'autre sens, puisque $\hat{\xi}$ décroît de 0,60 à 0,51 quand on remonte dans la queue. Ces

dérives ne suffisent pas à exclure un indice de queue de 1,42 dans une autre famille compatible avec l'échantillon.

La calibration sur la PRC, par la conversion de Jacobs, donne $\hat{\xi}_{\text{PRC}} = 1{,}03$ (seuil $u = 4{,}18$ M€, 2 258 excès), supérieur à $\hat{\xi}_{\text{OpRisk}} = 0{,}595$. Les intervalles à 90 % ne se chevauchent pas. Un indice supérieur à un correspond à une espérance de sévérité infinie, situation que la littérature du risque opérationnel traite explicitement (Nešlehová et al., 2006).

Nous posons un plafond de sévérité de 40 M€, ancré sur une capacité de réassurance cyber. Ce choix assure des moments finis ; il n'est pas nécessaire à l'existence du quantile simulé. Ce plafond ne s'applique qu'à la PRC, la calibration OpRisk ($\xi < 1$) restant non plafonnée. L'écart entre les deux calibrations ne mesure pas une différence de risque : la sévérité PRC est une puissance du nombre d'enregistrements, et une puissance multiplie l'indice de queue par son exposant (§3.7). Les deux sources confirment le même régime de queue lourde ($\xi > 0$). Aucune ne prime sur l'autre, et leur écart est traité comme une composante de l'incertitude totale.

B.7 Le seuil de la calibration, deux règles écrites

On peut se demander pourquoi *ce* seuil, et ce qu'aurait retenu une règle écrite. Nous appliquons deux règles à dix percentiles candidats, du 70e au 95e. La première retient le plus bas seuil que le test d'adéquation ne rejette pas, puisque descendre gagne des excès. La seconde retient le plus bas seuil au-dessus duquel l'indice de queue cesse de dériver, c'est-à-dire tel que tous les indices estimés plus haut tombent dans son intervalle de confiance à 90 %.

La règle de stabilité retient 19,32 M€ contre 20,03 publiés, soit un écart de −3,5 %, et un quantile supérieur de 1,5 % à celui qui est publié. Le seuil publié est donc voisin du plus bas seuil au-dessus duquel $\hat{\xi}$ se stabilise. Cette règle fournit un contrôle rétrospectif du seuil publié ; elle n'a pas été préenregistrée avant sa calibration. Le seuil publié est aussi le mieux ajusté du balayage, avec une p-value d'Anderson-Darling de 0,986 contre 0,943 pour le second meilleur candidat. Deux diagnostics sur le même échantillon désignent des points voisins, ce qui n'était pas garanti.

La règle la plus permissive descendrait plus bas et donnerait davantage de capital, ce qui écarte le soupçon d'un choix opportuniste. Elle retient 15,53 M€, soit 22,5 % sous le seuil publié, où le quantile de sévérité vaut 731,0 contre 662,8, soit 10,3 % de plus. Le seuil publié n'est donc pas celui qui maximise le chiffre. Parmi les candidats acceptables, il est du côté qui le minore.

Sur les seuils testés, remonter réduit l'écart-type bootstrap du quantile à 99,5 %, de 578,7 à 137,5 M€, soit une division par 4,2, alors que le nombre d'excès passe de 171 à 29. Au percentile 70, l'indice atteint 1,126 : la moyenne diverge, mais pas le quantile. Ces ajustements changent à la fois la queue estimée et l'effectif. Ils ne démontrent ni la disparition du compromis biais-variance ni l'absence de biais au seuil le plus haut, où 29 excès donnent une incertitude elle-même mal connue. Le choix reste conditionnel à l'adéquation et à la stabilité.

B.8 Backtest hors échantillon, détail des tests

B.8.1 Fréquence et forme de la queue

La binomiale négative l'emporte sur le Poisson hors échantillon, et c'est le résultat le plus net. Les comptes annuels du périmètre ont pour moyenne 24,50 et pour variance 58,55, soit un indice de dispersion de 2,39, sans tendance significative ($-0{,}092$ incident par an, $p = 0{,}7297$). Une loi sans mémoire n'est donc pas mal spécifiée sur ce point.

Sur les douze années notées, un intervalle de prévision annoncé à 90 % en couvre 91,7 % sous la binomiale négative contre 75,0 % sous le Poisson. La couverture ne suffit pas à trancher, puisqu'un intervalle inutilement large peut couvrir sans rien valoir. Le log-score prédictif cumulé pénalise la largeur autant que l'étroitesse, et il désigne le même gagnant : $-41{,}334$ contre $-44{,}388$, soit 3,054 nats sur douze années. Ce résultat favorise la binomiale négative sur les douze années notées, sans mesurer la significativité de son avantage prédictif. Il ne valide pas le facteur de dispersion posé dans le moteur, qui reste distinct des ajustements de ce backtest.

La forme de la queue survit, et ce n'était pas acquis. Chaque ajustement d'origine ne dispose que de vingt à quatre-vingt-dix excès. La transformée de probabilité intégrale des excès de test doit être uniforme si la loi ajustée est la bonne. Elle a pour moyenne 0,532 et le test de Kolmogorov-Smirnov ne la rejette pas ($D = 0{,}100$, $p = 0{,}4087$). L'écart de cette moyenne à 0,500 indique des pertes qui tombent plus haut dans la queue ajustée que prévu, mais il n'est pas significatif, et l'énoncer autrement serait surinterpréter un test qui ne rejette pas. Ce qui est établi est plus modeste et suffit : ces données ne rejettent pas la GPD ; elles ne démontrent pas son adéquation.

B.8.2 Quantiles de sévérité et dérive de l'échelle

Les quantiles sont en revanche dépassés trois fois trop souvent. Sur les 280 pertes notées, le quantile de sévérité annoncé à 99 % par l'apprentissage est franchi huit fois pour 2,8 attendues ($p = 0{,}0078$), et celui à 99,5 % cinq fois pour 1,4 ($p = 0{,}0140$). Le test de dépassement rejette donc aux deux niveaux, là où le test de forme ne rejetait pas. Les deux constats semblent s'opposer, mais ils ne portent pas sur le même objet. La transformée intégrale ne regarde que les excès au-dessus du seuil, donc la queue conditionnelle, alors qu'un quantile combine la forme, le seuil et le taux de dépassement. Ce non-rejet ne localise pas à lui seul le défaut. Le taux observé change aussi : 15,1 % en apprentissage par construction de la règle, 27,1 % hors échantillon, soit un rapport de 1,80 que le test binomial situe à $p = 2{,}35 \cdot 10^{-7}$. La dérive se lit aussi sur le seuil, quantile de l'apprentissage qui passe de 8,56 à 18,20 M€ en onze ans. La médiane annuelle des pertes monte de 13,0 % par an en logarithme ($p = 0{,}0003$). Ces constats motivent une échelle variable, sans exclure un défaut de famille.

Mesurer une dérive ne dit pas ce qu'elle déplace sur le nombre publié. Nous calculons cet effet sur l'échantillon de la chaîne publiée, soit 570 pertes dont 86 excès au-dessus du seuil de 20,03 M€. Un ajustement stationnaire y donne un quantile de sévérité à 99,5 % de 662,78 M€, soit la valeur publiée.

Nous rendons ensuite l'échelle non stationnaire, $\sigma_t = \sigma\, e^{\,b\,(t - t_{\mathrm{ref}})}$ à indice de queue constant, et

l'estimons par maximum de vraisemblance sur les mêmes excès. La dérive de la queue vaut alors 3,40 % par an, d'écart-type 2,47 %, et le rapport de vraisemblance ne la distingue pas de zéro (1,81, $p = 0{,}1786$). Le quantile évalué en fin de période passe à 774,73 M€, soit 112 M€ et 16,9 % de plus. Cette estimation n'a pas de signification statistique propre ; c'est une comparaison conditionnelle, non une borne statistique. Le taux de dépassement est tenu commun aux deux branches ; le faire varier demanderait de réestimer conjointement la loi complète.

La dérive n'est pas la même selon l'endroit de la distribution, ce qui modère le résultat précédent. Le corps dérive de 13,0 % par an quand la queue ne dérive que de 3,40 %, soit un facteur 3,8. Lire la dérive du corps comme une dérive du capital serait donc une erreur d'un facteur voisin de quatre. La contre-épreuve le confirme. Indexer toutes les pertes à la tendance de la médiane, puis rejouer la chaîne à percentile de seuil constant, donne un quantile de 1 870 M€, soit 2,8 fois la référence. L'indice de queue reste sous l'unité (0,68 à la borne haute de l'intervalle de la tendance). L'hypothèse n'est pas écartée par un argument d'existence, mais par la mesure : la dérive du corps se situe à plus de trois écarts-types de celle de la queue.

Une part de la dérive est monétaire. Les montants de la chaîne publiée sont nominaux (chapitre 3). Sur la valeur courante de la même base, qui les corrige d'une inflation implicite de 2,19 % par an, la tendance de la médiane passe de 13,0 à 10,6 % par an et reste significative ($p = 0{,}0021$). L'inflation générale n'en explique que 17 %.

Dans la queue, au même seuil publié désormais franchi par 100 excès, la dérive passe de 3,40 à 3,30 % par an et reste non significative ($p = 0{,}149$). L'inflation monétaire n'en explique donc qu'une faible part, et la dérive de queue ne se distingue pas du bruit sur cet historique. Pour un capital exprimé en euros courants, le sens de l'écart déclaré ne change pas, car une perte ancienne comptée à sa valeur nominale est sous-évaluée, que ce soit par l'inflation ou par une aggravation du risque. Sa lecture reste prudente : la hausse de l'échelle réelle des pertes de queue n'est pas démontrée.

Modéliser la dérive fait tomber l'indice de queue, de 0,5952 à 0,5392, et ce déplacement va en sens contraire. Le mécanisme est simple : regrouper des excès d'années dont les échelles diffèrent fabrique un mélange, et un mélange d'échelles peut faire paraître la queue plus lourde à seuil fini, sans changer nécessairement son indice asymptotique. L'ajustement stationnaire attribue ainsi à la forme une part de ce qui relève de la dérive. Les deux écarts du modèle publié sont de sens contraires : l'indice de queue est légèrement prudent quand l'échelle est anti-conservatrice. Ils ne se compensent pas, puisqu'ils ne portent pas sur la même grandeur.

B.8.3 Effet de la dérive sur l'écart entre états

On pourrait affirmer qu'une dérive commune aux deux états de conformité se simplifie dans un rapport, donc que l'écart DORA n'est pas concerné. L'affirmation est exacte pour une variation de la seule échelle de sévérité, et nous l'avons mesurée. Multiplier l'échelle multiplie les deux états par le même facteur, 1,3209 en conforme contre 1,3166 en non conforme, soit un rapport de 0,9968 alors que les niveaux montent de 32 %. Pour cette variation, l'invariance d'échelle du facteur entre états vaut donc à 0,32 % près ; multiplier toutes les pertes laisserait le facteur inchangé.

La dérive mesurée n'est pourtant pas une pure variation d'échelle. La modéliser réattribue à l'échelle ce que l'ajustement stationnaire lisait comme de la forme, et l'indice de queue tombe de 0,5952 à 0,5392. Or c'est la forme qui pèse. La composante de forme déplace seule le facteur de −4,9 %, soit 4,01 écarts-types de simulation, alors que la composante d'échelle ne le déplace que de −0,3 %, sans être résolue. Les deux sont additives, le résidu d'interaction valant 0,05 écart-type. Le facteur entre états passe ainsi de 3,337 à 3,164, un déplacement résolu.

L'écart en euros bouge à peine, mais par compensation et non par insensibilité. Il passe de 14 129 à 13 629 M€, soit −3,5 % pour un écart-type de 733 M€ entre graines, donc un déplacement non résolu. Il serait faux d'en conclure que l'écart est robuste à la sévérité : la composante de forme seule le ramènerait à 10 382 M€ et celle d'échelle seule le porterait à 18 577. L'écart est très sensible à la sévérité prise composante par composante, et presque insensible à la seule combinaison que produit la dérive. Le signe et l'ordre de grandeur sont conservés dans cette variante. Le sens est favorable, puisque l'écart comme le facteur sont plus petits sous la sévérité dérivée, le calage stationnaire donnant ici un écart plus élevé que l'ajustement avec dérive. Le sens dépend donc de la grandeur : le niveau et l'écart entre états ne se déplacent pas ensemble. Cette variante ne fournit aucune borne sur le capital réel.

B.8.4 Charge annuelle agrégée

Les tests précédents portent sur les lois marginales prises séparément, alors que le capital est le quantile de la charge annuelle. Un modèle composé peut avoir deux marginales correctes et un agrégat faux, reproche que cette classe de modèles reçoit le plus souvent. L'observable noté est la somme annuelle des sinistres dépassant le seuil d'apprentissage, qui est l'objet que produit la chaîne publiée puisqu'elle donne une sévérité nulle sous le seuil. La prédictive est obtenue par 200 000 années simulées à chaque origine. Le verdict est négatif. La transformée intégrale de l'agrégat vaut 0,734 en moyenne pour 0,500 attendu, et Kolmogorov-Smirnov la rejette ($D = 0{,}484$, $p = 0{,}0042$). L'intervalle de prévision annoncé à 90 % n'en couvre que 75,0 %, avec trois dépassements de sa borne haute concentrés dans les quatre dernières années notées.

Ce rejet est compatible avec une dérive, sans exclure d'autres défauts de spécification. Une dérive laisse une signature reconnaissable, puisqu'elle ne désaligne pas les premières années notées mais seulement les dernières, l'apprentissage prenant du retard à mesure qu'elle s'accumule. La mesure le montre : la transformée intégrale vaut 0,611 sur les six premières années notées contre 0,857 sur les six dernières, un écart que le test de Mann-Whitney situe à $p = 0{,}0130$. La charge observée passe en moyenne de 363 à 1 255 M€ entre les deux moitiés, quand la médiane prédictive ne passe que de 183 à 248. Aucune limite nouvelle ne s'ajoute donc à l'inventaire du chapitre 10. La même s'y lit plus fort, l'agrégat cumulant la dérive de l'échelle et celle du taux de dépassement, quand chaque marginale n'en portait qu'une.

L'avantage de la binomiale négative sur les comptes se retrouve peu sur la charge annuelle. Notée au score de probabilité continu classé sur la charge agrégée, son avance sur le Poisson tombe à 0,3 %. La charge annuelle est portée par un sinistre unique, donc par la queue de sévérité et non par la surdispersion du comptage. La binomiale négative reste le bon choix, mais elle n'est plus un

déterminant du niveau de capital et il ne faut pas la présenter ainsi.

Reste l'indépendance entre fréquence et sévérité. Le modèle composé retenu la suppose ; des modèles composés dépendants existent aussi. Une dépendance positive pourrait modifier la queue de l'agrégat. Sur l'ensemble de la distribution, la régression du logarithme du montant d'un sinistre sur le nombre d'incidents de son année donne une pente négative et significative, $-0{,}02397$ à $p = 0{,}0419$. Une tendance linéaire en année y est contrôlée pour ne pas confondre l'effet avec la dérive. Sur les seuls excès, qui sont la population que le modèle tire, cette pente tombe à $-0{,}00331$ et cesse d'être significative ($p = 0{,}84$), soit 0,14 de sa valeur. Cette différence est compatible avec un effet de profondeur de collecte : une année à beaucoup d'incidents enregistrés est une année où l'on descend plus bas, et non une propriété du risque. Prise au pied de la lettre sur les excès, sa conséquence sur le quantile de l'agrégat est de l'ordre du pour cent et symétrique en signe. Les corrélations de rang entre le compte annuel et la médiane ou le maximum de l'année ne rejettent rien non plus. Le rang est ici le bon outil : à $\hat{\xi}$ voisin de 0,6, la variance de la sévérité est infinie, si bien qu'un test adossé à la variance de l'agrégat n'aurait pas d'objet.

C

Adaptations par pilier et cas d'usage

La queue de sévérité, l'accumulation par les tiers et la détection appellent des adaptations distinctes. Les diagnostics suivants en comparent les effets sous des hypothèses déclarées ; ils ne calibrent pas les mécanismes par pilier. Le classement peut changer selon l'assignation des queues.

C.1 Queue de sévérité par pilier

Une seule queue ξ est appliquée aux cinq piliers. La queue est pourtant hétérogène selon la catégorie Bâle. Sur la table recalculée pour ce travail, ξ varie de 0,87 (*Employment*) à 1,37 (*Execution, Delivery & Process Management*), soit une dispersion de 0,50. L'hétérogénéité est un fait, son assignation aux piliers n'en est pas un. Les catégories Bâle décrivent la nature de la perte, pas les domaines de contrôle de DORA, et la plus proche des TIC (*Business Disruption & System Failures*) ne compte que 111 observations, sous le seuil d'estimation de 150. Nous ne posons donc pas $\xi_j = f(\text{pilier})$. Nous suivons la logique du chapitre 8 : chaque pilier reçoit l'une des cinq queues observées, nous énumérons les 120 assignations, et le besoin de capital est borné. Pour isoler l'effet de l'hétérogénéité, les cinq queues sont centrées sur la valeur de référence.

Même à moyenne des queues fixe, donner à chaque pilier sa propre queue relève le besoin de capital de +55 % à +96 %. Cet effet tient à la convexité. La VaR croît plus vite que linéairement en ξ, de sorte qu'une queue lourde sur un pilier n'est pas compensée par une queue légère ailleurs. Une queue commune sous-estime ainsi le capital, ce qui justifie de lire le niveau en bande. Le classement résiste : le pilier de tête reste dominant dans 83 % des 30 assignations tirées parmi les 120, sans être invariant (figure C.1).

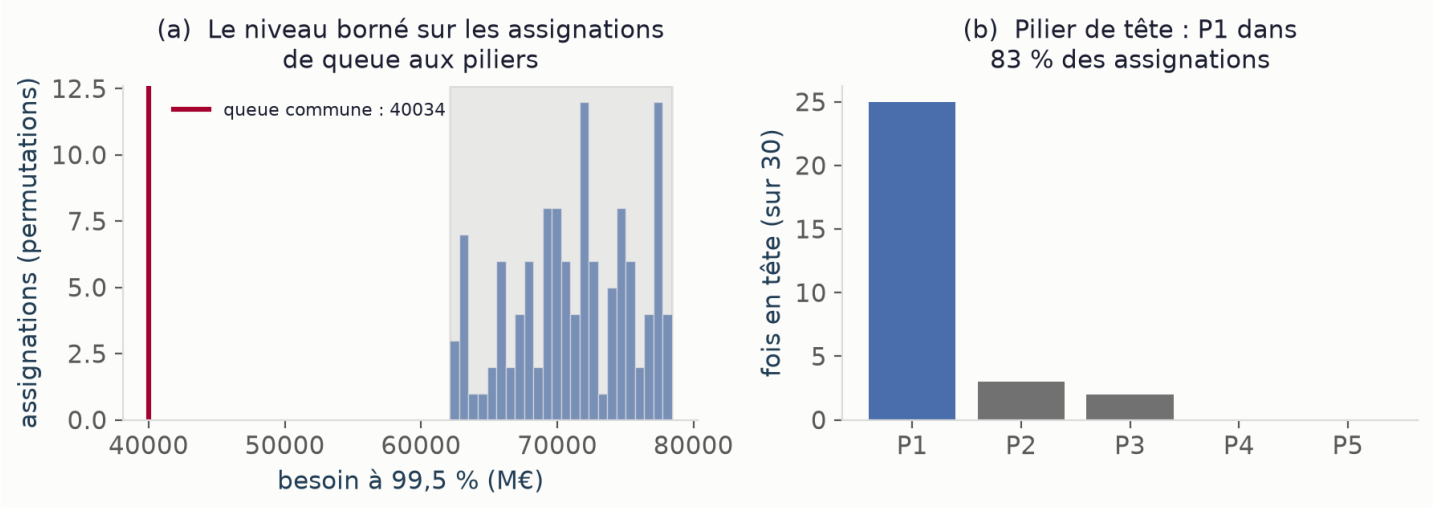


FIGURE C.1. Queue de sévérité par pilier. (a) Besoin de capital borné sur les 120 assignations des queues observées aux piliers ; une queue commune (trait) est en bas de la bande. (b) Le pilier de tête peut changer selon l'assignation ; les positions affichées sont celles du diagnostic.

C.2 PILIER DES TIERS ET ACCUMULATION

P4 n'est pas un nœud de cascade comme les autres. La défaillance d'un prestataire partagé dégrade plusieurs piliers à la fois, par dépendance commune, au lieu de se propager de proche en proche. C'est le mécanisme de MOVEit, où 191 victimes tombent d'un seul choc *(voir le Matériel Complémentaire en ligne)*. Nous lui substituons un *choc commun* : lorsque l'incident commence en P4, chaque autre pilier est inclus indépendamment avec une probabilité ω, au lieu d'une propagation dirigée.

Le choc commun produit des co-occurrences sans direction. Les incidents chez un prestataire partagé motivent ce mécanisme, mais ne calibrent ni son intensité au sein d'une entité ni la partie symétrique S de la décomposition $W = S + A$. Celle-ci reste posée à dire d'expert (chapitre 8). La concentration du nuage sert d'ancrage au scénario ; elle ne mesure pas une probabilité de transmission entre piliers.

L'intensité ω n'est pas identifiée au sein d'une entité isolée, car le *batch* observé est un phénomène de portefeuille. Nous la bornons sur $[0, \gamma]$, où $\gamma = 0{,}68$ est la concentration du nuage déjà retenue. Le besoin de capital se lit alors en bande. À $\omega = \gamma$, une dépendance partagée emporte en moyenne 3,7 piliers d'un coup, soit +19 % de besoin de capital par rapport au traitement en nœud de cascade.

Dans ce scénario, le choc commun augmente la fréquence des incidents multi-piliers : la probabilité qu'un incident P4 touche au moins trois piliers passe de 0,22 avec la cascade à 0,90 avec le choc commun (figure C.2). Ce calcul compare les ensembles atteints au cours d'un incident, sans estimer les délais entre défaillances.

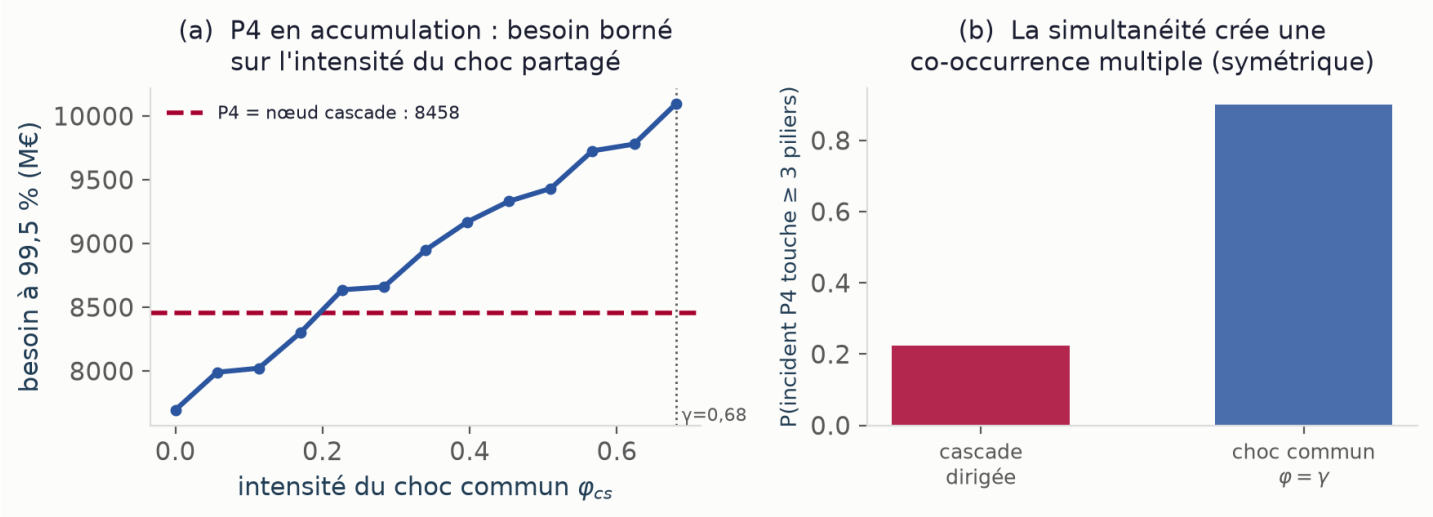


FIGURE C.2. Le pilier des tiers en accumulation. (a) Besoin de capital borné sur l'intensité du choc partagé $\omega \in [0, \gamma]$, comparé au traitement de P4 en nœud de cascade (trait). (b) Probabilité de toucher plusieurs piliers au cours d'un incident amorcé en P4, selon le mécanisme retenu. Le caractère commun du choc ne suffit pas à identifier son intensité.

C.2.1 Seuil de déclenchement et dépendance de queue

Deux questions se séparent ici : celle de la marge, et celle de la dépendance. Le déclenchement d'un pilier est un franchissement de seuil,

$$\{\text{pilier } j \text{ déclenché}\} \;=\; \{X_j \geq K_j\}, \qquad K_j = F^{-1}(1 - p_j), \tag{C.1}$$

et pour P_4, $p_4 = 0{,}151$ donne $K_4 = 1{,}03$. La loi F de la latente n'y sert que de normalisation. Par construction, $\mathbb{P}(X_j \geq K_j) = p_j$ quelle que soit F continue et strictement croissante, donc le choix de F ne porte aucune information sur la fréquence de déclenchement. La queue lourde du capital se trouve dans la sévérité (GPD, chapitre 4), pas dans ce seuil. Une marge normale est une normalisation à copule et probabilités fixées, pas une validation du modèle.

L'accumulation est gouvernée par la dépendance de queue supérieure de la copule C qui lie les latentes,

$$\lambda_U \;=\; \lim_{u \to 1^-} \mathbb{P}\big(U_2 > u \,\big|\, U_1 > u\big) \;=\; \lim_{u \to 1^-} \frac{1 - 2u + C(u,u)}{1 - u}. \tag{C.2}$$

Une copule gaussienne non dégénérée vérifie $\lambda_U = 0$ pour une corrélation strictement inférieure à un. La copule de Gumbel de paramètre $\theta > 1$ donne

$$\lambda_U^{\text{Gumbel}} \;=\; 2 - 2^{1/\theta}, \tag{C.3}$$

soit 0,53 pour le $\theta = 1{,}8$ retenu ailleurs dans ce travail. Retenir une copule gaussienne ici sous-estimerait donc le co-extrême, en contradiction avec ce choix.

Nous ne tranchons pas la copule. Nous lisons le co-déclenchement en bande, à τ de Kendall égal, entre le plancher gaussien et le haut de Gumbel. La fréquence marginale d'un pilier reste $p_4 = 0{,}15$ dans les deux cas, car la copule ne change pas combien un pilier bascule seul, mais s'ils basculent *ensemble*. Seul le co-extrême diverge : la probabilité que les cinq piliers tombent

avec P4 passe de 0,17 pour la gaussienne à 0,39 pour Gumbel, soit un facteur 2,3. C'est le scénario MOVEit que la queue gaussienne manque (figure C.3). Le co-déclenchement d'un autre pilier tient dans [0,48 ; 0,58], sous la borne $\gamma = 0{,}68$ du choc commun, qui reçoit ainsi une origine structurelle. Tout est exprimé par pilier, c'est-à-dire en nombre de piliers de l'entité plutôt qu'en fraction de portefeuille. La vue inter-clients, avec les centaines d'entités victimes de MOVEit, relèverait d'une loi de Vasicek en dimension entité et sort du besoin de capital par entité.

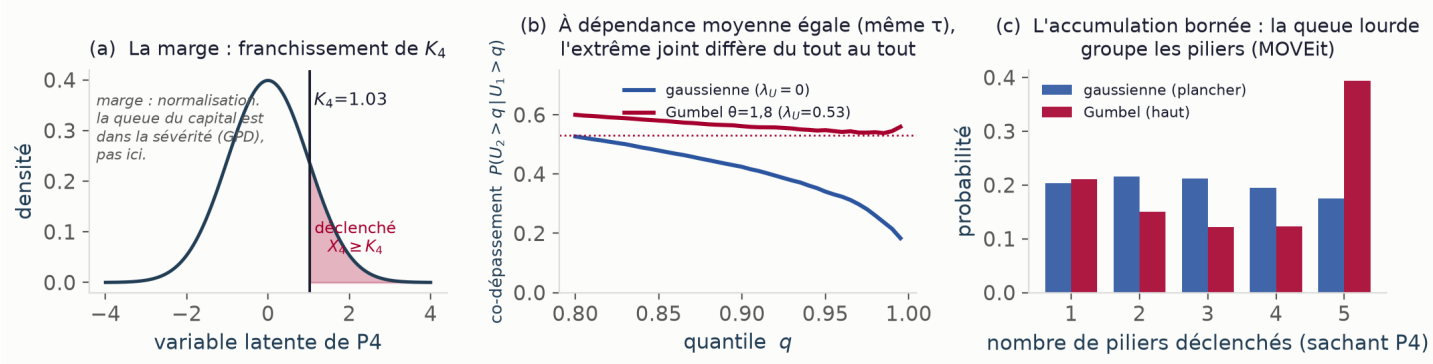


FIGURE C.3. Le seuil de P4 et l'accumulation bornée. (a) La marge : franchissement de K_4, où la normale n'est qu'une normalisation. (b) À dépendance moyenne égale, le co-dépassement s'effondre vers 0 pour la gaussienne mais plafonne à 0,53 pour Gumbel. (c) L'accumulation par pilier, Gumbel concentrant la masse sur les cinq piliers groupés.

C.2.2 Déclenchement comme temps d'arrêt

Le seuil z^* est jusqu'ici un niveau statique. Si le facteur tiers est un processus continu $(Z_t)_{t\geq 0}$ adapté à une filtration $(\mathcal{F}_t)$, le déclenchement devient un temps de premier passage,

$$\tau \;=\; \inf\{\, t \geq 0 \;:\; Z_t \geq z^* \,\}, \tag{C.4}$$

qui est un temps d'arrêt, puisque $\{\tau \leq t\} = \{\sup_{s\leq t} Z_s \geq z^*\} \in \mathcal{F}_t$.

Proposition C.1 (Loi du délai de déclenchement)**.** *Si (Z_t) est un mouvement brownien standard issu de 0 et $z^* > 0$, alors pour tout horizon $T > 0$*

$$\mathbb{P}(\tau \leq T) \;=\; 2\,\Phi\!\left(-\frac{z^*}{\sqrt{T}}\right) \;=\; 2\,\mathbb{P}(Z_T \geq z^*). \tag{C.5}$$

Démonstration. C'est le principe de réflexion. Par symétrie du mouvement brownien après τ, on a $\mathbb{P}(\tau \leq T,\; Z_T < z^*) = \mathbb{P}(\tau \leq T,\; Z_T > z^*) = \mathbb{P}(Z_T > z^*)$, la dernière égalité tenant car $\{Z_T > z^*\} \subset \{\tau \leq T\}$. En sommant les deux événements disjoints, $\mathbb{P}(\tau \leq T) = 2\,\mathbb{P}(Z_T > z^*) = 2\,\Phi(-z^*/\sqrt{T})$. □

La lecture dynamique est le double de la lecture statique $\mathbb{P}(Z_T \geq z^*)$, puisqu'elle compte tous les franchissements survenus avant l'horizon, et pas seulement la position finale. À $\rho = 0{,}50$, la probabilité de déclenchement de P4 en moins d'un an est de 0,14, pour un délai médian de l'ordre de cinq ans. À $\rho = 0{,}75$, elle monte à 0,23, pour un médian d'environ trois ans (figure C.4).

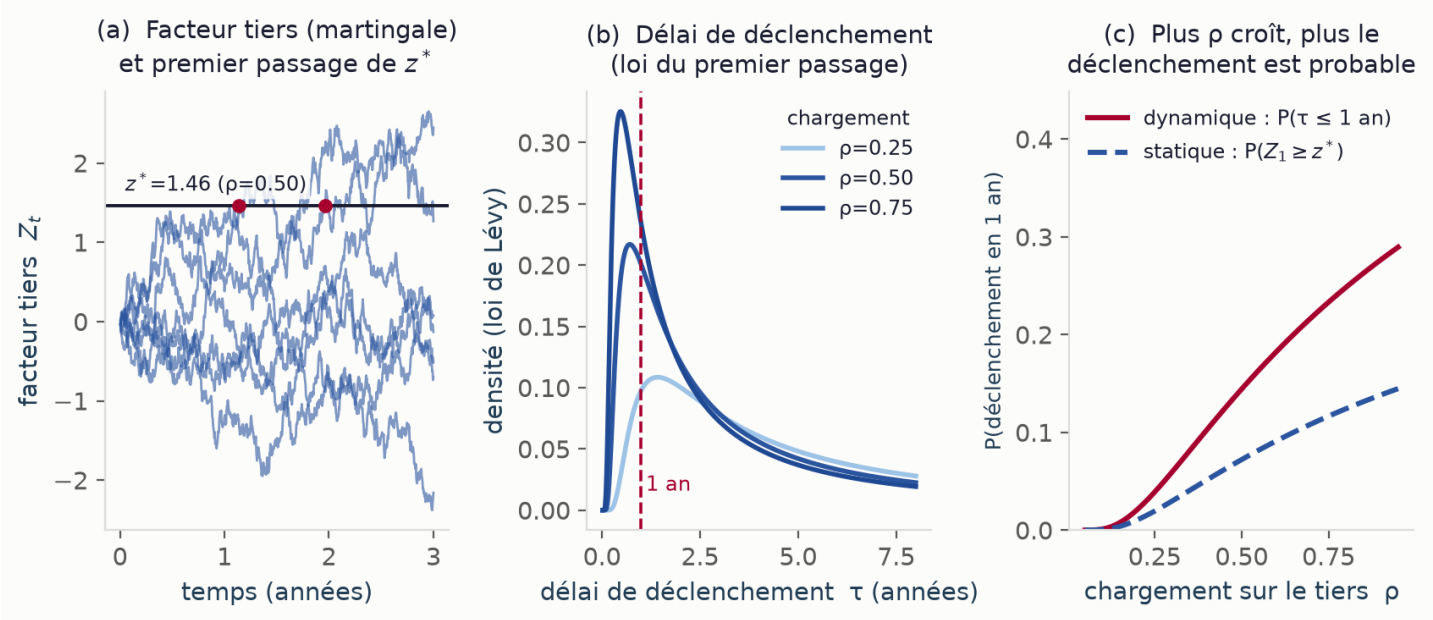


FIGURE C.4. Le déclenchement de P4 comme temps d'arrêt. (a) Le facteur tiers (martingale) et le premier passage de z^*. (b) La loi du délai de déclenchement. (c) La lecture dynamique $\mathbb{P}(\tau \leq 1 \text{ an})$ vaut environ le double de la statique.

Le principe de réflexion utilise la propriété de Markov forte et la symétrie des accroissements du brownien ; la propriété de martingale seule ne suffit pas. La forme de Dirichlet du chapitre 7 est un objet distinct. Aucun changement de mesure n'intervient. Le cadre complet est déporté *(voir le Matériel Complémentaire en ligne)*. En revanche, le comptage journalier des brèches du secteur financier (2016–2023) se diagnostique par son résidu compensé, qui est une différence de martingale si l'intensité prévisible est bien spécifiée.

Une tendance seule laisse une autocorrélation de +0,26 au premier retard ; une excitation des jours antérieurs la ramène à −0,02, avec un branchement de 0,29, puis de 0,09 sans la semaine MOVEit. Les seuils sont recalibrés par bootstrap avec réestimation et la spécification reste rejetée. Les vulnérabilités du catalogue CISA KEV n'améliorent pas l'ajustement sur 2022–2023 ($p = 0{,}90$), et la faille MOVEit y est ajoutée quatre jours après son pic. Ce diagnostic ne prouve ni causalité ni contagion. Le brownien pur atteint le niveau presque sûrement, mais son délai est d'espérance infinie. Un facteur à retour à la moyenne (Ornstein-Uhlenbeck) donnerait un taux de déclenchement récurrent et fini, plus réaliste pour un facteur systémique. Nous gardons le brownien parce qu'il permet un calcul explicite.

C.2.3 Sous-processus tiers sur donnée ouverte

Descendre P4 au niveau du sous-processus (quel sous-traitant, quelle fonction critique, quelle substituabilité) suppose le registre d'externalisation de DORA. Sa structure est fixée par la norme technique d'exécution (Commission européenne, 2024), mais seules les données de l'entité le renseignent. La donnée ouverte tranche déjà deux points opposés (figure C.5).

La taxonomie fine du tiers y est trop rare. La sous-catégorie « Vendors & Suppliers » d'OpRisk ne compte que 20 incidents en finance, soit 1 % des incidents TIC, et `actor.Partner` du VCDB

en compte 56. Ces effectifs tombent à zéro deux niveaux plus bas, ce qui renvoie au registre. La concentration et l'origine tierces sont en revanche ancrées sur des données européennes officielles, qui permettent de situer deux paramètres jusque-là posés.

— Le premier rapport d'incidents DORA des autorités européennes (Autorités européennes de surveillance (ESAs), 2026) établit que 29 % des 3 383 incidents TIC majeurs de 2025 proviennent d'une défaillance de tiers. P4 est donc une amorce majeure, ce que le classeur posait par jugement ($\texttt{ROOT}[4] = 0{,}90$).

— L'analyse des registres d'externalisation par la BCE (Banque centrale européenne, 2024) montre que plus de 30 % du budget des grandes banques va à 10 fournisseurs, et 50 % du budget critique à 30. Les autorités européennes ont désigné 19 fournisseurs TIC critiques. Ces chiffres motivent le scénario d'accumulation, sans identifier ω ni mesurer la charge de facteur $\gamma = 0{,}68$. Concentration du marché et probabilité de choc sont distinctes.

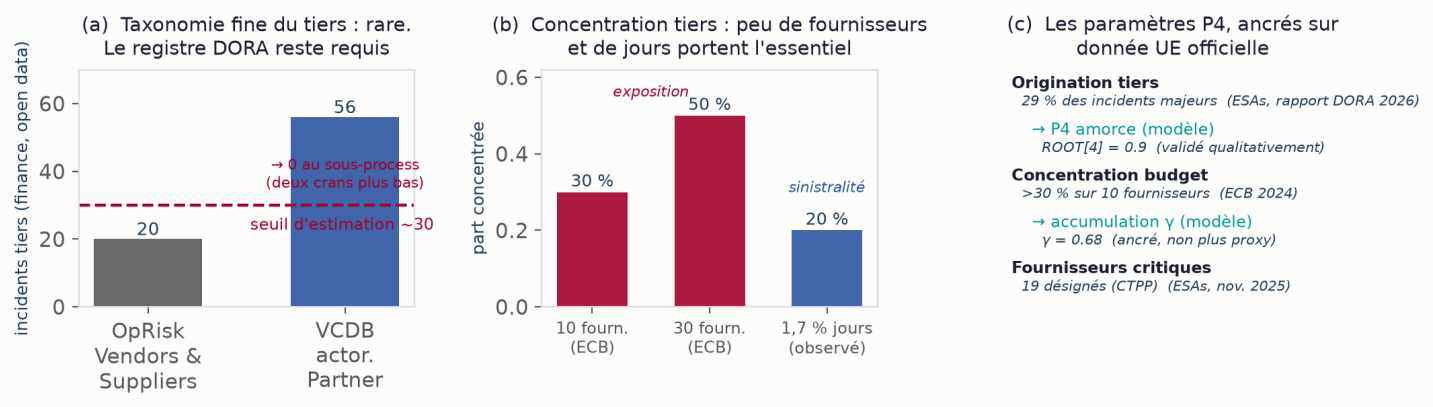


FIGURE C.5. Le sous-processus tiers sur donnée ouverte. (a) La taxonomie fine du tiers est sous le seuil d'estimation (registre DORA requis). (b) La concentration est nette, côté exposition (BCE) comme côté sinistralité (Gini 0,69). (c) Origine et concentration tierces ancrées sur donnée européenne officielle.

C.3 DÉTECTION DE P2 ET P3 COMME COURBE DE SURVIE

P2 (gestion des incidents) et P3 (tests) ne sont pas des nœuds de sévérité. Ils gouvernent le temps de détection, car un incident non détecté à temps escalade et devient matériel. Le modèle résume cet effet par un multiplicateur du taux de matérialité par pilier touché, de 0,85 à l'état conforme et 1,20 à l'état non conforme. Nous le remplaçons par une lecture de survie ancrée sur donnée.

Le VCDB donne la distribution du délai de découverte en finance ($n = 278$). Elle est bimodale : 47 % des incidents sont découverts le jour même, 8 % en semaines et 45 % en mois ou plus. La matérialité vient des incidents à découverte lente, d'où un taux de matérialité par pilier touché proportionnel à la part de découverte lente, ancrée à $\pi_{\text{slow}} = 0{,}45$.

Ce point est mesuré, mais l'élasticité de la détection à la maturité de P2 et P3 (de combien un pilier conforme détecte-t-il plus vite) ne l'est pas, et nous la bornons. Le surcoût du seul canal détection est alors une bande, de 1 775 à 8 052 M€ selon l'élasticité. Le multiplicateur grossier 0,85/1,20 est retrouvé pour une élasticité $\eta \approx 0{,}36$. Il est donc compatible avec un point de la courbe de scénario ancrée sur le VCDB, sans que son élasticité soit estimée (figure C.6).

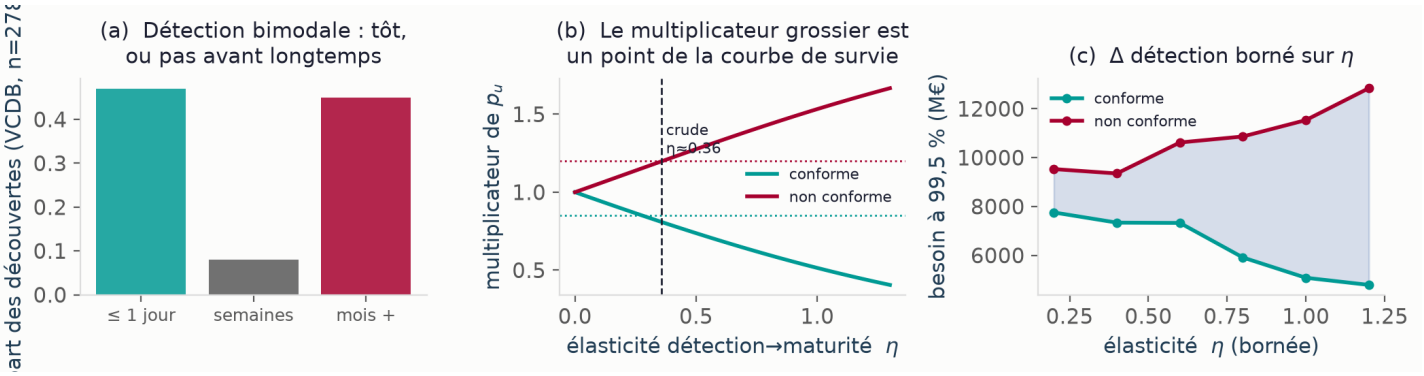


FIGURE C.6. P2 et P3, la détection comme courbe de survie. (a) Distribution bimodale observée au VCDB. (b) Le multiplicateur de matérialité comme point de la courbe de survie ; le multiplicateur grossier actuel correspond à $\eta \approx 0{,}36$. (c) Surcoût du canal détection, borné sur l'élasticité.

C.4 CAS D'USAGE, DES ADAPTATIONS AUX INDICATEURS PILOTABLES

Les adaptations se lisent comme un tableau de bord opposable à un souscripteur ou à un superviseur. Chaque indicateur observable est rattaché à un canal du moteur : fréquence d'entrée, délai de notification (P2), délai de confinement (P3), concentration des tiers (P4). Le capital en jeu derrière chacun se mesure par l'écart entre l'état conforme et l'état non conforme, soit 14 139 M€ (6 049 → 20 188) pour le périmètre financier étudié, avec un écart-type de 734 entre quatre graines.

C.4.1 Trois lectures d'un canal

On peut partir de l'état conforme et ne dégrader que ce canal (lecture *isolée*), partir de l'état non conforme et ne remédier qu'à ce canal (marginal de *fermeture*), ou moyenner sur les vingt-quatre ordres d'entrée (valeur de *Shapley*). La figure C.7(b) compare les trois lectures, dont une seule somme à l'écart total. La lecture isolée manque 5 001 M€ et celle de fermeture dépasse l'écart d'autant, le rapport des deux allant de 1,5 à 3,1 selon le canal. Remédier à un canal rapporte donc davantage à une entité défaillante partout qu'à une entité déjà conforme, puisque ce canal ferme aussi les effets croisés qu'il portait. La lecture de fermeture répond au scénario d'une entité défaillante sur tous les canaux.

Deux des trois sommes ne mesurent rien, et il ne faut pas les resommer. La question a été posée en séance sous la forme d'un soupçon de double comptage. Il n'y a pas de double comptage, et c'est une identité. En notant $m(S)$ les coefficients de Möbius,

$$\sum_i \text{isolé}(i) = \sum_{|S|=1} m(S), \qquad \sum_i \text{fermeture}(i) = \sum_S |S|\, m(S), \qquad \sum_i \varphi_i = \sum_S m(S) = \Delta.$$

Quand on ferme un canal, il emporte tous les croisés auxquels il participe, et un croisé d'ordre k est donc compté k fois : $1 \times 9\,138 + 2 \times 5\,345 + 3 \times (-691) + 4 \times 346 = 19\,141$, à la précision machine, aux arrondis d'affichage près. L'encadrement $9\,138 \le 14\,139 \le 19\,141$ est en revanche constaté ici, non garanti : la sur-modularité de la fonction de capital l'assurerait, mais la paire propagation × accumulation (-330) y échappe.

Shapley est la seule lecture qui répartisse l'interaction sans la perdre ni la dupliquer. Elle reste

une convention d'attribution, pas une prévision, car deux des quatre canaux sont bornés et leur part n'est pas un budget actionnable. Le défaut de la colonne isolée est celui que rencontre l'analyse de sensibilité lorsque les entrées cessent d'être indépendantes : les indices de Sobol ne somment plus au total, alors que la valeur de Shapley y somme par construction (Owen, 2014 ; Iooss et Prieur, 2019). Ces travaux décomposent toutefois une variance, alors que la fonction caractéristique employée ici est un écart de capital. L'argument se transpose, pas le résultat.

C.4.2 L'état non conforme comme coin supérieur

Sur les soixante-cinq paires emboîtées des seize configurations, relâcher un canal de plus ne fait jamais baisser le capital estimé, et cela vaut graine par graine, pas seulement en moyenne. Parmi ces seize configurations, le quantile estimé le plus élevé est donc celui du coin haut, sur chacune des graines utilisées, ce qui suffit à un test de résistance limité aux deux valeurs de chaque canal. Les valeurs intermédiaires des canaux ne sont pas testées, et aucune démonstration n'étend ce constat au pavé continu. C'est la forme que prend ici le résultat de statique comparative monotone du préprint cité au chapitre 2 (Karimi et al., 2026).

Deux réserves s'y attachent. D'abord, l'ordre observé porte sur les quantiles estimés, pas trajectoire par trajectoire. À uniformes communs, la perte d'une année donnée baisse dans 16,2 % des cas lorsque l'on relâche la propagation et dans 30,7 % lorsque l'on relâche la détection. Les motifs diffèrent : la table des sous-ensembles dans le premier cas, la transformation de sévérité dans le second. La version trajectorielle demanderait un couplage monotone, donc d'autres tirages, ce que le gel de la calibration interdit pour renforcer un énoncé sans déplacer une conclusion. Ensuite, un coin peut être infaisable. Deux des quatre canaux sont des bornes posées, et rien ne garantit qu'une entité présente les quatre canaux à leur maximum en même temps. Le coin haut est le maximum observé parmi les seize configurations évaluées, non la description d'une entité.

C.4.3 Test de résistance inversé

L'ordre observé sur les configurations évaluées autorise la question réciproque, que pose aussi un dispositif ORSA. Au lieu de fixer un état et de lire un capital, nous fixons le capital et cherchons les états qui le produisent. Parmi ces configurations, celles qui atteignent une cible forment un ensemble croissant, décrit par ses éléments minimaux ; pour les cibles étudiées, ils ne sont jamais plus de quatre sur seize.

Cible	configurations minimales classées qui l'atteignent	minimum de canaux
8 000	fréq. ; dét.+prop. ; dét.+accum. ; prop.+accum.	1
10 000	fréq. ; dét.+prop.+accum.	1
12 000	fréq.+dét. ; fréq.+prop. ; fréq.+accum.	2
15 000	les trois triplets contenant la fréquence	3
18 000	les quatre canaux	4

Deux nombres résument le tableau. Le canal de fréquence seul atteint 10 377 M€, soit 1,72 fois l'état conforme, alors que les trois autres canaux réunis n'atteignent que 11 413, soit 1,89 fois. L'ordre de ces deux bornes tient sur les quatre graines. Toute cible sous le premier seuil se produit donc par

un canal unique, et toute cible au-dessus du second exige la fréquence. Les trois autres canaux, pris seuls, restent sous la cible la plus basse : la détection plafonne à 7 497 M€, la propagation à 7 682 et l'accumulation à 7 777. Dans ce modèle, être exposé à un seul canal revient à être exposé à la fréquence.

Le canal d'accumulation n'admet pas d'inversion continue, et son effet isolé est un solde net. À l'état conforme, le pilier des tiers est un nœud de cascade ordinaire ; à l'état non conforme, il devient un choc commun. Ce sont deux structures de table différentes, pas les extrémités d'un continuum. Un test inverse ne peut donc pas demander à ce canal jusqu'où il doit se dégrader. La bascule à paramètre nul fait baisser le capital de 239 M€, résolu sur les quatre graines, parce qu'elle retire la propagation propre du pilier avant d'ajouter le choc commun. L'effet isolé publié, 1 728 M€, est le solde d'un retrait de 239 et d'un ajout de 1 967. On ne peut donc pas sommer les quatre canaux.

Deux réserves restent à faire. Une cible déclarée inatteignable l'est parmi les seize configurations évaluées, jamais pour une entité, puisque deux canaux sur quatre sont des bornes posées. Et une configuration proche d'une cible n'est pas classée, parce que son appartenance dépend de la graine. Une frontière non résolue est d'ailleurs un résultat : elle indique que la cible tombe dans le bruit de simulation.

C.4.4 Décomposition de l'interaction

L'interaction n'est plus un résidu, elle se décompose et vit aux paires. La décomposition de Möbius sur le treillis des seize configurations rend compte des +5 001 M€ terme par terme. Elle compte quatre effets principaux (9 138 M€), six croisés de paires (5 345), quatre croisés de triplets (−691) et un croisé des quatre canaux (+346). Leur somme vaut 14 139 à la précision machine, aux arrondis d'affichage près. Cette identité atteste que la table est complète ; elle ne vérifie rien statistiquement. Les trois paires porteuses passent toutes par la fréquence et font 86 % de l'ordre 2 : fréquence × détection 1 739 ± 708, fréquence × accumulation 1 666 ± 354 et fréquence × propagation 1 182 ± 444 M€. Ces ± sont des étendues de simulation à paramètres fixés. Une loi d'échelle le montre : l'écart-type tombe de 1 785 à 339 M€ lorsque le nombre d'années simulées passe de 10 000 à 160 000, soit une pente de −0,60 contre −0,50 attendu pour du Monte-Carlo. Cette largeur se réduit en simulant davantage. L'incertitude de paramètre est dix fois plus grande : le même croisé va de 429 à 7 998 M€ aux deux bornes de l'IC90 de $\hat{\xi}$. Les deux premières paires ne sont séparées que de 73 M€, et leur ordre s'inverse en perte moyenne. On ne peut donc pas les classer.

Sur les seize configurations, quatorze mélangent des canaux conformes et non conformes. Ce sont des contrefactuels de calcul pour attribuer l'écart. Une entité peut avoir des contrôles de maturités différentes ; la donnée ne montre pas qu'elle puisse atteindre exactement les valeurs posées de chaque configuration. Un état mixte doit donc rester présenté comme un scénario conditionnel.

Une seule paire est négative : propagation × accumulation, à −330 ± 242 M€, sur les seize graines et les deux métriques. Les deux canaux se substituent l'un à l'autre au lieu de se compléter. La cascade et le choc commun sont deux manières de faire tomber plusieurs piliers sur un même sinistre, et quand l'une joue, il reste moins à gagner à l'autre. Le capital est donc super-additif en euros, mais sous-additif entre ses deux canaux de co-occurrence. Cela borne l'amplitude que l'on peut imputer

à la contagion en général.

Les canaux se composent de façon quasi multiplicative. Une décomposition additive d'effets qui se multiplient produit une interaction positive par simple arithmétique, $(1+a)(1+b)-1$ dépassant $a+b$. La décomposition refaite sur le logarithme du capital le montre. Le produit des quatre facteurs isolés vaut 3,47 quand le facteur publié vaut 3,34, soit 0,961 fois ce produit. Un modèle purement multiplicatif produirait 5 813 M€ d'interaction, dont les 5 001 M€ publiés font 86 %. Aucune des seize configurations ne s'écarte de plus de 8,1 % du produit de ses facteurs isolés. L'interaction en euros s'explique donc par la multiplicativité, et le résidu propre est une légère sous-multiplicativité, portée par la paire propagation × accumulation.

Deux canaux suivent même une forme fermée. Par l'approximation de la perte unique (Böcker et Klüppelberg, 2005), le quantile croît comme $(\lambda\, p_u)^{\xi}$, ce qui prédit un facteur $(53{,}62/21{,}56)^{0{,}5954} = 1{,}720$ pour la fréquence contre 1,715 simulé, et 1,228 pour la détection contre 1,239.

Les conclusions de gestion restent les mêmes : remédier à un canal rapporte toujours davantage à une entité défaillante partout. Leur statut change en revanche, car elles reposent sur une forme fermée contrôlée par la simulation et non sur la seule simulation. L'interaction ne se lit donc pas comme un effet propre de la contagion (figure C.7).

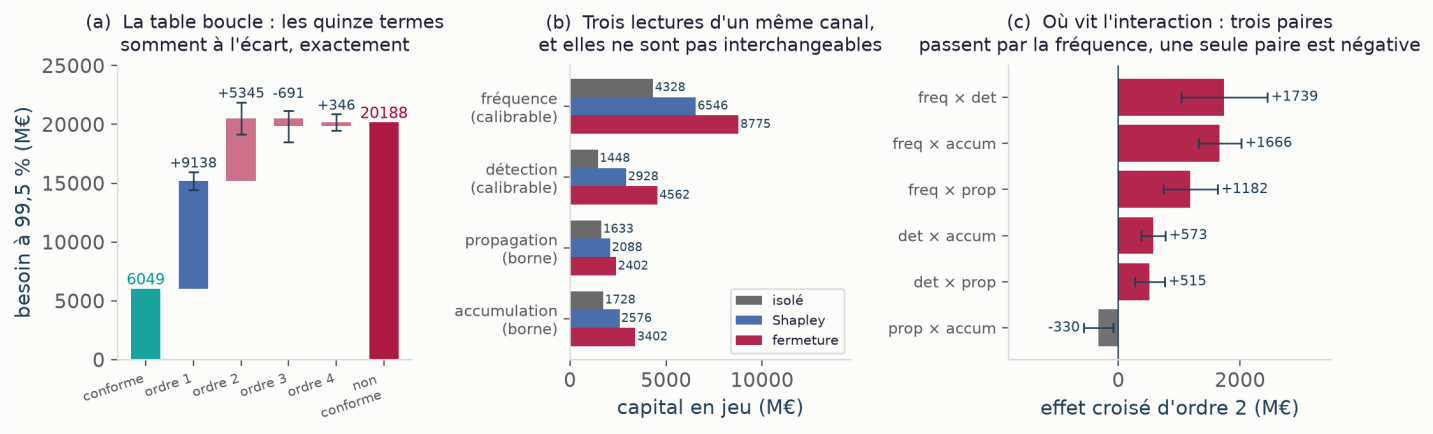


FIGURE C.7. La table complète des quatre canaux. (a) Réconciliation par ordre : les quinze termes de Möbius somment à l'écart, exactement. (b) Les trois lectures d'un même canal, isolée, Shapley et fermeture. (c) Les six croisés de paires avec leur écart-type de simulation ; une seule est négative.

C.4.5 Classement des indicateurs par capital et par statut

La fréquence et la détection pèsent lourd en capital et sont calibrables : ce sont les leviers de remédiation à activer en premier. La propagation et l'accumulation pèsent aussi, mais elles sont bornées. Elles mesurent surtout une incertitude, que la donnée résorbera, c'est-à-dire le registre DORA, plus sûrement qu'une action directe (figure C.8).

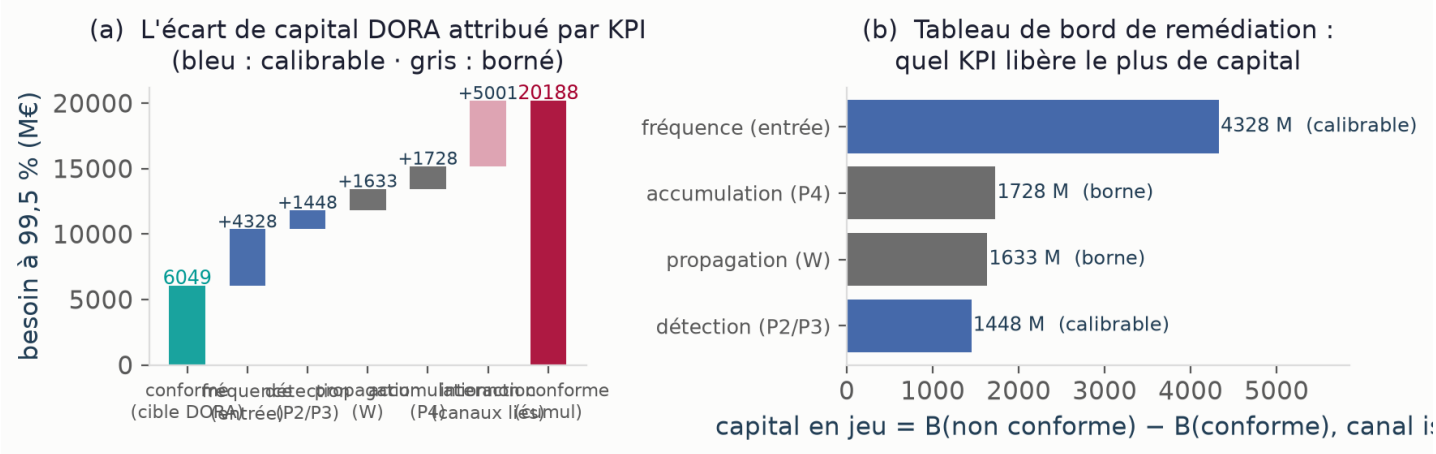


FIGURE C.8. Des indicateurs descriptifs aux indicateurs pilotables. (a) Écart de capital DORA attribué par indicateur, chaque canal étant isolé (bleu : calibrable ; gris : borné), avec l'interaction qui referme la cascade. (b) Tableau de bord de remédiation, indicateurs classés par capital libéré.

C.4.6 Retour sur investissement de la conformité

Le tableau de bord se lit en euros, et deux mots demandent une définition. Le portage est le coût de détention du capital : sous Solvabilité II, il se lit dans la marge de risque, un pourcentage annuel du capital immobilisé. Au taux de 6 % du règlement délégué, les 14 139 M€ que libère, pour le périmètre financier étudié, la conformité totale valent 848 M€ par an, et non une fois. La fréquence en porte à elle seule près de la moitié.

Le bénéfice a deux composantes, et ce calcul n'en monétise qu'une. Le portage économisé représente 848 M€/an, la sinistralité évitée 3 247, la charge annuelle moyenne passant de 3 869 à 622 M€. La composante laissée de côté vaut 3,8 fois celle qui est retenue, de sorte que le portage seul minore le bénéfice. Le retour de 6 à 35 ans est donc un majorant, pour un coût de remédiation de 25 à 150 M€ par grande entité, soit 5 à 30 Md€ pour deux cents entités.

Ajouter les pertes évitées raccourcit cette durée sous les mêmes hypothèses, sans borner le retour réel. Les deux composantes réunies donnent 4 095 M€/an et un retour de 1 à 7 ans. Cette addition mêle un flux de compte de résultat à un coût du capital. Cette convention de retour sur investissement n'est pas une sortie du modèle. Le chiffre de référence reste le portage seul, avec le sens de sa borne.

Ce taux de convention n'est ni le coût moyen pondéré du capital de l'entité ni son taux d'exigence sur un projet ; la durée calculée ne valide pas une décision d'investissement.

Le taux de 6 % est celui du règlement délégué 2015/35. La directive (UE) 2025/2 le ramène à 4,75 %, taux qu'emploient les calculs d'échelle d'entité. Le portage monétisé tombe alors à 672 M€/an, soit une baisse de 21 %, et le majorant du retour passe de 35 à 45 ans. Aucune conclusion ne bascule : la durée reste un majorant, et la composante dominante du bénéfice n'est pas monétisée. La chaîne publiée reste au taux historique, la calibration étant gelée (figure C.9). La conformité n'est donc pas un simple coût. Elle libère du capital, que le modèle chiffre, face à un coût externe et incertain, affiché comme tel. On priorise les leviers calibrables.

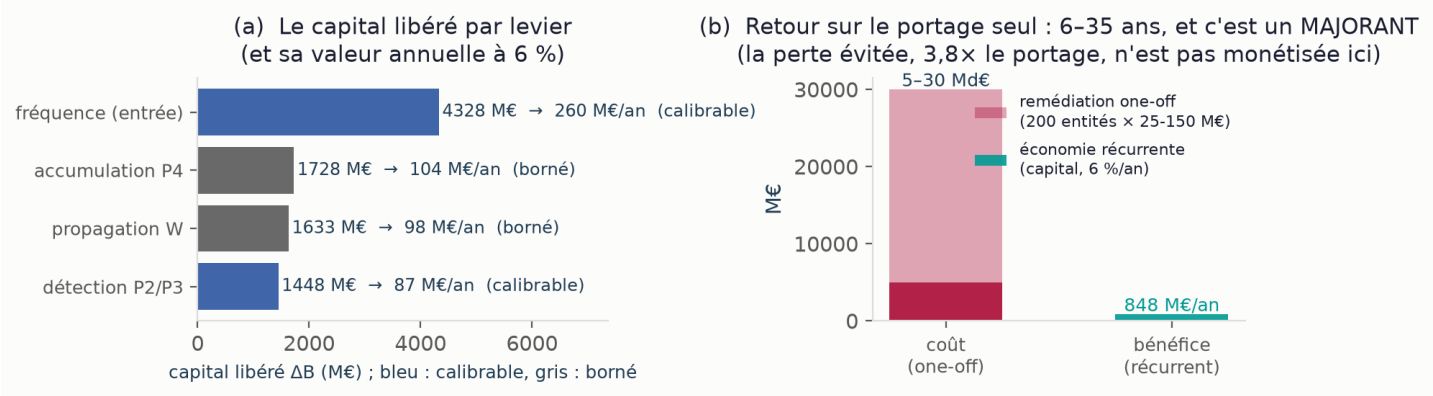


FIGURE C.9. Retour sur investissement de la conformité. (a) Capital libéré par levier, classé, avec sa valeur annuelle à 6 % (bleu : calibrable ; gris : borné). (b) Coût de remédiation ponctuel contre économie récurrente de portage du capital. Le retour sur le portage seul est de 6 à 35 ans, et c'est un majorant, la perte évitée n'étant pas monétisée ici.

C.5 PILIERS LAISSÉS EN PERSPECTIVE

Deux piliers appelleraient un traitement propre, mais aucune donnée ne le soutient. Les modéliser par des paramètres non identifiables contredirait la démarche, et nous les laissons en perspective.

— P1 (gouvernance) ressemble moins à un nœud qu'à un modificateur systémique : une gouvernance défaillante charge la sensibilité ρ de tous les piliers à la fois. Aucune donnée ne relie la qualité de gouvernance à une hausse du hasard, et cette relation est à borner plutôt qu'à estimer.

— P5 (partage d'informations) agit plutôt comme un réducteur de fréquence, l'alerte précoce diminuant les entrées. Rien ne le mesure non plus.

Les diagnostics motivent des adaptations distinctes : hétérogénéité des pertes, choc commun et détection. Ils n'identifient pas tous les paramètres correspondants. Les scénarios examinés relèvent le niveau du capital sans renverser le classement des piliers. Leur usage reste conditionnel aux hypothèses de chaque calcul ; un registre au niveau de l'entité serait nécessaire pour estimer les mécanismes encore posés.

D

Protocole d'élicitation et relectures de praticiens

Le protocole d'élicitation de la matrice de contagion a été préparé, diffusé, puis laissé sans panel. Trois relectures qualitatives ont été reçues à la place.

D.1 Méthode de Cooke

Le modèle classique de Cooke (Cooke, 1991) ne traite pas les experts comme interchangeables. Il les note sur des questions dont l'analyste connaît la réponse, puis pondère leurs avis par cette note. La méthode se déroule en quatre temps.

1. Chaque expert donne trois quantiles, à 5, 50 et 95 %, plutôt qu'un point. Son incertitude déclarée devient mesurable.
2. Sur les questions-graines, dont la réponse est connue de l'analyste et masquée à l'expert, on compare la fréquence empirique des réalisations dans les intervalles déclarés à la fréquence théorique. L'écart se lit comme une statistique d'information de Kullback-Leibler, et son niveau de signification est le score de calibration.
3. Un expert bien calibré qui déclare des intervalles très larges n'apporte rien. Le score d'information mesure donc la concentration de ses distributions par rapport à une loi de référence.
4. Le poids d'un expert est le produit des deux scores, et il est nul sous un seuil de calibration. L'avis agrégé est la combinaison linéaire pondérée des distributions individuelles.

Le quatrième point fait la force et la fragilité de la méthode. Un expert mal calibré est écarté, ce qui protège des avis péremptoires, mais la taille effective du panel diminue d'autant.

D.2 Protocole construit pour la matrice de contagion

Le questionnaire comporte deux parties. La partie d'étalonnage pose des questions à réponse connue, tirées de sources publiques vérifiables, sur des grandeurs du même domaine que les cibles. La partie cible interroge un à un les liens dirigés entre piliers, sous la forme d'une probabilité conditionnelle : sachant que le pilier source est défaillant, quelle est la probabilité que le pilier cible le devienne ?

Le dispositif complet demande seize questions par expert, dont dix questions-graines. Ce nombre est un choix de l'instrument, pas un minimum statistique universel. La stabilité des poids resterait à examiner sur les réponses recueillies. Le protocole, le questionnaire et le gabarit de réponses sont

versionnés dans le dépôt, et deux scripts implémentent l'agrégation : l'un sur des réponses fictives, pour valider la chaîne de traitement, l'autre prêt à recevoir des réponses réelles.

Une graine a été retirée de la première version. Elle portait sur l'indice de queue de sévérité ξ, de valeur vraie annoncée 0,90. Or 0,90 est la valeur posée du scénario de pire cas, la calibration figée donnant $\hat{\xi} = 0{,}5954$; dans la méthode de Cooke, une graine fausse inverse les poids en pénalisant le répondant qui vise juste. De plus, ξ est une estimation dont l'intervalle $[0{,}30\,;\,0{,}83]$ a une largeur proche de la valeur elle-même, alors qu'une graine doit être une grandeur réalisée. Les dix graines de l'instrument révisé sont toutes reproductibles par une sortie de script versionnée.

D.3 Documents produits et diffusés

Quatre pièces sont versionnées au dépôt : le protocole, qui fixe la méthode, les seuils et la règle d'agrégation ; le questionnaire, dans sa troisième version ; un formulaire en ligne reprenant ses questions ; le gabarit de réponses, qui alimente la chaîne d'agrégation. L'appel a été adressé à une commission de l'Institut des Actuaires et à des praticiens du cabinet, qui ne sont pas nommés. Il est resté sans réponse, et aucun panel n'a pu être constitué. Ce fait de démarche n'est pas présenté comme un résultat : il dit la difficulté d'obtenir un jugement quantitatif structuré sur un objet aussi récent, et rien de la disposition des personnes sollicitées.

D.4 Portée de l'absence de panel

L'absence de panel limite la confrontation externe du barème. Une à deux réponses auraient aussi laissé un panel fragile : un seul expert pourrait franchir le seuil, ou les poids dépendre fortement des dix graines. Cela ne démontre pas qu'un petit panel serait nécessairement sans information.

Une élicitation biaisée pourrait aussi être trompeuse. Dans l'expérience, un panel biaisé déplace le SCR de 777 M€ sans qu'aucun signal n'avertisse le lecteur (chapitre 8), alors que l'approche par bornes reste invariante si seule la direction change et si la partie symétrique d'expert reste fixée. Cette invariance ne protège pas d'un biais sur la force des liens : sans panel, celle-ci demeure posée.

Ce travail s'appuie pourtant ailleurs sur un jugement d'expert : le codage, par un seul codeur, du corpus de rapports post-incident. Trois différences le justifient. Le codage est auditable, car le protocole est écrit et les récits sont publics. Son biais principal est testé contre une loi nulle exacte (§7.7). Son produit est un ordre partiel, que la suite borne, et non des coefficients qui entreraient directement dans le capital. Le codage à juge unique reste une limite déclarée, bornée au §7.7 ; un second codage en aveugle la réduirait.

D.5 Dispositifs de substitution

Trois dispositifs complètent le jugement d'expert, sans remplacer la partie symétrique posée.

— Les rapports post-incident officiels sont codés selon un protocole écrit, et le sens des transitions est testé contre une loi nulle exacte de permutation ($z = +5{,}12$ sur le corpus étendu).

— Une échelle de repli suppose la direction de rang faible. Son premier cran capte 74,1 % de la variance de la direction posée et resserre le capital dans [7 761 ; 8 316] M€, soit une largeur de 555 M€ contre 1 839 sous ignorance totale. C'est une hypothèse structurelle, déclarée comme telle.

— Les niveaux d'exigence des textes et les publications des autorités fournissent des repères externes sur les états de conformité.

D.6 RELECTURES DE PRATICIENS

La direction de W n'étant pas identifiable sur les données disponibles (chapitre 7), un seul contrôle externe reste possible : le jugement de praticiens qui ont vu des défaillances réelles. Un praticien peut corroborer ou contredire une structure, non la calibrer. L'instrument soumet donc sept affirmations qualitatives du modèle, dont deux sur l'ordre de P1 vers P2, en demandant de les contredire : un désaccord argumenté désigne l'endroit où le modèle s'écarte du terrain, un accord ne discrimine rien.

Première réponse. Une consultante de Nexialog, en gestion des risques et du contrôle depuis une dizaine d'années, ne contredit aucune des sept phrases (deux accords pleins, cinq nuancés). Elle juge les trois indicateurs pilotables cohérents et produisibles, et décrit l'usage établi d'un tableau de bord des incidents par prestataire pour évaluer, au titre de DORA, la fréquence de défaillance système et le taux d'indisponibilité sur douze mois. Sa nuance principale distingue l'occurrence et la maîtrise : une gouvernance solide ne change pas le fait qu'un prestataire critique tombe, mais la capacité à en limiter les conséquences. Dans le modèle, cela déplacerait l'arc de la gouvernance vers les tiers de la matrice de propagation vers le canal de détection. Cette réserve est déclarée sans être traitée, le gel interdisant la recalibration. Sur la gestion des incidents comme puits, elle avance un argument de précédence (les tests précèdent la mise en service), que le corpus ne code pas. Cette réponse a conduit à ajouter trois questions à choix forcé, dont l'une offre la modalité *je ne peux pas trancher*, qui corroborerait la frontière d'identifiabilité.

Deuxième réponse. Un consultant de Nexialog, expert de la résilience dans les services financiers depuis sept ans, donne quatre accords nuancés et deux désaccords argumentés. Il note que plusieurs domaines peuvent céder ensemble par une cause partagée (manque de ressources, transformation mal pilotée, architecture vieillissante) : c'est la frontière d'identifiabilité formulée par un praticien. Il conteste que la gouvernance soit une source pure et la gestion des incidents un puits. La plupart de ses exemples décrivent une rétroaction corrective, qui relève de l'évolution des états de conformité (chapitre 6). Un seul décrit une dégradation en retour, de la gestion des incidents vers le partage d'information, sens qu'aucun rapport du corpus ne code. Ce désaccord ne déplace pas le capital publié, l'ensemble admissible du chapitre 8 ne fixant aucune direction ; il affaiblit la structure suggérée par le corpus, déjà déclarée corroborée et non calibrée. Il juge le registre réaliste sous condition de règles de qualification précises, et signale un manque : la gestion des changements et des vulnérabilités, déclencheurs transversaux sans place propre dans le modèle.

Troisième réponse. Un consultant en données, qui exerce depuis un an, conteste les deux mêmes

phrases et juge le registre réaliste mais risqué pour la confidentialité. Il n'apporte pas d'argument nouveau et a demandé à n'être cité que par sa fonction.

Trois réponses ne font pas un panel. Cette relecture n'entre dans aucune table de robustesse et ne modifie aucun niveau publié.

D.7 COÛT DE L'ABSENCE ET RÉVERSIBILITÉ

L'élicitation devait départager P1 et P4 en tête du classement des piliers sources. Sans elle, les deux restent presque à égalité sur 220 sommets admissibles tirés au hasard, P1 arrivant premier dans 43,6 % des tirages et P4 dans 37,7 %, pour un écart de regret maximal observé de 1,5 % (§10.2). P1 et P4 devancent nettement les trois autres piliers, et l'analyse ne tranche pas entre eux par un avis.

Le protocole, le questionnaire, le gabarit et la chaîne d'agrégation sont prêts et testés ; il manque un panel d'une dizaine de répondants. La reprise demanderait recrutement et contrôle des réponses. Elle pourrait départager P1 et P4 et resserrer la bande, sans gain garanti à l'avance.

E

Paramètres et notations

E.1 Nature et sensibilité des paramètres

Trois natures sont distinguées : calibré sur données (avec son incertitude), *posé* par jugement d'expert ou choix normatif (non identifiable, cf. chapitre 7), et semi-ancré sur un proxy externe non spécifique au périmètre.

Paramètre	**Valeur**	**Nature**	**Justification**	**Sensibilité du besoin**
Queue de sévérité ξ	0,5954 (OpRisk, résultat principal) ; PRC 1,03 ; 0,90 posé en pire cas de modèle	calibré, incertain	GPD sur pertes réelles ; hétérogène par catégorie (0,87–1,37)	**forte** : de 0,60 à 0,38 quand le seuil monte au-dessus de celui retenu, dans l'IC90 [0,30 ; 0,83] ; pilote la queue
Échelle GPD σ, seuil u, p_u	57,97 M€ ; 20,03 M€ ; 0,15	calibré	POT au percentile 85 de l'échantillon 2000–2026, 86 excès sur 570 pertes ; $p_u = 86/570$ (§10.5.1)	modérée (via la queue)
Fréquence λ	~21,6/an (OpRisk)	convention de calage	582 événements collectés / 27 ans, dont douze d'avant 2000 : +2,1 % sur l'échantillon (§10.5.1)	sous-linéaire sur le niveau
Multiplicateur de fréquence par état	×1,525 partiel ; ×2,487 non conforme (λ de 21,56 à 53,62)	semi-ancré	parts Hackmageddon et fourchettes posées sur des effets publiés (chapitre 6) ; aux bornes, λ de 41,7 à 65,6	**forte** : canal dominant du résultat principal
Sur-dispersion ϕ	9,20	**posé** (prudent)	2,24 mesuré sur la série annuelle détendancée, maintenu entre scénarios	élasticité −0,44 sur l'écart entre états
Choc commun fréquence a	0,60	**posé** (prudent)	dépasse l'IC empirique haut (0,22) : conservateur	enveloppe le modèle à paquets (×2,5)
Structure $W = g\,T/s_{\max}$	classeur qualitatif	**posé** / normatif	jugement d'expert consigné ; direction non identifiable	l'asymétrie départage les deux piliers de tête ; l'essentiel du surcoût de contagion vient de la partie symétrique
Gain de propagation g	0,90 base ; par état 0,45/0,68/0,90	**posé**	amplitude de W, bornée par Leontief $\rho(W) \leq g < 1$	**levier** : ×1,6 sur [0,05 ; 0,90]
Score de conformité q / états	continu $[0, 1]$ (ou NC/PC/C)	**posé**	décrit le profil, subsume 3 ou 5 niveaux	**levier** : −53 % de NC à C sur le seul score ; facteur 3,34 sur les quatre canaux

Paramètre	Valeur	Nature	Justification	Sensibilité du besoin
Multiplicateur de matérialité par état	0,85/1,00/1,20	**posé**	module p_u selon la conformité	modérée (canal détection)
Charge systémique γ	0,68	semi-ancré	proxy concentration cloud (AWS+Azure+GCP, Synergy 2025)	modérée
Seuil de crise θ_{crise}	$-2{,}5$	**posé**	déclenche le régime de co-mouvement extrême	agit sur la seule queue crise
Probabilités d'état P(NC/PC/C)	0,35/0,35/0,30	semi-ancré	enquêtes conformité DORA ~50 % non conformes (Deloitte, ESA)	déplace le mélange, pas les états
Copule de dépendance θ	Gumbel 1,8	**posé**	queue supérieure entre briques	**négligeable** : $\Delta_{\text{DORA}} < 1{,}4\,\%$ sur $[1, 4]$
Excès de source u_{ij}	logit p_{ij} = logit $p_j + u_{ij}$	**non identifié**	la direction elle-même ; normalisation $\sum_i u_{ij} = 0$ (repérage, non information)	mesurée par l'échelle de repli (ch. 8) : rang 1 capte 74 % et resserre les bornes de 25 % ; à $u = 0$ P1 et P4 deviennent indiscernables
Élasticité sévérité/taille b	0,087 [0,026 ; 0,148]	calibré, tronqué	EMV lognormale tronquée au seuil de collecte (ch. 3)	faible : ×0,86 sur la sévérité transposée
Plafond de sévérité	40 M€	**posé**	capacité de réassurance ($\xi \geq 1$) ; appliqué par pilier touché	borne la queue extrême

Les paramètres à forte sensibilité sont soit calibrés sur données (la queue ξ, dont l'incertitude est chiffrée), soit des *leviers voulus* (g, q, le multiplicateur de fréquence), qui portent l'effet de la conformité et de la contagion sur le capital. Les paramètres purement posés qui ne sont pas des leviers (θ de copule, γ, θ_{crise}, probabilités d'état, matérialité) ont une influence faible à modérée dans ces tests. Les correspondances entre conformité et canaux restent posées. Leur effet sur l'écart est déterminant ; l'unité de perte et le bootstrap conjoint en précisent la portée (§10.7).

E.2 TABLE DES NOTATIONS

Les symboles sont regroupés par brique du modèle. Les probabilités, scores et gains sont sans unité ; les pertes sont en M€ et les fréquences en incidents par an. Les indices i, j, k, n et y désignent respectivement l'entité, les piliers, l'incident et l'année. Certains symboles ont un sens local : A désigne une matrice antisymétrique ou des actifs, S une matrice symétrique ou une coalition, et ρ une corrélation ou un rayon spectral.

Symbole	Signification	Ch.
Piliers et cascade dirigée		
$P_1, \ldots, P_5$	Les cinq piliers DORA : gouvernance, gestion des incidents, tests de résilience, prestataires tiers, partage d'informations	5
$T = (t_{jk})$	Matrice d'influence brute du classeur qualitatif, asymétrique, non normalisée	5

suite page suivante

Symbole	Signification	Ch.
ROOT	Propension de chaque pilier à *amorcer* une chaîne ; répartit les amorces du moteur	5
GBASE	Gravité intrinsèque de chaque pilier s'il cède seul, barème ordinal du modèle qualitatif, absent du moteur de capital	5
s_j	Somme de la ligne j de T ; $s_{\max} = \max_j s_j$	5
g	Gain de propagation, somme maximale des probabilités émises par un pilier dans la matrice normalisée de référence ; sans unité	5
W	Matrice de contagion normalisée à la Leontief, $W = g\,T/s_{\max}$. **Convention : W_{jk} va de la source j vers la cible k ; la ligne émet, la colonne reçoit**	5
e_j	Propension à propager depuis j, $e_j = g\,s_j/s_{\max}$	5
$\rho(W)$	Rayon spectral de W ; $\rho(W) \le g < 1$ garantit la stabilité	5
$(I-W)^{-1}$	Inverse de Leontief, somme des marches pondérées avec multiplicité ; I est l'identité, $W^\top$ la transposée	5
$M,\ R_0$	Matrice de génération suivante et son rayon spectral (extinction si $R_0 < 1$)	5
S_a	Ensemble des piliers atteints depuis l'amorce a	5
$K_j,\ u_j$	Seuil latent d'incident ; seuil monétaire POT. Ils diffèrent des critères réglementaires DORA (art. 18)	5
$X_i,\ X_{ij}$	Stress latent de l'entité i, puis de son pilier j ; sans unité, distinct de la perte monétaire X_n	5
$\Phi,\ \Phi^{-1}$	Répartition et fonction quantile de la normale standard ; $\mathbf{1}\{E\}$ vaut un si E se réalise	5
Identifiabilité et identification partielle		
$S,\ A$	Parties symétrique et antisymétrique de W ; S est posé à dire d'expert, A est exploré sous contraintes	7
J_{jk}	Courant de probabilité $\pi_j P_{jk} - \pi_k P_{kj}$; nul ssi réversibilité	7
$\pi,\ \tilde{P}$	Loi stationnaire ; noyau adjoint (chaîne renversée dans le temps)	7
$\mathcal{E}(f,f)$	Forme de Dirichlet de la chaîne auxiliaire stationnaire ; ne dépend que de la symétrisée pondérée S_π	7
σ	Production d'entropie ; nulle ssi la chaîne est réversible	7
$\Delta(N),\ z$	Statistique d'asymétrie de la matrice N des transitions observées et son écart réduit au placebo par permutation	7
t	Degré d'ignorance directionnelle, $\lvert A_{jk}\rvert \le t\,S_{jk}$; $t = 1$ = ignorance totale	8
$\mathcal{W}(t)$	Ensemble admissible conditionnel au S d'expert et aux contraintes posées ; les extrema aux sommets ne sont pas des bornes globales démontrées	8
u_{ij}	Excès de propagation propre à la source, logit p_{ij} = logit $p_j + u_{ij}$	8
$L(\mathcal{V}),\ V(\mathcal{I})$	Largeur de bande de capital ; valeur d'une information	10.8
Socle : fréquence et sévérité		
$\xi,\ \sigma_{\text{GPD}},\ u$	Indice de queue, échelle et seuil POT de la GPD de sévérité	4
$\zeta_u = p_u$	Probabilité de dépassement du seuil par une sévérité élémentaire, $\mathbb{P}(X > u)$	4
N_u	Nombre d'excès au-delà de u	4

suite page suivante

Symbole	Signification	Ch.
λ_{ref}	Fréquence de référence PRC (341/an) : *clé de répartition* par vecteur, n'alimente pas le moteur	3
λ	Fréquence d'entrée, événements TIC enregistrés (21,6/an au secteur), avant le tirage de la perte par pilier	3
ϕ (φ), a	Rapport variance/moyenne du comptage ; charge commune du mélange lognormal	4
r, p	Forme et probabilité de la binomiale négative (p distinct de p_u)	4
N_y, $Y_{n,k}$, X_n, L_y	Incidents de l'année ; perte du pilier k dans l'incident n ; perte de l'incident ; somme annuelle	4
b	Élasticité de la sévérité à la taille de la firme	3
Conformité multi-états		
$C_j^\star$, Θ, ε_j	Capacité latente du pilier j ; facteur commun ; choc propre (normales réduites indépendantes)	6
U_j	Score de conformité $\Phi(C_j^\star) \in [0,1]$, de coupures 0,35 et 0,70	6
γ	Charge systémique de la latente de conformité (0,68)	6
ω	Probabilité du choc commun d'accumulation (0 en C, 0,68 en NC)	6
$K_{\text{bas}}, K_{\text{haut}}$	Seuils ordonnés découpant les états NC / PC / C	6
Q	Générateur de la chaîne de mise en conformité (séjours de type phase)	6
ν_0, $\overline{B}(t)$	Probabilités initiales des phases ; capital moyen conditionnel en t, distinct du quantile du mélange	6
S_0, S_1, S_2	Scénarios C / PC / NC (multiplicateurs de fréquence)	4
Capital, allocation et décision		
$\text{VaR}_\alpha(L)$, $\text{TVaR}_\alpha(L)$	Value-at-Risk et Tail-VaR de la charge **annuelle agrégée** L, au niveau $\alpha = 99{,}5\,\%$: quantile de capital et diagnostic de moyenne de queue	4
B, B_e, $B(W)$, $B(A)$	Besoin ORSA du modèle, $\text{VaR}_{99{,}5\%}(L)$, sous un état e, une matrice W ou à des actifs A ; pas un SCR réglementaire	6
$\text{q}_\alpha(X)$, $\overline{\text{q}}_\alpha(X)$	Quantile d'un sinistre unique et moyenne des pertes au-delà ; grandeurs descriptives distinctes du capital annuel	4
Δ_{DORA}	Écart de capital entre états NC et C supposés, sans lecture causale	9
C_j, AC_j, φ_j	Contributions à la TVaR en queue ; Shapley du pilier j (distinct de ϕ)	9
A, A_m, Λ	Actifs de l'entité ; actifs médians des pertes ; incidents annuels moyens du panel	9
b_λ, $m(A)$	Exposant de fréquence aux actifs ; facteur de sévérité à la taille de l'entité	9
D, d, τ, Adj	Écart ajouté ; D/BSCR ; part retenue en agrégation corrélée ; absorption des pertes	9
LR	Ratio de sinistralité, pertes attendues sur primes (sans unité)	9
CoC	Coût du capital de la marge de risque (6 %, puis 4,75 %)	9
ℓ, $\ell^\star$	Portée d'un traité en excès de perte annuel ; portée optimale	9
κ	Coefficient d'inefficacité du transfert (capacité, base, contrepartie)	9
θ	Paramètre de la copule de Gumbel (comparaison, non modèle)	10

F

Pistes pour de futurs mémoires d'actuariat

Les pistes suivantes prolongent des travaux préparés dans ce mémoire et restés ouverts. Elles vont de la mise en œuvre d'un protocole existant à la construction d'un nouveau modèle.

F.1 Exécuter l'élicitation structurée

L'annexe D décrit un protocole de Cooke complet, préparé et diffusé, resté sans réponse. Le questionnaire est rédigé ; son étalonnage comporte dix questions de graine, dont les valeurs vraies sont calculées et contrôlées. Il manque le panel. Un futur mémoire partirait d'un instrument prêt : il constituerait le panel, mesurerait la calibration des experts, pondérerait leurs avis, puis confronterait les poids obtenus aux directions que le corpus indique déjà.

Les réponses aux questions de graine restent confidentielles afin de préserver l'étalonnage du questionnaire.

F.2 Documenter la dépendance entre gouvernance et gestion des incidents

La section 10.8 hiérarchise les données manquantes par leur valeur d'information. Fixer le seul sens de la dépendance entre la gouvernance du risque TIC et la gestion des incidents lèverait 13,3 % de l'ambiguïté de capital en moyenne sur quatre graines, de 10,6 à 18,5 %. Fixer celui du lien entre tests et prestataires tiers n'en lèverait que 2,3 %. Le corpus public ne couvre pas les deux dépendances les plus utiles. Un mémoire conduit chez un assureur disposant d'une chronologie interne d'incidents, horodatée et classée par domaine de contrôle, mesurerait de combien la bande se resserre réellement.

F.3 Le second codage en aveugle du corpus

La direction des dépendances est codée par un seul lecteur, limite déclarée. La réception d'un second codage est outillée : le script d'accord ne produit rien sans le second jeu. Il dirait si la direction retenue tient à la lecture ou au texte.

F.4 Calibrer l'amplitude des liens, et non leur seul sens

Même avec les dix directions connues, une bande de capital subsisterait, imputable à l'amplitude des coefficients. Connaître le sens d'un lien ne donne pas sa force. Toute la valeur d'information mesurée ici, 32,7 % de resserrement en moyenne si l'on retenait le sens documenté par les rapports publics, porte sur la direction. Un mémoire qui estimerait les amplitudes, par exemple sur des séries d'incidents d'une même entité où la sévérité transmise est observable, traiterait la moitié du problème que celui-ci laisse intacte.

F.5 Dérive d'échelle et passage à l'entité

Le backtest couvre la forme de la queue et la loi de fréquence, mais pas le niveau de la charge annuelle : une dérive est examinée, sans validation hors échantillon d'un modèle non stationnaire. Un mémoire sur la non-stationnarité de la sévérité cyber partirait de ce diagnostic chiffré. De même, le besoin de capital est ramené à l'entité par ses actifs et des lectures d'exposition, sans seuil de validité statistique démontré. Un mémoire conduit dans une entité, avec son exposition et son registre de prestataires, remplacerait cet ancrage par une mesure directe.

F.6 Le coût d'un sinistre multi-piliers

Lorsqu'un incident touche plusieurs piliers, le mémoire additionne leurs coûts. C'est la plus lourde des hypothèses qu'il ne teste pas ; il la relâche par un exposant sur le nombre de piliers touchés (§10.6). Sur la plage étudiée, l'écart reste positif et du même ordre de grandeur. Le sens du biais d'additivité reste inconnu : mutualiser la remédiation réduit les coûts, alors que saturer la capacité de réponse les augmente.

Un modèle de coût à contrainte de capacité ferait du sens de l'effet une conséquence plutôt qu'un scénario. L'enjeu se mesure : élasticités de 0,95 à l'état non conforme contre 0,39 à l'état conforme, soit un facteur 2,42, car l'exposant ne pèse que sur les sinistres multi-piliers. Il faudrait un registre interne donnant le coût de chaque incident et le nombre de domaines touchés.

F.7 La contagion entre entités, par le prestataire partagé

La cascade court entre les cinq piliers d'une entité, non entre entités (chapitre 2). Le canal d'accumulation est pourtant ancré sur ce que les entités *partagent* : la concentration du marché de l'informatique en nuage et les prestataires critiques. Une cascade à deux étages, entre piliers puis entre entités, donnerait un besoin de capital de place. Le registre d'informations exigé par le règlement liste les prestataires de chaque entité : en croiser les registres donne un graphe de fournisseurs partagés *observé*, sans identifier pour autant les probabilités de transmission. Mais l'énumération des sommets deviendrait impossible, et l'identification partielle devrait passer par une optimisation.

G

Usage de l'intelligence artificielle générative

Des outils d'intelligence artificielle générative ont servi dans ce travail. Ils ont aidé à rédiger et à reformuler le manuscrit, y compris la réécriture de chapitres entiers, et à écrire les scripts d'analyse. Ils ont aussi servi à relire le texte et le code, pour signaler des incohérences que l'auteur a ensuite vérifiées et corrigées lui-même.

G.1 Usage déclaré

L'appui d'outils d'intelligence artificielle générative a porté sur six points :

1. la rédaction et la reformulation du manuscrit, y compris la réécriture de chapitres entiers : mise en forme, resserrement, harmonisation du registre et de la terminologie entre chapitres ;
2. l'écriture et la relecture des scripts d'analyse (calibrations, simulations, tests, figures), dont les sorties de référence sont versionnées au dépôt et se rejouent ;
3. cinq agents de relecture automatique (cohérence actuarielle, données au regard du règlement, figures, registre d'écriture, relecture critique d'un chapitre du point de vue d'un lecteur académique), qui signalent des écarts à corriger à la main et ne produisent aucun résultat ;
4. le programme de vérification des nombres, lui-même écrit avec assistance ;
5. la reprise, depuis le supplément et le matériel complémentaire déjà publiés, de passages qui étaient hors du rapport pour l'ENSAE (démonstrations, compléments de validation, protocole d'élicitation, adaptations par pilier), et leur réécriture en phrases plus courtes. L'assistance a aussi servi à rédiger les sections nouvelles sur la spécification d'un registre d'incidents et sur la gouvernance du modèle, et à refondre les chapitres 1, 3 et 10 à partir du rapport pour l'ENSAE. Une passe de lisibilité a porté sur ces textes (suppression de tournures lourdes, variation de la longueur des phrases). Dans tous ces cas, les nombres, les formules et les références sont ceux des textes d'origine, contrôlés par le programme de vérification ;
6. une relecture critique assistée en octobre 2026 (démonstrations, sources bibliographiques, portée des formulations, regroupement de sections, définitions reportées au glossaire). Elle a été suivie du rejeu des tests de sévérité sur l'échantillon 2000–2026 et de la mise à jour des textes concernés ; l'auteur a examiné et retenu chaque correction. Aucune de ces relectures ne tient lieu de validation indépendante par un actuaire. L'assistance a aussi porté sur le code et la rédaction des expériences d'unité de perte et de bootstrap conjoint de la section 10.7. Leurs nombres proviennent de l'exécution des scripts, avec contrôles de convergence numérique et

comparaison au moteur historique.

G.2 Part de l'auteur

La problématique, les choix de modélisation, dont la cascade dirigée et le capital publié en bornes, la qualification des sources et de leurs biais, la hiérarchie des limites et l'interprétation des résultats sont de l'auteur, qui en répond. C'est notamment lui qui a réfuté l'hypothèse qui donnait au travail son titre initial, et requalifié le besoin d'une entité notionnelle en extrapolation d'ordre de grandeur. Les outils ont servi à discuter et à corriger ces éléments ; les décisions et le contenu livré restent ceux de l'auteur.

G.3 Vérification des résultats

Chaque nombre publié est rattaché au script qui le produit, sauf les citations externes et les valeurs posées, que le texte déclare comme telles. Chaque bloc du manuscrit déclare en commentaire les scripts dont il tire ses nombres. Un programme cherche chaque nombre publié dans les sorties versionnées de ces scripts, à la tolérance d'arrondi d'écriture près. Au dernier passage, tous les nombres vérifiables de ce mémoire et de son supplément sont confirmés. Ce contrôle établit l'origine d'un nombre, non la justesse de la phrase qui l'entoure.

Une section sans source déclarée compte comme un défaut plus grave qu'un nombre non confirmé, puisqu'elle échappe au contrôle sans abaisser le taux de confirmation ; chaque exemption est comptée et motivée. Toute grandeur issue d'une simulation est publiée avec son bruit ; celui des extrema est mesuré séparément au chapitre 8, à paramètres fixés et sur toute la grille des sommets.

G.4 Limite du dispositif

Un taux de confirmation ne mesure pas la justesse du texte. Une relecture des chapitres au filtre des superlatifs, des comptages et des renvois a trouvé huit erreurs sémantiques que le programme confirmait toutes : chaque nombre sortait bien du script cité, seule la phrase qui l'entourait était fausse. Deux venaient d'un message écrit en dur dans un script ; depuis, un superlatif ou un comptage se calcule dans le script, au même titre qu'un nombre. La relecture des énoncés qui comparent, comptent ou renvoient reste manuelle.